CIS Center for Internet Security®

CIS Benchmarks™

CIS Microsoft 365 Foundations Benchmark

v7.0.0 - 05-20-2026

Terms of Use

Please see the below link for our current terms of use:

https://www.cisecurity.org/cis-securesuite/cis-securesuite-membership-terms-of-use/

For information on referencing and/or citing CIS Benchmarks in 3rd party documentation (including using portions of Benchmark Recommendations) please contact CIS Legal (legalnotices@cisecurity.org) and request guidance on copyright usage.

NOTE: It is ***NEVER*** acceptable to host a CIS Benchmark in ***ANY*** format (PDF, etc.) on a 3rd party (non-CIS owned) site.

Table of Contents

Terms of Use *1*

Table of Contents *2*

Overview *8*

Important Usage Information **8**

Key Stakeholders **8**

Apply the Correct Version of a Benchmark **9**

Exceptions **9**

Remediation **10**

Summary **10**

Target Technology Details **11**

Intended Audience **11**

Consensus Guidance **13**

Typographical Conventions **14**

Recommendation Definitions *15*

Title **15**

Assessment Status **15**

Automated **15**

Manual **15**

Profile **15**

Description **15**

Rationale Statement **15**

Impact Statement **16**

Audit Procedure **16**

Remediation Procedure **16**

Default Value **16**

References **16**

CIS Critical Security Controls® (CIS Controls®) **16**

Additional Information **16**

Profile Definitions **17**

Acknowledgements **18**

Recommendations *19*

1 Microsoft 365 admin center **19**

1.1 Users **20**

1.1.1 Ensure Administrative accounts are cloud-only (Automated) 21

1.1.2 Ensure two emergency access accounts have been defined (Manual) 24

1.1.3 Ensure that between two and four global admins are designated (Automated) 28

1.1.4 Ensure administrative accounts use licenses with a reduced application footprint (Automated) 33
1.2 Teams & groups 38
1.2.1 Ensure that only organizationally managed/approved public groups exist (Automated) 39
1.2.2 Ensure sign-in to shared mailboxes is blocked (Automated) 42
1.3 Settings 46
1.3.1 Ensure the 'Password expiration policy' is set to 'Set passwords to never expire (recommended)' (Automated) 47
1.3.2 Ensure 'Idle session timeout' is set to '3 hours (or less)' for unmanaged devices (Automated) 50
1.3.3 Ensure 'External sharing' of calendars is not available (Automated) 56
1.3.4 Ensure 'User owned apps and services' is restricted (Automated) 59
1.3.5 Ensure internal phishing protection for Forms is enabled (Automated) 63
1.3.6 Ensure the customer lockbox feature is enabled (Automated) 65
1.3.7 Ensure 'third-party storage services' are restricted in 'Microsoft 365 on the web' (Automated) 67
1.3.8 Ensure that Sways cannot be shared with people outside of your organization (Manual) 71
1.3.9 Ensure shared bookings pages are restricted to select users (Automated) 73
2 Microsoft Defender 76
2.1 Email & collaboration 77
2.1.1 Ensure Safe Links for Office Applications is Enabled (Automated) 78
2.1.2 Ensure the Common Attachment Types Filter is enabled (Automated) 84
2.1.3 Ensure notifications for internal users sending malware is Enabled (Automated) 88
2.1.4 Ensure Safe Attachments policy is enabled (Automated) 92
2.1.5 Ensure Safe Attachments for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated) 96
2.1.6 Ensure Exchange Online Spam Policies are set to notify administrators (Automated) 99
2.1.7 Ensure that an anti-phishing policy has been created (Automated) 102
2.1.8 Ensure that SPF records are published for all Exchange Domains (Automated) 108
2.1.9 Ensure that DKIM is enabled for all Exchange Online Domains (Automated) 112
2.1.10 Ensure DMARC records for all Exchange Online domains are published (Automated) 116
2.1.11 Ensure comprehensive attachment filtering is applied (Automated) 121
2.1.12 Ensure the connection filter IP allow list is not used (Automated) 128
2.1.13 Ensure the connection filter safe list is off (Automated) 131
2.1.14 Ensure inbound anti-spam policies do not contain allowed domains (Automated) 134
2.1.15 Ensure outbound anti-spam message limits are in place (Automated) 137
2.2 Cloud apps 141
2.2.1 Ensure emergency access account activity is monitored (Manual) 142
2.3 Audit 144
2.4 System 145
2.4.1 Ensure Priority account protection is enabled and configured (Automated) 146
2.4.2 Ensure Priority accounts have 'Strict protection' presets applied (Automated) 151
2.4.3 Ensure Microsoft Defender for Cloud Apps is enabled and configured (Manual) 154
2.4.4 Ensure Zero-hour auto purge for Microsoft Teams is on (Automated) 157
2.4.5 Ensure 'AIR' remediation is enabled (Manual) 159
3 Microsoft Purview 162
3.1 Audit 163
3.1.1 Ensure Microsoft 365 audit log search is Enabled (Automated) 164
3.2 Data Loss Protection 166
3.2.1 Ensure DLP policies are enabled (Automated) 167
3.2.2 Ensure DLP policies are enabled for Microsoft Teams (Automated) 170
3.2.3 Ensure DLP policies are published for Copilot users (Automated) 174
3.3 Information Protection 178

3.3.1 Ensure Information Protection sensitivity label policies are published (Automated) 179
3.4 Insider Risk Management 182
3.5 Communication Compliance 182
4 Microsoft Intune admin center 183
4.1 Ensure devices without a compliance policy are marked 'not compliant' (Automated) 184
4.2 Ensure device enrollment for personally owned devices is blocked by default (Automated) 187
5 Microsoft Entra admin center 191
5.1 Entra ID 193
5.1.1 Overview 193
5.1.2 Users 193
5.1.2.1 Ensure 'Per-user MFA' is disabled (Manual) 194
5.1.2.2 Ensure users cannot register applications (Automated) 197
5.1.2.3 Ensure 'Restrict non-admin users from creating tenants' is set to 'Yes' (Automated) 200
5.1.2.4 Ensure access to the Entra admin center is restricted (Manual) 203
5.1.2.5 Ensure the option to remain signed in is hidden (Manual) 205
5.1.2.6 Ensure 'LinkedIn account connections' is disabled (Manual) 207
5.1.3 Groups 209
5.1.3.1 Ensure users cannot create security groups (Automated) 210
5.1.3.2 Ensure that 'Restrict user ability to access groups features in My Groups' is set to 'Yes' (Manual) 213
5.1.3.3 Ensure that 'Owners can manage group membership requests in My Groups' is set to 'No' (Manual) 215
5.1.3.4 Ensure that 'Users can create Microsoft 365 groups in Azure portals, API or PowerShell' is set to 'No' (Automated) 217
5.1.4 Devices 220
5.1.4.1 Ensure the ability to join devices to Entra is restricted (Automated) 221
5.1.4.2 Ensure the maximum number of devices per user is limited (Automated) 224
5.1.4.3 Ensure the GA role is not added as a local administrator during Entra join (Automated) 226
5.1.4.4 Ensure local administrator assignment is limited during Entra join (Automated) 229
5.1.4.5 Ensure Local Administrator Password Solution is enabled (Automated) 232
5.1.4.6 Ensure users are restricted from recovering BitLocker keys (Automated) 235
5.1.5 Enterprise apps 238
5.1.5.1 Ensure user consent to apps accessing company data on their behalf is not allowed (Automated) 239
5.1.5.2 Ensure the admin consent workflow is enabled (Automated) 242
5.1.5.3 Ensure password addition is blocked for applications (Automated) 245
5.1.5.4 Ensure password lifetime for applications does not exceed 180 days (Automated) .. 250
5.1.5.5 Ensure new application passwords are system-generated (Automated) 255
5.1.5.6 Ensure maximum certificate lifetime for applications does not exceed 180 days (Automated) 260
5.1.6 External Identities 265
5.1.6.1 Ensure that collaboration invitations are sent to allowed domains only (Automated) 266
5.1.6.2 Ensure that guest user access is restricted (Automated) 269
5.1.6.3 Ensure guest user invitations are limited (Automated) 272
5.1.7 User experiences 275
5.1.8 Hybrid management 276
5.1.8.1 Ensure that password hash sync is enabled for hybrid deployments (Automated) 277
5.2 ID Protection 280
5.2.1 Identity Protection 280
5.2.2 Conditional Access 281
5.2.2.1 Ensure multifactor authentication is enabled for all users in administrative roles (Automated) 282
5.2.2.2 Ensure multifactor authentication is enabled for all users (Automated) 286

5.2.2.3 Enable Conditional Access policies to block legacy authentication (Automated) 290
5.2.2.4 Ensure Sign-in frequency is enabled and browser sessions are not persistent for Administrative users (Automated) 294
5.2.2.5 Ensure 'Phishing-resistant MFA strength' is required for Administrators (Automated) 298
5.2.2.6 Enable Identity Protection user risk policies (Automated) 302
5.2.2.7 Enable Identity Protection sign-in risk policies (Automated) 306
5.2.2.8 Ensure 'sign-in risk' is blocked for medium and high risk (Automated) 310
5.2.2.9 Ensure a managed device is required for authentication (Automated) 313
5.2.2.10 Ensure a managed device is required to register security information (Automated) 318
5.2.2.11 Ensure sign-in frequency for Intune Enrollment is set to 'Every time' (Automated) . 322
5.2.2.12 Ensure the device code sign-in flow is blocked (Automated) 326
5.2.2.13 Ensure that periodic reauthentication is required for all users (Automated) 329
5.2.2.14 Ensure trusted 'named locations' are defined (Automated) 332
5.2.2.15 Ensure exclusionary geographic access controls are utilized (Automated) 335
5.2.2.16 Ensure Token Protection is enforced for session tokens (Automated) 339
5.2.2.17 Ensure authentication transfer is blocked (Automated) 343
5.2.3 Authentication Methods 347
5.2.3.1 Ensure Microsoft Authenticator is configured to protect against MFA fatigue (Automated) 348
5.2.3.2 Ensure custom banned passwords lists are used (Automated) 351
5.2.3.3 Ensure password protection is enabled for on-prem Active Directory (Automated) ... 356
5.2.3.4 Ensure all member users are 'MFA capable' (Automated) 359
5.2.3.5 Ensure weak authentication methods are disabled (Automated) 363
5.2.3.6 Ensure system-preferred multifactor authentication is enabled (Automated) 367
5.2.3.7 Ensure the email OTP authentication method is disabled (Automated) 370
5.2.3.8 Ensure that Account 'Lockout threshold' is '10' or less (Automated) 373
5.2.3.9 Ensure that Account 'Lockout duration in seconds' is at least 60 seconds (Automated) 376
5.2.3.10 Ensure Microsoft Authenticator on companion applications is disabled (Automated) 379
5.2.4 Password reset 382
5.2.4.1 Ensure 'Self service password reset enabled' is set to 'All' (Manual) 383
5.2.4.2 Ensure that 2 methods are required for password reset (Manual) 385
5.2.4.3 Ensure SSPR registration and authentication re-confirmation are required (Manual) 387
5.2.4.4 Ensure that users are notified on password resets (Manual) 389
5.2.4.5 Ensure all admins are notified when other admins reset their password (Manual) 391
5.3 ID Governance 393
5.3.1 Ensure privileged role assignments are activated and not assigned (Automated) 394
5.3.2 Ensure 'Access reviews' for guest users are configured (Automated) 398
5.3.3 Ensure 'Access reviews' for privileged roles are configured (Automated) 403
5.3.4 Ensure approval is required for Global Administrator role activation (Automated) 409
5.3.5 Ensure approval is required for Privileged Role Administrator activation (Automated) . 412
6 Exchange admin center 415
6.1 Audit 416
6.1.1 Ensure 'AuditDisabled' organizationally is set to 'False' (Automated) 417
6.1.2 Ensure mailbox audit actions are configured (Automated) 419
6.1.3 Ensure 'AuditBypassEnabled' is not enabled on mailboxes (Automated) 426
6.2 Mail flow 429
6.2.1 Ensure all forms of mail forwarding are blocked and/or disabled (Automated) 430
6.2.2 Ensure mail transport rules do not whitelist specific domains (Automated) 434
6.2.3 Ensure email from external senders is identified (Automated) 437
6.3 Roles 439
6.3.1 Ensure users installing Outlook add-ins is not allowed (Automated) 440

6.3.2 Ensure the ability to add personal email accounts and calendars is disabled (Automated) 444
6.4 Reports 447
6.5 Settings 448
6.5.1 Ensure modern authentication for Exchange Online is enabled (Automated) 449
6.5.2 Ensure MailTips are enabled for end users (Automated) 452
6.5.3 Ensure additional storage providers are restricted in Outlook on the web (Automated) 454
6.5.4 Ensure SMTP AUTH is disabled (Automated) 456
6.5.5 Ensure Direct Send submissions are rejected (Automated) 458
7 SharePoint admin center 461
7.1 Sites 461
7.2 Policies 462
7.2.1 Ensure modern authentication for SharePoint applications is required (Automated) 463
7.2.2 Ensure SharePoint and OneDrive integration with Azure AD B2B is enabled (Automated) 466
7.2.3 Ensure external content sharing is restricted (Automated) 468
7.2.4 Ensure OneDrive content sharing is restricted (Automated) 471
7.2.5 Ensure that SharePoint guest users cannot share items they don't own (Automated) 474
7.2.6 Ensure SharePoint external sharing is restricted (Automated) 476
7.2.7 Ensure link sharing is restricted in SharePoint and OneDrive (Automated) 480
7.2.8 Ensure external sharing is restricted by security group (Automated) 483
7.2.9 Ensure guest access to a site or OneDrive will expire automatically (Automated) 487
7.2.10 Ensure reauthentication with verification code is restricted (Automated) 490
7.2.11 Ensure the SharePoint default sharing link permission is set (Automated) 493
7.3 Settings 495
7.3.1 Ensure Office 365 SharePoint infected files are disallowed for download (Automated) 496
8 Microsoft Teams admin center 498
8.1 Teams 499
8.1.1 Ensure external file sharing in Teams is enabled for only approved cloud storage services (Automated) 500
8.1.2 Ensure users can't send emails to a channel email address (Automated) 504
8.2 Users 507
8.2.1 Ensure external domains are restricted in the Teams admin center (Automated) 508
8.2.2 Ensure communication with unmanaged Teams users is disabled (Automated) 512
8.2.3 Ensure external Teams users cannot initiate conversations (Automated) 516
8.2.4 Ensure the organization cannot communicate with accounts in trial Teams tenants (Automated) 521
8.3 Teams devices 524
8.4 Teams apps 525
8.4.1 Ensure app permission policies are configured (Manual) 526
8.5 Meetings 528
8.5.1 Ensure anonymous users can't join a meeting (Automated) 529
8.5.2 Ensure anonymous users and dial-in callers can't start a meeting (Automated) 532
8.5.3 Ensure only people in my org can bypass the lobby (Automated) 535
8.5.4 Ensure users dialing in can't bypass the lobby (Automated) 539
8.5.5 Ensure meeting chat does not allow anonymous users (Automated) 541
8.5.6 Ensure only organizers and co-organizers can present (Automated) 543
8.5.7 Ensure external participants can't give or request control (Automated) 545
8.5.8 Ensure external meeting chat is off (Automated) 548
8.5.9 Ensure meeting recording is off by default (Automated) 550
8.6 Messaging 553
8.6.1 Ensure users can report security concerns in Teams (Automated) 554
9 Microsoft Fabric 558
9.1 Tenant settings 559

9.1.1 Ensure guest user access is restricted (Automated) 564
9.1.2 Ensure external user invitations are restricted (Automated) 567
9.1.3 Ensure guest access to content is restricted (Automated) 570
9.1.4 Ensure 'Publish to web' is restricted (Automated) 573
9.1.5 Ensure 'Interact with and share R and Python' visuals is 'Disabled' (Automated) 576
9.1.6 Ensure 'Allow users to apply sensitivity labels for content' is 'Enabled' (Automated) 578
9.1.7 Ensure shareable links are restricted (Automated) 581
9.1.8 Ensure enabling of external data sharing is restricted (Automated) 584
9.1.9 Ensure 'Block ResourceKey Authentication' is 'Enabled' (Automated) 587
9.1.10 Ensure access to APIs by service principals is restricted (Automated) 590
9.1.11 Ensure service principals cannot create and use profiles (Automated) 593
9.1.12 Ensure service principals ability to create workspaces, connections and deployment pipelines is restricted (Automated) 596

Appendix: Summary Table 599

Appendix: Change History 613

Overview

All CIS Benchmarks™ (Benchmarks) focus on technical configuration settings used to maintain and/or increase the security of the addressed technology, and they should be used in **conjunction** with other essential cyber hygiene tasks like:

- Monitoring the base operating system and applications for vulnerabilities and quickly updating with the latest security patches.
- End-point protection (Antivirus software, Endpoint Detection and Response (EDR), etc.).
- Logging and monitoring user and system activity.

In the end, the Benchmarks are designed to be a key **component** of a comprehensive cybersecurity program.

Important Usage Information

All Benchmarks are available free for non-commercial use from the CIS Website. They can be used to manually assess and remediate systems and applications. In lieu of manual assessment and remediation, there are several tools available to assist with assessment:

- CIS Configuration Assessment Tool (CIS-CAT® Pro Assessor)
- CIS Benchmarks™ Certified 3rd Party Tooling

These tools make the hardening process much more scalable for large numbers of systems and applications.

NOTE: Some tooling focuses only on the Benchmark Recommendations that can be fully automated (skipping ones marked **Manual**). It is important that ***ALL*** Recommendations (**Automated** and **Manual**) be addressed since all are important for properly securing systems and are typically in scope for audits.

Key Stakeholders

Cybersecurity is a collaborative effort, and cross functional cooperation is imperative within an organization to discuss, test, and deploy Benchmarks in an effective and efficient way. The Benchmarks are developed to be best practice configuration guidelines applicable to a wide range of use cases. In some organizations, exceptions to specific Recommendations will be needed, and this team should work to prioritize the problematic Recommendations based on several factors like risk, time, cost, and labor. These exceptions should be properly categorized and documented for auditing purposes.

Apply the Correct Version of a Benchmark

Benchmarks are developed and tested for a specific set of products and versions and applying an incorrect Benchmark to a system can cause the resulting pass/fail score to be incorrect. This is due to the assessment of settings that do not apply to the target systems. To assure the correct Benchmark is being assessed:

- **Deploy the Benchmark applicable to the way settings are managed in the environment:** An example of this is the Microsoft Windows family of Benchmarks, which have separate Benchmarks for Group Policy, Intune, and Stand-alone systems based upon how system management is deployed. Applying the wrong Benchmark in this case will give invalid results.

- **Use the most recent version of a Benchmark**: This is true for all Benchmarks, but especially true for cloud technologies. Cloud technologies change frequently and using an older version of a Benchmark may have invalid methods for auditing and remediation.

Exceptions

The guidance items in the Benchmarks are called recommendations and not requirements, and exceptions to some of them are expected and acceptable. The Benchmarks strive to be a secure baseline, or starting point, for a specific technology, with known issues identified during Benchmark development are documented in the Impact section of each Recommendation. In addition, organizational, system specific requirements, or local site policy may require changes as well, or an exception to a Recommendation or group of Recommendations (e.g. A Benchmark could Recommend that a Web server not be installed on the system, but if a system's primary purpose is to function as a Webserver, there should be a documented exception to this Recommendation for that specific server).

In the end, exceptions to some Benchmark Recommendations are common and acceptable, and should be handled as follows:

- The reasons for the exception should be reviewed cross-functionally and be well documented for audit purposes.
- A plan should be developed for mitigating, or eliminating, the exception in the future, if applicable.
- If the organization decides to accept the risk of this exception (not work toward mitigation or elimination), this should be documented for audit purposes.

It is the responsibility of the organization to determine their overall security policy, and which settings are applicable to their unique needs based on the overall risk profile for the organization.

Remediation

CIS has developed Build Kits for many technologies to assist in the automation of hardening systems. Build Kits are designed to correspond to Benchmark's "Remediation" section, which provides the manual remediation steps necessary to make that Recommendation compliant to the Benchmark.

When remediating systems (changing configuration settings on deployed systems as per the Benchmark's Recommendations), please approach this with caution and test thoroughly.

The following is a reasonable remediation approach to follow:

- CIS Build Kits, or internally developed remediation methods should never be applied to production systems without proper testing.
- Proper testing consists of the following:
  - Understand the configuration (including installed applications) of the targeted systems. Various parts of the organization may need different configurations (e.g., software developers vs standard office workers).
  - Read the Impact section of the given Recommendation to help determine if there might be an issue with the targeted systems.
  - Test the configuration changes with representative lab system(s). If issues arise during testing, they can be resolved prior to deploying to any production systems.
  - When testing is complete, initially deploy to a small sub-set of production systems and monitor closely for issues. If there are issues, they can be resolved prior to deploying more broadly.
  - When the initial deployment above is completed successfully, iteratively deploy to additional systems and monitor closely for issues. Repeat this process until the full deployment is complete.

Summary

Using the Benchmarks Certified tools, working as a team with key stakeholders, being selective with exceptions, and being careful with remediation deployment, it is possible to harden large numbers of deployed systems in a cost effective, efficient, and safe manner.

NOTE: As previously stated, the PDF versions of the CIS Benchmarks™ are available for free, non-commercial use on the CIS Website. All other formats of the CIS Benchmarks™ (MS Word, Excel, and Build Kits) are available for CIS SecureSuite® members.

CIS-CAT® Pro is also available to CIS SecureSuite® members.

Target Technology Details

This document, Security Configuration Benchmark for Microsoft 365, provides prescriptive guidance for establishing a secure configuration posture for Microsoft 365 services hosted in the Commercial Cloud. The recommendations in this guide were validated against Microsoft 365 Commercial and cover key services, including Exchange Online, SharePoint Online, OneDrive for Business, Microsoft Teams, Power BI (Fabric), and Microsoft Entra ID.

To ensure all PowerShell cmdlets work in your tenant please download the latest versions of the PowerShell modules. Scripts and cmdlets referenced in this benchmark were tested using the following module versions.

- Az.Accounts `5.3.4`
- ExchangeOnlineManagement `3.9.2`
- Microsoft.Graph.Applications `2.36.1`
- Microsoft.Graph.Authentication `2.36.1`
- Microsoft.Graph.DeviceManagement `2.36.1`
- Microsoft.Graph.Groups `2.36.1`
- Microsoft.Graph.Identity.DirectoryManagement `2.36.1`
- Microsoft.Graph.Identity.Governance `2.36.1`
- Microsoft.Graph.Identity.SignIns `2.36.1`
- Microsoft.Graph.Reports `2.36.1`
- Microsoft.Graph.Users `2.36.1`
- Microsoft.Online.SharePoint.PowerShell `16.0.27111.12000`
- MicrosoftTeams `7.7.0`
- PnP.PowerShell `3.1.0`

Note: The individual software applications installed on the end user device: Word, Excel, etc. are covered in separate benchmarks that compliment this guide. See the CIS Microsoft Office Enterprise Benchmark for details, available at https://workbench.cisecurity.org/communities/39

To obtain the latest version of this guide, please visit http://cisecurity.org. If you have questions, comments, or have identified ways to improve this guide, please write us at feedback@cisecurity.org.

Intended Audience

This benchmark is intended for system and application administrators, security specialists, auditors, help desk, and platform deployment personnel who plan to develop, deploy, assess, or secure solutions that incorporate Microsoft 365. Where possible audit and remediation guidance is provided using both PowerShell and relevant Admin Centers, using either method is acceptable when attempting to determine a Pass or Fail for a particular recommendation.

Consensus Guidance

This CIS Benchmark™ was created using a consensus review process comprised of a global community of subject matter experts. The process combines real world experience with data-based information to create technology specific guidance to assist users to secure their environments. Consensus participants provide perspective from a diverse set of backgrounds including consulting, software development, audit and compliance, security research, operations, government, and legal.

Each CIS Benchmark undergoes two phases of consensus review. The first phase occurs during initial Benchmark development. During this phase, subject matter experts convene to discuss, create, and test working drafts of the Benchmark. This discussion occurs until consensus has been reached on Benchmark recommendations. The second phase begins after the Benchmark has been published. During this phase, all feedback provided by the Internet community is reviewed by the consensus team for incorporation in the Benchmark. If you are interested in participating in the consensus process, please visit https://workbench.cisecurity.org/.

Typographical Conventions

The following typographical conventions are used throughout this guide:

Convention	Meaning
`Stylized Monospace font`	Used for blocks of code, command, and script examples. Text should be interpreted exactly as presented.
`Monospace font`	Used for inline code, commands, UI/Menu selections or examples. Text should be interpreted exactly as presented.
`<Monospace font in brackets>`	Text set in angle brackets denote a variable requiring substitution for a real value.
Italic font	Used to reference other relevant settings, CIS Benchmarks and/or Benchmark Communities. Also, used to denote the title of a book, article, or other publication.
Bold font	Additional information or caveats things like **Notes**, **Warnings**, or **Cautions** (usually just the word itself and the rest of the text normal).

Recommendation Definitions

The following defines the various components included in a CIS recommendation as applicable. If any of the components are not applicable it will be noted, or the component will not be included in the recommendation.

Title

Concise description for the recommendation's intended configuration.

Assessment Status

An assessment status is included for every recommendation. The assessment status indicates whether the given recommendation can be automated or requires manual steps to implement. Both statuses are equally important and are determined and supported as defined below:

Automated

Represents recommendations for which assessment of a technical control can be fully automated and validated to a pass/fail state. Recommendations will include the necessary information to implement automation.

Manual

Represents recommendations for which assessment of a technical control cannot be fully automated and requires all or some manual steps to validate that the configured state is set as expected. The expected state can vary depending on the environment.

Profile

A collection of recommendations for securing a technology or a supporting platform. Most benchmarks include at least a Level 1 and Level 2 Profile. Level 2 extends Level 1 recommendations and is not a standalone profile. The Profile Definitions section in the benchmark provides the definitions as they pertain to the recommendations included for the technology.

Description

Detailed information pertaining to the setting with which the recommendation is concerned. In some cases, the description will include the recommended value.

Rationale Statement

Detailed reasoning for the recommendation to provide the user a clear and concise understanding on the importance of the recommendation.

Impact Statement

Any security, functionality, or operational consequences that can result from following the recommendation.

Audit Procedure

Systematic instructions for determining if the target system complies with the recommendation.

Remediation Procedure

Systematic instructions for applying recommendations to the target system to bring it into compliance according to the recommendation.

Default Value

Default value for the given setting in this recommendation, if known. If not known, either not configured or not defined will be applied.

References

Additional documentation relative to the recommendation.

CIS Critical Security Controls® (CIS Controls®)

The mapping between a recommendation and the CIS Controls is organized by CIS Controls version, Safeguard, and Implementation Group (IG). The Benchmark in its entirety addresses the CIS Controls safeguards of (v7) “5.1 - Establish Secure Configurations” and (v8) '4.1 - Establish and Maintain a Secure Configuration Process” so individual recommendations will not be mapped to these safeguards.

Additional Information

Supplementary information that does not correspond to any other field but may be useful to the user.

Profile Definitions

The following configuration profiles are defined by this Benchmark:

- **E3 Level 1**

  Items in this profile apply to customer deployments of Microsoft M365 with an E3 license and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

- **E3 Level 2**

  This profile extends the "E3 Level 1" profile. Items in this profile exhibit one or more of the following characteristics and is focused on customer deployments of Microsoft M365 E3:

  - are intended for environments or use cases where security is paramount
  - acts as defense in depth measure
  - may negatively inhibit the utility or performance of the technology.

- **E5 Level 1**

  Items in this profile extend what is provided by the "E3 Level 1" profile for customer deployments of Microsoft M365 with an E5 license and intend to:

  - be practical and prudent;
  - provide a clear security benefit; and
  - not inhibit the utility of the technology beyond acceptable means.

- **E5 Level 2**

  This profile extends the "E3 Level 1" and "E5 Level 1" profiles and will effectively include all E3 and E5 recommendations at both levels. Items in this profile exhibit one or more of the following characteristics and is focused on customer deployments of Microsoft M365 E5:

  - are intended for environments or use cases where security is paramount
  - acts as defense in depth measure
  - may negatively inhibit the utility or performance of the technology.

Acknowledgements

This Benchmark exemplifies the great things a community of users, vendors, and subject matter experts can accomplish through consensus collaboration. The CIS community thanks the entire consensus team with special recognition to the following individuals who contributed greatly to the creation of this guide:

Contributor
Dan Menicucci
Richard Handley
Jennifer Jarose
Mack Bodie
Jason Inks
Samuel Emangard
Kyle Cira
Oleksii Burchynskyi
Havard Overas
Talbert Houle
Kaua Pickett
JJ Milner
Rex Farabee
Michael Smith
Steven Los
Mark Michael
James Robinson
Holger Warth
Jason Morton
Ian McRee
Daniel Wahlgren
Zan Liffick

Editor
Cody McLees
Caleb Eifert

Recommendations

1 Microsoft 365 admin center

The Microsoft 365 admin center is the primary landing page for everything 365 related and contains navigational links to all the other admin centers.

https://admin.microsoft.com/

1.1 Users

1.1.1 Ensure Administrative accounts are cloud-only (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Administrative accounts are special privileged accounts that could have varying levels of access to data, users, and settings. Regular user accounts should never be utilized for administrative tasks and care should be taken, in the case of a hybrid environment, to keep administrative accounts separate from on-prem accounts. Administrative accounts should not have applications assigned so that they have no access to potentially vulnerable services (EX. email, Teams, SharePoint, etc.) and only access to perform tasks as needed for administrative purposes.

Ensure administrative accounts are not `On-premises sync enabled`.

Rationale:

In a hybrid environment, having separate accounts will help ensure that in the event of a breach in the cloud, that the breach does not affect the on-prem environment and vice versa.

Impact:

Administrative users will need to utilize login/logout functionality to switch accounts when performing administrative tasks, which means they will not benefit from SSO. This will require a migration process from the 'daily driver' account to a dedicated admin account.

Once the new admin account is created, permission sets should be migrated from the 'daily driver' account to the new admin account. This includes both M365 and Azure RBAC roles. Failure to migrate Azure RBAC roles could prevent an admin from seeing their subscriptions/resources while using their admin account.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Identity > Users and select All users.
3. To the right of the search box click the Add filter button.
4. Add the On-premises sync enabled filter with the value set to Yes and click Apply.
5. Verify that no user accounts in administrative roles are present in the filtered list.

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "RoleManagement.Read.Directory","User.Read.All"
2. Run the following PowerShell script:

```
$DirectoryRoles = Get-MgDirectoryRole

# Get privileged role IDs
$PrivilegedRoles = $DirectoryRoles | Where-Object {
    $_.DisplayName -like "*Administrator*" -or $_.DisplayName -eq "Global
Reader"
}

# Get the members of these various roles
$RoleMembers = $PrivilegedRoles | ForEach-Object { Get-MgDirectoryRoleMember
-DirectoryRoleId $_.Id } |
    Select-Object Id -Unique

# Retrieve details about the members in these roles
$PrivilegedUsers = $RoleMembers | ForEach-Object {
    Get-MgUser -UserId $_.Id -Property UserPrincipalName, DisplayName, Id,
OnPremisesSyncEnabled
}

$PrivilegedUsers | Where-Object { $_.OnPremisesSyncEnabled -eq $true } |
    ft DisplayName,UserPrincipalName,OnPremisesSyncEnabled
```

3. The script will output any hybrid users that are also members of privileged roles. If nothing returns, then no users with that criteria exist.

Remediation:

Remediation will require first identifying the privileged accounts that are synced from on-premises and then creating a new cloud-only account for that user. Once a replacement account is established, the hybrid account should have its role reduced to that of a non-privileged user or removed depending on the need.

Default Value:

N/A

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/add-users/add-users?view=o365-worldwide
2. https://learn.microsoft.com/en-us/microsoft-365/enterprise/protect-your-global-administrator-accounts?view=o365-worldwide
3. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/best-practices#9-use-cloud-native-accounts-for-microsoft-entra-roles
4. https://learn.microsoft.com/en-us/entra/fundamentals/whatis
5. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.1 Maintain Inventory of Administrative Accounts Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.		●	●

1.1.2 Ensure two emergency access accounts have been defined (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Emergency access or "break glass" accounts are limited for emergency scenarios where normal administrative accounts are unavailable. They are not assigned to a specific user and will have a combination of physical and technical controls to prevent them from being accessed outside a true emergency. These emergencies could be due to several things, including:

- Technical failures of a cellular provider or Microsoft related service such as MFA.
- The last remaining Global Administrator account is inaccessible.

Ensure two `Emergency Access` accounts have been defined.

Note: Microsoft provides several recommendations for these accounts and how to configure them. For more information on this, please refer to the references section. The CIS Benchmark outlines the more critical things to consider.

Rationale:

In various situations, an organization may require the use of a break glass account to gain emergency access. In the event of losing access to administrative functions, an organization may experience a significant loss in its ability to provide support, lose insight into its security posture, and potentially suffer financial losses.

Impact:

Failure to properly implement emergency access accounts can weaken the security posture. Microsoft recommends excluding at least one of the two emergency access accounts from all conditional access rules, necessitating passwords with sufficient entropy and length to protect against random guesses. For a secure passwordless solution, FIDO2 security keys may be used instead of passwords.

Audit:

To audit using the UI:

Step 1 - Ensure a policy and procedure is in place at the organization:

- In order for accounts to be effectively used in a break-glass situation the proper policies and procedures must be authorized and distributed by senior management.
- FIDO2 Security Keys should be locked in a secure separate fireproof location.
- Passwords should be at least 16 characters, randomly generated and MAY be separated in multiple pieces to be joined in case of an emergency.

Step 2 - Ensure two emergency access accounts are defined:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Expand `Users` > `Active Users`
3. Inspect the designated emergency access accounts and ensure the following:
    - The accounts are named correctly, and do NOT identify with a particular person.
    - The accounts use the default `.onmicrosoft.com` domain and not the organization's.
    - The accounts are cloud-only.
    - The accounts are unlicensed.
    - The accounts are not disabled or `Sign-in blocked`.
    - The accounts are assigned the `Global Administrator` directory role.

Step 3 - Ensure at least one account is excluded from all conditional access rules:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Protection` > `Conditional Access`.
3. Inspect the conditional access rules.
4. Ensure one of the emergency access accounts is excluded from all rules.

Warning: As of 10/15/2024 MFA is required for all users including Break Glass Accounts. It is recommended to update these accounts to use passkey (FIDO2) or configure certificate-based authentication for MFA. Both methods satisfy the MFA requirement.

Remediation:

To remediate using the UI:

Step 1 - Create two emergency access accounts:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Expand `Users` > `Active Users`
3. Click `Add user` and create a new user with this criteria:
    - Name the account in a way that does NOT identify it with a particular person.
    - Assign the account to the default `.onmicrosoft.com` domain and not the organization's.
    - The password must be at least 16 characters and generated randomly.
    - Do not assign a license.
    - Assign the user the `Global Administrator` role.
4. Repeat the above steps for the second account.

Step 2 - Exclude at least one account from conditional access policies:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Protection` > `Conditional Access`.
3. Inspect the conditional access policies.
4. For each rule add an exclusion for at least one of the emergency access accounts.
5. `Users` > `Exclude` > `Users and groups` and select one emergency access account.

Step 3 - Ensure the necessary procedures and policies are in place:

- In order for accounts to be effectively used in a break glass situation the proper policies and procedures must be authorized and distributed by senior management.
- FIDO2 Security Keys should be locked in a secure separate fireproof location.
- Passwords should be at least 16 characters, randomly generated and MAY be separated in multiple pieces to be joined in case of an emergency.

Warning: As of 10/15/2024 MFA is required for all users including Break Glass Accounts. It is recommended to update these accounts to use passkey (FIDO2) or configure certificate-based authentication for MFA. Both methods satisfy the MFA requirement.

Additional suggestions for emergency account management:

- Create access reviews for these users.
- Exclude users from conditional access rules.
- Add the account to a restricted management administrative unit.

Warning: If CA (conditional access) exclusion is managed by a group, this group should be added to PIM for groups (licensing required) or be created as a role-assignable group. If it is a regular security group, then users with the Group Administrators role are able to bypass CA entirely.

Default Value:

Not defined.

References:

1. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-planning#stage-1-critical-items-to-do-right-now
2. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access
3. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/admin-units-restricted-management
4. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-mandatory-multifactor-authentication#accounts

Additional Information:

Microsoft has additional instructions regarding using Azure Monitor to capture events in the Log Analytics workspace, and then generate alerts for Emergency Access accounts. This requires an Azure subscription but should be strongly considered as a method of monitoring activity on these accounts:

https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access#monitor-sign-in-and-audit-logs

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.1.3 Ensure that between two and four global admins are designated (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Between two and four global administrators should be designated in the tenant. Ideally, these accounts will not have licenses assigned to them which supports additional controls found in this benchmark.

Rationale:

The Global Administrator role grants unrestricted access across all services in Microsoft Entra ID and should never be used for routine daily activities. Limiting the number of Global Administrators reduces the attack surface of the tenant and aligns with the principle of least privilege.

Fewer than two Global Administrators creates a single point of failure and removes the peer oversight needed to detect unauthorized actions. More than four increases the likelihood of account compromise by an external attacker. Maintaining between two and four Global Administrators balances operational redundancy against privileged access risk.

For any accounts assigned the Global Administrator role, at least one strong authentication method such as a FIDO2 key or certificate is strongly advised.

Impact:

The potential impact associated with ensuring compliance with this requirement is dependent upon the current number of global administrators configured in the tenant. If there is only one global administrator in a tenant, an additional global administrator will need to be identified and configured. If there are more than four global administrators, a review of role requirements for current global administrators will be required to identify which of the users require global administrator access.

Audit:

Note: If an organization's tenant is using a third-party identity provider, the audit and remediation procedures presented here may not be relevant. The principle of the recommendation is still relevant, and compensating controls that are relevant to the third-party identity provider should be implemented.

To audit using the UI:

1. Navigate to the `Microsoft 365 admin center` https://admin.microsoft.com
2. Select `Roles` > `Role assignments`.
3. Select the `Global Administrator` role from the list and click on `Assigned`.
4. Review the list of Global Administrators.
    - If there are groups present, then inspect each group and its members.
    - Take note of the total number of Global Administrators in and outside of groups.
5. Verify the number of Global Administrators is between two and four.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes Directory.Read.All`
2. Run the following PowerShell script:

```
# Determine Id of GA role using the immutable RoleTemplateId value.
$GlobalAdminRole = Get-MgDirectoryRole -Filter "RoleTemplateId eq '62e90394-
69f5-4237-9190-012177145e10'"
$RoleMembers = Get-MgDirectoryRoleMember -DirectoryRoleId $GlobalAdminRole.Id

$GlobalAdmins = [System.Collections.Generic.List[Object]]::new()
foreach ($object in $RoleMembers) {
    $Type = $object.AdditionalProperties.'@odata.type'
    # Check for and process role assigned groups
    if ($Type -eq '#microsoft.graph.group') {
        $GroupId = $object.Id
        $GroupMembers = (Get-MgGroupMember -GroupId
$GroupId).AdditionalProperties

        foreach ($member in $GroupMembers) {
            if ($member.'@odata.type' -eq '#microsoft.graph.user') {
                $GlobalAdmins.Add([PSCustomObject][Ordered]@{
                        DisplayName       = $member.displayName
                        UserPrincipalName = $member.userPrincipalName
                    })
            }
        }
    } elseif ($Type -eq '#microsoft.graph.user') {
        $DisplayName = $object.AdditionalProperties.displayName
        $UPN = $object.AdditionalProperties.userPrincipalName
        $GlobalAdmins.Add([PSCustomObject][Ordered]@{
                DisplayName       = $DisplayName
                UserPrincipalName = $UPN
            })
    }
}

$GlobalAdmins = $GlobalAdmins | select DisplayName,UserPrincipalName -Unique
Write-Host "*** There are" $GlobalAdmins.Count "Global Administrators in the
organization."
```

3. Review the output and ensure there are between 2 and 4 Global Administrators.

Note: When tallying the number of Global Administrators, the above does not account for Partner relationships. Those are located under `Settings` > `Partner Relationships` and should be reviewed on a recurring basis.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft 365 admin center` https://admin.microsoft.com
2. Select `Users` > `Active Users`.
3. In the `Search` field enter the name of the user to be made a Global Administrator.
4. To create a new Global Admin:
    1. Select the user's name.
    2. A window will appear to the right.
    3. Select `Manage roles`.
    4. Select `Admin center access`.
    5. Check `Global Administrator`.
    6. Click `Save changes`.
5. To remove a Global Admin:
    1. In the `Search` field, enter the name of the user to be removed.
    2. Select the user's name.
    3. A window will appear to the right.
    4. Under `Roles`, select `Manage roles`.
    5. Uncheck `Global Administrator`.
    6. Click `Save changes`.

References:

1. https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.identity.directorymanagement/get-mgdirectoryrole?view=graph-powershell-1.0
2. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference#all-roles
3. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/best-practices#5-limit-the-number-of-global-administrators-to-less-than-5
4. https://learn.microsoft.com/en-us/microsoft-365/admin/add-users/about-admin-roles?view=o365-worldwide#security-guidelines-for-assigning-roles

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	4.1 Maintain Inventory of Administrative Accounts Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.		●	●

1.1.4 Ensure administrative accounts use licenses with a reduced application footprint (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Administrative accounts are special privileged accounts that could have varying levels of access to data, users, and settings. A license can enable an account to gain access to a variety of different applications, depending on the license assigned.

The recommended state is to not license a privileged account or use licenses without associated applications such as `Microsoft Entra ID P1` or `Microsoft Entra ID P2`.

Rationale:

Ensuring administrative accounts do not use licenses with applications assigned to them will reduce the attack surface of high privileged identities in the organization's environment. Granting access to a mailbox or other collaborative tools increases the likelihood that privileged users might interact with these applications, raising the risk of exposure to social engineering attacks or malicious content. These activities should be restricted to an unprivileged 'daily driver' account.

Note: In order to participate in Microsoft 365 security services such as Identity Protection, PIM and Conditional Access an administrative account will need a license attached to it. Ensure that the license used does not include any applications with potentially vulnerable services by using either **Microsoft Entra ID P1** or **Microsoft Entra ID P2** for the cloud-only account with administrator roles.

Impact:

Administrative users will be required to switch accounts and use manual login/logout procedures when performing privileged tasks. This change also means they will not benefit from Single Sign-On (SSO), potentially impacting workflow efficiency and user experience.

Note: Alerts will be sent to **TenantAdmins**, including Global Administrators, by default. To ensure proper receipt, configure alerts to be sent to security or operations staff with valid email addresses or a security operations center. Otherwise, after adoption of this recommendation, alerts sent to **TenantAdmins** may go unreceived due to the lack of an application-based license assigned to the Global Administrator accounts.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Users` > `Active users`.
3. Sort by the `Licenses` column.
4. For each user account in an administrative role verify the account is assigned a license that is not associated with applications i.e. (Microsoft Entra ID P1, Microsoft Entra ID P2).
    - If an organization uses PIM to elevate a daily driver account to privileged levels, this control and licensing requirement can be considered satisfied.

Note: The final step assumes PIM is properly configured to best practices. Accounts eligible for the Global Administrator role should require approval to activate. Using the PIM blade to permanently assign accounts to privileged roles would not satisfy this audit procedure.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "RoleManagement.Read.Directory","User.Read.All"`
2. Run the following PowerShell script:

```
$DirectoryRoles = Get-MgDirectoryRole

# Get privileged role IDs
$PrivilegedRoles = $DirectoryRoles | Where-Object {
    $_.DisplayName -like "*Administrator*" -or $_.DisplayName -eq "Global
Reader"
}

# Get the members of these various roles
$RoleMembers = $PrivilegedRoles | ForEach-Object { Get-MgDirectoryRoleMember
-DirectoryRoleId $_.Id } |
    Select-Object Id -Unique

# Retrieve details about the members in these roles
$PrivilegedUsers = $RoleMembers | ForEach-Object {
    Get-MgUser -UserId $_.Id -Property UserPrincipalName, DisplayName, Id
}

$Report = [System.Collections.Generic.List[Object]]::new()

foreach ($Admin in $PrivilegedUsers) {
    $License = $null
    $License = (Get-MgUserLicenseDetail -UserId $Admin.id).SkuPartNumber -
join ", "
    $Object = [pscustomobject][ordered]@{
        DisplayName           = $Admin.DisplayName
        UserPrincipalName     = $Admin.UserPrincipalName
        License               = $License
    }
    $Report.Add($Object)
}

$Report
```

3. The output will display users assigned privileged roles alongside their assigned licenses. Additional manual assessment is required to determine if the licensing is appropriate for the user.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Users` > `Active users`.
3. Click `Add a user`.
4. Fill out the appropriate fields for Name, user, etc.
5. When prompted to assign licenses select as needed `Microsoft Entra ID P1` or `Microsoft Entra ID P2`, then click `Next`.
6. Under the `Option settings` screen you may choose from several types of privileged roles. Choose `Admin center access` followed by the appropriate role then click `Next`.
7. Select `Finish adding`.

Note: Utilizing PIM to best practices will satisfy this control. CIS and Microsoft recommend an organization keep zero permanently active assignments for roles other than emergency access accounts.

Default Value:

N/A

References:

1. https://learn.microsoft.com/en-us/microsoft-365/enterprise/protect-your-global-administrator-accounts?view=o365-worldwide
2. https://learn.microsoft.com/en-us/entra/fundamentals/whatis#what-are-the-microsoft-entra-id-licenses
3. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference
4. https://learn.microsoft.com/en-us/microsoft-365/business-premium/m365bp-protect-admin-accounts?view=o365-worldwide
5. https://learn.microsoft.com/en-us/microsoft-365/enterprise/subscriptions-licenses-accounts-and-tenants-for-microsoft-cloud-offerings?view=o365-worldwide#licenses
6. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-deployment-plan#principle-of-least-privilege

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v7	4.1 Maintain Inventory of Administrative Accounts Use automated tools to inventory all administrative accounts, including domain and local accounts, to ensure that only authorized individuals have elevated privileges.		●	●

1.2 Teams & groups

1.2.1 Ensure that only organizationally managed/approved public groups exist (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Microsoft 365 Groups is the foundational membership service that drives all teamwork across Microsoft 365. With Microsoft 365 Groups, you can give a group of people access to a collection of shared resources. When a new group is created in the Administration panel, the default privacy value of the group is "Public". (In this case, ‘public’ means accessible to the identities within the organization without requiring group owner authorization to join.)

The recommended state is Microsoft 365 Groups are set to `Private` in the Administration panel.

Note: Although there are several different group types, this recommendation concerns Microsoft 365 Groups specifically.

Rationale:

If group privacy is not controlled, any user may access sensitive information, depending on the group they try to access.

When the privacy value of a group is set to "Public," users may access data related to this group (e.g. SharePoint) via three methods:

1. The Azure Portal: Users can add themselves to the public group via the Azure Portal; however, administrators are notified when users access the Portal.
2. Access Requests: Users can request to join the group via the Groups application in the Access Panel. This provides the user with immediate access to the group, even though they are required to send a message to the group owner when requesting to join.
3. SharePoint URL: Users can directly access a group via its SharePoint URL, which is usually guessable and can be found in the Groups application within the Access Panel.

Impact:

If the recommendation is applied, group owners could receive more access requests than usual, especially regarding groups originally meant to be public.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Teams & groups` > `Active teams & groups`.
3. On the **Active teams and groups page**, check that no groups have the status 'Public' in the privacy column.

To audit using PowerShell:

1. Connect to the Microsoft Graph service using `Connect-MgGraph -Scopes "Group.Read.All"`.
2. Run the following Microsoft Graph PowerShell command:

```
$Groups = Get-MgGroup -All -Filter "groupTypes/any(c:c eq 'Unified')" `
    -Property Id,DisplayName,Visibility,GroupTypes

# Displays the groups to the console for review
$Groups | ft Id,DisplayName,Visibility
```

3. Verify that `Visibility` is `Private` for each group.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Teams & groups` > `Active teams & groups`.
3. On the **Active teams and groups page**, select the group's name that is public.
4. On the popup **groups name page**, Select `Settings`.
5. Under Privacy, select `Private`.

Default Value:

Public when created from the Administration portal; private otherwise.

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/groups-self-service-management
2. https://learn.microsoft.com/en-us/microsoft-365/admin/create-groups/compare-groups?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	13.1 Maintain an Inventory Sensitive Information Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.	●	●	●

1.2.2 Ensure sign-in to shared mailboxes is blocked (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Shared mailboxes are used when multiple people need access to the same mailbox, such as a company information or support email address, reception desk, or other function that might be shared by multiple people.

Users with permissions to the group mailbox can send as or send on behalf of the mailbox email address if the administrator has given that user permissions to do that. This is particularly useful for help and support mailboxes because users can send emails from "Contoso Support" or "Building A Reception Desk."

Shared mailboxes are created with a corresponding user account using a system generated password that is unknown at the time of creation.

The recommended state is `Sign in blocked` for `Shared mailboxes`.

Rationale:

The intent of the shared mailbox is to only allow delegated access from other mailboxes. An admin could reset the password, or an attacker could potentially gain access to the shared mailbox allowing the direct sign-in to the shared mailbox and subsequently the sending of email from a sender that does not have a unique identity. To prevent this, block sign-in for the account that is associated with the shared mailbox.

Impact:

Blocking sign-in to shared mailboxes prevents direct authentication to these accounts. Authorized users can still access shared mailbox content through their own accounts using Outlook delegation or by being granted Send As/Send on Behalf permissions.

This change strengthens security by ensuring shared mailboxes cannot serve as entry points for unauthorized access.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com/
2. Expand `Teams & groups` and select `Shared mailboxes`.
3. Take note of all shared mailboxes.
4. Expand `Users` and select `Active users`.
5. Select a shared mailbox account to open its properties pane, and review.
6. Verify that the text under the name reads `Sign-in blocked`.
7. Repeat for any additional shared mailboxes.

Note: If sign-in is not blocked there will be an option to `Block sign-in`. This means the shared mailbox is out of compliance with this recommendation.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`
2. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "User.Read.All"`
3. Run the following PowerShell commands:

```
$MBX = Get-EXOMailbox -RecipientTypeDetails SharedMailbox -ResultSize
Unlimited
$MBX | ForEach-Object { Get-MgUser -UserId $_.ExternalDirectoryObjectId `
    -Property DisplayName, UserPrincipalName, AccountEnabled } |
    Format-Table DisplayName, UserPrincipalName, AccountEnabled
```

4. Ensure `AccountEnabled` is set to `False` for all Shared Mailboxes.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com/
2. Click to expand `Teams & groups` and select `Shared mailboxes`.
3. Take note of all shared mailboxes.
4. Click to expand `Users` and select `Active users`.
5. Select a shared mailbox account to open its properties pane and then select `Block sign-in`.
6. Check the box for `Block this user from signing in`.
7. Repeat for any additional shared mailboxes.

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "User.ReadWrite.All"`
2. Connect to Exchange Online using `Connect-ExchangeOnline`.
3. To disable sign-in for a single account:

```
$MBX = Get-EXOMailbox -Identity TestUser@example.com
Update-MgUser -UserId $MBX.ExternalDirectoryObjectId -AccountEnabled:$false
```

The following can be used block sign-in to all Shared Mailboxes:

```
$MBX = Get-EXOMailbox -RecipientTypeDetails SharedMailbox
$MBX | ForEach-Object { Update-MgUser -UserId $_.ExternalDirectoryObjectId -
AccountEnabled:$false }
```

Default Value:

AccountEnabled: `True`

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/email/about-shared-mailboxes?view=o365-worldwide
2. https://learn.microsoft.com/en-us/microsoft-365/admin/email/create-a-shared-mailbox?view=o365-worldwide#block-sign-in-for-the-shared-mailbox-account
3. https://learn.microsoft.com/en-us/microsoft-365/enterprise/block-user-accounts-with-microsoft-365-powershell?view=o365-worldwide#block-individual-user-accounts

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.3 Settings

1.3.1 Ensure the 'Password expiration policy' is set to 'Set passwords to never expire (recommended)' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft cloud-only accounts have a pre-defined password policy that cannot be changed. The only items that can change are the number of days until a password expires and whether or not passwords expire at all.

Rationale:

Organizations such as NIST and Microsoft recommend against arbitrarily requiring users to change their passwords after a set period, unless there is evidence of compromise or the user has forgotten the password. This guidance applies even to single-factor (password-only) scenarios, as forced, periodic changes often lead to weaker passwords and reduced security. Additionally, this Benchmark advises implementing multi-factor authentication (MFA) for all accounts, which further diminishes the value of password expiration policies. Long-lived passwords can be further strengthened by enabling additional password protection features in Entra ID.

Impact:

When setting passwords not to expire it is important to have other controls in place to supplement this setting. See below for related recommendations and user guidance.

- Ban common passwords.
- Educate users to not reuse organization passwords anywhere else.
- Enforce Multi-Factor Authentication registration for all users.

Audit:

To audit using the UI:

1. Navigate to Microsoft 365 admin center https://admin.microsoft.com.
2. Expand Settings > Org Settings.
3. Click on Security & privacy.
4. Select Password expiration policy and verify that Set passwords to never expire (recommended) has been checked.

To audit using PowerShell:

1. Connect to the Microsoft Graph service using Connect-MgGraph -Scopes "Domain.Read.All".
2. Run the following Microsoft Online PowerShell command:

```
Get-MgDomain | ft id,PasswordValidityPeriodInDays
```

3. Verify the value returned for valid domains is 2147483647

Remediation:

To remediate using the UI:

1. Navigate to Microsoft 365 admin center https://admin.microsoft.com.
2. Expand Settings > Org Settings.
3. Click on Security & privacy.
4. Check the Set passwords to never expire (recommended) box.
5. Click Save.

To remediate using PowerShell:

1. Connect to the Microsoft Graph service using Connect-MgGraph -Scopes "Domain.ReadWrite.All".
2. Run the following Microsoft Graph PowerShell command:

```
Update-MgDomain -DomainId <Domain> -PasswordValidityPeriodInDays 2147483647
```

Default Value:

If the property is not set, a default value of 90 days will be used

References:

1. https://pages.nist.gov/800-63-3/sp800-63b.html
2. https://www.cisecurity.org/white-papers/cis-password-policy-guide/
3. https://learn.microsoft.com/en-us/microsoft-365/admin/misc/password-policy-recommendations?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.3.2 Ensure 'Idle session timeout' is set to '3 hours (or less)' for unmanaged devices (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Idle session timeout allows the configuration of a setting which will timeout inactive users after a pre-determined amount of time. When a user reaches the set idle timeout session, they'll get a notification that they're about to be signed out. They must choose to stay signed in or they'll be automatically signed out of all Microsoft 365 web apps. Combined with a Conditional Access rule this will only impact unmanaged devices.

A managed device is considered a device managed by Intune MDM or joined to a domain (Entra ID or Hybrid joined).

The following Microsoft 365 web apps are supported.

- Outlook Web App
- OneDrive
- SharePoint
- Microsoft Fabric
- Microsoft365.com and other start pages
- Microsoft 365 web apps (Word, Excel, PowerPoint)
- Microsoft 365 Admin Center
- M365 Defender Portal
- Microsoft Purview Compliance Portal

The recommended setting is `3 hours` (or less) for unmanaged devices.

Note: Idle session timeout doesn't affect Microsoft 365 desktop and mobile apps.

Rationale:

Ending idle sessions through an automatic process can help protect sensitive company data and will add another layer of security for end users who work on unmanaged devices that can potentially be accessed by the public. Unauthorized individuals onsite or remotely can take advantage of systems left unattended over time. Automatic timing out of sessions makes this more difficult.

Impact:

If step 2 in the Audit/Remediation procedure is left out, then there is no issue with this from a security standpoint. However, it will require users on trusted devices to sign in more frequently which could result in credential prompt fatigue.

Users don’t get signed out in these cases:

- If they get single sign-on (SSO) into the web app from the device joined account.
- If they selected Stay signed in at the time of sign-in. For more info on hiding this option for your organization, see Add branding to your organization's sign-in page.
- If they're on a managed device, that is compliant or joined to a domain and using a supported browser, like Microsoft Edge, or Google Chrome with the Microsoft Single Sign On extension.

Note: Idle session timeout also affects the Azure Portal idle timeout if this is not explicitly set to a different timeout. The Azure Portal idle timeout applies to all kinds of devices, not just unmanaged. See: change the directory timeout setting admin

Audit:

Step 1 - Ensure Idle session timeout is configured:

To audit using the UI:

1. Navigate to the `Microsoft 365 admin center` https://admin.microsoft.com/.
2. Expand `Settings` > `Org settings`.
3. Click `Security & Privacy` tab.
4. Select `Idle session timeout`.
5. Verify that `Turn on to set the period of inactivity for users to be signed off of Microsoft 365 web apps` is set to `3 hours` (or less).

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`:
2. Run the following script:

```
$TimeoutPolicy = Get-MgPolicyActivityBasedTimeoutPolicy
$BenchmarkTimeSpan = [TimeSpan]::Parse('03:00:00') # 3 hours

if ($TimeoutPolicy) {
    $PolicyDefinition = $TimeoutPolicy.Definition | ConvertFrom-Json
    $Timeout =
$PolicyDefinition.ActivityBasedTimeoutPolicy.ApplicationPolicies[0].WebSessio
nIdleTimeout
    $TimeSpan = [TimeSpan]::Parse($Timeout)
    $TimeoutReadable = "{0} days, {1} hours, {2} minutes" `
        -f $TimeSpan.Days, $TimeSpan.Hours, $TimeSpan.Minutes
    if ($TimeSpan -le $BenchmarkTimeSpan) {
        Write-Host "** PASS ** Timeout is set to $TimeoutReadable."
    } else {
        Write-Host "** FAIL ** Timeout is too long. It is set to
$TimeoutReadable."
    }
} else {
    Write-Host "** FAIL **: Idle session timeout is not configured."
}
```

3. Verify the policy exists and is `3 hours` or less.

Step 2 - Ensure the Conditional Access policy is in place:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Protect` > `Conditional Access`.
3. Inspect existing conditional access rules for one that meets the below conditions:
    - `Users or agents (Preview)` is set to include `All users`.
    - `Cloud apps or actions` > `Select apps` is set to `Office 365`.
    - `Conditions` > `Client apps` is `Browser` and nothing else.
    - `Session` is set to `Use app enforced restrictions`.
    - `Enable Policy` is set to `On`

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`:
2. Run the following script:

```
$Caps = Get-MgIdentityConditionalAccessPolicy -All |
    Where-Object {
$_.SessionControls.ApplicationEnforcedRestrictions.IsEnabled }
$CapReport = [System.Collections.Generic.List[Object]]::new()
# Filter to policies with "Use app enforced restrictions" enabled

# Loop through policies and generate a per policy report.
foreach ($policy in $Caps) {
    $Name = $policy.DisplayName
    $Users = $policy.Conditions.Users.IncludeUsers
    $Targets = $policy.Conditions.Applications.IncludeApplications
    $ClientApps = $policy.Conditions.ClientAppTypes
    $Restrictions =
$policy.SessionControls.ApplicationEnforcedRestrictions.IsEnabled
    $State = $policy.State

    $CountPass = $Targets.count -eq 1 -and $ClientApps.count -eq 1
    $Pass = $Targets -eq 'Office365' -and $ClientApps -eq 'browser' -and
            $Restrictions -and $CountPass -and $State -eq 'enabled'

    $obj = [PSCustomObject]@{
        DisplayName             = $Name
        AuditState              = if ($Pass) { "PASS" } else { "FAIL" }
        IncludeUsers            = $Users
        IncludeApplications     = $Targets
        ClientAppTypes          = $ClientApps
        AppEnforcedRestrictions = $Restrictions
        State                   = $State
    }
    $CapReport.Add($obj)
}

if ($Caps) {
    $CapReport
} else {
    Write-Host "** FAIL **: There are no qualifying conditional access
policies."
}
```

3. The script will output qualifying Conditional Access Policies. If one policy passes, then the recommendation passes. A passing policy will have the following properties:

```
DisplayName             : (CIS) Idle timeout for unmanaged
AuditState              : PASS
IncludeUsers            : {All}   # IncludeUsers not currently scored
IncludeApplications     : {Office365}
ClientAppTypes          : {browser}
AppEnforcedRestrictions : True
State                   : enabled
```

Note: Both steps 1 and 2 must pass audit checks in order for the recommendation to pass as a whole.

Remediation:

Step 1 - Configure Idle session timeout:

To remediate using the UI:

1. Navigate to the `Microsoft 365 admin center` https://admin.microsoft.com/.
2. Expand `Settings` > `Org settings`.
3. Click `Security & Privacy` tab.
4. Select `Idle session timeout`.
5. Check the box `Turn on to set the period of inactivity for users to be signed off of Microsoft 365 web apps`
6. Set a maximum value of `3 hours`.
7. Click save.

Step 2 - Ensure the Conditional Access policy is in place:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Protect` > `Conditional Access`.
3. Click `New policy` and give the policy a name.
    - Select `Users` > `All users`.
    - Select `Cloud apps or actions` > `Select apps` and select `Office 365`
    - Select `Conditions` > `Client apps` > `Yes` check only `Browser` unchecking all other boxes.
    - Select `Sessions` and check `Use app enforced restrictions`.
4. Set `Enable policy` to `On` and click `Create`.

Note: To ensure that idle timeouts affect only unmanaged devices, both steps 1 and 2 must be completed. Otherwise managed devices will also be impacted by the timeout policy.

Default Value:

Not configured. (Idle sessions will not timeout.)

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/manage/idle-session-timeout-web-apps?view=o365-worldwide

Additional Information:

According to Microsoft idle session timeout isn't supported when third party cookies are disabled in the browser. Users won't see any sign-out prompts.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●

1.3.3 Ensure 'External sharing' of calendars is not available (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

External calendar sharing allows an administrator to enable the ability for users to share calendars with anyone outside of the organization. Outside users will be sent a URL that can be used to view the calendar.

Rationale:

Attackers often spend time learning about organizations before launching an attack. Publicly available calendars can help attackers understand organizational relationships and determine when specific users may be more vulnerable to an attack, such as when they are traveling.

Impact:

This functionality is not widely used. As a result, it is unlikely that implementation of this setting will cause an impact to most users. Users that do utilize this functionality are likely to experience a minor inconvenience when scheduling meetings or synchronizing calendars with people outside the tenant.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. In the `Services` section click `Calendar`.
4. Verify that `Let your users share their calendars with people outside of your organization who have Office 365 or Exchange` is unchecked.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following Exchange Online PowerShell command:

```
Get-SharingPolicy -Identity "Default Sharing Policy" | ft Name,Enabled
```

3. Verify that `Enabled` is set to `False`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` select `Org settings`.
3. In the `Services` section click `Calendar`.
4. Uncheck `Let your users share their calendars with people outside of your organization who have Office 365 or Exchange`.
5. Click `Save`.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following Exchange Online PowerShell command:

```
Set-SharingPolicy -Identity "Default Sharing Policy" -Enabled $False
```

Default Value:

Enabled (True)

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/manage/share-calendars-with-external-users?view=o365-worldwide

Additional Information:

The following script can be used to audit any mailboxes that might be sharing calendars prior to disabling the feature globally:

```
$mailboxes = Get-Mailbox -ResultSize Unlimited

foreach ($mailbox in $mailboxes) {
    # Get the name of the default calendar folder (depends on the mailbox's
language)
    $calendarFolder = [string](Get-ExoMailboxFolderStatistics
$mailbox.PrimarySmtpAddress -FolderScope Calendar| Where-Object {
$_.FolderType -eq 'Calendar' }).Name

    # Get users calendar folder settings for their default Calendar folder
    # calendar has the format identity:\<calendar folder name>
    $calendar = Get-MailboxCalendarFolder -Identity
"$($mailbox.PrimarySmtpAddress):\$calendarFolder"

    if ($calendar.PublishEnabled) {
        Write-Host -ForegroundColor Yellow "Calendar publishing is enabled
for $($mailbox.PrimarySmtpAddress) on $($calendar.PublishedCalendarUrl)"
    }
}
```

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

1.3.4 Ensure 'User owned apps and services' is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

By default, users can install add-ins in their Microsoft Word, Excel, and PowerPoint applications, allowing data access within the application.

Do not allow users to install add-ins in Word, Excel, or PowerPoint.

Rationale:

Attackers commonly use vulnerable and custom-built add-ins to access data in user applications.

While allowing users to install add-ins by themselves does allow them to easily acquire useful add-ins that integrate with Microsoft applications, it can represent a risk if not used and monitored carefully.

Disabling future users' ability to install add-ins in Microsoft Word, Excel, or PowerPoint helps reduce your threat-surface and mitigate this risk.

Impact:

Implementation of this change will impact both end users and administrators. End users will not be able to install add-ins that they may want to install.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. In `Services` select `User owned apps and services`.
4. Verify that `Let users access the Office Store` and `Let users start trials on behalf of your organization` are **not checked**.

To Audit using PowerShell:

1. Connect to the Microsoft Graph service using `Connect-MgGraph -Scopes "OrgSettings-AppsAndServices.Read.All"`.
2. Run the following Microsoft Graph PowerShell command:

```
$Uri = "https://graph.microsoft.com/beta/admin/appsAndServices/settings"
Invoke-MgGraphRequest -Uri $Uri
```

3. Verify both `isOfficeStoreEnabled` and `isAppAndServicesTrialEnabled` are `False`.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft 365 admin center https://admin.microsoft.com.
2. Expand Settings > Org settings.
3. In Services select User owned apps and services.
4. Uncheck Let users access the Office Store and Let users start trials on behalf of your organization.
5. Click Save.

To remediate using PowerShell

1. Connect to the Microsoft Graph service using Connect-MgGraph -Scopes "OrgSettings-AppsAndServices.ReadWrite.All".
2. Run the following Microsoft Graph PowerShell commands:

```
$uri = "https://graph.microsoft.com/beta/admin/appsAndServices"
$body = @{
    "Settings" = @{
        "isAppAndServicesTrialEnabled" = $false
        "isOfficeStoreEnabled"         = $false
    }
} | ConvertTo-Json
Invoke-MgGraphRequest -Method PATCH -Uri $uri -Body $body
```

Default Value:

Let users access the Office Store is Checked

Let users start trials on behalf of your organization is Checked

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/manage/manage-addins-in-the-admin-center?view=o365-worldwide#manage-add-in-downloads-by-turning-onoff-the-office-store-across-all-apps-except-outlook

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.		●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

1.3.5 Ensure internal phishing protection for Forms is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft Forms can be used for phishing attacks by asking personal or sensitive information and collecting the results. Microsoft 365 has built-in protection that will proactively scan for phishing attempt in forms such personal information request.

Rationale:

Enabling internal phishing protection for Microsoft Forms will prevent attackers using forms for phishing attacks by asking personal or other sensitive information and URLs.

Impact:

If potential phishing was detected, the form will be temporarily blocked and cannot be distributed, and response collection will not happen until it is unblocked by the administrator or keywords were removed by the creator.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. Under Services select `Microsoft Forms`.
4. Verify the checkbox labeled `Add internal phishing protection` is checked under `Phishing protection`.

To Audit using PowerShell:

1. Connect to the Microsoft Graph service using `Connect-MgGraph -Scopes "OrgSettings-Forms.Read.All"`.
2. Run the following Microsoft Graph PowerShell commands:

```
$uri = 'https://graph.microsoft.com/beta/admin/forms/settings'
Invoke-MgGraphRequest -Uri $uri | select isInOrgFormsPhishingScanEnabled
```

3. Verify that `isInOrgFormsPhishingScanEnabled` is 'True'.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. Under Services select `Microsoft Forms`.
4. Click the checkbox labeled `Add internal phishing protection` under `Phishing protection`.
5. Click Save.

To remediate using PowerShell

1. Connect to the Microsoft Graph service using `Connect-MgGraph -Scopes "OrgSettings-AppsAndServices.ReadWrite.All"`.
2. Run the following Microsoft Graph PowerShell commands:

```
$uri = 'https://graph.microsoft.com/beta/admin/forms/settings'
$body = @{ "isInOrgFormsPhishingScanEnabled" = $true } | ConvertTo-Json
Invoke-MgGraphRequest -Method PATCH -Uri $uri -Body $body
```

Default Value:

Internal Phishing Protection is enabled.

References:

1. https://learn.microsoft.com/en-US/microsoft-forms/administrator-settings-microsoft-forms
2. https://learn.microsoft.com/en-US/microsoft-forms/review-unblock-forms-users-detected-blocked-potential-phishing

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v8	14.2 Train Workforce Members to Recognize Social Engineering Attacks Train workforce members to recognize social engineering attacks, such as phishing, pre-texting, and tailgating.	●	●	●

1.3.6 Ensure the customer lockbox feature is enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Customer Lockbox is a security feature that provides an additional layer of control and transparency to customer data in Microsoft 365. It offers an approval process for Microsoft support personnel to access organization data and creates an audited trail to meet compliance requirements.

Rationale:

Enabling this feature protects organizational data against data spillage and exfiltration.

Impact:

Administrators will need to grant Microsoft access to the tenant environment prior to a Microsoft engineer accessing the environment for support or troubleshooting.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. Select `Security & privacy` tab.
4. Click `Customer lockbox`.
5. Verify the box labeled `Require approval for all data access requests` is checked.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-OrganizationConfig | Select-Object CustomerLockBoxEnabled
```

3. Verify the value is set to `True`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. Select `Security & privacy` tab.
4. Click `Customer lockbox`.
5. Check the box `Require approval for all data access requests`.
6. Click `Save`.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-OrganizationConfig -CustomerLockBoxEnabled $true
```

Default Value:

`Require approval for all data access requests` - `Unchecked`

`CustomerLockboxEnabled` - `False`

References:

1. https://learn.microsoft.com/en-us/purview/customer-lockbox-requests#turn-customer-lockbox-requests-on-or-off

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

1.3.7 Ensure 'third-party storage services' are restricted in 'Microsoft 365 on the web' (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Third-party storage can be enabled for users in Microsoft 365, allowing them to store and share documents using services such as Dropbox, alongside OneDrive and team sites.

Ensure `Microsoft 365 on the web` third-party storage services are restricted.

Rationale:

By using external storage services an organization may increase the risk of data breaches and unauthorized access to confidential information. Additionally, third-party services may not adhere to the same security standards as the organization, making it difficult to maintain data privacy and security.

Impact:

Impact associated with this change is highly dependent upon current practices in the tenant. If users do not use other storage providers, then minimal impact is likely. However, if users do regularly utilize providers outside of the tenant this will affect their ability to continue to do so.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Go to `Settings` > `Org Settings` > `Services` > `Microsoft 365 on the web`
3. Verify that `Let users open files stored in third-party storage services in Microsoft 365 on the web` is not checked.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Application.Read.All"`.
2. Run the following script:

```
$SP = Get-MgServicePrincipal -Filter "appId eq 'c1f33bc0-bdb4-4248-ba9b-
096807ddb43e'"

if ((-not $SP) -or $SP.AccountEnabled) {
    Write-Host "Audit Result: ** FAIL **"
} else {
    Write-Host "Audit Result: ** PASS **"
}
```

3. Verify that `AccountEnabled` is `False`.

Note: The check will also fail if the Service Principal does not exist as users will still be able to open files stored in third-party storage services in Microsoft 365 on the web.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Go to `Settings` > `Org Settings` > `Services` > `Microsoft 365 on the web`
3. Uncheck `Let users open files stored in third-party storage services in Microsoft 365 on the web`

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Application.ReadWrite.All"`
2. Run the following script:

```
$SP = Get-MgServicePrincipal -Filter "appId eq 'c1f33bc0-bdb4-4248-ba9b-
096807ddb43e'"
# If the service principal doesn't exist then create it first.
if (-not $SP) {
    $SP = New-MgServicePrincipal -AppId "c1f33bc0-bdb4-4248-ba9b-
096807ddb43e"
}

Update-MgServicePrincipal -ServicePrincipalId $SP.Id -AccountEnabled:$false
```

Default Value:

Enabled - Users are able to open files stored in third-party storage services

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/setup/set-up-file-storage-and-sharing?view=o365-worldwide#enable-or-disable-third-party-storage-services

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	13.1 Maintain an Inventory Sensitive Information Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.	●	●	●
v7	13.4 Only Allow Access to Authorized Cloud Storage or Email Providers Only allow access to authorized cloud storage or email providers.		●	●

1.3.8 Ensure that Sways cannot be shared with people outside of your organization (Manual)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Sway is a Microsoft 365 app that lets organizations create interactive, web-based presentations using images, text, videos and other media. Its design engine simplifies the process, allowing for quick customization. Presentations can then be shared via a link.

This setting controls user Sway sharing capability, both within and outside of the organization. By default, Sway is enabled for everyone in the organization.

Rationale:

Disable external sharing of Sway documents that can contain sensitive information to prevent accidental or arbitrary data leaks.

Impact:

Interactive reports, presentations, newsletters, and other items created in Sway will not be shared outside the organization by users.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` > `Org settings`.
3. Under Services select `Sway`.
4. Verify that under `Sharing`, the following is *not* checked:
    - `Let people in your organization share their sways with people outside your organization`.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft 365 admin center https://admin.microsoft.com.
2. Expand Settings > Org settings.
3. Under Services select Sway
    - Uncheck: Let people in your organization share their sways with people outside your organization.
4. Click Save.

Default Value:

Let people in your organization share their sways with people outside your organization - Enabled

References:

1. https://support.microsoft.com/en-us/office/administrator-settings-for-sway-d298e79b-b6ab-44c6-9239-aa312f5784d4
2. https://learn.microsoft.com/en-us/office365/servicedescriptions/microsoft-sway-service-description

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	13.1 Maintain an Inventory Sensitive Information Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.	●	●	●

1.3.9 Ensure shared bookings pages are restricted to select users (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Shared Bookings allows you to invite your team members and create booking pages and let your customers book time with you and your team. It contains various settings to define services, manage staff members, configure schedules and availability, business hours and customize how appointments are scheduled. These pages can be customized to fit the diverse needs of your organization. It is an extension of Person Bookings.

The recommended state is to restrict the `OwaMailboxPolicy-Default` policy or disable at the organization level.

Rationale:

Shared Bookings pages can be exploited by threat actors to impersonate legitimate users using convincing internal email addresses. A compromised low-privilege account could be used to mimic high-profile identities (e.g., the CEO) and bypass impersonation filters to initiate fraudulent actions like fund transfers.

Additionally, attackers may create authoritative-looking addresses (e.g., admin@, hostmaster@) to conduct social engineering attacks on external parties aimed at the transfer of infrastructure control.

To reduce this risk, access to Shared Bookings should be limited to users with a clear business need and subject to monitoring and governance.

Impact:

Disabling Shared Bookings will limit users' ability to create self-service scheduling pages, which may reduce convenience for teams that rely on automated meeting coordination. Approved users will need to be added to a separate OWA Policy which will increase administrative overhead.

Note: Before modifying the default owa policy, ensure that any users who rely on Shared Bookings are assigned a separate policy that explicitly allows its use. This will help prevent unintended service disruptions.

Audit:

Ensure Shared Bookings is turned off in the OWA Default policy. If booking is disabled at the tenant (OrganizationConfig) level this is also a compliant state.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following command:

```
Get-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default | fl
BookingsMailboxCreationEnabled
```

3. Verify that `BookingsMailboxCreationEnabled` is set to `False`.

Optionally: If Bookings is disabled at the organization level, this is also considered a compliant state.

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following command:

```
Get-OrganizationConfig | fl BookingsEnabled
```

3. If `BookingsEnabled` is set to `False`, the organization is using a more restrictive and compliant configuration. In this case changing the default OWA policy would not be required for compliance.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-OwaMailboxPolicy "OwaMailboxPolicy-Default" -
BookingsMailboxCreationEnabled $false
```

Optionally: For a more restrictive state Bookings can be disabled at the organization level

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following command:

```
Set-OrganizationConfig -BookingsEnabled $false
```

Note: Disabling Bookings at the tenant (organization) level will be more impactful to end users and is not required for compliance.

Default Value:

BookingsMailboxCreationEnabled : True (OwaMailboxPolicy-Default)

BookingsEnabled : True

References:

1. https://learn.microsoft.com/en-us/microsoft-365/bookings/turn-bookings-on-or-off?view=o365-worldwide
2. https://techcommunity.microsoft.com/blog/office365businessappsblog/enhancing-security-in-microsoft-bookings-best-practices-for-admins/4382447
3. https://learn.microsoft.com/en-us/microsoft-365/bookings/best-practices-shared-bookings?view=o365-worldwide&source=recommendations
4. https://www.cyberis.com/article/microsoft-bookings-facilitating-impersonation

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

2 Microsoft Defender

Microsoft Defender, also known as Security, contains settings relating to policies, rules, and security controls that are common to many Microsoft 365 applications.

Direct link: https://security.microsoft.com/

2.1 Email & collaboration

2.1.1 Ensure Safe Links for Office Applications is Enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Enabling Safe Links policy for Office applications allows URL's that exist inside of Office documents and email applications opened by Office, Office Online and Office mobile to be processed against Defender for Office time-of-click verification and rewritten if required.

Note: E5 Licensing includes a number of Built-in Protection policies. When auditing policies note which policy you are viewing, and keep in mind CIS recommendations often extend the Default or Built-in Policies provided by MS. In order to **Pass** the highest priority policy must match all settings recommended.

Rationale:

Safe Links for Office applications extends phishing protection to documents and emails that contain hyperlinks, even after they have been delivered to a user.

Impact:

User impact associated with this change is minor - users may experience a very short delay when clicking on URLs in Office documents before being directed to the requested site. Users should be informed of the change as, in the event a link is unsafe and blocked, they will receive a message that it has been blocked.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com
2. Under `Email & collaboration` select `Policies & rules`
3. Select `Threat policies` then `Safe Links`
4. Inspect each policy and attempt to identify one that matches the parameters outlined below.
5. Scroll down the pane and click on `Edit Protection settings` (Global Readers will look for on or off values)
6. Verify that the following protection settings are set as outlined:

   Email

   - Checked `On: Safe Links checks a list of known, malicious links when users click links in email. URLs are rewritten by default`
   - Checked `Apply Safe Links to email messages sent within the organization`
   - Checked `Apply real-time URL scanning for suspicious links and links that point to files`
   - Checked `Wait for URL scanning to complete before delivering the message`
   - Unchecked `Do not rewrite URLs, do checks via Safe Links API only.`

   Teams

   - Checked `On: Safe Links checks a list of known, malicious links when users click links in Microsoft Teams. URLs are not rewritten`

   Office 365 Apps

   - Checked `On: Safe Links checks a list of known, malicious links when users click links in Microsoft Office apps. URLs are not rewritten`

   Click protection settings

   - Checked `Track user clicks`
   - Unchecked `Let users click through the original URL`
7. There is no recommendation for organization branding.
8. Click close

To audit using PowerShell:

1. Connect using `Connect-ExchangeOnline`.
2. Run the following to output properties from all Safe Links policies:

```
$params = @(
    'Identity',
    'EnableSafeLinksForEmail',
    'EnableSafeLinksForTeams',
    'EnableSafeLinksForOffice',
    'TrackClicks',
    'AllowClickThrough',
    'ScanUrls',
    'EnableForInternalSenders',
    'DeliverMessageAfterScan',
    'DisableUrlRewrite'
)

Get-SafeLinksPolicy | Select-Object -Property $Params
```

3. Verify there is at least one policy that matches the properties and values below:

```
Identity                  : <Example CIS SafeLinks Policy>
EnableSafeLinksForEmail   : True
EnableSafeLinksForTeams   : True
EnableSafeLinksForOffice  : True
TrackClicks               : True
AllowClickThrough         : False
ScanUrls                  : True
EnableForInternalSenders  : True
DeliverMessageAfterScan   : True
DisableUrlRewrite         : False
```

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com
2. Under Email & collaboration select Policies & rules
3. Select Threat policies then Safe Links
4. Click on +Create
5. Name the policy then click Next
6. In Domains select all valid domains for the organization and Next
7. Ensure the following URL & click protection settings are defined:

   Email

   - Checked On: Safe Links checks a list of known, malicious links when users click links in email. URLs are rewritten by default
   - Checked Apply Safe Links to email messages sent within the organization
   - Checked Apply real-time URL scanning for suspicious links and links that point to files
   - Checked Wait for URL scanning to complete before delivering the message
   - Unchecked Do not rewrite URLs, do checks via Safe Links API only.

   Teams

   - Checked On: Safe Links checks a list of known, malicious links when users click links in Microsoft Teams. URLs are not rewritten

   Office 365 Apps

   - Checked On: Safe Links checks a list of known, malicious links when users click links in Microsoft Office apps. URLs are not rewritten

   Click protection settings

   - Checked Track user clicks
   - Unchecked Let users click through the original URL
   - There is no recommendation for organization branding.
8. Click Next twice and finally Submit

To remediate using PowerShell:

1. Connect using `Connect-ExchangeOnline`.
2. Run the following PowerShell script to create a policy at highest priority that will apply to all valid domains on the tenant:

```
# Create the Policy
$params = @{
    Name = "CIS SafeLinks Policy"
    EnableSafeLinksForEmail = $true
    EnableSafeLinksForTeams = $true
    EnableSafeLinksForOffice = $true
    TrackClicks = $true
    AllowClickThrough = $false
    ScanUrls = $true
    EnableForInternalSenders = $true
    DeliverMessageAfterScan = $true
    DisableUrlRewrite = $false

}

New-SafeLinksPolicy @params

# Create the rule for all users in all valid domains and associate with
Policy
New-SafeLinksRule -Name "CIS SafeLinks" -SafeLinksPolicy "CIS SafeLinks
Policy" -RecipientDomainIs (Get-AcceptedDomain).Name -Priority 0
```

References:

1. https://learn.microsoft.com/en-us/defender-office-365/safe-links-policies-configure?view=o365-worldwide
2. https://learn.microsoft.com/en-us/powershell/module/exchange/set-safelinkspolicy?view=exchange-ps
3. https://learn.microsoft.com/en-us/defender-office-365/preset-security-policies?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.3 Maintain and Enforce Network-Based URL Filters Enforce and update network-based URL filters to limit an enterprise asset from connecting to potentially malicious or unapproved websites. Example implementations include category-based filtering, reputation-based filtering, or through the use of block lists. Enforce filters for all enterprise assets.		●	●
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v7	7.4 Maintain and Enforce Network-Based URL Filters Enforce network-based URL filters that limit a system's ability to connect to websites not approved by the organization. This filtering shall be enforced for each of the organization's systems, whether they are physically at an organization's facilities or not.		●	●

2.1.2 Ensure the Common Attachment Types Filter is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The Common Attachment Types Filter is a setting within Exchange Online Protection's anti-malware policy that blocks inbound and outbound email messages containing attachments of specified file types. When enabled, messages with attachments matching the blocked extensions are quarantined before delivery. Microsoft maintains a default set of file types considered high risk; organizations may also add custom extensions to the list.

The recommended state is `Enable the common attachments filter` set to `On`, on the default anti-malware policy, with the default list of blocked file types.

Rationale:

Email is a primary delivery vector for malware, including ransomware, trojans, and remote access tools distributed via executable, script, and installer file formats. The Common Attachment Types Filter blocks delivery of file types that have no legitimate business use in email but are routinely weaponized (such as `.exe`, `.vbs`, `.bat`, `.msi`), and similar formats. Enforcing this filter at the gateway reduces the attack surface before any client-side or endpoint control has the opportunity to respond.

Impact:

Emails containing attachments with blocked extensions, including those sent by trusted internal senders, will be quarantined and not delivered. Some file types in the default block list may be used legitimately in some IT workflows. Administrators who need to permit specific extensions for specific users or groups should create a scoped custom anti-malware policy with a higher priority than the Default policy rather than modifying the Default policy's file type list.

Audit:

Note: The following procedures audit only the `Default` anti-malware policy. Auditing custom policies is not required for compliance and is discretionary based on the organization's needs.

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules`.
3. On the Policies & rules page select `Threat policies`.
4. Under **Policies** select `Anti-malware` and click on the `Default (Default)` policy.
5. On the policy page that appears on the righthand pane, under `Protection settings`, verify that the `Enable the common attachments filter` has the value of `On`.
6. Click on `Edit protection settings` to view the list of file types that are blocked by the common attachment filter. Verify that the list of file types contains at least the 53 file types found in the `Default Value` section of this document.

Note: Verifying the complete file type list via the UI requires manual comparison against the default extensions listed in the Default Value section of this document. Auditors who require a programmatic comparison should use the PowerShell method.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following Exchange Online PowerShell command:

```
Get-MalwareFilterPolicy -Identity Default
```

3. Verify that the `EnableFileFilter` property has the value of `True`.
4. Verify that the `FileTypes` property contains at least default list of 53 file types found in the `Default Value` section of this document.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules.
3. On the Policies & rules page select Threat policies.
4. Under polices select Anti-malware and click on the Default (Default) policy.
5. On the Policy page that appears on the right hand pane scroll to the bottom and click on Edit protection settings, check the Enable the common attachments filter.
    - If any of the default file types are missing click Select file types and add the missing file types in.
    - Reference the Default Value section of this document for the list of extensions that should be blocked.
6. Click Save to save the changes.

To remediate using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following to enable the common attachment filter:

```
Set-MalwareFilterPolicy -Identity Default -EnableFileFilter $true
```

3. Use Set-MalwareFilterPolicy -Identity Default with the -FileTypes parameter to add any missing file types from the default list.
    - FileTypes accepts an array of strings.
    - To avoid using it destructively, first retrieve the existing list of file types using Get-MalwareFilterPolicy and append any missing file types to the list before using Set-MalwareFilterPolicy to update the policy.

Default Value:

EnableFileFilter : `True`

Default extensions:

```
[
  "ani", "apk", "app", "appx", "arj", "bat", "cab", "cmd", "com",
  "deb", "dex", "dll", "docm", "elf", "exe", "hta", "img", "iso",
  "jar", "jnlp", "kext", "lha", "lib", "library", "lnk", "lzh",
  "macho", "msc", "msi", "msix", "msp", "mst", "pif", "ppa",
  "ppam", "reg", "rev", "scf", "scr", "sct", "sys", "uif", "vb",
  "vbe", "vbs", "vxd", "wsc", "wsf", "wsh", "xll", "xz", "z", "ace"
]
```

References:

1. https://learn.microsoft.com/en-us/powershell/module/exchange/get-malwarefilterpolicy?view=exchange-ps
2. https://learn.microsoft.com/en-us/defender-office-365/anti-malware-policies-configure?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.6 Block Unnecessary File Types Block unnecessary file types attempting to enter the enterprise's email gateway.		●	●
v7	7.9 Block Unnecessary File Types Block all e-mail attachments entering the organization's e-mail gateway if the file types are unnecessary for the organization's business.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.1.3 Ensure notifications for internal users sending malware is Enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Exchange Online Protection (EOP) is Microsoft's cloud-based filtering service that protects organizations against spam, malware, and other email threats. EOP is included in all Microsoft 365 organizations with Exchange Online mailboxes.

EOP uses flexible anti-malware policies for malware protection settings. These policies can be set to notify Admins of malicious activity.

Rationale:

This setting alerts administrators that an internal user sent a message that contained malware. This may indicate an account or machine compromise that would need to be investigated.

Impact:

Notification of account with potential issues should not have an impact on the user.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `E-mail & Collaboration` > `Policies & rules`.
3. On the Policies & rules page select `Threat policies`.
4. Under Policies select `Anti-malware`.
5. Click on the `Default (Default)` policy.
6. Verify that `Notify an admin about undelivered messages from internal senders` is set to `On` and that there is at least one email address under `Administrator email address`.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following command:

```
Get-MalwareFilterPolicy | fl Identity,
EnableInternalSenderAdminNotifications, InternalSenderAdminAddress
```

3. Verify that `EnableInternalSenderAdminNotifications` is set to `True` and a `InternalSenderAdminAddress` address is defined.

Note: Audit and Remediation guidance may focus on the **Default policy** however, if a Custom Policy exists in the organization's tenant, then ensure the setting is set as outlined in the highest priority policy listed.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `E-mail & Collaboration` > `Policies & rules`.
3. On the Policies & rules page select `Threat policies`.
4. Under Policies select `Anti-malware`.
5. Click on the `Default (Default)` policy.
6. Click on `Edit protection settings` and change the settings for `Notify an admin about undelivered messages from internal senders` to `On` and enter the email address of the administrator who should be notified under `Administrator email address`.
7. Click Save.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following command:

```
Set-MalwareFilterPolicy -Identity '{Identity Name}' -
EnableInternalSenderAdminNotifications $True -InternalSenderAdminAddress
{admin@domain1.com}
```

Note: Audit and Remediation guidance may focus on the **Default policy** however, if a Custom Policy exists in the organization's tenant, then ensure the setting is set as outlined in the highest priority policy listed.

Default Value:

```
EnableInternalSenderAdminNotifications : False
InternalSenderAdminAddress             : $null
```

References:

1. https://learn.microsoft.com/en-us/defender-office-365/anti-malware-protection-about
2. https://learn.microsoft.com/en-us/defender-office-365/anti-malware-policies-configure

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.1.4 Ensure Safe Attachments policy is enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

The Safe Attachments policy helps protect users from malware in email attachments by scanning attachments for viruses, malware, and other malicious content. When an email attachment is received by a user, Safe Attachments will scan the attachment in a secure environment and provide a verdict on whether the attachment is safe or not.

Rationale:

Enabling Safe Attachments policy helps protect against malware threats in email attachments by analyzing suspicious attachments in a secure, cloud-based environment before they are delivered to the user's inbox. This provides an additional layer of security and can prevent new or unseen types of malware from infiltrating the organization's network.

Impact:

Delivery of email with attachments may be delayed while scanning is occurring.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `E-mail & Collaboration` > `Policies & rules`.
3. On the Policies & rules page select `Threat policies`.
4. Under `Policies` select `Safe Attachments`.
5. Inspect the highest priority policy.
6. Verify that `Users and domains` and `Included recipient domains` are in scope for the organization.
7. Verify that `Safe Attachments detection response:` is set to `Block - Block current and future messages and attachments with detected malware`.
8. Verify that `Quarantine Policy` is set to `AdminOnlyAccessPolicy`.
9. Verify that the policy is not disabled.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-SafeAttachmentPolicy | ft Identity,Enable,Action,QuarantineTag
```

3. Inspect the highest priority safe attachments policy and ensure the properties and values match the below:

```
Enable        : True
Action        : Block
QuarantineTag : AdminOnlyAccessPolicy
```

Note: To view the priority for a policy the `Get-SafeAttachmentRule` must be used. Built-in policies will always have a priority of `lowest` while presets like strict and standard can be viewed with `Get-ATPProtectionPolicyRule`. Strict and standard presets always operate at a higher priority than custom policies.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand E-mail & Collaboration > Policies & rules.
3. On the Policies & rules page select Threat policies.
4. Under Policies select Safe Attachments.
5. Click + Create.
6. Create a Policy Name and Description, and then click Next.
7. Select all valid domains and click Next.
8. Select Block.
9. Quarantine policy is AdminOnlyAccessPolicy.
10. Leave Enable redirect unchecked.
11. Click Next and finally Submit.

To remediate using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. To change an existing policy modify the example below and run the following PowerShell command:

```
Set-SafeAttachmentPolicy -Identity 'Example policy' -Action 'Block' -
QuarantineTag 'AdminOnlyAccessPolicy' -Enable $true
```

3. Or, edit and run the below example to create a new safe attachments policy.

```
New-SafeAttachmentPolicy -Name "CIS 2.1.4" -Enable $true -Action 'Block' -
QuarantineTag 'AdminOnlyAccessPolicy'

New-SafeAttachmentRule -Name "CIS 2.1.4 Rule" -SafeAttachmentPolicy "CIS
2.1.4" -RecipientDomainIs 'exampledomain[.]com'
```

Note: Policy targets such as users and domains should include domains, or groups that provide coverage for a majority of users in the organization. Different inclusion and exclusion use cases are not covered in the benchmark.

Default Value:

```
Identity      : Built-In Protection Policy
Enable        : True
Action        : Block
QuarantineTag : AdminOnlyAccessPolicy
Priority      : (lowest)
```

References:

1. https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-about
2. https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-policies-configure

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v7	7.10 Sandbox All Email Attachments Use sandboxing to analyze and block inbound email attachments with malicious behavior.			●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.1.5 Ensure Safe Attachments for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated)

Profile Applicability:

- E5 Level 2

Description:

Safe Attachments for SharePoint, OneDrive, and Microsoft Teams scans these services for malicious files.

Rationale:

Safe Attachments for SharePoint, OneDrive, and Microsoft Teams protect organizations from inadvertently sharing malicious files. When a malicious file is detected that file is blocked so that no one can open, copy, move, or share it until further actions are taken by the organization's security team.

Impact:

Impact associated with Safe Attachments is minimal, and equivalent to impact associated with anti-virus scanners in an environment.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Under `Email & collaboration` select `Policies & rules`.
3. Select `Threat policies` then `Safe Attachments`.
4. Click on `Global settings`.
5. Verify that the `Turn on Defender for Office 365 for SharePoint, OneDrive, and Microsoft Teams` toggle is set to `Enabled`.
6. Verify that the `Turn on Safe Documents for Office clients` toggle is set to `Enabled`.
7. Verify that the `Allow people to click through Protected View even if Safe Documents identified the file as malicious` toggle is set to `Disabled`.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-AtpPolicyForO365 | fl
Name,EnableATPForSPOTeamsODB,EnableSafeDocs,AllowSafeDocsOpen
```

Verify the values for each parameter as below:

```
EnableATPForSPOTeamsODB : True
EnableSafeDocs : True
AllowSafeDocsOpen : False
```

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com
2. Under `Email & collaboration` select `Policies & rules`
3. Select Threat policies then `Safe Attachments`.
4. Click on `Global settings`
5. Click to `Enable Turn on Defender for Office 365 for SharePoint, OneDrive, and Microsoft Teams`
6. Click to `Enable Turn on Safe Documents for Office clients`
7. Click to `Disable Allow people to click through Protected View even if Safe Documents identified the file as malicious`.
8. Click `Save`

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-AtpPolicyForO365 -EnableATPForSPOTeamsODB $true -EnableSafeDocs $true -
AllowSafeDocsOpen $false
```

References:

1. https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-for-spo-odfb-teams-about

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.1.6 Ensure Exchange Online Spam Policies are set to notify administrators (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft 365 organizations with mailboxes in Exchange Online or standalone Exchange Online Protection (EOP) organizations without Exchange Online mailboxes, email messages are automatically protected against spam (junk email) by EOP.

Configure Exchange Online Spam Policies to copy emails and notify someone when a sender in the organization has been blocked for sending spam emails.

Rationale:

A blocked account is a good indication that the account in question has been breached, and an attacker is using it to send spam emails to other people.

Impact:

Notification of users that have been blocked should not cause an impact to the user.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules` > `Threat policies`.
3. Under Policies select `Anti-spam`.
4. Click on the `Anti-spam outbound policy (default)`.
5. Verify that `Send a copy of suspicious outbound messages or message that exceed these limits to these users and groups` is set to `On`, ensure the email address is correct.
6. Verify that `Notify these users and groups if a sender is blocked due to sending outbound spam` is set to `On`, ensure the email address is correct.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-HostedOutboundSpamFilterPolicy | Select-Object Bcc*, Notify*
```

3. Verify both `BccSuspiciousOutboundMail` and `NotifyOutboundSpam` are set to `True` and the email addresses to be notified are correct.

Note: Audit and Remediation guidance may focus on the **Default policy** however, if a Custom Policy exists in the organization's tenant, then ensure the setting is set as outlined in the highest priority policy listed.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules`> `Threat policies`.
3. Under Policies select `Anti-spam`.
4. Click on the `Anti-spam outbound policy (default)`.
5. Select `Edit protection settings` then under `Notifications`:
6. Check `Send a copy of suspicious outbound messages or message that exceed these limits to these users and groups` then enter the desired email addresses.
7. Check `Notify these users and groups if a sender is blocked due to sending outbound spam` then enter the desired email addresses.
8. Click `Save`.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
$BccEmailAddress = @("<INSERT-EMAIL>")

$NotifyEmailAddress = @("<INSERT-EMAIL>")

Set-HostedOutboundSpamFilterPolicy -Identity Default -
BccSuspiciousOutboundAdditionalRecipients $BccEmailAddress -
BccSuspiciousOutboundMail $true -NotifyOutboundSpam $true -
NotifyOutboundSpamRecipients $NotifyEmailAddress
```

Note: Audit and Remediation guidance may focus on the **Default policy** however, if a Custom Policy exists in the organization's tenant, then ensure the setting is set as outlined in the highest priority policy listed.

Default Value:

```
BccSuspiciousOutboundAdditionalRecipients : {}
BccSuspiciousOutboundMail                 : False
NotifyOutboundSpamRecipients              : {}
NotifyOutboundSpam                        : False
```

References:

1. https://learn.microsoft.com/en-us/defender-office-365/outbound-spam-protection-about

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.1.7 Ensure that an anti-phishing policy has been created (Automated)

Profile Applicability:

- E5 Level 2

Description:

By default, Office 365 includes built-in features that help protect users from phishing attacks. Set up anti-phishing polices to increase this protection, for example by refining settings to better detect and prevent impersonation and spoofing attacks. The default policy applies to all users within the organization and is a single view to fine-tune anti-phishing protection. Custom policies can be created and configured for specific users, groups or domains within the organization and will take precedence over the default policy for the scoped users.

Rationale:

Protects users from phishing attacks (like impersonation and spoofing) and uses safety tips to warn users about potentially harmful messages.

Impact:

Mailboxes that are used for support systems such as helpdesk and billing systems send mail to internal users and are often not suitable candidates for impersonation protection. Care should be taken to ensure that these systems are excluded from Impersonation Protection.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules`
3. Select `Threat policies`.
4. Under Policies select `Anti-phishing`.
5. Verify an AntiPhish policy exists that is `On` and meets the following criteria:
6. Under **Users, groups, and domains**
   - Verify that the included domains and groups includes a majority of the organization.
7. Under **Phishing threshold & protection** verify the following:
   - `Phishing email threshold` is at least `3 - More Aggressive`.
   - `User impersonation protection` is `On` and contains a subset of users.
   - `Domain impersonation protection` is `On for owned domains`.
   - `Mailbox intelligence` and `Mailbox intelligence for impersonations` and `Spoof intelligence` are `On`.
8. Under **Actions** verify the following:
   - `If a message is detected as user impersonation` is set to `Quarantine the message`.
   - `If a message is detected as domain impersonation` is set to `Quarantine the message`.
   - `If Mailbox Intelligence detects an impersonated user` is set to `Quarantine the message`.
   - `First contact safety tip` is `On`.
   - `User impersonation safety tip` is `On`.
   - `Domain impersonation safety tip` is `On`.
   - `Unusual characters safety tip` is `On`.
   - `Honor DMARC record policy when the message is detected as spoof` is `On`.

Note: `DefaultFullAccessWithNotificationPolicy` is suggested but not required. Users will be notified that impersonation emails are in the Quarantine.

To audit using PowerShell:

1. Connect to Exchange Online service using `Connect-ExchangeOnline`.
2. Run the following Exchange Online PowerShell commands:

```
$params = @(
    "name","Enabled","PhishThresholdLevel","EnableTargetedUserProtection"
    "EnableOrganizationDomainsProtection","EnableMailboxIntelligence"
    "EnableMailboxIntelligenceProtection","EnableSpoofIntelligence"
    "TargetedUserProtectionAction","TargetedDomainProtectionAction"
    "MailboxIntelligenceProtectionAction","EnableFirstContactSafetyTips"
    "EnableSimilarUsersSafetyTips","EnableSimilarDomainsSafetyTips"
    "EnableUnusualCharactersSafetyTips","TargetedUsersToProtect"
    "HonorDmarcPolicy"
)

Get-AntiPhishPolicy | fl $params
```

3. Verify there is a policy created that has matching values for the following parameters:

```
Enabled                              : True
PhishThresholdLevel                  : 3
EnableTargetedUserProtection         : True
EnableOrganizationDomainsProtection  : True
EnableMailboxIntelligence            : True
EnableMailboxIntelligenceProtection  : True
EnableSpoofIntelligence              : True
TargetedUserProtectionAction         : Quarantine
TargetedDomainProtectionAction       : Quarantine
MailboxIntelligenceProtectionAction  : Quarantine
EnableFirstContactSafetyTips         : True
EnableSimilarUsersSafetyTips         : True
EnableSimilarDomainsSafetyTips       : True
EnableUnusualCharactersSafetyTips    : True
TargetedUsersToProtect               : {<contains users>}
HonorDmarcPolicy                     : True
```

4. Verify that `TargetedUsersToProtect` contains a subset of the organization, up to 350 users, for targeted Impersonation Protection.
5. Use PowerShell to verify the AntiPhishRule is configured and enabled.

```
Get-AntiPhishRule |
ft AntiPhishPolicy,Priority,State,SentToMemberOf,RecipientDomainIs
```

6. Identity correct rule from the matching `AntiPhishPolicy` name in step 3. Ensure the rule defines groups or domains that include the majority of the organization by inspecting `SentToMemberOf` or `RecipientDomainIs`.

Note: Audit guidance is intended to help identify a qualifying AntiPhish policy+rule that meets the recommended criteria while protecting the majority of the organization. It's understood some individual user exceptions may exist or exceptions for the entire policy if another product stands in as an equivalent control.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules`
3. Select `Threat policies`.
4. Under Policies select `Anti-phishing` and click `Create`.
5. Name the policy, continuing and clicking `Next` as needed:
    - Add `Groups` and/or `Domains` that contain a majority of the organization.
    - Set `Phishing email threshold` to `3 - More Aggressive`
    - Check `Enable users to protect` and add up to 350 users
    - Check `Enable domains to protect` and check `Include domains I own`
    - Check `Enable mailbox intelligence (Recommended)`
    - Check `Enable Intelligence for impersonation protection (Recommended)`
    - Check `Enable spoof intelligence (Recommended)`
6. Under **Actions** configure the following:
    - Set `If a message is detected as user impersonation` to `Quarantine the message`
    - Set `If a message is detected as domain impersonation` to `Quarantine the message`
    - Set `If Mailbox Intelligence detects an impersonated user` to `Quarantine the message`
    - Leave `Honor DMARC record policy when the message is detected as spoof` checked.
    - Check `Show first contact safety tip (Recommended)`
    - Check `Show user impersonation safety tip`
    - Check `Show domain impersonation safety tip`
    - Check `Show user impersonation unusual characters safety tip`
7. Finally, click `Next` and `Submit` the policy.

Note: `DefaultFullAccessWithNotificationPolicy` is suggested but not required. Users will be notified that impersonation emails are in the Quarantine.

To remediate using PowerShell:

1. Connect to Exchange Online service using `Connect-ExchangeOnline`.
2. Run the following Exchange Online PowerShell script to create an AntiPhish policy:

```
# Create the Policy
$params = @{
    Name = "CIS AntiPhish Policy"
    PhishThresholdLevel = 3
    EnableTargetedUserProtection = $true
    EnableOrganizationDomainsProtection = $true
    EnableMailboxIntelligence = $true
    EnableMailboxIntelligenceProtection = $true
    EnableSpoofIntelligence = $true
    TargetedUserProtectionAction = 'Quarantine'
    TargetedDomainProtectionAction = 'Quarantine'
    MailboxIntelligenceProtectionAction = 'Quarantine'
    TargetedUserQuarantineTag = 'DefaultFullAccessWithNotificationPolicy'
    MailboxIntelligenceQuarantineTag =
'DefaultFullAccessWithNotificationPolicy'
    TargetedDomainQuarantineTag = 'DefaultFullAccessWithNotificationPolicy'
    EnableFirstContactSafetyTips = $true
    EnableSimilarUsersSafetyTips = $true
    EnableSimilarDomainsSafetyTips = $true
    EnableUnusualCharactersSafetyTips = $true
    HonorDmarcPolicy = $true
}

New-AntiPhishPolicy @params

# Create the rule for all users in all valid domains and associate with
Policy
New-AntiPhishRule -Name $params.Name -AntiPhishPolicy $params.Name -
RecipientDomainIs (Get-AcceptedDomain).Name -Priority 0
```

3. The new policy can be edited in the UI or via PowerShell.

Note: Remediation guidance is intended to help create a qualifying AntiPhish policy that meets the recommended criteria while protecting the majority of the organization. It's understood some individual user exceptions may exist or exceptions for the entire policy if another product acts as a similar control.

References:

1. https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-protection-about
2. https://learn.microsoft.com/en-us/defender-office-365/anti-phishing-policies-eop-configure

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v7	7 Email and Web Browser Protections Email and Web Browser Protections			

2.1.8 Ensure that SPF records are published for all Exchange Domains (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

For each domain that is configured in Exchange, a corresponding Sender Policy Framework (SPF) record should be created.

Rationale:

SPF records enable Exchange Online Protection and other mail systems to verify which servers are authorized to send email for a domain. This helps those systems determine whether a message is legitimate or potentially spoofed. Enforcing a `-all` or `~all` ensures that any undocumented or unauthorized networks attempting to send on behalf of the organization are immediately rejected, reducing the risk of impersonation.

If an organization does not have full visibility into where its email originates, this represents a significant security gap. For example, if an email server is sending mail from an unexpected location across the country without your knowledge, that is a serious issue. Addressing this requires a deliberate discovery process to identify all legitimate sending sources, rather than allowing unknown systems to continue sending email unchecked.

Impact:

Setting up SPF records typically has minimal operational impact. However, organizations must ensure proper configuration, as misconfigured SPF records can cause legitimate email to be flagged as spam or fail authentication checks. Additionally, identifying all legitimate senders outside of the default Microsoft 365 IP ranges may require extra time and coordination during the discovery phase.

Audit:

STEP 1: Determine the list of domains to audit

Using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Expand `Settings` > `Domains`.
3. Take note of all custom domains and subdomains defined.
    - Exclude the (MOERA) domain `*.onmicrosoft.com`
    - Exclude the coexistence domain `*.mail.onmicrosoft.com` (if shown).
4. Use this list of domains in the audit procedure.

Using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following:

```
Get-AcceptedDomain |
Where-Object {$_.IsCoExistenceDomain -eq $false -and $_.InitialDomain -eq
$false}
```

3. Use this list in the audit procedure.

Note: Microsoft owns the tenant's organizational level *.onmicrosoft.com domains, so it is not necessary to create SPF records for the initial (MOERA) or the coexistence (hybrid) domain.

STEP 2: Perform the Audit using PowerShell:

1. Open a PowerShell prompt.
2. Run the following for each custom domain identified in Step 1 that sends email from Exchange Online:

```
Resolve-DnsName domain1.com -Type TXT | fl
```

Ensure the following criteria are met:

1. A valid TXT record must begin with `v=spf1`, which indicates it is SPF v1 (the current standard).
2. The record must be either **directly** or **indirectly** managed:
    - An indirectly managed record uses a modifier like redirect=[domain], which allows centralized SPF management by a trusted vendor.
3. The record must end with a **hard or soft fail policy:**
    - The record **must end with:** `-all` or `~all`, allowing for a hard fail or soft fail.

- If the SPF record uses the `redirect=` modifier, the redirected SPF record must terminate with a compliant qualifier (not the parent). This will require repeating the DNS lookup against the redirected domain.
- Other qualifiers not listed are not compliant as an end state.

Parked domains: Ensure that any domain not used for sending email has an SPF record explicitly indicating that no mail is authorized from that domain, using `v=spf1 -all`.

Below are examples of SPF records that are compliant. The audit does not evaluate specific `include` domains for compliant states.

```
v=spf1 include:spf.protection.outlook.com -all
v=spf1 include:spf.protection.outlook.com ~all

# GCC High or DoD example
v=spf1 include:exampledomain.net include:spf.protection.office365.us ~all

# 21Vianet
v=spf1 include:spf.protection.partner.outlook.cn ~all

# Parked domains
v=spf1 -all
```

Note: Resolve-DnsName is not available on versions of Windows earlier than Windows 8 and Windows Server 2012. Use alternatives such as nslookup when needed.

Remediation:

To remediate using a DNS provider:

For each domain identified as non-compliant during the audit, make the necessary updates in your DNS provider or through your third-party SPF management service.

Missing SPF Record: If a domain does not currently have an SPF record, create one similar to the example below, assuming all email is routed through Exchange Online (Microsoft 365 or Microsoft 365 GCC):

```
# Hard fail
v=spf1 include:spf.protection.outlook.com -all
# Soft fail
v=spf1 include:spf.protection.outlook.com ~all
```

Additional Senders: If other authorized email services are used, add their SPF entries using the include: mechanism as needed. For example:

```
v=spf1 include:spf.protection.outlook.com include:exampledomain.net -all
```

References:

1. https://learn.microsoft.com/en-us/microsoft-365/security/office-365-security/email-authentication-spf-configure?view=o365-worldwide
2. https://datatracker.ietf.org/doc/html/rfc7208
3. https://learn.microsoft.com/en-us/defender-office-365/email-authentication-spf-configure?view=o365-worldwide#scenario-parked-domains

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.5 Implement DMARC To lower the chance of spoofed or modified emails from valid domains, implement DMARC policy and verification, starting with implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail (DKIM) standards.		●	●
v7	7.8 Implement DMARC and Enable Receiver-Side Verification To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.		●	●

2.1.9 Ensure that DKIM is enabled for all Exchange Online Domains (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

DKIM is one of the trio of Authentication methods (SPF, DKIM and DMARC) that help prevent attackers from sending messages that look like they come from your domain.

DKIM lets an organization add a digital signature to outbound email messages in the message header. When DKIM is configured, the organization authorizes it's domain to associate, or sign, it's name to an email message using cryptographic authentication. Email systems that get email from this domain can use a digital signature to help verify whether incoming email is legitimate.

Use of DKIM in addition to SPF and DMARC to help prevent malicious actors using spoofing techniques from sending messages that look like they are coming from your domain.

Rationale:

By enabling DKIM with Office 365, messages that are sent from Exchange Online will be cryptographically signed. This will allow the receiving email system to validate that the messages were generated by a server that the organization authorized and not being spoofed.

Impact:

There should be no impact of setting up DKIM however, organizations should ensure appropriate setup to ensure continuous mail-flow.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `Email & collaboration` > `Policies & rules` > `Threat policies`.
3. Under `Rules` section click `Email authentication settings`.
4. Select `DKIM`.
5. For each `Accepted domain` that **is configured to send email**:
    - Skip any *.onmicrosoft.com domain (MOERA or Coexistence), these outbound messages are automatically signed by Microsoft.
    - Click on the domain name.
    - Confirm `Sign messages for this domain with DKIM signatures` is `Enabled`.
    - Ensure `Status` reads `Signing DKIM signatures for this domain.`
6. A status of **Not signing DKIM signatures for this domain** or **No DKIM keys saved for this domain** is out of compliance.

Note: For step 5 these can also be audited the overview showing all domains. In this case a passing audit procedure will display the `Toggle` set as `Enabled` and `Status` as `Valid`.

To audit using PowerShell:

1. Connect to Exchange Online service using `Connect-ExchangeOnline`.
2. Run the following:

```
# Get-DkimSigningConfig does not display unconfigured domains,
# so we first get all accepted domains and then match them against
# the DKIM signing configurations.
$Domains = Get-AcceptedDomain |
    Where-Object {$_.IsCoExistenceDomain -eq $false -and $_.InitialDomain -eq
$false}

$DKIMCfg = Get-DkimSigningConfig

# Generate the report
$Report = foreach ($Domain in $Domains) {
    $DKIM = $DKIMCfg | Where-Object { $_.Name -eq $Domain.Name }

    [PSCustomObject]@{
        DomainName     = $Domain.Name
        Enabled        = [bool]$DKIM.Enabled
        Status         = if ($DKIM) { $DKIM.Status } else { "Not Configured"
}
        IsCISCompliant = ($DKIM.Enabled -and $DKIM.Status -eq "Valid")
    }
}

# Output the report
$Report | Format-Table -AutoSize
# Optionally, export the report to a CSV file
# $Report | Export-Csv -Path "2_1_9.csv" -NoTypeInformation
```

3. For each domain that is **configured to send email** verify:
    - `Enabled` is `True`
    - `Status` is `Valid`.
    - **Note:** The property `IsCISCompliant` will also validate whether the state is compliant.

Note: If you own registered domains that aren't used for email or anything at all (also known as parked domains), don't publish DKIM records for those domains. The lack of a DKIM record (hence, the lack of a public key in DNS to validate the message signature) prevents DKIM validation of forged domains.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `Email & collaboration` > `Policies & rules` > `Threat policies`.
3. Under `Rules` section click `Email authentication settings`.
4. Select `DKIM`
5. Select the domain to remediate.
6. Click `Create DKIM keys`.
7. Microsoft provides the properly formatted CNAME records, copy these for later use.
8. In another browser tab or window, go to the domain registrar for the domain, and then create the two CNAME records using the information from the previous step.
9. Return the domain properties flyout and toggle `Sign messages for this domain with DKIM signatures` to `Enabled`.

If successful the status will show `Signing DKIM signatures for this domain`.

Default Value:

Custom domains: Not configured by default

MOERA onmicrosoft.com domain: Outbound email is automatically signed

References:

1. https://learn.microsoft.com/en-us/microsoft-365/security/office-365-security/email-authentication-dkim-configure?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.5 Implement DMARC To lower the chance of spoofed or modified emails from valid domains, implement DMARC policy and verification, starting with implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail (DKIM) standards.		●	●
v7	7.8 Implement DMARC and Enable Receiver-Side Verification To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.		●	●

2.1.10 Ensure DMARC records for all Exchange Online domains are published (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

DMARC, or Domain-based Message Authentication, Reporting, and Conformance, assists recipient mail systems in determining the appropriate action to take when messages from a domain fail to meet SPF or DKIM authentication criteria.

Rationale:

DMARC strengthens the trustworthiness of messages sent from an organization's domain to destination email systems. When combined with SPF (Sender Policy Framework) and DKIM (DomainKeys Identified Mail), DMARC significantly enhances defenses against email spoofing and phishing attempts.

This includes the MOERA domain (e.g., contoso.onmicrosoft.com), which is provisioned with every Microsoft 365 tenant and is capable of originating email. Because it is often overlooked in favor of custom domains, it represents a common gap in email authentication coverage if left unprotected.

Leaving a DMARC policy set to `p=none` can result in the mail system taking no action when a spear-phishing email fails DMARC but passes SPF and DKIM checks. Having DMARC fully configured is a critical part of preventing business email compromise.

Impact:

The remediation portion can take time to implement and involves a multi-staged approach over time. First, a baseline of the current state of email will be established with `p=none` and `rua` and `ruf`. Once the environment is better understood and reports have been analyzed, an organization will move to the final state with DMARC record values as outlined in the audit section.

Audit:

STEP 1: Determine the list of domains to audit

Using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com
2. Expand `Settings` > `Domains`.
3. Take note of all custom domains and subdomains defined.
    - Exclude the coexistence domain `*.mail.onmicrosoft.com` (if shown).
4. Include the MOERA domain: [tenant].onmicrosoft.com
5. Use this list of domains in the audit procedure.

Using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following:

```
Get-AcceptedDomain |
Where-Object {$_.IsCoExistenceDomain -eq $false}
```

3. Use this list in the audit procedure.

STEP 2: Perform the Audit using PowerShell:

Note: Resolve-DnsName is not available on versions of Windows earlier than Windows 8 and Windows Server 2012. Use alternatives such as nslookup when needed.

1. Open a PowerShell prompt.
2. Run the following for each domain identified in Step 1:

```
Resolve-DnsName _dmarc.domain1.com -Type TXT
```

3. Ensure the following criteria are met:
    1. The record must be either **directly** or **indirectly** managed:
        - An indirectly managed record would use a CNAME to point to another record.
        - If the record is managed indirectly then that record must meet all criteria. This would require an additional DNS lookup.
    2. The **version** `v` tag value must be `v=DMARC1`, which identifies it as a DMARC record.
    3. The **policy** `p` tag value is `p=quarantine` OR `p=reject`.
    4. The **sampling rate** `pct` tag value is `pct=100` or does not exist. (A non-existent pct tag indicates sampling is 100 percent)
    5. The **aggregate data** `rua` tag value is configured, i.e. `rua=mailto:<reporting email address>`.

6. The **failure data** `ruf` tag value is configured, i.e. `ruf=mailto:<reporting email address>`.

4. **Subdomain considerations**
    - When subdomains of the organizational domain are in scope, DMARC policy is determined using a two-step record discovery process (RFC 7489, Section 6.6.3):

1. If the subdomain has its own valid DMARC record (i.e., a record that includes the required `p=` tag), only that record is used. Nothing is inherited from the organizational domain. Any tags not explicitly defined in the subdomain's record fall back to their RFC-defined default values.
2. If the subdomain does not have a valid DMARC record — either because no record exists or because the record is malformed (e.g., missing the required `p=` tag) — the organizational domain's record is used. When determining policy disposition, the `sp=` (subdomain policy) tag is applied if present; otherwise, the `p=` tag is used.
    - This fallback is record discovery, not per-tag inheritance. The lookup always falls back to the organizational domain directly. Intermediate parent subdomains are never consulted.
    - The `sp=` tag is only meaningful when set on the organizational domain's record and is ignored on subdomain records.
5. Compliance is met when each domain and subdomain meets the requirements in steps 3 and 4.

Parked Domains: Ensure that any domain not used for sending email has a DMARC record explicitly indicating that no mail is authorized from that domain.

1. The **version** `v` tag value must be `v=DMARC1`, which identifies it as a DMARC record.
2. The **policy** `p` tag value is `p=reject`.

The following example records would pass as they contain a policy that would either `quarantine` or `reject` messages failing DMARC, and the policy affects 100% of mail `pct=100` as well as containing valid reporting and aggregate addresses:

```
v=DMARC1; p=reject; pct=100; rua=mailto:rua@example.com;
ruf=mailto:ruf@example.com; fo=1

v=DMARC1; p=reject; rua=mailto:rua@example.com; ruf=mailto:ruf@example.com;
fo=1

v=DMARC1; p=quarantine; pct=100; sp=none; fo=1; ri=3600;
rua=mailto:rua@example.com; ruf=mailto:ruf@example.com;

# Parked domains
v=DMARC1; p=reject;
```

Note: The third example includes `sp=none`, which sets the subdomain policy to monitor-only. While the organizational domain itself would be compliant, any subdomains would **not** meet the audit criteria if they exist. Auditors must evaluate subdomains separately to confirm compliance.

Remediation:

To remediate using a DNS provider:

1. For any out of compliance domain sending email, add the following record to DNS:

```
Record: _dmarc.domain1.com
Type: TXT
Value: v=DMARC1; p=none; rua=mailto:<rua-report@example.com>;
ruf=mailto:<ruf-report@example.com>
```

2. This will create a basic DMARC policy that will allow the organization to start monitoring message statistics.
3. One week is enough time for data generated by the reports to be useful in understanding email trends and traffic. The final step requires implementing a policy of `p=reject` OR `p=quarantine` and `pct=100` with the necessary `rua` and `ruf` email addresses defined:

```
Record: _dmarc.domain1.com
Type: TXT
Value: v=DMARC1; p=reject; pct=100; rua=mailto:<rua-report@example.com>;
ruf=mailto:<ruf-report@example.com>
```

Parked Domains: For any domain not used for sending email, add the following record to DNS:

```
Record: _dmarc.domain1.com
Type: TXT
Value: v=DMARC1; p=reject;
```

To remediate the MOERA domain using the UI:

1. Navigate to the Microsoft 365 admin center https://admin.microsoft.com/
2. Expand `Settings` and select `Domains`.
3. Select your tenant domain (for example, contoso.onmicrosoft.com).
4. Select `DNS records` and click `+ Add record`.
5. Add a new record with the TXT name of `_dmarc` with the appropriate values outlined above.

References:

1. https://learn.microsoft.com/en-us/defender-office-365/email-authentication-dmarc-configure?view=o365-worldwide
2. https://learn.microsoft.com/en-us/defender-office-365/step-by-step-guides/how-to-enable-dmarc-reporting-for-microsoft-online-email-routing-address-moera-and-parked-domains?view=o365-worldwide
3. https://media.defense.gov/2024/May/02/2003455483/-1/-1/0/CSA-NORTH-KOREAN-ACTORS-EXPLOIT-WEAK-DMARC.PDF
4. https://www.rfc-editor.org/rfc/rfc7489

Additional Information:

Microsoft has a list of best practices for implementing DMARC that cover these steps in detail.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.5 Implement DMARC To lower the chance of spoofed or modified emails from valid domains, implement DMARC policy and verification, starting with implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail (DKIM) standards.		●	●
v7	7.8 Implement DMARC and Enable Receiver-Side Verification To lower the chance of spoofed or modified emails from valid domains, implement Domain-based Message Authentication, Reporting and Conformance (DMARC) policy and verification, starting by implementing the Sender Policy Framework (SPF) and the DomainKeys Identified Mail(DKIM) standards.		●	●

2.1.11 Ensure comprehensive attachment filtering is applied (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

The Common Attachment Types Filter lets a user block known and custom malicious file types from being attached to emails. The policy provided by Microsoft covers 53 extensions, and an additional custom list of extensions can be defined.

The list of 186 extensions provided in this recommendation is comprehensive but not exhaustive.

Rationale:

Blocking known malicious file types can help prevent malware-infested files from infecting a host or performing other malicious attacks such as phishing and data extraction.

Defining a comprehensive list of attachments can help protect against additional unknown and known threats. Many legacy file formats, binary files and compressed files have been used as delivery mechanisms for malicious software. Organizations can protect themselves from Business E-mail Compromise (BEC) by allow-listing only the file types relevant to their line of business and blocking all others.

Impact:

For file types that are business necessary users will need to use other organizationally approved methods to transfer blocked extension types between business partners.

Audit:

For this control, a Level 2 comprehensive attachment policy is defined as one that includes at least 120 extensions. The 184 extensions included are a known vector for malicious activity. To pass, organizations must demonstrate at least a 90% adoption rate of the extension list referenced in the script below, with allowances for justified exceptions. Since individual extensions are not assigned specific risk weights, exceptions should be based on documented business needs.

Note: Utilizing the UI for auditing Anti-malware policies can be very time consuming so it is recommended to use a script like the one supplied below.

To Audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following script:

```
$AttachExts  = @(
    '7z', 'a3x', 'ace', 'ade', 'adp', 'ani', 'apk', 'app', 'appinstaller',
    'applescript', 'application', 'appref-ms', 'appx', 'appxbundle', 'arj',
    'asd', 'asx', 'bas', 'bat', 'bgi', 'bz2', 'cab', 'chm', 'cmd', 'com',
    'cpl', 'crt', 'cs', 'csh', 'daa', 'dbf', 'dcr', 'deb',
    'desktopthemepackfile', 'dex', 'diagcab', 'dif', 'dir', 'dll', 'dmg',
    'doc', 'docm', 'dot', 'dotm', 'elf', 'eml', 'exe', 'fxp', 'gadget',
    'gz', 'hlp', 'hta', 'htc', 'htm', 'html', 'hwpx', 'ics', 'img',
    'inf', 'ins', 'iqy', 'iso', 'isp', 'jar', 'jnlp', 'js', 'jse', 'kext',
    'ksh', 'lha', 'lib', 'library', 'library-ms', 'lnk', 'lzh', 'macho',
    'mam', 'mda', 'mdb', 'mde', 'mdt', 'mdw', 'mdz', 'mht', 'mhtml', 'mof',
    'msc', 'msi', 'msix', 'msp', 'msrcincident', 'mst', 'ocx', 'odt', 'ops',
    'oxps', 'pcd', 'pif', 'plg', 'pot', 'potm', 'ppa', 'ppam', 'ppkg', 'pps',
    'ppsm', 'ppt', 'pptm', 'prf', 'prg', 'ps1', 'ps11', 'ps11xml', 'ps1xml',
    'ps2', 'ps2xml', 'psc1', 'psc2', 'pub', 'py', 'pyc', 'pyo', 'pyw', 'pyz',
    'pyzw', 'rar', 'reg', 'rev', 'rtf', 'scf', 'scpt', 'scr', 'sct',
    'searchConnector-ms', 'service', 'settingcontent-ms', 'sh', 'shb', 'shs',
    'shtm', 'shtml', 'sldm', 'slk', 'so', 'spl', 'stm', 'svg', 'swf', 'sys',
    'tar', 'theme', 'themepack', 'timer', 'uif', 'url', 'uue', 'vb', 'vbe',
    'vbs', 'vhd', 'vhdx', 'vxd', 'wbk', 'website', 'wim', 'wiz', 'ws', 'wsc',
    'wsf', 'wsh', 'xla', 'xlam', 'xlc', 'xll', 'xlm', 'xls', 'xlsb', 'xlsm',
    'xlt', 'xltm', 'xlw', 'xnk', 'xps', 'xsl', 'xz', 'z'
)

$MalwareFilterPolicies = Get-MalwareFilterPolicy
$MalwareFilterRules = Get-MalwareFilterRule
# A policy must have at least 90% of the extensions in the reference list to
pass.
# This allows for some flexibility with exceptions.
$PassingValue = .90 # 90%
$FailThreshold = [int]($AttachExts.count * (1 - $PassingValue))

# Only evaluate policies that have more than 120 extensions defined
# so we don't output failures on policies that aren't specific to
# extension filtering.
$CompPolicies = $MalwareFilterPolicies | Where-Object { $_.FileTypes.Count -
gt 120 }
if (-not $CompPolicies) {
    Write-Output "## FAIL ## No comprehensive policies found to evaluate."
    return
}

$ExtensionReport = foreach ($policy in $CompPolicies) {
    $Missing = Compare-Object -ReferenceObject $AttachExts `
        -DifferenceObject $policy.FileTypes `
        -PassThru | Where-Object { $_.SideIndicator -eq '<=' }
    $FoundRule = $MalwareFilterRules |
        Where-Object { $_.MalwareFilterPolicy -eq $policy.Id }

    # Define passing conditions to determine if this policy passes all
checks.
    $Pass = ($Missing.Count -lt $FailThreshold) -and
            ($FoundRule.State -eq 'Enabled') -and
            ($policy.EnableFileFilter -eq $true)

    [PSCustomObject]@{
        PolicyName        = $policy.Identity
```

```
        IsCISCompliant    = $Pass
        EnableFileFilter  = $policy.EnableFileFilter
        State             = $FoundRule.State
        MissingCount      = $Missing.count
        MissingExtensions = $Missing -join ", "
        ExtensionCount    = $policy.FileTypes.count
    }
}

# Output results in various formats
$ExtensionReport | Format-Table -AutoSize
<# Optional: Export methods
$ExtensionReport | Out-GridView -Title "Attachment Filter results"
$ExtensionReport | Export-Csv -Path "2.1.11.csv" -NoTypeInformation
$ExtensionReport | ConvertTo-Json | Out-File -FilePath "2.1.11.json"
#>
```

3. Review the results, only policies with over 120 extensions defined will be evaluated. At the end of the script examples of different output formats are given.
4. A pass is given for the following conditions:
    - A single active policy exists that covers all file extensions listed except those defined as an exception by the organization.
    - The policy has a state of `Enabled`.
    - The `EnableFileFilter` property is set to `True`.
5. The report includes a `IsCISCompliant` property, where `True` indicates in compliance, allowing for up to 10% of the listed extensions to be missing as documented exceptions.

Note: Organizations should evaluate any extensions missing from the report to determine if they are valid exceptions.

Note: The audit procedure intentionally does not include the action taken for matched extensions, e.g. Reject with NDR or Quarantine the message. These are considered organization specific and are not scored. When `FileTypeAction` is not specified the action will default to `Reject the message with a non-delivery receipt (NDR)`. The Quarantine Policy is also considered organization specific.

Remediation:

To Remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following script after editing `InternalSenderAdminAddress`:

```
# Create an attachment policy and associated rule. The rule is
# intentionally disabled allowing the org to enable it when ready

$Policy = @{
    Name              = "CIS L2 Attachment Policy"
    EnableFileFilter  = $true
    ZapEnabled        = $true
    EnableInternalSenderAdminNotifications = $true
    InternalSenderAdminAddress = 'admin@contoso.com' # Change this.
}

$L2Extensions = @(
    "7z", "a3x", "ace", "ade", "adp", "ani", "app", "appinstaller",
    "applescript", "application", "appref-ms", "appx", "appxbundle", "arj",
    "asd", "asx", "bas", "bat", "bgi", "bz2", "cab", "chm", "cmd", "com",
    "cpl", "crt", "cs", "csh", "daa", "dbf", "dcr", "deb",
    "desktopthemepackfile", "dex", "diagcab", "dif", "dir", "dll", "dmg",
    "doc", "docm", "dot", "dotm", "elf", "eml", "exe", "fxp", "gadget", "gz",
    "hlp", "hta", "htc", "htm", "html", "hwpx", "ics", "img",
    "inf", "ins", "iqy", "iso", "isp", "jar", "jnlp", "js", "jse", "kext",
    "ksh", "lha", "lib", "library-ms", "lnk", "lzh", "macho", "mam", "mda",
    "mdb", "mde", "mdt", "mdw", "mdz", "mht", "mhtml", "mof", "msc", "msi",
    "msix", "msp", "msrcincident", "mst", "ocx", "odt", "ops", "oxps", "pcd",
    "pif", "plg", "pot", "potm", "ppa", "ppam", "ppkg", "pps", "ppsm", "ppt",
    "pptm", "prf", "prg", "ps1", "ps11", "ps11xml", "ps1xml", "ps2",
    "ps2xml", "psc1", "psc2", "pub", "py", "pyc", "pyo", "pyw", "pyz",
    "pyzw", "rar", "reg", "rev", "rtf", "scf", "scpt", "scr", "sct",
    "searchConnector-ms", "service", "settingcontent-ms", "sh", "shb", "shs",
    "shtm", "shtml", "sldm", "slk", "so", "spl", "stm", "svg", "swf", "sys",
    "tar", "theme", "themepack", "timer", "uif", "url", "uue", "vb", "vbe",
    "vbs", "vhd", "vhdx", "vxd", "wbk", "website", "wim", "wiz", "ws", "wsc",
    "wsf", "wsh", "xla", "xlam", "xlc", "xll", "xlm", "xls", "xlsb", "xlsm",
    "xlt", "xltm", "xlw", "xnk", "xps", "xsl", "xz", "z"
)

# Create the policy
New-MalwareFilterPolicy @Policy -FileTypes $L2Extensions
# Create the rule for all accepted domains
$Rule = @{
    Name = $Policy.Name
    Enabled = $false
    MalwareFilterPolicy = $Policy.Name
    RecipientDomainIs = (Get-AcceptedDomain).Name
    Priority = 0
}

New-MalwareFilterRule @Rule
```

3. When prepared enable the rule either through the UI or PowerShell.

Note: Due to the number of extensions the UI method is not covered. The objects can however be edited in the UI or manually added using the list from the script.

1. Navigate to `Microsoft Defender` at https://security.microsoft.com/
2. Browse to `Policies & rules` > `Threat policies` > `Anti-malware`.

Default Value:

The following extensions are blocked by default:

ace, ani, apk, app, appx, arj, bat, cab, cmd, com, deb, dex, dll, docm, elf, exe, hta, img, iso, jar, jnlp, kext, lha, lib, library, lnk, lzh, macho, msc, msi, msix, msp, mst, pif, ppa, ppam, reg, rev, scf, scr, sct, sys, uif, vb, vbe, vbs, vxd, wsc, wsf, wsh, xll, xz, z

References:

1. https://learn.microsoft.com/en-us/powershell/module/exchange/get-malwarefilterpolicy?view=exchange-ps
2. https://learn.microsoft.com/en-us/microsoft-365/security/office-365-security/anti-malware-policies-configure?view=o365-worldwide
3. https://learn.microsoft.com/en-us/office/compatibility/office-file-format-reference

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.6 Block Unnecessary File Types Block unnecessary file types attempting to enter the enterprise's email gateway.		●	●
v7	7.9 Block Unnecessary File Types Block all e-mail attachments entering the organization's e-mail gateway if the file types are unnecessary for the organization's business.		●	●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

2.1.12 Ensure the connection filter IP allow list is not used (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft 365 organizations with Exchange Online mailboxes or standalone Exchange Online Protection (EOP) organizations without Exchange Online mailboxes, connection filtering and the default connection filter policy identify good or bad source email servers by IP addresses. The key components of the default connection filter policy are **IP Allow List**, **IP Block List** and **Safe list**.

The recommended state is `IP Allow List` empty or undefined.

Rationale:

Without additional verification like mail flow rules, email from sources in the IP Allow List skips spam filtering and sender authentication (SPF, DKIM, DMARC) checks. This method creates a high risk of attackers successfully delivering email to the Inbox that would otherwise be filtered. Messages that are determined to be malware or high confidence phishing are filtered.

Impact:

This is the default behavior. IP Allow lists may reduce false positives, however, this benefit is outweighed by the importance of a policy which scans all messages regardless of the origin. This supports the principle of zero trust.

Audit:

To audit using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules > Threat policies.
3. Under Policies select Anti-spam.
4. Click on the Connection filter policy (Default).
5. Verify that IP Allow list contains no entries.

To audit using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following PowerShell command:

```
Get-HostedConnectionFilterPolicy -Identity Default | fl IPAllowList
```

3. Verify that IPAllowList is empty or {}

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules> Threat policies.
3. Under Policies select Anti-spam.
4. Click on the Connection filter policy (Default).
5. Click Edit connection filter policy.
6. Remove any IP entries from Always allow messages from the following IP addresses or address range:.
7. Click Save.

To remediate using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following PowerShell command:

```
Set-HostedConnectionFilterPolicy -Identity Default -IPAllowList @{}
```

Default Value:

IPAllowList : {}

References:

1. https://learn.microsoft.com/en-us/defender-office-365/connection-filter-policies-configure
2. https://learn.microsoft.com/en-us/defender-office-365/create-safe-sender-lists-in-office-365#use-the-ip-allow-list
3. https://learn.microsoft.com/en-us/defender-office-365/how-policies-and-protections-are-combined#user-and-tenant-settings-conflict

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.1.13 Ensure the connection filter safe list is off (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft 365 organizations with Exchange Online mailboxes or standalone Exchange Online Protection (EOP) organizations without Exchange Online mailboxes, connection filtering and the default connection filter policy identify good or bad source email servers by IP addresses. The key components of the default connection filter policy are **IP Allow List**, **IP Block List** and **Safe list**.

The safe list is a pre-configured allow list that is dynamically updated by Microsoft.

The recommended safe list state is: `Off` or `False`

Rationale:

Without additional verification like mail flow rules, email from sources in the IP Allow List skips spam filtering and sender authentication (SPF, DKIM, DMARC) checks. This method creates a high risk of attackers successfully delivering email to the Inbox that would otherwise be filtered. Messages that are determined to be malware or high confidence phishing are filtered.

The safe list is managed dynamically by Microsoft, and administrators do not have visibility into which senders are included. Incoming messages from email servers on the safe list bypass spam filtering.

Impact:

This is the default behavior. IP Allow lists may reduce false positives, however, this benefit is outweighed by the importance of a policy which scans all messages regardless of the origin. This supports the principle of zero trust.

Audit:

To audit using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules > Threat policies.
3. Under Policies select Anti-spam.
4. Click on the Connection filter policy (Default).
5. Verify that Safe list is Off.

To audit using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following PowerShell command:

```
Get-HostedConnectionFilterPolicy -Identity Default | fl EnableSafeList
```

3. Verify that EnableSafeList is False

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules> Threat policies.
3. Under Policies select Anti-spam.
4. Click on the Connection filter policy (Default).
5. Click Edit connection filter policy.
6. Uncheck Turn on safe list.
7. Click Save.

To remediate using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following PowerShell command:

```
Set-HostedConnectionFilterPolicy -Identity Default -EnableSafeList $false
```

Default Value:

EnableSafeList : False

References:

1. https://learn.microsoft.com/en-us/defender-office-365/connection-filter-policies-configure
2. https://learn.microsoft.com/en-us/defender-office-365/create-safe-sender-lists-in-office-365#use-the-ip-allow-list
3. https://learn.microsoft.com/en-us/defender-office-365/how-policies-and-protections-are-combined#user-and-tenant-settings-conflict

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.1.14 Ensure inbound anti-spam policies do not contain allowed domains (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Anti-spam protection is a feature of Exchange Online that utilizes policies to help to reduce the amount of junk email, bulk and phishing emails a mailbox receives. These policies contain lists to allow or block specific senders or domains.

- The allowed senders list
- The allowed domains list
- The blocked senders list
- The blocked domains list

The recommended state is: Do not define any `Allowed domains`

Rationale:

Messages from entries in the allowed senders list or the allowed domains list bypass most email protection (except malware and high confidence phishing) and email authentication checks (SPF, DKIM and DMARC). Entries in the allowed senders list or the allowed domains list create a high risk of attackers successfully delivering email to the Inbox that would otherwise be filtered. The risk is increased even more when allowing common domain names as these can be easily spoofed by attackers.

Microsoft specifies in its documentation that allowed domains should be used for testing purposes only.

Impact:

This is the default behavior. Allowed domains may reduce false positives, however, this benefit is outweighed by the importance of having a policy which scans all messages regardless of the origin. As an alternative consider sender based lists. This supports the principle of zero trust.

Audit:

To audit using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules > Threat policies.
3. Under Policies select Anti-spam.
4. Inspect each **inbound anti-spam** policy
5. Verify that Allowed domains does not contain any domain names.
6. Repeat as needed for any additional inbound anti-spam policy.

To audit using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following PowerShell command:

```
Get-HostedContentFilterPolicy | ft Identity,AllowedSenderDomains
```

3. Verify that AllowedSenderDomains is undefined for each inbound policy.

Note: Each inbound policy must pass for this recommendation to be considered to be in a passing state.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com.
2. Expand Email & collaboration > Policies & rules> Threat policies.
3. Under Policies select Anti-spam.
4. Open each out of compliance inbound anti-spam policy by clicking on it.
5. Click Edit allowed and blocked senders and domains.
6. Select Allow domains.
7. Delete each domain from the domains list.
8. Click Done > Save.
9. Repeat as needed.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-HostedContentFilterPolicy -Identity <Policy name> -AllowedSenderDomains
@{}
```

Or, run this to remove allowed domains from all inbound anti-spam policies:

```
$AllowedDomains = Get-HostedContentFilterPolicy | Where-Object
{$_.AllowedSenderDomains}
$AllowedDomains | Set-HostedContentFilterPolicy -AllowedSenderDomains @{}
```

Default Value:

AllowedSenderDomains : {}

References:

1. https://learn.microsoft.com/en-us/defender-office-365/anti-spam-protection-about#allow-and-block-lists-in-anti-spam-policies

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.1.15 Ensure outbound anti-spam message limits are in place (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The default outbound anti-spam policy in Microsoft Defender automatically applies to all users and is designed to detect and limit suspicious email-sending behavior. The policy enforces limits based on both volume and spam detection. If a user sends too many emails too quickly or if a high percentage of their messages are flagged as spam, their ability to send email can be temporarily restricted. This helps prevent abuse from compromised accounts or inadvertent spam campaigns.

When these limits are exceeded, Microsoft routes the messages through a high-risk delivery pool to protect its IP reputation and notifies administrators through built-in alert policies.

The recommended state is:

- External: `Restrict sending to external recipients (per hour)` - `500`
- Internal: `Restrict sending to internal recipients (per hour)` - `1000`
- Daily: `Maximum recipient limit per day` - `1000`
- Action: `Over limit action` - `Restrict the user from sending mail`

Rationale:

Message limit settings help lessen the impact of a Business Email Compromise (BEC) by automatically restricting accounts that send unusually high volumes of email. This containment prevents compromised accounts from launching large-scale attacks and helps ensure the organization's email remains trusted and deliverable. Without these limits, excessive or suspicious outbound traffic could result in Microsoft blocking the organization's email, disrupting communication and damaging reputation.

Impact:

Enforcing message limits may result in legitimate users being temporarily blocked from sending email if their bulk messaging activity resembles spam or exceeds volume thresholds. This can disrupt business operations, delay communication, and require administrative effort to investigate and restore access. However, these adverse effects typically stem from a lack of planning around mass mailings. To avoid triggering these limits, Microsoft recommends sending bulk email through custom subdomains or third-party bulk email providers.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules` > `Threat policies`.
3. Under Policies select `Anti-spam` and click to open `Anti-spam outbound policy (Default)`.
4. Verify the following settings are configured to the recommended level or a more restrictive value. Message limit values of `0` are not compliant, as it represents the service default:
    - External: `Restrict sending to external recipients (per hour)` - `500`
    - Internal: `Restrict sending to internal recipients (per hour)` - `1000`
    - Daily: `Maximum recipient limit per day` - `1000`
    - Action: `Over limit action` - `Restrict the user from sending mail`
5. Verify that a monitored mailbox is configured as a recipient under `Notify these users and groups if a sender is blocked due to sending outbound spam`.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following:

```
$params = @(
    'RecipientLimitExternalPerHour'
    'RecipientLimitInternalPerHour'
    'RecipientLimitPerDay'
    'ActionWhenThresholdReached'
    'NotifyOutboundSpamRecipients'
)

Get-HostedOutboundSpamFilterPolicy -Identity Default | fl $params
```

3. Verify that each of the following properties is configured as specified:
    - `RecipientLimitExternalPerHour` is `500` or less, but not 0
    - `RecipientLimitInternalPerHour` is `1000` or less, but not 0
    - `RecipientLimitPerDay` is `1000` or less, but not 0
    - `ActionWhenThresholdReached` is `BlockUser`
    - `NotifyOutboundSpamRecipients` contains a monitored mailbox.

Note: Microsoft's *Recommended Strict* values represent a more restrictive and also compliant configuration. These values 400, 800, and 800 align with the values above. For further details on Standard and Strict settings, refer to the references section.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com.
2. Expand `Email & collaboration` > `Policies & rules`> `Threat policies`.
3. Under Policies select `Anti-spam` and click to open `Anti-spam outbound policy (Default)`.
4. Select `Edit protection settings`.
5. Set the following settings to the recommended values, *or* more restrictive values. Message limit values of `0` are not compliant, as it represents the service default
    - External: `Set an external message limit` - `500`
    - Internal: `Set an internal message limit` - `1000`
    - Daily: `Set a daily message limit` - `1000`
    - Action: `Restriction placed on users who reach the message limit` - `Restrict the user from sending mail`
6. Verify that `Notify these users and groups if a sender is blocked due to sending outbound spam` contains a monitored mailbox.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Change the example email addresses below and run the following PowerShell commands:

```
$params = @{
    RecipientLimitExternalPerHour = 500
    RecipientLimitInternalPerHour = 1000
    RecipientLimitPerDay = 1000
    ActionWhenThresholdReached = 'BlockUser'
    NotifyOutboundSpamRecipients =
@('admin@example.com','security@example.com')
}

Set-HostedOutboundSpamFilterPolicy -Identity 'Default' @params
```

Default Value:

```
RecipientLimitExternalPerHour : 0
RecipientLimitInternalPerHour : 0
RecipientLimitPerDay          : 0
ActionWhenThresholdReached    : BlockUserForToday
```

The value of `0` means the service defaults are being used. More information on sending limits is here: https://learn.microsoft.com/en-us/office365/servicedescriptions/exchange-online-service-description/exchange-online-limits#sending-limits-1

References:

1. https://learn.microsoft.com/en-us/defender-office-365/outbound-spam-protection-about
2. https://learn.microsoft.com/en-us/defender-office-365/recommended-settings-for-eop-and-office365#outbound-spam-policy-settings
3. https://learn.microsoft.com/en-us/office365/servicedescriptions/exchange-online-service-description/exchange-online-limits#sending-limits-1

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

2.2 Cloud apps

This section contains recommendations for Microsoft Defender for Cloud apps

2.2.1 Ensure emergency access account activity is monitored (Manual)

Profile Applicability:

- E5 Level 1

Description:

Organizations should monitor sign-in and audit log activity from the emergency accounts and trigger notifications to other administrators. When you monitor the activity for emergency access accounts, you can verify these accounts are only used for testing or actual emergencies. You can use Azure Monitor, Microsoft Sentinel, Defender for Cloud Apps or other tools to monitor the sign-in logs and trigger email and SMS alerts to your administrators whenever emergency access accounts sign in.

This recommendation uses Defender for Cloud Apps Policies to alert on emergency access account activity.

The recommended state is to monitor `Activity type Log on` on break-glass or emergency access accounts.

Rationale:

Emergency access accounts should be used in very few scenarios, for example, the last Global Administrator has left the organization and the account is inaccessible. All activity on an emergency access account should be reviewed at the time of the event to ensure the sign on is legitimate and authorized.

Impact:

There is no real world impact to monitoring these accounts beyond allocating staff. The frequency of emergency account sign on should be so low that any activity raises a red flag that is treated with the highest priority.

Audit:

To audit using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com
2. Under the **Cloud Apps** section select Policies -> Policy management.
3. Locate a **privileged accounts** policy that meets the following criteria
    - Policy severity is High severity.
    - Category is Privileged accounts.
    - Act on Single activity is selected.
    - Under **Activities matching all of the following** verify:
    - Filter1: Activity type equals Log on
    - Filter2: User Name equals <Emergency access account> as Any role
    - Verify all additional emergency access accounts are accounted for.
    - Under **Alerts**, verify alerting is configured.
4. Repeat this process for any additional emergency access or break-glass accounts in the organization. If matching policies do not exist, then the audit procedure is considered a fail.

Note: Multiple accounts can be monitored by a single policy or by separate policies.

Note: Emergency access account activity can be monitored in various ways. The audit procedure passes as long as all emergency access account activity is monitored.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Defender https://security.microsoft.com
2. Under the **Cloud Apps** section select Policies -> Policy management.
3. Click on All policies and then Create policy -> Activity policy.
4. Give the policy a name and set the following:
    - Policy severity to High severity.
    - Category to Privileged accounts.
    - Act on Single activity.
    - Click Select a filter -> Activity type equals Log on.
    - Click Add a filter -> User Name equals <Emergency access account> as Any role.
    - Ensure all emergency access accounts are added to this policy or another.
    - Select an alert method such as Send alert as email.

Note: Multiple accounts can be monitored by a single policy or by separate policies.

Default Value:

A policy to monitor emergency access accounts does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/security-emergency-access#monitor-sign-in-and-audit-logs
2. https://learn.microsoft.com/en-us/defender-cloud-apps/control-cloud-apps-with-policies

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 Conduct Audit Log Reviews Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v7	16 Account Monitoring and Control Account Monitoring and Control			

2.3 Audit

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

2.4 System

2.4.1 Ensure Priority account protection is enabled and configured (Automated)

Profile Applicability:

- E5 Level 1

Description:

Identify *priority accounts* to utilize Microsoft 365's advanced custom security features. This is an essential tool to bolster protection for users who are frequently targeted due to their critical positions, such as executives, leaders, managers, or others who have access to sensitive, confidential, financial, or high-priority information.

Once these accounts are identified, several services and features can be enabled, including threat policies, enhanced sign-in protection through conditional access policies, and alert policies, enabling faster response times for incident response teams.

Rationale:

Enabling priority account protection for users in Microsoft 365 is necessary to enhance security for accounts with access to sensitive data and high privileges, such as CEOs, CISOs, CFOs, and IT admins. These priority accounts are often targeted by spear phishing or whaling attacks and require stronger protection to prevent account compromise.

To address this, Microsoft 365 and Microsoft Defender for Office 365 offer several key features that provide extra security, including the identification of incidents and alerts involving priority accounts and the use of built-in custom protections designed specifically for them.

Audit:

To audit using the UI:

Audit with a 3-step process

Step 1: Verify Priority account protection is enabled:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Select `System` > `Settings` near the bottom of the left most panel.
3. Select `E-mail & collaboration` > `Priority account protection`
4. Verify that `Priority account protection` is set to `On`

Step 2: Verify that priority accounts are identified and tagged accordingly:

5. Select `User tags`
6. Select the `PRIORITY ACCOUNT` tag and click `Edit`
7. Verify the assigned members match the organization's defined priority accounts or groups.
8. Repeat the previous 2 steps for any additional tags identified, such as Finance or HR.

Step 3: Ensure alerts are configured:

9. Expand `E-mail & Collaboration` on the left column.
10. Select `Policies & rules` > `Alert policy`
11. Verify that at least two alert policies are configured to monitor priority accounts for the activities `Detected malware in an email message` and `Phishing email detected at time of delivery`. These alerts should meet the following criteria:
    - Severity: `High`
    - Category: `Threat management`
    - Mail Direction: `Inbound`
    - Recipient Tags: Includes `Priority account`

To audit using PowerShell:

1. Connect to Exchange using `Connect-ExchangeOnline`
2. Retrieve the Priority Account protection state:

```
Get-EmailTenantSettings | select EnablePriorityAccountProtection
```

- Ensure `EnablePriorityAccountProtection` is `true`.

3. Connect to Security & Compliance PowerShell using `Connect-IPPSSession`
4. Retrieve alert policies targeting priority accounts:

```
Get-ProtectionAlert | Where-Object { $_.RecipientTags -Match 'Priority
account' }
```

5. For each returned policy, verify all of the following criteria:
    - `Severity` is `High`
    - `Filter` matches the pattern `Mail.Direction -eq 'Inbound'`
    - `RecipientTags` matches the pattern `Priority account`
    - `NotificationEnabled` is `true`
    - `NotifyUser` contains a valid email recipient
    - `Disabled` is `false`
6. The control is compliant when the results include:
    - One passing **phishing** policy (`ThreatType` = `Phish`)
    - One passing **malware** policy (`ThreatType` = `Malware`).
    - `EnablePriorityAccountProtection` is `true` from step 2.

Remediation:

To remediate using the UI:

Remediate with a 3-step process

Step 1: Enable Priority account protection in Microsoft 365 Defender:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Select `System` > `Settings` near the bottom of the left most panel.
3. Select `E-mail & Collaboration` > `Priority account protection`
4. Ensure `Priority account protection` is set to `On`

Step 2: Tag priority accounts:

5. Select `User tags`
6. Select the `PRIORITY ACCOUNT` tag and click `Edit`
7. Select `Add members` to add users, or groups. **Groups are recommended.**
8. Repeat the previous 2 steps for any additional tags needed, such as Finance or HR.
9. `Next` and `Submit`.

Step 3: Configure E-mail alerts for Priority Accounts:

10. Expand `E-mail & Collaboration` on the left column.
11. Select `Policies & rules` > `Alert policy`
12. Select `New Alert Policy`
13. Enter a valid policy Name & Description. Set `Severity` to `High` and `Category` to `Threat management`.
14. Set `Activity is` to `Detected malware in an e-mail message`
15. Mail direction is `Inbound`
16. Select `Add Condition` and `User: recipient tags are`
17. In the `Selection option` field add chosen priority tags such as Priority account.
18. Select `Every time an activity matches the rule`.
19. `Next` and verify valid recipient(s) are selected.
20. `Next` and select `Yes, turn it on right away.` Click `Submit` to save the alert.
21. Repeat steps 12 - 18 to create a 2nd alert for the Activity field `Activity is`: `Phishing email detected at time of delivery`

Note: Any additional activity types may be added as needed. Above are the minimum recommended.

Default Value:

By default, priority accounts are undefined.

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/setup/priority-accounts
2. https://learn.microsoft.com/en-us/defender-office-365/priority-accounts-security-recommendations

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●

2.4.2 Ensure Priority accounts have 'Strict protection' presets applied (Automated)

Profile Applicability:

- E5 Level 1

Description:

Preset security policies have been established by Microsoft, utilizing observations and experiences within datacenters to strike a balance between the exclusion of malicious content from users and limiting unwarranted disruptions. These policies can apply to all, or select users and encompass recommendations for addressing spam, malware, and phishing threats. The policy parameters are pre-determined and non-adjustable.

`Strict protection` has the most aggressive protection of the 3 presets.

- EOP: Anti-spam, Anti-malware and Anti-phishing
- Defender: Spoof protection, Impersonation protection and Advanced phishing
- Defender: Safe Links and Safe Attachments

NOTE: The preset security polices cannot target Priority account TAGS currently, groups should be used instead.

Rationale:

Enabling priority account protection for users in Microsoft 365 is necessary to enhance security for accounts with access to sensitive data and high privileges, such as CEOs, CISOs, CFOs, and IT admins. These priority accounts are often targeted by spear phishing or whaling attacks and require stronger protection to prevent account compromise.

The implementation of stringent, pre-defined policies may result in instances of false positive, however, the benefit of requiring the end-user to preview junk email before accessing their inbox outweighs the potential risk of mistakenly perceiving a malicious email as safe due to its placement in the inbox.

Impact:

Strict policies are more likely to cause false positives in anti-spam, phishing, impersonation, spoofing and intelligence responses.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `E-mail & collaboration` > `Policies & rules` > `Threat policies`.
3. From here visit each section in turn: `Anti-phishing` `Anti-spam` `Anti-malware` `Safe Attachments` `Safe Links`
4. Verify that each contains a policy named `Strict Preset Security Policy` that includes the organization's priority accounts and groups.

To audit using PowerShell:

1. Connect to Exchange using `Connect-ExchangeOnline`
2. Retrieve the ATP strict presets rule for Defender:

```
Get-ATPProtectionPolicyRule | Where-Object { $_.Identity -eq 'Strict Preset
Security Policy' }
```

3. Retrieve the EOP strict preset rule for Defender:

```
Get-EOPProtectionPolicyRule | Where-Object { $_.Identity -eq 'Strict Preset
Security Policy' }
```

4. Verify the following criteria for **both** the EOP Rule and ATP Rule:
    - `State` is `Enabled`
    - At least one recipient target is populated with a **VIP**, i.e.:
        - `SentTo`, `SentToMemberOf` **or** `RecipientDomainIs` is not `null`
5. The control is compliant when **both** the ATP rule and the EOP rule exist and pass the criteria in step 4.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `E-mail & collaboration` > `Policies & rules` > `Threat policies`.
3. Select `Preset security policies`.
4. Click to `Manage protection settings` for `Strict protection` preset.
5. For `Apply Exchange Online Protection` select at minimum `Specific recipients` and include the Accounts/Groups identified as Priority Accounts.
6. For `Apply Defender for Office 365 Protection` select at minimum `Specific recipients` and include the Accounts/Groups identified as Priority Accounts.
7. For `Impersonation protection` click `Next` and add valid e-mails or priority accounts both internal and external that may be subject to impersonation.
8. For `Protected custom domains` add the organization's domain name, along side other key partners.
9. Click `Next` and finally `Confirm`

Default Value:

By default, presets are not applied to any users or groups.

References:

1. https://learn.microsoft.com/en-us/defender-office-365/preset-security-policies?view=o365-worldwide
2. https://learn.microsoft.com/en-us/defender-office-365/priority-accounts-security-recommendations
3. https://learn.microsoft.com/en-us/defender-office-365/recommended-settings-for-eop-and-office365?view=o365-worldwide#impersonation-settings-in-anti-phishing-policies-in-microsoft-defender-for-office-365

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v8	10.7 Use Behavior-Based Anti-Malware Software Use behavior-based anti-malware software.		●	●

2.4.3 Ensure Microsoft Defender for Cloud Apps is enabled and configured (Manual)

Profile Applicability:

- E5 Level 2

Description:

Microsoft Defender for Cloud Apps is a Cloud Access Security Broker (CASB). It provides visibility into suspicious activity in Microsoft 365, enabling investigation into potential security issues and facilitating the implementation of remediation measures if necessary.

Some risk detection methods provided by Entra Identity Protection also require Microsoft Defender for Cloud Apps:

- Suspicious manipulation of inbox rules
- Suspicious inbox forwarding
- New country detection
- Impossible travel detection
- Activity from anonymous IP addresses
- Mass access to sensitive files

Rationale:

Security teams can receive notifications of triggered alerts for atypical or suspicious activities, see how the organization's data in Microsoft 365 is accessed and used, suspend user accounts exhibiting suspicious activity, and require users to log back in to Microsoft 365 apps after an alert has been triggered.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Cloud apps`.
3. Scroll to `Connected apps` and select `App connectors`.
4. Verify that **Microsoft 365** and **Microsoft Azure** both show in the list as `Connected`.
5. Go to `Cloud Discovery` > `Microsoft Defender for Endpoint` and verify that the integration is enabled.
6. Go to `Information Protection` > `Files` and verify `Enable file monitoring` is checked.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Cloud apps`.
3. Scroll to `Information Protection` and select `Files`.
4. Check `Enable file monitoring`.
5. Scroll up to `Cloud Discovery` and select `Microsoft Defender for Endpoint.`
6. Check `Enforce app access`, configure a Notification URL and `Save`.

Note: Defender for Endpoint requires a Defender for Endpoint license.

Configure App Connectors:

1. Scroll to `Connected apps` and select `App connectors`.
2. Click on `Connect an app` and select `Microsoft 365`.
3. Check all Azure and Office 365 boxes then click `Connect Office 365`.
4. Repeat for the `Microsoft Azure` application.

Default Value:

Disabled

References:

1. https://learn.microsoft.com/en-us/defender-cloud-apps/protect-office-365#connect-microsoft-365-to-microsoft-defender-for-cloud-apps
2. https://learn.microsoft.com/en-us/defender-cloud-apps/protect-azure#connect-azure-to-microsoft-defender-for-cloud-apps
3. https://learn.microsoft.com/en-us/defender-cloud-apps/best-practices
4. https://learn.microsoft.com/en-us/defender-cloud-apps/get-started
5. https://learn.microsoft.com/en-us/entra/id-protection/concept-identity-protection-risks

Additional Information:

Additional Microsoft 365 Defender features include:

- The option to use Defender for cloud apps as a reverse proxy, allowing for the application of access or session controls through the definition of a conditional access policy.
- The purchase and implementation of the "App Governance" add-on, which provides more precise control over OAuth app permissions and includes additional built-in policies.

A list of Defender for Cloud Apps built-in policies for Office 365 can be found at https://learn.microsoft.com/en-us/defender-cloud-apps/protect-office-365.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.1 Centralize Security Event Alerting Centralize security event alerting across enterprise assets for log correlation and analysis. Best practice implementation requires the use of a SIEM, which includes vendor-defined event correlation alerts. A log analytics platform configured with security-relevant correlation alerts also satisfies this Safeguard.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●
v7	16 Account Monitoring and Control Account Monitoring and Control			

2.4.4 Ensure Zero-hour auto purge for Microsoft Teams is on (Automated)

Profile Applicability:

- E5 Level 1

Description:

Zero-hour auto purge (ZAP) is a protection feature that retroactively detects and neutralizes malware and high confidence phishing. When ZAP for Teams protection blocks a message, the message is blocked for everyone in the chat. The initial block happens right after delivery, but ZAP occurs up to 48 hours after delivery.

Rationale:

ZAP is intended to protect users that have received zero-day malware messages or content that is weaponized after being delivered to users. It does this by continually monitoring spam and malware signatures taking automated retroactive action on messages that have already been delivered.

Impact:

As with any anti-malware or anti-phishing product, false positives may occur.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Email & collaboration` > `Microsoft Teams protection`.
3. Verify that `Zero-hour auto purge (ZAP)` is set to `On (Default)`
4. Under `Exclude these participants` review the list of exclusions and verify they are justified and within tolerance for the organization.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following cmdlets:

```
Get-TeamsProtectionPolicy | fl ZapEnabled
Get-TeamsProtectionPolicyRule | fl ExceptIf*
```

3. Verify that `ZapEnabled` is `True`.
4. Review the list of exclusions and ensure they are justified and within tolerance for the organization. If nothing returns from the 2nd cmdlet then there are no exclusions defined.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Email & collaboration` > `Microsoft Teams protection`.
3. Set `Zero-hour auto purge (ZAP)` to `On (Default)`

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following cmdlet:

```
Set-TeamsProtectionPolicy -Identity "Teams Protection Policy" -ZapEnabled
$true
```

Default Value:

On (Default)

References:

1. https://learn.microsoft.com/en-us/defender-office-365/zero-hour-auto-purge?view=o365-worldwide#zero-hour-auto-purge-zap-in-microsoft-teams
2. https://learn.microsoft.com/en-us/defender-office-365/mdo-support-teams-about?view=o365-worldwide#configure-zap-for-teams-protection-in-defender-for-office-365-plan-2

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●

2.4.5 Ensure 'AIR' remediation is enabled (Manual)

Profile Applicability:

- E5 Level 1

Description:

Automated Investigation and Response (AIR) investigates alerts and correlates related signals into investigations. When AIR identifies malicious email messages, it groups them into clusters based on shared characteristics like common malicious file, URL, or sending attributes and produces remediation actions for each cluster.

This setting controls whether AIR-identified malicious message clusters are remediated automatically, without requiring SecOps approval. Administrators can enable automatic remediation for one or more cluster types:

- **Similar files:** Clusters sharing a similar malicious file
- **Similar URLs:** Clusters sharing a similar malicious URL
- **Multiple similar attributes:** Clusters grouped by multiple shared attributes such as sender IP address, sender domain, or message subject

When enabled, the configured remediation action is applied immediately upon cluster identification.

The recommended state is to automatically remediate message clusters.

Rationale:

When automatic remediation is disabled, malicious message clusters identified by AIR remain in users' mailboxes as pending actions until a security analyst manually approves each remediation. During this approval window, users may interact with, open, or forward malicious messages, increasing the risk of a successful compromise. Enabling automatic remediation ensures identified threats are contained immediately upon detection, minimizing the exposure window and reducing the operational burden on security teams to manually review and approve routine threat clusters.

Impact:

Automatic remediation removes the manual SecOps approval step for qualifying message cluster actions. If AIR incorrectly classifies a legitimate message cluster as malicious, affected messages will be soft deleted without prior review. Soft deleted messages are moved to the Recoverable Items folder and can be restored through the Action center, Threat Explorer, or Advanced Hunting, subject to each mailbox's deleted item retention period (14 days by default).

Organizations should verify retention policies and legal obligations before enabling this setting, as retention configuration affects whether soft deleted messages remain recoverable.

Clusters exceeding 10,000 messages are always excluded from automatic remediation and will continue to require manual approval.

License Requirement: This setting requires **Defender for Office 365 Plan 2** which is included in **Microsoft 365 E5**.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Email & collaboration` > `MDO automation settings`.
3. Verify that under `Message clusters` the following are checked:
    - `Similar files`
    - `Similar URLs`
    - `Multiple similar attributes`

Note: At the time of publication, `Soft delete` is the only available remediation action and is selected by default. Because the action cannot be changed, verifying the selected remediation action is not part of the audit criteria for this recommendation.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Defender` https://security.microsoft.com/
2. Expand `System` > `Settings` > `Email & collaboration` > `MDO automation settings`.
3. Under `Message clusters` check the following:
    - `Similar files`
    - `Similar URLs`
    - `Multiple similar attributes`
4. Click `Save` to apply the changes.

Default Value:

By default automatic remediation for message clusters is disabled.

References:

1. https://learn.microsoft.com/en-us/defender-office-365/air-auto-remediation
2. https://learn.microsoft.com/en-us/defender-office-365/air-about
3. https://learn.microsoft.com/en-us/exchange/security-and-compliance/recoverable-items-folder/recoverable-items-folder
4. https://learn.microsoft.com/en-us/exchange/recipients-in-exchange-online/manage-user-mailboxes/change-deleted-item-retention

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.7 Deploy and Maintain Email Server Anti-Malware Protections Deploy and maintain email server anti-malware protections, such as attachment scanning and/or sandboxing.			●
v7	7 Email and Web Browser Protections Email and Web Browser Protections			

3 Microsoft Purview

Microsoft Purview, also known as Compliance, contains settings related to all things compliance, data governance, information protection and risk management.

Direct link: https://purview.microsoft.com

3.1 Audit

3.1.1 Ensure Microsoft 365 audit log search is Enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

When audit log search is enabled in the Microsoft Purview compliance portal, user and admin activity within the organization is recorded in the audit log and retained for 180 days by default. However, some organizations may prefer to use a third-party security information and event management (SIEM) application to access their auditing data. In this scenario, a global admin can choose to turn off audit log search in Microsoft 365.

Rationale:

Enabling audit log search in the Microsoft Purview compliance portal can help organizations improve their security posture, meet regulatory compliance requirements, respond to security incidents, and gain valuable operational insights.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Purview` https://purview.microsoft.com/
2. Select `Solutions` and then `Audit` to open the audit search.
3. Choose a date and time frame in the past 30 days.
4. Verify search capabilities (e.g. try searching for Activities as `Accessed file` and results should be displayed).

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-AdminAuditLogConfig | Select-Object UnifiedAuditLogIngestionEnabled
```

3. Ensure `UnifiedAuditLogIngestionEnabled` is set to `True`.

Note: If the `Get-AdminAuditLogConfig` cmdlet is executed while connected to both Security & Compliance PowerShell as well as Exchange Online PowerShell then `UnifiedAuditLogIngestionEnabled` will always display `False`. This depends on the orders the module were imported. If Security & Compliance is needed in the same session be sure to connect to it first, and then Exchange PowerShell second.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Purview` https://purview.microsoft.com/
2. Select `Solutions` and then `Audit` to open the audit search.
3. Click blue bar `Start recording user and admin activity`.
4. Click `Yes` on the dialog box to confirm.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-AdminAuditLogConfig -UnifiedAuditLogIngestionEnabled $true
```

Default Value:

180 days

References:

1. https://learn.microsoft.com/en-us/purview/audit-log-enable-disable?view=o365-worldwide&tabs=microsoft-purview-portal
2. https://learn.microsoft.com/en-us/powershell/module/exchange/set-adminauditlogconfig?view=exchange-ps
3. https://learn.microsoft.com/en-us/purview/audit-log-enable-disable?view=o365-worldwide&tabs=microsoft-purview-portal#verify-the-auditing-status-for-your-organization

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

3.2 Data Loss Protection

3.2.1 Ensure DLP policies are enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Data Loss Prevention (DLP) policies allow Exchange Online and SharePoint Online content to be scanned for specific types of data like social security numbers, credit card numbers, or passwords.

Rationale:

Enabling DLP policies alerts users and administrators that specific types of data should not be exposed, helping to protect the data from accidental exposure.

Impact:

Enabling a Teams DLP policy will allow sensitive data in Exchange Online and SharePoint Online to be detected or blocked. Always ensure to follow appropriate procedures during testing and implementation of DLP policies based on organizational standards.

Audit:

To audit using the UI:

1. Navigate to Microsoft Purview https://purview.microsoft.com/
2. Click Solutions > Data loss prevention and then Policies.
3. Inspect the list of policies and verify the following criteria:
    - A policy exists that meets the organizations DLP needs
    - Mode is On
4. Open the policy and verify there is at least one of the following locations defined:
    - Exchange email
    - SharePoint sites
    - OneDrive accounts
    - Teams chat and channel messages
5. Compliance is met when there is at least one policy the meets the above criteria.

To audit using the PowerShell:

1. Connect to the Security & Compliance PowerShell using Connect-IPPSSession.
2. Execute the following cmdlet to get a list of DLP Policies:

```
Get-DlpCompliancePolicy
```

3. For each policy returned verify the following criteria:
    - Mode is Enable
    - **At least one of the following locations is defined:**
    - ExchangeLocation
    - SharePointLocation
    - OneDriveLocation
    - TeamsLocation
4. Compliance is met when there is at least one policy the meets the above criteria.

Note: The types of policies an organization should implement to protect information are specific to their industry. However, certain types of information, such as credit card numbers, social security numbers, and certain personally identifiable information (PII), are universally important to safeguard across all industries.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Purview https://purview.microsoft.com/
2. Click Solutions > Data loss prevention then Policies.
3. Click Create policy.
4. Create a policy that is specific to the types of data the organization wishes to protect.

References:

1. https://learn.microsoft.com/en-us/purview/dlp-learn-about-dlp?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.13 Deploy a Data Loss Prevention Solution Implement an automated tool, such as a host-based Data Loss Prevention (DLP) tool to identify all sensitive data stored, processed, or transmitted through enterprise assets, including those located onsite or at a remote service provider, and update the enterprise's sensitive data inventory.			●
v7	13 Data Protection Data Protection			

3.2.2 Ensure DLP policies are enabled for Microsoft Teams (Automated)

Profile Applicability:

- E5 Level 1

Description:

The default Teams Data Loss Prevention (DLP) policy rule in Microsoft 365 is a preconfigured rule that is automatically applied to all Teams conversations and channels. The default rule helps prevent accidental sharing of sensitive information by detecting and blocking certain types of content that are deemed sensitive or inappropriate by the organization.

By default, the rule includes a check for the sensitive info type *Credit Card Number* which is pre-defined by Microsoft.

Rationale:

Enabling the default Teams DLP policy rule in Microsoft 365 helps protect an organization's sensitive information by preventing accidental sharing or leakage of Credit Card information in Teams conversations and channels.

DLP rules are not one size fits all, but at a minimum something should be defined. The organization should identify sensitive information important to them and seek to intercept it using DLP.

Impact:

End-users may be prevented from sharing certain types of content, which may require them to adjust their behavior or seek permission from administrators to share specific content. Administrators may receive requests from end-users for permission to share certain types of content or to modify the policy to better fit the needs of their teams.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Under `Solutions` select `Data loss prevention` then `Policies`.
3. Locate the `Default policy for Teams`.
4. Verify the `Status` is `On`.
5. Verify `Locations` include `Teams chat and channel messages - All accounts`.
6. Verify `Policy settings` includes the Default Teams DLP policy rule or one specific to the organization.

Note: If there is not a default policy for teams inspect existing policies starting with step 4. DLP rules are specific to the organization and each organization should take steps to protect the data that matters to them. The default teams DLP rule will only alert on Credit Card matches.

To audit using PowerShell:

1. Connect to the Security & Compliance PowerShell using `Connect-IPPSSession`.
2. Run the following to return policies that include Teams chat and channel messages:

```
$DlpPolicy = Get-DlpCompliancePolicy
$DlpPolicy | Where-Object {$_.Workload -match "Teams"} |
    ft Name,Mode,TeamsLocation*
```

3. If nothing returns, then there are no policies that include Teams and remediation is required.
4. For any returned policy verify `Mode` is set to `Enable`.
5. Verify `TeamsLocation` includes `All`.
6. Verify `TeamsLocationException` includes only permitted exceptions.

Note: Some tenants may not have a default policy for teams as Microsoft started creating these by default at a particular point in time. In this case a new policy will have to be created that includes a rule to protect data important to the organization such as credit cards and PII.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Under `Solutions` select `Data loss prevention` then `Policies`.
3. Click `Policies` tab.
4. Check `Default policy for Teams` then click `Edit policy`.
5. The edit policy window will appear click Next
6. At the `Choose locations to apply the policy` page, turn the status toggle to `On` for `Teams chat and channel messages` location and then click Next.
7. On Customized advanced DLP rules page, ensure the `Default Teams DLP policy rule` Status is `On` and click Next.
8. On the Policy mode page, select the radial for `Turn it on right away` and click Next.
9. Review all the settings for the created policy on the Review your policy and create it page, and then click submit.
10. Once the policy has been successfully submitted click Done.

Note: Some tenants may not have a default policy for teams as Microsoft started creating these by default at a particular point in time. In this case a new policy will have to be created that includes a rule to protect data important to the organization such as credit cards and PII.

Default Value:

Enabled (On)

References:

1. https://learn.microsoft.com/en-us/powershell/exchange/connect-to-scc-powershell?view=exchange-ps
2. https://learn.microsoft.com/en-us/purview/dlp-teams-default-policy
3. https://learn.microsoft.com/en-us/powershell/module/exchange/connect-ippssession?view=exchange-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.13 Deploy a Data Loss Prevention Solution Implement an automated tool, such as a host-based Data Loss Prevention (DLP) tool to identify all sensitive data stored, processed, or transmitted through enterprise assets, including those located onsite or at a remote service provider, and update the enterprise's sensitive data inventory.			●
v7	13 Data Protection Data Protection			

3.2.3 Ensure DLP policies are published for Copilot users (Automated)

Profile Applicability:

- E5 Level 1

Description:

Microsoft Purview Data Loss Prevention (DLP) policies can be scoped to Microsoft 365 Copilot and Copilot Chat interactions. When active, these policies can restrict Copilot from processing or surfacing content that matches configured sensitive information types. Organizations must define the sensitive data categories relevant to their environment and configure at least one DLP policy that covers Copilot interactions in enforcement mode.

The recommended state is to configure at least one DLP policy that includes `Microsoft 365 Copilot and Copilot Chat - All accounts` as a location with rules specific to the organization's needs.

Rationale:

Microsoft 365 Copilot can retrieve, summarize, and generate content based on data the authenticated user has access to across M365 workloads, including SharePoint, OneDrive, Teams, and Exchange. Without a DLP policy scoped to Copilot interactions, no technical control exists to prevent sensitive information such as PII, financial data, or health records from being incorporated into Copilot-generated responses and potentially exposed to users who would not otherwise have direct access to the source content. Enforcing DLP policies for Copilot ensures that sensitive data categories defined by the organization are intercepted before they are processed or surfaced by AI-generated responses.

Impact:

Users may find that Copilot declines to process or respond to prompts that involve content matching the organization's configured sensitive information types. In these cases, Copilot will notify the user that the request was blocked by policy. Users who rely on Copilot to summarize, draft, or retrieve content containing sensitive data such as documents with PII, financial records, or health information may need to rephrase their prompts or work with the content directly outside of Copilot. Administrators should communicate the scope of active DLP policies to affected users prior to enforcement.

Audit:

Note: Some tenants may have a default policy called `Default DLP policy - Protect sensitive M365 Copilot interactions` that was automatically created. If not present, it can also be created using a guided process in the `Policies` blade. If this policy exists, it may be used to satisfy the requirements of this control provided it meets the compliance criteria below.

To audit using the UI:

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Under `Solutions` select `Data loss prevention` then `Policies`.
3. Inspect the list of policies and verify the following criteria:
    - `Locations` includes `Microsoft 365 Copilot and Copilot Chat - All accounts`.
    - `Mode` is `On`.
    - The policy includes `Rules` that restrict sensitive data from being shared in Copilot interactions based on the organization's needs.
4. Compliance is met when there is at least one policy that meets the above criteria.

To audit using PowerShell:

1. Connect to the Security & Compliance PowerShell using `Connect-IPPSSession`.
2. Run the following to return policies that include Teams chat and channel messages:

```
$DlpPolicy = Get-DlpCompliancePolicy
$DlpPolicy | Where-Object {$_.EnforcementPlanes -match "CopilotExperiences"}
|
    FT Name,Mode,LocationInclusions,LocationExclusions
```

3. If nothing returns, then there are no policies that include Copilot and remediation is required.
4. For any returned policy verify `Mode` is set to `Enable`.
5. Verify `LocationInclusions` includes `All`.
6. Verify `LocationExclusions` includes only permitted exceptions.

Note: DLP rules are specific to the organization and each organization should take steps to protect the data that matters to them. At a minimum, organizations should consider protecting personally identifiable information (PII) specific to their locale.

Remediation:

To remediate using the UI:

Note: Microsoft provides a guided wizard to create the `Default DLP policy - Protect sensitive M365 Copilot interactions` policy, which can be used when no Copilot DLP policy exists in the tenant. The steps below describe how to create a custom policy from scratch with Copilot included as a location.

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Under `Solutions` select `Data loss prevention` then `Policies`.
3. Click `Policies` tab.
4. Click `+ Create Policy`.
5. Click on `Enterprise applications & devices`.
6. Under `Categories` select `Custom` and then `Custom policy` for the regulation.
7. Name the policy, and if appropriate, select an Admin Unit.
8. In `Locations` select `Microsoft 365 Copilot and Copilot Chat`.
9. Click on `Next` to proceed to the `Advanced DLP rules` page.
10. Click on `+ Create Rule`
    1. Name the rule and give a brief description of the data that is being targeted.
    2. Click on `+ Add condition` and select `Content Contains`
    3. Click on `Add` and select `Sensitive info types`
    4. Select the sensitive information types the organization wants to protect from being processed in Copilot interactions and click `Add`.
    5. Click on `+ Add an action` and select `Restrict Copilot from processing content`
    6. Check the box for a relevant restriction.
    7. Click on `Save`.
11. Repeat step 10 to create as many rules as the organization requires
12. Click `Next`.
13. On the Policy mode page, select the radial for `Turn it on right away` and click `Next`.
14. Click `Submit` to create the policy once it has been reviewed.
15. Finally, click `Done`.

Note: Compliance with this recommendation is not achieved until the policy is in enforcement mode.

Default Value:

No Copilot DLP policy exists by default for most tenants. Some tenants may have had a `Default DLP policy - Protect sensitive M365 Copilot interactions` policy automatically provisioned by Microsoft; if present, it may satisfy this recommendation if it meets the audit criteria.

References:

1. https://learn.microsoft.com/en-us/purview/dlp-microsoft365-copilot-location-learn-about
2. https://learn.microsoft.com/en-us/purview/dlp-microsoft365-copilot-location-default-policy
3. https://learn.microsoft.com/en-us/powershell/exchange/connect-to-scc-powershell?view=exchange-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.13 Deploy a Data Loss Prevention Solution Implement an automated tool, such as a host-based Data Loss Prevention (DLP) tool to identify all sensitive data stored, processed, or transmitted through enterprise assets, including those located onsite or at a remote service provider, and update the enterprise's sensitive data inventory.			●
v7	13 Data Protection Data Protection			
v7	14.7 Enforce Access Control to Data through Automated Tools Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.			●

3.3 Information Protection

3.3.1 Ensure Information Protection sensitivity label policies are published (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Sensitivity labels enable organizations to classify and label content across Microsoft 365 based on its sensitivity and business impact. These labels can be applied manually by users or automatically based on the content. When applied, labels can automatically encrypt content, provide "Confidential" watermarks, restrict access, and offer various data protection features.

Labels can be scoped to data assets and containers:

- Files & other data assets in Microsoft 365, Fabric, Azure, AWS and other platforms
- Email messages sent from all versions of Outlook
- Meeting calendar events and schedules in Outlook and Teams
- Teams, Microsoft 365 Groups and SharePoint sites

Rationale:

Consistent usage of sensitivity labels can help reduce the risk of data loss or exposure and enable more effective incident response if a breach does occur. They can also help organizations comply with regulatory requirements and provide visibility and control over sensitive information.

Impact:

Encryption configurations (control access, DKE, BYOK) in the individual labels may impact users' ability to access site documents and information. Careful consideration of the individual sensitivity label configurations should be exercised prior to applying an auto labeling policy, publishing policy, sensitivity label configuration, or PowerShell based label settings to SharePoint sites.

Additionally, when updating or deleting Sensitivity Labels, an assessment of the potential impacts should be conducted to avoid unintended consequences. If tenants are configured for sharing with guests or external domains and Sensitivity Labels have encryption applied, this can affect the ability to share documents via email stored in SharePoint. Some recipients may be unable to open the document depending on their email client, which could trigger Purview Advanced Encryptions and OME flows based on the recipient type and the cloud license from which the email is sent (e.g., government clouds vs. commercial clouds).

Audit:

To audit using the UI:

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Select `Information protection` > `Policies` > `Label publishing policies`.
3. Ensure that a Label policy exists and is published according to the organization's information protection needs.

To audit using PowerShell:

1. Connect to the Security & Compliance PowerShell using `Connect-IPPSSession`.
2. Run the following script:

```
$Policies = Get-LabelPolicy -WarningAction Ignore |
    Where-Object { $_.Type -eq "PublishedSensitivityLabel" }

if ($Policies) {
        $Policies | Format-List -Property Name, *Location*
       Write-Host "$($Policies.Count) Sensitivity Label policies found."
} else {
    Write-Host "No Sensitivity Label policies found"
}
```

3. Ensure there is at least one sensitivity label policy published.
4. Review the locations defined to ensure they're in scope with the organization's needs.

Note: These policies are specific to the information protection needs of each organization. Whether an organization passes the audit is open to interpretation by the auditor and depends largely on how effectively it implements information protection features to safeguard data.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Purview` compliance portal https://purview.microsoft.com/
2. Select `Information protection` > `Sensitivity labels`.
3. Click `Create a label` to create a label.
4. Click `Publish labels` and select any newly created labels to publish according to the organization's information protection needs.

Default Value:

The "Global sensitivity label policy" exists by default.

References:

1. https://learn.microsoft.com/en-us/purview/sensitivity-labels
2. https://learn.microsoft.com/en-us/purview/create-sensitivity-labels

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.7 Establish and Maintain a Data Classification Scheme Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as “Sensitive,” “Confidential,” and “Public,” and classify their data according to those labels. Review and update the classification scheme annually, or when significant enterprise changes occur that could impact this Safeguard.		●	●

3.4 Insider Risk Management

Insider Risk Management is a compliance solution that helps minimize internal risks by enabling you to detect, investigate, and act on malicious and inadvertent activities in your organization. With insider risk policies, you can define the types of risks to identify and detect in your organization. You can also set up processes for acting on cases and escalating cases to Microsoft eDiscovery (Premium) if needed. Risk analysts in your organization can quickly take appropriate actions to make sure users are compliant with your organization's compliance standards.

3.5 Communication Compliance

Microsoft Purview Communication Compliance is an insider risk solution that helps you minimize communication risks by helping you detect, capture, and act on potentially inappropriate messages in your organization.

4 Microsoft Intune admin center

This section includes settings specific to hardening the Microsoft 365 tenant itself through Intune settings.

CIS has other platform specific benchmarks for Intune which are intended to harden endpoints through Endpoint Manager (Microsoft Intune admin center). Those are developed in the following WorkBench communities:

CIS Microsoft Intune for Windows:

https://workbench.cisecurity.org/communities/116

CIS Intune Apple iOS and iPadOS Benchmarks:

https://workbench.cisecurity.org/communities/179

4.1 Ensure devices without a compliance policy are marked 'not compliant' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Compliance policies are sets of rules and conditions that are used to evaluate the configuration of managed devices. These policies can help secure organizational data and resources from devices that don't meet those configuration requirements. Managed devices must satisfy the conditions you set in your policies to be considered compliant by Intune. When combined with conditional access, this allows more control over how non-compliant devices are treated.

The recommended state is `Mark devices with no compliance policy assigned as` as `Not compliant`

Rationale:

Implementing this setting is a first step in adopting compliance policies for devices. When used together with Conditional Access policies the attack surface can be reduced by forcing an action to be taken for non-compliant devices.

Note: This section does not focus on which compliance policies to use, only that an organization should adopt and enforce them to their needs.

Impact:

Any devices without a compliance policy will be marked not compliant. Care should be taken to first deploy any new compliance policies with a Conditional Access (CA) policy that is in the **Report-only** state. After the environment's device compliance is better understood it is then appropriate to finally align with `Mark devices with no compliance policy assigned as` and enable any CA policies that enforce actions based on device compliance.

If a mature environment already has an existing device compliance CA policy and a large number of devices without an assigned compliance policy, this could cause disruption as those devices would then be suddenly considered not compliant.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Intune admin center` https://intune.microsoft.com/
2. Select `Devices` and then under **Manage devices** click `Compliance`
3. Click `Compliance settings`.
4. Verify that `Mark devices with no compliance policy assigned as` is set to `Not compliant`.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "DeviceManagementConfiguration.Read.All"`
2. Run the following commands:

```
$Uri = 'https://graph.microsoft.com/v1.0/deviceManagement/settings'
Invoke-MgGraphRequest -Uri $Uri -Method GET
```

3. Verify that `secureByDefault` is set to `True`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Intune admin center` https://intune.microsoft.com/
2. Select `Devices` and then under **Manage devices** click `Compliance`
3. Click `Compliance settings`.
4. Set `Mark devices with no compliance policy assigned as` to `Not compliant`.

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "DeviceManagementConfiguration.ReadWrite.All"`
2. Run the following commands:

```
$Uri = 'https://graph.microsoft.com/v1.0/deviceManagement'
$Body = @{
    settings = @{
        secureByDefault = $true
    }
} | ConvertTo-Json
Invoke-MgGraphRequest -Uri $Uri -Method PATCH -Body $Body
```

Default Value:

UI: "Compliant"

Graph: secureByDefault = $false

References:

1. https://learn.microsoft.com/en-us/mem/intune/protect/device-compliance-get-started

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.		●	●

4.2 Ensure device enrollment for personally owned devices is blocked by default (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Device enrollment restrictions let you restrict devices from enrolling in Intune based on certain device attributes such as device limit, device platform, OS Version, manufacturer or device ownership (Personally owned devices).

The recommended state is to `Block` personally owned devices from enrollment.

Rationale:

Restricting the enrollment of personally owned devices prevents attackers who have bypassed other controls from registering a new device to gain an additional foothold, further hiding or obscuring their activities.

An attack path could be:

1. Account Compromise via Phishing and AiTM
2. Conditional Access Bypass
3. Reconnaissance using e.g. ROADrecon, GraphRunner or AADInternals
4. Lateral Movement, Privilege Escalation or Persistence through a newly registered device enrolled in Intune

Impact:

Per platform personally owned device enrollment impacts are listed below. It is important to test the changes to the defaults prior to moving into production and implementing this control.

Windows Devices

The following enrollment methods are authorized for corporate enrollment for Windows devices, any other enrollment method will be considered "Personal" and blocked:

- The device enrolls through Windows Autopilot.
- The device enrolls through GPO, or automatic enrollment from Configuration Manager for co-management.
- The device enrolls through a bulk provisioning package.
- The enrolling user is using a device enrollment manager account.

MacOS

By default, Intune classifies macOS devices as personally owned. To be classified as corporate-owned, a Mac must fulfill one of the following conditions:

- Registered with a serial number.
- Enrolled via Apple Automated Device Enrollment (ADE).

iOS/IPadOS devices

By default, Intune classifies iOS/iPadOS devices as personally owned. To be classified as corporate-owned, an iOS/iPadOS device must fulfill one of the following conditions:

- Registered with a serial number or IMEI.
- Enrolled by using Automated Device Enrollment (formerly Device Enrollment Program).

Android devices

By default, until you manually make changes in the admin center, your Android Enterprise work profile device settings and Android device administrator device settings are the same.

If you block Android Enterprise work profile enrollment on personal devices, only corporate-owned devices can enroll with personally owned work profiles.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Intune admin center` https://intune.microsoft.com/
2. Select `Devices` and then under **Device onboarding** click `Enrollment`
3. Under **Enrollment options** select `Device platform restriction`.
4. Inspect the policies listed under **Device type restrictions**
    - For the `Default` priority policy, click `All Users`.
    - Select `Properties`.
5. Verify that all platforms are set to `Block` in the `Personally owned` column.
6. If the `Platform` itself is set to `Block` for any of the platforms shown this is also a passing state for that platform.

Note: Blocking platforms that are not used in the organization is a more restrictive best practice and will also effectively block enrollment of personally owned devices for the selected platform, ensuring compliance for this recommendation.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "DeviceManagementConfiguration.Read.All"`
2. Run the following script:

```
$Uri =
'https://graph.microsoft.com/beta/deviceManagement/deviceEnrollmentConfigurat
ions'
$Config = (Invoke-MgGraphRequest -Uri $Uri -Method GET).value |
Where-Object { $_.id -match 'DefaultPlatformRestrictions' -and $_.priority -
eq 0 }

$Result = [PSCustomObject]@{
    WindowsPersonalDeviceEnrollmentBlocked        =
$Config.windowsRestriction.personalDeviceEnrollmentBlocked
    iOSPersonalDeviceEnrollmentBlocked            =
$Config.iosRestriction.personalDeviceEnrollmentBlocked
    AndroidForWorkPersonalDeviceEnrollmentBlocked =
$Config.androidForWorkRestriction.personalDeviceEnrollmentBlocked
    MacOPersonalDeviceEnrollmentBlocked           =
$Config.macOSRestriction.personalDeviceEnrollmentBlocked
    AndroidPersonalDeviceEnrollmentBlocked        =
$Config.androidRestriction.personalDeviceEnrollmentBlocked
}

$Result
```

3. Inspect the output, ensure each platform displays `True` next to its property. A passing output will look like the below:

```
WindowsPersonalDeviceEnrollmentBlocked        : True
iOSPersonalDeviceEnrollmentBlocked            : True
AndroidForWorkPersonalDeviceEnrollmentBlocked : True
MacOPersonalDeviceEnrollmentBlocked           : True
AndroidPersonalDeviceEnrollmentBlocked        : True
```

Note: If `platformBlocked` is `true` then that platform is also in compliance as the platform is blocked from enrollment entirely. This is not currently reflected in the audit script but can be queried from the same API call.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Intune admin center` https://intune.microsoft.com/
2. Select `Devices` and then under **Device onboarding** click `Enrollment`
3. Under **Enrollment options** select `Device platform restriction`.
4. Inspect the policies listed under **Device type restrictions**
   - For the `Default` priority policy, click `All Users`.
   - Select `Properties`.
5. Click `Edit` to change **Platform settings**.
6. In the **Personally owned** column set each platform to `Block`.

Note: Blocking platforms that are not used in the organization is a more restrictive best practice and will also effectively block enrollment of personally owned devices for the selected platform, ensuring compliance for this recommendation.

Default Value:

Allow

References:

1. https://learn.microsoft.com/en-us/mem/intune/enrollment/enrollment-restrictions-set
2. https://www.glueckkanja.com/blog/security/2025/01/compliant-device-bypass-en/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5 Microsoft Entra admin center

Microsoft Entra, also known as Identity, contains settings related to identity, conditional access, and was formerly named Azure AD.

Direct link: https://entra.microsoft.com/

Notes on Automated Audit Procedures

Audit procedures in this section may rely on the Microsoft Graph API, which returns objects formatted as structured JSON. Within these procedures, nested JSON properties are referenced using dot-notation, where periods (.) indicate each level of the hierarchy. This convention provides a concise and readable way to identify these attributes within the automated audit procedures.

When used in audit procedures, the relative URI and HTTP method required to query the Microsoft Graph API for the relevant information will be referenced. When building the URI, the base URL `https://graph.microsoft.com/` should be prefixed to the relative URI provided in the audit procedure. For example, if the audit procedure specifies a relative URI of `v1.0/identity/conditionalAccess/policies`, the full URI to query would be `https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies`.

How to query the Microsoft Graph API with PowerShell

1. Install the `Microsoft.Graph.Authentication` PowerShell module and connect with `Connect-MgGraph`
2. Determine the URI and method you want to query.
3. The below example retrieves conditional access policies with the GET method.

```
$URI = "https://graph.microsoft.com/v1.0/identity/conditionalAccess/policies"
$Policy = Invoke-MgGraphRequest -Method GET -Uri $URI
```

4. The output is contained in the variable `$Policy`.

Note: Either Delegated or application permissions are required depending on how you authenticate. For more details visit Microsoft's extensive documentation on the topic. https://learn.microsoft.com/en-us/graph/overview

Examples of Dot-Notation from a Conditional Access Policy

`conditions.users.includeUsers` is `all`

`conditions.applications.includeApplications` is `all`

`grantControls.builtInControls` contains `mfa`

`grantControls.authenticationStrength.id` contains any valid GUID

Corresponding JSON Structure

Below is a minimal JSON example illustrating how dot-notation paths correspond to actual Conditional Access policy properties. Rather than referencing the full JSON structure, the audit procedure uses the more concise dot-notation format to represent nested properties.

```
{
  "conditions": {
    "users": {
      "includeUsers": [
           "All"
      ]
    },
    "applications": {
      "includeApplications": [
           "All"
      ]
    }
  },
  "grantControls": {
    "builtInControls": [
         "mfa"
    ],
    "authenticationStrength": {
      "id": "12345678-1234-1234-1234-123456789abc"
    }
  },
  "state": "enabled"
}
```

5.1 Entra ID

5.1.1 Overview

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

5.1.2 Users

5.1.2.1 Ensure 'Per-user MFA' is disabled (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Legacy per-user Multi-Factor Authentication (MFA) can be configured to require individual users to provide multiple authentication factors, such as passwords and additional verification codes, to access their accounts. It was introduced in earlier versions of Office 365, prior to the more comprehensive implementation of Conditional Access (CA).

Rationale:

Both security defaults and conditional access with security defaults turned off are not compatible with per-user multi-factor authentication (MFA), which can lead to undesirable user authentication states. The CIS Microsoft 365 Benchmark explicitly employs Conditional Access for MFA as an enhancement over security defaults and as a replacement for the outdated per-user MFA. To ensure a consistent authentication state disable per-user MFA on all accounts.

Impact:

Accounts using per-user MFA will need to be migrated to use CA.

Prior to disabling per-user MFA the organization must be prepared to implement conditional access MFA to avoid security gaps and allow for a smooth transition. This will help ensure relevant accounts are covered by MFA during the change phase from disabling per-user MFA to enabling CA MFA. Section 5.2.2 in this document covers the creation of a CA rule for both administrators and all users in the tenant.

Microsoft has documentation on migrating from per-user MFA Convert users from per-user MFA to Conditional Access based MFA

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `All users`.
3. Click on `Per-user MFA` on the top row.
4. Verify that the `Multi-factor Auth Status` column shows `Disabled` for each account.

To audit using Microsoft Graph

1. Determine the `id` or `userPrincipalName` of the user being audited.
2. Execute a `GET` request to the following relative URI:

```
beta/users/{id | userPrincipalName}/authentication/requirements

# Example
https://graph.microsoft.com/beta/users/071cc716-8147-4397-a5ba-
b2105951cc0b/authentication/requirements
```

3. Verify that the `perUserMfaState` property is set to `disabled`.
4. Repeat this process for all users within the tenant.

Note: This API is in beta and does not support a list operation. To prevent server-side throttling, clients should implement batching and client-side rate limiting when auditing medium to large sized environments.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `All users`.
3. Click on `Per-user MFA` on the top row.
4. Click the empty box next to `Display Name` to select all accounts.
5. On the far right under *quick steps* click `Disable`.

Default Value:

Disabled

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-mfa-userstates#convert-users-from-per-user-mfa-to-conditional-access
2. https://learn.microsoft.com/en-us/microsoft-365/admin/security-and-compliance/set-up-multi-factor-authentication?view=o365-worldwide#use-conditional-access-policies
3. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-mfa-userstates#convert-per-user-mfa-enabled-and-enforced-users-to-disabled
4. https://learn.microsoft.com/en-us/graph/api/authentication-get?view=graph-rest-beta

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.2.2 Ensure users cannot register applications (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting controls whether standard users can register applications in the Microsoft Entra ID directory. When enabled, any user can create app registrations, which function as identity objects for applications.

Rationale:

Allowing standard users to create app registrations expands the tenant's attack surface. A compromised account or malicious insider could create a rogue app registration to establish a persistent OAuth client, facilitate token theft, or impersonate a legitimate application. Restricting app registration to privileged roles ensures that new application identities in the directory are subject to administrative review and approval before they can be granted permissions to organizational resources.

Impact:

End users will no longer be able to register applications independently, including both third-party integrations and custom applications. Developers and IT staff who create app registrations as part of normal workflows will be affected and will need to submit registration requests to a privileged administrator (e.g., Application Administrator or Cloud Application Administrator). Organizations should establish a formal request and approval process before implementing this change to avoid workflow disruption.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `Users settings`.
3. Verify that `Users can register applications` is set to `No`.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following command:

```
(Get-MgPolicyAuthorizationPolicy).DefaultUserRolePermissions | fl
AllowedToCreateApps
```

3. Verify the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `Users settings`.
3. Set `Users can register applications` to `No`.
4. Click Save.

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"`
2. Run the following commands:

```
$param = @{ AllowedToCreateApps = $false }
Update-MgPolicyAuthorizationPolicy -DefaultUserRolePermissions $param
```

Default Value:

Yes (Users can register applications.)

References:

1. https://learn.microsoft.com/en-us/entra/identity-platform/how-applications-are-added
2. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/delegate-app-roles#restrict-who-can-create-applications

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.		●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	2.6 Address unapproved software Ensure that unauthorized software is either removed or the inventory is updated in a timely manner	●	●	●

5.1.2.3 Ensure 'Restrict non-admin users from creating tenants' is set to 'Yes' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Non-privileged users can create tenants in the Microsoft Entra ID and Microsoft Entra administration portal under "Manage tenant". The creation of a tenant is recorded in the Audit log as category "DirectoryManagement" and activity "Create Company". By default, the user who creates a Microsoft Entra tenant is automatically assigned the Global Administrator role. The newly created tenant doesn't inherit any settings or configurations.

Rationale:

Restricting tenant creation prevents unauthorized or uncontrolled deployment of resources and ensures that the organization retains control over its infrastructure. User generation of shadow IT could lead to multiple, disjointed environments that can make it difficult for IT to manage and secure the organization's data, especially if other users in the organization began using these tenants for business purposes under the misunderstanding that they were secured by the organization's security team.

Impact:

Non-admin users will need to contact I.T. if they have a valid reason to create a tenant.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Verify that `Restrict non-admin users from creating tenants` is set to `Yes`

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following commands:

```
(Get-MgPolicyAuthorizationPolicy).DefaultUserRolePermissions |
    Select-Object AllowedToCreateTenants
```

3. Verify the returned value is `False`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Set `Restrict non-admin users from creating tenants` to `Yes` then `Save`.

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"`
2. Run the following commands:

```
# Create hashtable and update the auth policy
$params = @{ AllowedToCreateTenants = $false }
Update-MgPolicyAuthorizationPolicy -DefaultUserRolePermissions $params
```

Default Value:

No - Non-administrators can create tenants.

`AllowedToCreateTenants` is `True`

References:

1. https://learn.microsoft.com/en-us/entra/fundamentals/users-default-permissions#restrict-member-users-default-permissions
2. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference#tenant-creator

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.2.4 Ensure access to the Entra admin center is restricted (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting restricts non-administrators from loading a set of frequently visited pages in the Microsoft Entra admin center and Azure portal, including home, tenant overview, and the users list.

What does it not do?

- It does not block programmatic access to Microsoft Entra data via PowerShell, Microsoft Graph API, or other tools like Visual Studio.
- It does not apply to users with an administrative role, including custom roles.
- It does not prevent all access to the admin center. Many areas are still reachable through alternate paths.

Rationale:

The Microsoft Entra admin center contains sensitive data and permission settings, which are still enforced based on the user's role. However, an end user may inadvertently change properties or account settings on their own account. This could result in increased administrative overhead.

Additionally, a compromised end-user account could be used to enumerate tenant structure, users, and group memberships to support privilege escalation or lateral movement.

Impact:

Non-administrators who own groups will be unable to reach group management pages through the standard admin center navigation. Self-service access to other portal-facing features may also be affected depending on the navigation path used. Because the restriction targets specific frequently accessed pages rather than all portal content, users with direct (deep) links to other admin center sections may still be able to access them.

Note: Users will still be able to sign into Microsoft Entra admin center but will be unable to see directory information.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Verify under the **Administration center** section that `Restrict access to Microsoft Entra admin center` is set to `Yes`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Set `Restrict access to Microsoft Entra admin center` to `Yes` then `Save`.

Default Value:

No - Non-administrators can access the Microsoft Entra admin center.

References:

1. https://learn.microsoft.com/en-us/entra/fundamentals/users-default-permissions#restrict-member-users-default-permissions

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.2.5 Ensure the option to remain signed in is hidden (Manual)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

The option for the user to `Stay signed in`, or the `Keep me signed in` option, will prompt a user after a successful login. When the user selects this option, a persistent refresh token is created. The refresh token lasts for 90 days by default and does not prompt for sign-in or multifactor.

Rationale:

Allowing users to select this option presents risk, especially if the user signs into their account on a publicly accessible computer/web browser. In this case it would be trivial for an unauthorized person to gain access to any associated cloud data from that account.

Impact:

Once this setting is hidden users will no longer be prompted upon sign-in with the message `Stay signed in?`. This may mean users will be forced to sign in more frequently. Important: some features of SharePoint Online and Office 2010 have a dependency on users remaining signed in. If you hide this option, users may get additional and unexpected sign in prompts.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Verify that `Show keep user signed in` is highlighted `No`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Set `Show keep user signed in` to `No`.
4. Click `Save`.

Default Value:

Users may select `stay signed in`

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concepts-azure-multi-factor-authentication-prompts-session-lifetime
2. https://learn.microsoft.com/en-us/entra/fundamentals/how-to-manage-stay-signed-in-prompt

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●

5.1.2.6 Ensure 'LinkedIn account connections' is disabled (Manual)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

LinkedIn account connections allow users to connect their Microsoft work or school account with LinkedIn. After a user connects their accounts, information and highlights from LinkedIn are available in some Microsoft apps and services.

Rationale:

Disabling LinkedIn integration prevents potential phishing attacks and risk scenarios where an external party could accidentally disclose sensitive information.

Impact:

Users will not be able to sync contacts or use LinkedIn integration.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Under `LinkedIn account connections`, verify that `No` is selected.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Users` and select `User settings`.
3. Under `LinkedIn account connections` select `No`.
4. Click `Save`.

Default Value:

LinkedIn integration is enabled by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/linkedin-integration
2. https://learn.microsoft.com/en-us/entra/identity/users/linkedin-user-consent

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	13.3 Monitor and Block Unauthorized Network Traffic Deploy an automated tool on network perimeters that monitors for unauthorized transfer of sensitive information and blocks such transfers while alerting information security professionals.			●

5.1.3 Groups

5.1.3.1 Ensure users cannot create security groups (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting allows users in the organization to create new security groups and add members to these groups in the Azure portal, API, or PowerShell. These new groups also show up in the Access Panel for all other users. If the policy setting on the group allows it, other users can create requests to join these groups.

The recommended state is `Users can create security groups in Azure portals, API or PowerShell` set to `No`.

Rationale:

Allowing end users to create security groups without oversight can lead to uncontrolled group sprawl, increasing the risk of inappropriate access to sensitive data. The default assignment of group ownership to the creator introduces a potential for privilege escalation, especially if IT teams overlook how these groups are later used to manage access.

A more malicious scenario arises when a compromised non-privileged user creates deceptively named security groups such as “Accounting” or “Break-glass”, or uses homograph techniques to mimic legitimate group names. Third-party IT teams may be particularly susceptible, as they might not be familiar with the environment or lack consistent naming conventions. An unsuspecting administrator could then mistakenly assign elevated privileges, grant access to sensitive data, or exclude these groups from Conditional Access policies, inadvertently creating a serious security gap.

Impact:

Restrictions may introduce some operational friction, particularly in fast-paced or decentralized environments where teams rely on self-service capabilities for collaboration and access management.

This can increase reliance on IT teams for routine tasks, potentially causing delays. However, these impacts can be minimized through automated approval workflows and clear governance processes.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Groups and select General.
3. Verify that Users can create security groups in Azure portals, API or PowerShell is set to No.

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Policy.Read.All"
2. Run the following command:

```
(Get-MgPolicyAuthorizationPolicy).DefaultUserRolePermissions | fl
```

3. Verify that AllowedToCreateSecurityGroups is False.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Groups and select General.
3. Set Users can create security groups in Azure portals, API or PowerShell to No.
4. Click Save.

To remediate using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"
2. Run the following commands:

```
$params = @{
        defaultUserRolePermissions = @{
                AllowedToCreateSecurityGroups = $false
        }
}

Update-MgPolicyAuthorizationPolicy -BodyParameter $params
```

Default Value:

AllowedToCreateSecurityGroups : True

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/groups-self-service-management?WT.mc_id=Portal-Microsoft_AAD_IAM#group-settings
2. https://learn.microsoft.com/en-us/graph/api/authorizationpolicy-get?view=graph-rest-1.0&tabs=http
3. https://learn.microsoft.com/en-us/entra/identity/users/groups-self-service-management#making-a-group-available-for-end-user-self-service

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.3.2 Ensure that 'Restrict user ability to access groups features in My Groups' is set to 'Yes' (Manual)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting restricts standard users from accessing the My Groups web interface in the My Account portal (`https://myaccount.microsoft.com/groups`). When set to `Yes`, this web interface access is removed for standard users.

The recommended state is `Yes`.

Rationale:

By default, any authenticated user can access the My Groups portal and enumerate group memberships, SharePoint site URLs, group email addresses, Teams URLs, and Yammer URLs across the tenant. This information enables reconnaissance, where a user could identify high-value or privileged groups, map resource URLs, and use that data to plan further attacks or lateral movement. Restricting the web interface limits passive enumeration by users who do not require group browsing as part of their duties, reducing the available attack surface without impacting core productivity.

Note: This setting applies only to the My Groups web interface. API-based enumeration remains possible for users with appropriate permissions or tooling, and this control should not be treated as a complete enumeration defense.

Impact:

Setting this to `Yes` creates administrative overhead for users who need to look up group memberships and must now request that information from an administrator.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` and select `General`.
3. Under `Self Service Group Management`, verify that `Restrict user ability to access groups features in My Groups. Group and User Admin will have read-only access when the value of this setting is 'Yes'` is set to `Yes`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` and select `General`.
3. Under `Self Service Group Management`, set `Restrict user ability to access groups features in My Groups. Group and User Admin will have read-only access when the value of this setting is 'Yes'` to `Yes`.
4. Click `Save`.

Default Value:

`No`

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/groups-self-service-management

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.3.3 Ensure that 'Owners can manage group membership requests in My Groups' is set to 'No' (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft Entra ID provides self-service group management features that enable users to create and manage their own security groups or Microsoft 365 groups. The owner of the group can approve or deny membership requests and delegate control of group membership. Self-service group management features aren't available for mail-enabled security groups or distribution lists.

The recommended state is `No`.

Rationale:

Group owners are standard users who may not have visibility into access governance requirements for a given group. Allowing owners to approve membership requests through My Groups means additions to security groups or Microsoft 365 groups can occur without administrator review, bypassing formal access provisioning controls. Unauthorized or excessive group membership can expand a user's effective permissions and increase the blast radius of a compromised account.

Impact:

Administrators will be responsible for managing group membership requests instead of group owners, which is the default behavior. Administrative overhead will only increase if this setting was previously changed to `Yes`.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` and select `General`.
3. Verify that `Owners can manage group membership requests in My Groups` is set to `No`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` select `General`.

3. Set `Owners can manage group membership requests in My Groups` to `No`.
4. Click `Save`.

Default Value:

`No`

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/groups-self-service-management#making-a-group-available-for-end-user-self-service

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.3.4 Ensure that 'Users can create Microsoft 365 groups in Azure portals, API or PowerShell' is set to 'No' (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

All users within a Microsoft Entra organization are permitted to create new Microsoft 365 groups and add members to those groups through the Azure portal, API, or PowerShell. Newly created groups also appear in the Access Panel for all other users. When the applicable group policy settings allow it, users can submit requests to join these groups.

The recommended state is `No`.

Rationale:

Restricting Microsoft 365 group creation to administrators only ensures that creation of Microsoft 365 groups is controlled by the administrator. Appropriate groups should be created and managed by the administrator and group creation rights should not be delegated to any other user.

Impact:

Enabling this setting could create a number of requests that would need to be managed by an administrator.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` and select `General`.
3. Verify that `Users can create Microsoft 365 groups in Azure portals, API or PowerShell` is set to `No`

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/groupSettings
```

2. Filter to groups with the `templateId` of `62375ab9-6b52-47ed-826b-58e47e0e304b`
3. Verify that `EnableGroupCreation` is `false`.
4. If the group with the above `templateId` does not exist, then it means the setting is in its default state and is not compliant.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Groups` and select `General`.
3. Set `Users can create Microsoft 365 groups in Azure portals, API or PowerShell` to `No`
4. Click `Save`.

To remediate using the Microsoft Graph API:

1. Execute a `PATCH` request to the following relative URI:

```
v1.0/groupSettings
```

2. Target the object with the `templateId` of `62375ab9-6b52-47ed-826b-58e47e0e304b`
3. Update `EnableGroupCreation` to `false`.

Note: If a group with the above `templateId` doesn't exist this means the defaults are present and it would be advisable to use the UI to remediate, as this will automatically create the `Group.Unified` object with its defaults. Microsoft's documentation does cover using a POST request to build this using the API, however.

Default Value:

Yes

References:

1. https://learn.microsoft.com/en-us/microsoft-365/solutions/manage-creation-of-groups
2. https://learn.microsoft.com/en-us/graph/api/group-list-settings?view=graph-rest-1.0&tabs=http
3. https://learn.microsoft.com/en-us/graph/api/groupsetting-update?view=graph-rest-1.0&tabs=http

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

5.1.4 Devices

This section contains settings related to device management. While some organizations may opt not to use Intune for managing devices, it is still advisable to harden these configurations beyond their default values. Doing so ensures a stronger security posture should these features be utilized in the future.

5.1.4.1 Ensure the ability to join devices to Entra is restricted (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting enables you to select the users who can register their devices as Microsoft Entra joined devices.

The recommended state is `Selected` or `None`.

Note: This setting is applicable only to Microsoft Entra join on Windows 10 or newer. This setting doesn't apply to Microsoft Entra hybrid joined devices, Microsoft Entra joined VMs in Azure, or Microsoft Entra joined devices that use Windows Autopilot self-deployment mode because these methods work in a userless context.

Rationale:

If a threat actor compromises a standard user account, they can enroll a rogue device under that user's identity. This device may inherit MDM policies and appear compliant, giving attackers persistent access to cloud resources without triggering MFA.

In a 2023 blog, Microsoft IR reports that it has detected threat actors registering their own devices to the Microsoft Entra tenant, giving them a platform to escalate the cyberattack. While simply joining a device to a Microsoft Entra tenant may present limited immediate risk, it could allow a threat actor to establish a foothold in the environment.

Impact:

Restricting the setting requires IT teams to assign enrollment permissions to specific staff, such as helpdesk or provisioning personnel, which may impact user-driven Autopilot scenarios and increase administrative overhead for device onboarding and support.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Users may join devices to Microsoft Entra` is set to `Selected` *or* `None`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
beta/policies/deviceRegistrationPolicy
```

3. Verify that `azureADJoin.allowedToJoin.@odata.type` is one of the following:
   - `#microsoft.graph.enumeratedDeviceRegistrationMembership` **(Selected)**
   - `#microsoft.graph.noDeviceRegistrationMembership` **(None)**.

Note: When set to `Selected`, users and groups will also appear in the output of the Graph Request.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Users may join devices to Microsoft Entra` to `Selected` (and add members) or `None`.

Default Value:

All

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://www.microsoft.com/en-us/security/blog/2023/12/05/microsoft-incident-response-lessons-on-preventing-cloud-identity-compromise/#poor-device
3. https://learn.microsoft.com/en-us/graph/api/resources/deviceregistrationpolicy?view=graph-rest-beta

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.4.2 Ensure the maximum number of devices per user is limited (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting defines the maximum number of Microsoft Entra joined or registered devices that a user can have in Microsoft Entra ID. Once this limit is reached, no additional devices can be added until existing ones are removed. Values above 100 are automatically capped at 100.

The recommended state is `10` or less.

Rationale:

Microsoft incident response teams have observed threat actors enrolling their own devices to establish persistence after a non-privileged user has been compromised. High device quotas can exacerbate this risk by enabling attackers to register multiple devices that appear legitimate, while also contributing to unmanaged or personal devices cluttering the environment, driving up licensing costs and complicating compliance efforts.

Enforcing a reasonable device limit per user supports good governance, reduces the attack surface, and encourages administrators to reassess and clean up legacy or unused device enrollments.

Impact:

IT staff who need to enroll more than 10 devices on behalf of the organization must be assigned the role of Device Enrollment Manager in the Intune admin center. Device Enrollment Managers are non-administrator accounts that can enroll and manage up to 1,000 devices. It is recommended to use dedicated service accounts for this role rather than assigning it to users' primary or daily-use accounts.

Warning: Do not delete accounts assigned as a Device enrollment manager if any devices were enrolled using the account. Doing so will lead to issues with these devices.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Maximum number of devices per user` is set to `10` or less.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/policies/deviceRegistrationPolicy
```

2. Verify that `userDeviceQuota` is `10` or less.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Maximum number of devices per user` to `10` or less.

Default Value:

50

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://learn.microsoft.com/en-us/intune/intune-service/enrollment/device-enrollment-manager-enroll
3. https://learn.microsoft.com/en-us/graph/api/resources/deviceregistrationpolicy?view=graph-rest-beta

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.4.3 Ensure the GA role is not added as a local administrator during Entra join (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting controls whether the Global Administrator role is automatically added to the local administrators group on a device during the Microsoft Entra join process.

The recommended state is `No`.

Rationale:

System administrators may be inclined to use over-privileged accounts for convenience when managing devices. Enforcing this control helps discourage that behavior by requiring administrative actions to be performed using accounts specifically designated for local administration. This promotes adherence to the principle of least privilege and reduces the risk associated with using high-level roles for routine tasks. For example, using a Global Administrator account to authenticate to a compromised endpoint and continue performing tasks significantly increases the risk of broader organizational compromise.

Impact:

Restricting the default behavior and requiring manual assignment to least privilege roles introduces minor administrative overhead. During the Microsoft Entra join process, the **Microsoft Entra Joined Device Local Administrator** role is automatically added to the device's local administrators group and should be used instead.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Global administrator role is added as local administrator on the device during Microsoft Entra join (Preview)` is set to `No`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
beta/policies/deviceRegistrationPolicy
```

2. Verify that `azureADJoin.localAdmins.enableGlobalAdmins` is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Global administrator role is added as local administrator on the device during Microsoft Entra join (Preview)` to `No`.

Default Value:

Yes

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://learn.microsoft.com/en-us/graph/api/resources/deviceregistrationpolicy?view=graph-rest-beta
3. https://learn.microsoft.com/en-us/entra/identity/devices/assign-local-admin

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.4.4 Ensure local administrator assignment is limited during Entra join (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting determines if the Microsoft Entra user registering their device as Microsoft Entra join will be added to the local administrators group. This setting applies only once during the actual registration of the device as Microsoft Entra join.

The recommended state is `Selected` *or* `None`.

Rationale:

To uphold the principle of least privilege, the assignment of local administrator rights during Microsoft Entra join should be centrally managed using appropriate built-in roles through Intune. This approach minimizes the number of disparate users with elevated privileges, reducing the attack surface and potential for misuse. Centralized management also streamlines the deprovisioning process, ensuring that administrative access can be revoked efficiently and consistently across all devices, rather than requiring manual intervention on each individual endpoint.

Impact:

Restricting the default behavior and requiring manual assignment to built-in roles introduces minor administrative overhead. During the Microsoft Entra join process, the **Microsoft Entra Joined Device Local Administrator** role is automatically added to the device's local administrators group and should be used instead.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Registering user is added as local administrator on the device during Microsoft Entra join (Preview)` is set to `Selected` *or* `None`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
beta/policies/deviceRegistrationPolicy
```

2. Verify that `azureADJoin.localAdmins.registeringUsers.@odata.type` is one of the following:
   - `#microsoft.graph.enumeratedDeviceRegistrationMembership` **(Selected)**
   - `#microsoft.graph.noDeviceRegistrationMembership` **(None)**.

Note: When set to `Selected`, users and groups will also appear in the output of the Graph Request.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Registering user is added as local administrator on the device during Microsoft Entra join (Preview)` to `Selected` (and add members) *or* `None`.

Default Value:

All

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://learn.microsoft.com/en-us/graph/api/resources/deviceregistrationpolicy?view=graph-rest-beta
3. https://learn.microsoft.com/en-us/entra/identity/devices/assign-local-admin

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.4.5 Ensure Local Administrator Password Solution is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Local Administrator Password Solution (LAPS) is the management of local account passwords on Windows devices. LAPS provides a solution to securely manage and retrieve the built-in local admin password. With cloud version of LAPS, customers can enable storing and rotation of local admin passwords for both Microsoft Entra and Microsoft Entra hybrid join devices

The recommended state is `Yes`.

Rationale:

Managing local Administrator passwords across multiple systems can be challenging. As a result, many organizations opt to configure the same password on all workstations and/or member servers during deployment. However, this practice introduces a significant security risk: if an attacker compromises one system and obtains the local Administrator password, they can potentially gain administrative access to every other system using that same password.

Additionally, enabling LAPS at the tenant level is a prerequisite for implementing LAPS-related recommendations outlined in the CIS Microsoft Intune for Windows Workstation Benchmarks.

Note: Enabling LAPS at the tenant level does not automatically enforce password rotation for built-in Administrator accounts. To activate LAPS functionality, appropriate policies must be configured in Intune Settings Catalog or under the `Endpoint security` > `Account protection` blade. The CIS Microsoft 365 Foundations Benchmark focuses on hardening at the tenant level, while the CIS Intune Benchmarks focus on endpoint-specific configurations.

Impact:

Enabling LAPS requires some additional operational overhead.

Although unlikely if a password is rotated and not retrieved or backed up before the device becomes unreachable (e.g., due to hardware failure, network isolation, or being decommissioned), administrators may be locked out.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Enable Microsoft Entra Local Administrator Password Solution (LAPS)` is set to `Yes`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/policies/deviceRegistrationPolicy
```

2. Verify that `localAdminPassword.isEnabled` is `True`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Enable Microsoft Entra Local Administrator Password Solution (LAPS)` to `Yes`.

Default Value:

No

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://learn.microsoft.com/en-us/graph/api/resources/deviceregistrationpolicy?view=graph-rest-beta
3. https://learn.microsoft.com/en-us/entra/identity/devices/howto-manage-local-admin-passwords

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.7 Manage Default Accounts on Enterprise Assets and Software Manage default accounts on enterprise assets and software, such as root, administrator, and other pre-configured vendor accounts. Example implementations can include: disabling default accounts or making them unusable.	●	●	●
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v8	5.4 Restrict Administrator Privileges to Dedicated Administrator Accounts Restrict administrator privileges to dedicated administrator accounts on enterprise assets. Conduct general computing activities, such as internet browsing, email, and productivity suite use, from the user's primary, non-privileged account.	●	●	●

5.1.4.6 Ensure users are restricted from recovering BitLocker keys (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting determines if users can self-service recover their BitLocker key(s). 'Yes' restricts non-admin users from being able to see the BitLocker key(s) for their owned devices if there are any. 'No' allows all users to recover their BitLocker key(s).

The recommended state is `Yes`.

Rationale:

Restricting user access to the self-service BitLocker recovery key portal helps mitigate the risk of recovery key exposure in the event of a compromised user account. If an attacker gains access to both the user's credentials and the physical device, they could potentially retrieve the recovery key and decrypt sensitive data. The recovery key itself is also considered sensitive information.

Impact:

Restricting this setting will increase administrative overhead and may introduce friction between end users and the helpdesk, as users will no longer be able to retrieve BitLocker recovery keys through the self-service portal. This portal was originally designed to streamline recovery and reduce support burden. During the CrowdStrike Falcon Sensor outage in July 2024, many endpoints entered recovery mode, and delays in accessing recovery keys contributed to prolonged downtime. Limiting self-service access could exacerbate such delays in future incidents, especially in large or distributed environments.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Verify that `Restrict users from recovering the BitLocker key(s) for their owned devices` is set to `Yes`.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following:

```
(Get-MgPolicyAuthorizationPolicy).DefaultUserRolePermissions | fl
```

3. Verify that `AllowedToReadBitlockerKeysForOwnedDevice` is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Devices` and select `Device settings`.
3. Set `Restrict users from recovering the BitLocker key(s) for their owned devices` to `Yes`.

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"`
2. Run the following:

```
$params = @{
        defaultUserRolePermissions = @{
                AllowedToReadBitlockerKeysForOwnedDevice = $false
        }
}

Update-MgPolicyAuthorizationPolicy -BodyParameter $params
```

Default Value:

No

References:

1. https://learn.microsoft.com/en-us/entra/identity/devices/manage-device-identities#configure-device-settings
2. https://learn.microsoft.com/en-us/graph/api/authorizationpolicy-get?view=graph-rest-1.0
3. https://techcommunity.microsoft.com/blog/intunecustomersuccess/user-self-service-bitlocker-recovery-key-access-with-intune-company-portal-websi/4150458
4. https://learn.microsoft.com/en-us/windows/security/operating-system-security/data-protection/bitlocker/recovery-process#self-recovery

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

5.1.5 Enterprise apps

5.1.5.1 Ensure user consent to apps accessing company data on their behalf is not allowed (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Control when end users and group owners are allowed to grant consent to applications, and when they will be required to request administrator review and approval. Allowing users to grant apps access to data helps them acquire useful applications and be productive but can represent a risk in some situations if it's not monitored and controlled carefully.

Rationale:

Attackers commonly use custom applications to trick users into granting them access to company data. Restricting user consent mitigates this risk and helps to reduce the threat-surface.

Impact:

If user consent is disabled, previous consent grants will still be honored but all future consent operations must be performed by an administrator. Tenant-wide admin consent can be requested by users through an integrated administrator consent request workflow or through organizational support processes.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under `Security` select `Consent and permissions` > `User consent settings`.
4. Verify that `User consent for applications` is set to `Do not allow user consent`.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following command:

```
(Get-MgPolicyAuthorizationPolicy).DefaultUserRolePermissions |
    Select-Object -ExpandProperty PermissionGrantPoliciesAssigned
```

3. Verify that the returned array does not contain either `ManagePermissionGrantsForSelf.microsoft-user-default-low` or `ManagePermissionGrantsForSelf.microsoft-user-default-legacy`. If either of these strings is present, the audit fails.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under `Security` select `Consent and permissions` > `User consent settings`.
4. Under `User consent for applications` select `Do not allow user consent`.
5. Click the `Save` option at the top of the window.

Default Value:

UI - `Allow user consent for apps`

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-user-consent?pivots=portal
2. https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.identity.signins/get-mgpolicyauthorizationpolicy?view=graph-powershell-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.		●	●

5.1.5.2 Ensure the admin consent workflow is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The admin consent workflow gives admins a secure way to grant access to applications that require admin approval. When a user tries to access an application but is unable to provide consent, they can send a request for admin approval. The request is sent via email to admins who have been designated as reviewers. A reviewer takes action on the request, and the user is notified of the action.

Rationale:

The admin consent workflow (Preview) gives admins a secure way to grant access to applications that require admin approval. When a user tries to access an application but is unable to provide consent, they can send a request for admin approval. The request is sent via email to admins who have been designated as reviewers. A reviewer acts on the request, and the user is notified of the action.

Impact:

To approve requests, a reviewer must be a global administrator, cloud application administrator, or application administrator. The reviewer must already have one of these admin roles assigned; simply designating them as a reviewer doesn't elevate their privileges.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID and select Enterprise apps.
3. Under Security select Consent and permissions.
4. Under Manage select Admin consent settings.
5. Verify that Users can request admin consent to apps they are unable to consent to is set to Yes.

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Policy.Read.All"
2. Run the following command:

```
Get-MgPolicyAdminConsentRequestPolicy |
    fl IsEnabled,NotifyReviewers,RemindersEnabled
```

3. Verify that IsEnabled is True.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID and select Enterprise apps.
3. Under Security select Consent and permissions.
4. Under Manage select Admin consent settings.
5. Set Users can request admin consent to apps they are unable to consent to to Yes under Admin consent requests.
6. Under the Reviewers choose the Roles and Groups that will review user generated app consent requests.
7. Set Selected users will receive email notifications for requests to Yes
8. Select Save at the top of the window.

Default Value:

- Users can request admin consent to apps they are unable to consent to: No
- Selected users to review admin consent requests: None
- Selected users will receive email notifications for requests: Yes
- Selected users will receive request expiration reminders: Yes
- Consent request expires after (days): 30

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-admin-consent-workflow

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.		●	●
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●
v7	18.3 Verify That Acquired Software is Still Supported Verify that the version of all software acquired from outside your organization is still supported by the developer or appropriately hardened based on developer security recommendations.		●	●

5.1.5.3 Ensure password addition is blocked for applications (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

In Microsoft Entra ID, applications and service principals can authenticate using either certificate credentials or password credentials (also referred to as client secrets). This setting enforces a tenant-wide restriction that prevents new password credentials from being added to any application registration or service principal. The policy is implemented through the default app management policy and applies to all applications unless scoped exceptions are configured.

The setting does not revoke or invalidate existing password credentials; credentials created before the policy was enabled remain valid until they expire or are explicitly removed.

The recommended state is `Block password addition` set to `On`.

Rationale:

Password credentials (client secrets) used for application authentication are static string values that offer weaker security guarantees than certificate or federated credentials. Unlike certificates, client secrets carry no built-in proof of possession and are frequently stored in plaintext in source code, configuration files, CI/CD pipelines, and shell history. A leaked client secret grants any holder the ability to authenticate as the application to Microsoft Entra ID, potentially accessing any resource or permission scope assigned to that application.

Blocking the addition of new password credentials eliminates this attack surface for applications created going forward and forces adoption of stronger credential types such as certificates.

Impact:

This policy applies to new password credential additions only. Existing client secrets remain valid until they expire or are explicitly revoked; this recommendation does not retroactively invalidate credentials created before the policy was enabled.

Any automated process, pipeline, or script that programmatically adds client secrets to application registrations or service principals will be blocked once the policy is enabled, unless an exception is configured. Applications that have not yet migrated to certificate-based authentication or workload identity federation will require changes before new credentials can be added.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Block password addition`.
5. Verify that `Status` is set to `On`.
6. Verify that `Applies to` is set to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, verify they are reviewed annually).
7. Verify that `Only apply to apps created after` is one of the following states:
    - Not configured (Field will show `Select a date` with no date selected)
    - A date that is on or before the date of the assessment.
8. Compliance is met when all of the above conditions are satisfied.

To audit using the Microsoft Graph API:

Note: Both the application restrictions and service principal restrictions must be audited to ensure password addition is properly blocked, as they can be independently configured in Graph or PowerShell. The UI only surfaces the combined state of both settings.

1. Execute a `GET` request to the following relative URI to get the default app management policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Verify that `isEnabled` is `true`, this indicates that the default app management policy is enabled and being applied to the tenant.

Part 1: Audit application restrictions

1. Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordAddition`.
2. Verify the following conditions are met for `applicationRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Part 2: Audit service principal restrictions

1. Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordAddition`.
2. Verify the following conditions are met for `servicePrincipalRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Note: Presently the API does not surface application exclusions, only excluded callers, so it is not necessary to audit them for compliance.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Block password addition`.
5. Set `Status` to `On`.
6. Set `Applies to` to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, ensure they are reviewed annually).
7. Set `Only apply to apps created after` to a desired date or leave it unconfigured.
8. Select `Save and close` to apply the changes.

To remediate using the Microsoft Graph API:

Important: The PATCH request replaces the `passwordCredentials` array in full. Retrieve the current policy first and include all existing entries in the request body to avoid overwriting other configured restrictions or exclusions.

1. Execute a `GET` request to retrieve the current policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Modify the returned JSON to reflect the following changes:

- Set `isEnabled` to `true`.
- Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordAddition` and set the following:
  - `state` to `enabled`
  - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
- Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordAddition` and set the following:
  - `state` to `enabled`
  - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.

3. Execute a `PATCH` request to the same URI with the modified JSON in the request body to apply the changes.

Note: The References section includes a link to the API documentation with full remediation examples in multiple languages including HTTP, PowerShell, and Python.

Default Value:

`Off`

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-app-management-policies?tabs=portal
2. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/tutorial-enforce-secret-standards?pivots=ms-graph
3. https://learn.microsoft.com/en-us/graph/api/resources/tenantappmanagementpolicy?view=graph-rest-1.0
4. https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities#enforce-standards-for-app-secrets-and-certificates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.5.4 Ensure password lifetime for applications does not exceed 180 days (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft Entra ID, applications and service principals can authenticate using password credentials (also referred to as client secrets). This setting enforces a tenant-wide maximum lifetime for new password credentials added to any application registration or service principal. When enabled, any client secret created must have an expiration date that falls within the configured maximum, which for this recommendation is 180 days or less. The policy is implemented through the default app management policy and applies to all applications unless scoped exceptions are configured.

The setting does not retroactively shorten or invalidate existing password credentials; secrets created before the policy was enabled remain valid until they expire or are explicitly removed.

The recommended state is `Restrict max password lifetime` set to `On`: `180` days or less.

Rationale:

Long-lived client secrets extend the window of exploitation if a credential is compromised. A secret valid for multiple years that is never rotated remains usable even if it was leaked in source code, a build log, or a security breach long after the initial exposure. Enforcing a maximum lifetime of 180 days ensures that client secrets expire on a regular basis, limiting the period during which a stolen credential remains valid and reducing the blast radius of a compromise. This control also encourages teams to establish automated rotation practices, which further reduces reliance on static, long-lived credentials.

Impact:

Any automated process, pipeline, or script that creates client secrets with a lifetime exceeding the configured maximum will fail once the policy is enabled, unless an exception is configured. Organizations will need to update secret creation workflows to specify expiration dates within the allowed range and establish rotation processes for secrets approaching expiry.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Restrict max password lifetime`.
5. Verify that `Status` is set to `On`.
6. Verify that the configured maximum lifetime is `180` days or less.
7. Verify that `Applies to` is set to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, verify they are reviewed annually).
8. Verify that `Only apply to apps created after` is one of the following states:
    - Not configured (Field will show `Select a date` with no date selected)
    - A date that is on or before the date of the assessment.
9. Compliance is met when all of the above conditions are satisfied.

To audit using the Microsoft Graph API:

Note: Both the application restrictions and service principal restrictions must be audited to ensure the password lifetime is properly restricted, as they can be independently configured in Graph or PowerShell. The UI only surfaces the combined state of both settings.

1. Execute a `GET` request to the following relative URI to get the default app management policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Verify that `isEnabled` is `true`, this indicates that the default app management policy is enabled and being applied to the tenant.

Part 1: Audit application restrictions

1. Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordLifetime`.
2. Verify the following conditions are met for `applicationRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `maxLifetime` is `P180D` or a shorter duration (e.g., `P90D`, `P30D`, etc.)
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Part 2: Audit service principal restrictions

1. Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordLifetime`.
2. Verify the following conditions are met for `servicePrincipalRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `maxLifetime` is `P180D` or a shorter duration (e.g., `P90D`, `P30D`, etc.)
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Note: Presently the API does not surface application exclusions, only excluded callers, so it is not necessary to audit them for compliance.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Restrict max password lifetime`.
5. Set `Status` to `On`.
6. Set the maximum lifetime to `180` days or less.
7. Set `Applies to` to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, ensure they are reviewed annually).
8. Set `Only apply to apps created after` to a desired date or leave it unconfigured.
9. Select `Save and close` to apply the changes.

To remediate using the Microsoft Graph API:

Important: The PATCH request replaces the `passwordCredentials` array in full. Retrieve the current policy first and include all existing entries in the request body to avoid overwriting other configured restrictions or exclusions.

1. Execute a `GET` request to retrieve the current policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Modify the returned JSON to reflect the following changes:
    - Set `isEnabled` to `true`.
    - Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordLifetime` and set the following:
        - `state` to `enabled`
        - `maxLifetime` to `P180D` or a shorter duration.
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
    - Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `passwordLifetime` and set the following:
        - `state` to `enabled`
        - `maxLifetime` to `P180D` or a shorter duration.
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
3. Execute a `PATCH` request to the same URI with the modified JSON in the request body to apply the changes.

Note: The References section includes a link to the API documentation with full remediation examples in multiple languages including HTTP, PowerShell, and Python.

Default Value:

`Off`

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-app-management-policies?tabs=portal
2. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/tutorial-enforce-secret-standards?pivots=ms-graph
3. https://learn.microsoft.com/en-us/graph/api/resources/tenantappmanagementpolicy?view=graph-rest-1.0
4. https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities#enforce-standards-for-app-secrets-and-certificates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.5.5 Ensure new application passwords are system-generated (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft Entra ID, applications and service principals can authenticate using password credentials (also referred to as client secrets). By default, when adding a new password credential, the caller may supply a custom password value or allow the system to generate one. This setting enforces a tenant-wide restriction that blocks the use of custom password values, requiring all new password credentials to be system-generated. The policy is implemented through the default app management policy and applies to all applications unless scoped exceptions are configured.

The setting does not affect existing password credentials; credentials created before the policy was enabled remain valid until they expire or are explicitly removed.

The recommended state is `Block custom passwords` set to `On`.

Rationale:

Custom password values are chosen by the caller and are susceptible to low entropy, predictable patterns, and reuse across multiple applications. A weak or reused client secret that is compromised through source code exposure, logging, or a supply-chain breach can be trivially exploited by an attacker to authenticate as the application. System-generated passwords use random values of sufficient length and complexity, making them resistant to brute-force and dictionary attacks. Blocking custom passwords removes the weakest credential creation path and ensures that all new client secrets meet a consistent entropy baseline.

Impact:

Any automated process, pipeline, or script that programmatically creates a client secret by supplying a custom password value will be blocked once the policy is enabled, unless an exception is configured. Most tooling, including the Microsoft Entra admin center, Azure CLI, and Azure PowerShell, already defaults to system-generated values, so the operational impact for typical workflows is minimal. Organizations that rely on custom password values in their automation will need to update those workflows to omit the custom value and accept the system-generated secret.

Organizations that have policies or regulatory requirements that mandate specific password formats may need to maintain exclusions for certain applications. Exceptions should be scoped narrowly and reviewed regularly to minimize risk.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Block custom passwords`.
5. Verify that `Status` is set to `On`.
6. Verify that `Applies to` is set to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, verify they are reviewed annually).
7. Verify that `Only apply to apps created after` is one of the following states:
    - Not configured (Field will show `Select a date` with no date selected)
    - A date that is on or before the date of the assessment.
8. Compliance is met when all of the above conditions are satisfied.

To audit using the Microsoft Graph API:

Note: Both the application restrictions and service principal restrictions must be audited to ensure custom password addition is properly blocked, as they can be independently configured in Graph or PowerShell. The UI only surfaces the combined state of both settings.

1. Execute a `GET` request to the following relative URI to get the default app management policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Verify that `isEnabled` is `true`, this indicates that the default app management policy is enabled and being applied to the tenant.

Part 1: Audit application restrictions

1. Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `customPasswordAddition`.
2. Verify the following conditions are met for `applicationRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Part 2: Audit service principal restrictions

1. Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `customPasswordAddition`.
2. Verify the following conditions are met for `servicePrincipalRestrictions.passwordCredentials`:
    - `state` is `enabled`
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Note: Presently the API does not surface application exclusions, only excluded callers, so it is not necessary to audit them for compliance.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Block custom passwords`.
5. Set `Status` to `On`.
6. Set `Applies to` to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, ensure they are reviewed annually).
7. Set `Only apply to apps created after` to a desired date or leave it unconfigured.
8. Select `Save and close` to apply the changes.

To remediate using the Microsoft Graph API:

Important: The PATCH request replaces the `passwordCredentials` array in full. Retrieve the current policy first and include all existing entries in the request body to avoid overwriting other configured restrictions or exclusions.

1. Execute a `GET` request to retrieve the current policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Modify the returned JSON to reflect the following changes:
    - Set `isEnabled` to `true`.
    - Under `applicationRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `customPasswordAddition` and set the following:
        - `state` to `enabled`
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
    - Under `servicePrincipalRestrictions.passwordCredentials`, locate the entry where `restrictionType` is `customPasswordAddition` and set the following:
        - `state` to `enabled`
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
3. Execute a `PATCH` request to the same URI with the modified JSON in the request body to apply the changes.

Note: The References section includes a link to the API documentation with full remediation examples in multiple languages including HTTP, PowerShell, and Python.

Default Value:

`Off`

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-app-management-policies?tabs=portal
2. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/tutorial-enforce-secret-standards?pivots=ms-graph
3. https://learn.microsoft.com/en-us/graph/api/resources/tenantappmanagementpolicy?view=graph-rest-1.0
4. https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities#enforce-standards-for-app-secrets-and-certificates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.1.5.6 Ensure maximum certificate lifetime for applications does not exceed 180 days (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In Microsoft Entra ID, applications and service principals can authenticate using certificate credentials. This setting enforces a tenant-wide maximum lifetime for new certificate credentials added to any application registration or service principal. When enabled, any certificate uploaded must have a validity period that falls within the configured maximum, which for this recommendation is 180 days or less. The policy is implemented through the default app management policy and applies to all applications unless scoped exceptions are configured.

The setting does not retroactively shorten or invalidate existing certificate credentials; certificates uploaded before the policy was enabled remain valid until they expire or are explicitly removed.

The recommended state is `Restrict maximum certificate lifetime` set to `On`: `180` days or less.

Rationale:

Long-lived certificates extend the window of exploitation if a credential is compromised. A certificate valid for multiple years that is never rotated remains usable even if the private key was exposed through a server breach, misconfigured storage, or supply-chain compromise long after the initial exposure. Enforcing a maximum lifetime of 180 days ensures that certificates expire on a regular basis, limiting the period during which a stolen credential remains valid and reducing the blast radius of a compromise. This control also encourages teams to establish automated certificate rotation practices, which further reduces reliance on static, long-lived credentials.

Impact:

Any automated process, pipeline, or script that uploads certificates with a validity period exceeding the configured maximum will be blocked once the policy is enabled, unless an exception is configured. Organizations will need to update certificate issuance workflows to generate certificates with expiration dates within the allowed range and establish rotation processes for certificates approaching expiry.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Restrict max certificate lifetime`.
5. Verify that `Status` is set to `On`.
6. Verify that `Applies to` is set to one of the following:
   - `All applications`
   - `All applications with exclusions` (if using exclusions, verify they are reviewed annually).
7. Verify that `Only apply to apps created after` is one of the following states:
   - Not configured (Field will show `Select a date` with no date selected)
   - A date that is on or before the date of the assessment.
8. Verify that `Maximum lifetime (in days)` is `180` days or less.
9. Compliance is met when all of the above conditions are satisfied.

To audit using the Microsoft Graph API:

Note: Both the application restrictions and service principal restrictions must be audited to ensure the certificate lifetime is properly restricted, as they can be independently configured in Graph or PowerShell. The UI only surfaces the combined state of both settings.

1. Execute a `GET` request to the following relative URI to get the default app management policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Verify that `isEnabled` is `true`, this indicates that the default app management policy is enabled and being applied to the tenant.

Part 1: Audit application restrictions

1. Under `applicationRestrictions.keyCredentials`, locate the entry where `restrictionType` is `asymmetricKeyLifetime`.
2. Verify the following conditions are met for `applicationRestrictions.keyCredentials`:
   - `state` is `enabled`
   - `maxLifetime` is `P180D` or a shorter duration (e.g., `P90D`, `P30D`, etc.)
   - `restrictForAppsCreatedAfterDateTime` is one of the following states:
     - `0001-01-01T00:00:00Z` (not configured)
     - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Part 2: Audit service principal restrictions

1. Under `servicePrincipalRestrictions.keyCredentials`, locate the entry where `restrictionType` is `asymmetricKeyLifetime`.
2. Verify the following conditions are met for `servicePrincipalRestrictions.keyCredentials`:
    - `state` is `enabled`
    - `maxLifetime` is `P180D` or a shorter duration (e.g., `P90D`, `P30D`, etc.)
    - `restrictForAppsCreatedAfterDateTime` is one of the following states:
        - `0001-01-01T00:00:00Z` (not configured)
        - A date that is on or before the date of the assessment.
3. Compliance is met when all of the above conditions are satisfied.

Note: Presently the API does not surface application exclusions, only excluded callers, so it is not necessary to audit them for compliance.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` and select `Enterprise apps`.
3. Under Security select `Application policies`.
4. Select `Restrict max certificate lifetime`.
5. Set `Status` to `On`.
6. Set `Applies to` to one of the following:
    - `All applications`
    - `All applications with exclusions` (if using exclusions, ensure they are reviewed annually).
7. Set `Only apply to apps created after` to a desired date or leave it unconfigured.
8. Set `Maximum lifetime (in days)` to `180` days or less.
9. Select `Save and close` to apply the changes.

To remediate using the Microsoft Graph API:

1. Execute a `GET` request to retrieve the current policy:

```
v1.0/policies/defaultAppManagementPolicy
```

2. Modify the returned JSON to reflect the following changes:
    - Set `isEnabled` to `true`.
    - Under `applicationRestrictions.keyCredentials`, locate the entry where `restrictionType` is `asymmetricKeyLifetime` and set the following:
        - `state` to `enabled`
        - `maxLifetime` to `P180D` or a shorter duration.
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
    - Under `servicePrincipalRestrictions.keyCredentials`, locate the entry where `restrictionType` is `asymmetricKeyLifetime` and set the following:
        - `state` to `enabled`
        - `maxLifetime` to `P180D` or a shorter duration.
        - `restrictForAppsCreatedAfterDateTime` to `0001-01-01T00:00:00Z` or a desired date.
3. Execute a `PATCH` request to the same URI with the modified JSON in the request body to apply the changes.

Note: The References section includes a link to the API documentation with full remediation examples in multiple languages including HTTP, PowerShell, and Python.

Default Value:

`Off`

References:

1. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/configure-app-management-policies?tabs=portal
2. https://learn.microsoft.com/en-us/entra/identity/enterprise-apps/tutorial-enforce-secret-standards?pivots=ms-graph
3. https://learn.microsoft.com/en-us/graph/api/resources/tenantappmanagementpolicy?view=graph-rest-1.0
4. https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities#enforce-standards-for-app-secrets-and-certificates

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.1.6 External Identities

5.1.6.1 Ensure that collaboration invitations are sent to allowed domains only (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

B2B collaboration is a feature within Microsoft Entra External ID that allows for guest invitations to an organization.

Ensure users can only send invitations to `specified domains`.

Note: This list works independently from OneDrive for Business and SharePoint Online allow/block lists. To restrict individual file sharing in SharePoint Online, set up an allow or blocklist for OneDrive for Business and SharePoint Online. For instance, in SharePoint or OneDrive users can still share with external users from prohibited domains by using Anyone links if they haven't been disabled.

Rationale:

By specifying allowed domains for collaborations, external user's companies are explicitly identified. Also, this prevents internal users from inviting unknown external users such as personal accounts and granting them access to resources.

Impact:

This could make collaboration more difficult if the setting is not quickly updated when a new domain is identified as "allowed".

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Collaboration restrictions**, verify that `Allow invitations only to the specified domains (most restrictive)` is selected. Then verify allowed domains are specified under `Target domains`.

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following:

```
$Uri = "https://graph.microsoft.com/beta/legacy/policies"
$Response = (Invoke-MgGraphRequest -Uri $Uri).value |
Where-Object { $_.type -eq 'B2BManagementPolicy' }

if ($Response) {
    $Definition = $Response.definition | ConvertFrom-Json
    $DomainsPolicy =
$Definition.B2BManagementPolicy.InvitationsAllowedAndBlockedDomainsPolicy
} else {
    Write-Output "No policy found."
    return
}

$DomainsPolicy
```

3. Verify that the output includes an `AllowedDomains` property that either contains no domains or lists only organizationally approved domains. If a *BlockedDomains* property is present, the configuration is considered non-compliant.

Example of a compliant output with AllowedDomains defined:

```
AllowedDomains
--------------
{cisecurity.org, contoso.com, example.com}
```

Allowed with no domains allowed (also compliant):

```
AllowedDomains
--------------
{}
```

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Collaboration restrictions**, select `Allow invitations only to the specified domains (most restrictive)` is selected. Then specify the allowed domains under `Target domains`.

Default Value:

Allow invitations to be sent to any domain (most inclusive)

References:

1. https://learn.microsoft.com/en-us/entra/external-id/allow-deny-list
2. https://learn.microsoft.com/en-us/entra/external-id/what-is-b2b

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●
v7	13.1 Maintain an Inventory Sensitive Information Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.	●	●	●

5.1.6.2 Ensure that guest user access is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft Entra ID, part of Microsoft Entra, allows you to restrict what external guest users can see in their organization in Microsoft Entra ID. Guest users are set to a limited permission level by default in Microsoft Entra ID, while the default for member users is the full set of user permissions.

These directory level permissions are enforced across Microsoft Entra services including Microsoft Graph, PowerShell v2, the Azure portal, and My Apps portal. Microsoft 365 services leveraging Microsoft 365 groups for collaboration scenarios are also affected, specifically Outlook, Microsoft Teams, and SharePoint. They do not override the SharePoint or Microsoft Teams guest settings.

The recommended state is at least `Guest users have limited access to properties and memberships of directory objects` or more restrictive.

Rationale:

By limiting guest access to the *most restrictive* state this helps prevent malicious group and user object enumeration in the Microsoft 365 environment. This first step, known as *reconnaissance* in The Cyber Kill Chain, is often conducted by attackers prior to more advanced targeted attacks.

Impact:

The default is `Guest users have limited access to properties and memberships of directory objects`.

When using the 'most restrictive' setting, guests will only be able to access their own profiles and will not be allowed to see other users' profiles, groups, or group memberships.

There are some known issues with Yammer that will prevent guests that are signed in from leaving the group.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Guest user access** verify that `Guest user access restrictions` is set to one of the following:
    - `Guest users have limited access to properties and memberships of directory objects`
    - `Guest user access is restricted to properties and memberships of their own directory objects (most restrictive)`

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following command:

```
Get-MgPolicyAuthorizationPolicy | fl GuestUserRoleId
```

3. Verify that the value returned is `10dae51f-b6af-4016-8d66-8c2a99b929b3` or `2af84b1e-32c8-42b7-82bc-daa82404023b` (most restrictive)

Note: Either setting allows for a passing state.

Note 2: The value of `a0b1b346-4d3e-4e8b-98f8-753987be4970` is equal to `Guest users have the same access as members (most inclusive)` and should not be used.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Guest user access** set `Guest user access restrictions` to one of the following:
    - `Guest users have limited access to properties and memberships of directory objects`
    - `Guest user access is restricted to properties and memberships of their own directory objects (most restrictive)`

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"`
2. Run the following command to set the guest user access restrictions to default:

```
# Guest users have limited access to properties and memberships of directory objects
Update-MgPolicyAuthorizationPolicy -GuestUserRoleId '10dae51f-b6af-4016-8d66-8c2a99b929b3'
```

3. Or, run the following command to set it to the "most restrictive":

```
# Guest user access is restricted to properties and memberships of their own directory objects (most restrictive)
Update-MgPolicyAuthorizationPolicy -GuestUserRoleId '2af84b1e-32c8-42b7-82bc-daa82404023b'
```

Note: Either setting allows for a passing state.

Default Value:

- UI: `Guest users have limited access to properties and memberships of directory objects`
- PowerShell: `10dae51f-b6af-4016-8d66-8c2a99b929b3`

References:

1. https://learn.microsoft.com/en-us/entra/identity/users/users-restrict-guest-permissions
2. https://www.lockheedmartin.com/en-us/capabilities/cyber/cyber-kill-chain.html

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.1.6.3 Ensure guest user invitations are limited (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

By default, all users in the organization, including B2B collaboration guest users, can invite external users to B2B collaboration. The ability to send invitations can be limited by turning it on or off for everyone, or by restricting invitations to certain roles.

The recommended state is `Only users assigned to specific admin roles can invite guest users` or `No one in the organization can invite guest users including admins (most restrictive)`.

Rationale:

Restricting who can invite guests limits the exposure the organization might face from unauthorized accounts. The default behavior allows anyone within the organization to invite guests and non-admins to the tenant, posing a security risk.

Impact:

This introduces an obstacle to collaboration by restricting who can invite guest users to the organization. Designated Guest Inviters must be assigned, and an approval process established and clearly communicated to all users.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Guest invite settings** verify that `Guest invite restrictions` is set to one of the following:
    - `Only users assigned to specific admin roles can invite guest users`
    - `No one in the organization can invite guest users including admins (most restrictive)`

To audit using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.Read.All"`
2. Run the following command:

```
Get-MgPolicyAuthorizationPolicy | fl AllowInvitesFrom
```

3. Verify the value returned is `adminsAndGuestInviters` or `none`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `External Identities` and select `External collaboration settings`.
3. Under **Guest invite settings** set `Guest invite restrictions` to one of the desired compliant states:
   - `Only users assigned to specific admin roles can invite guest users`
   - `No one in the organization can invite guest users including admins (most restrictive)`

To remediate using PowerShell:

1. Connect to Microsoft Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.Authorization"`
2. Run one of the following PowerShell commands depending on the desired compliant state:

To set to `Only users assigned to specific admin roles can invite guest users`:

```
Update-MgPolicyAuthorizationPolicy -AllowInvitesFrom 'adminsAndGuestInviters'
```

To set to `No one in the organization can invite guest users including admins (most restrictive)`:

```
Update-MgPolicyAuthorizationPolicy -AllowInvitesFrom "none"
```

Default Value:

- UI: `Anyone in the organization can invite guest users including guests and non-admins (most inclusive)`
- PowerShell: `everyone`

References:

1. https://learn.microsoft.com/en-us/entra/external-id/external-collaboration-settings-configure
2. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference#guest-inviter

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	13.1 Maintain an Inventory Sensitive Information Maintain an inventory of all sensitive information stored, processed, or transmitted by the organization's technology systems, including those located onsite or at a remote service provider.	●	●	●

5.1.7 User experiences

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

5.1.8 Hybrid management

5.1.8.1 Ensure that password hash sync is enabled for hybrid deployments (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Password Hash Synchronization is one of the sign-in methods used to enable hybrid identity authentication. With this method, Microsoft Entra Connect synchronizes a cryptographically derived representation of a user’s on-premises Active Directory password to Microsoft Entra ID.

The original NT password hash (MD4) is never transmitted to Entra ID. Instead, Entra Connect computes a SHA-256 hash of the original MD4 hash and synchronizes that value. Because only this secondary hash is stored in the cloud, the credential material in Entra ID cannot be reused for on-premises pass-the-hash attacks, even if compromised.

Note: The audit and remediation procedures described in this recommendation are applicable only to Microsoft 365 tenants operating in a hybrid identity configuration using Microsoft Entra Connect. They do not apply to federated or cloud-only deployments.

Rationale:

Password hash synchronization helps by reducing the number of passwords your users need to maintain to just one and enables leaked credential detection for your hybrid accounts. Leaked credential protection is leveraged through Entra ID Protection and is a subset of that feature which can help identify if an organization's user account passwords have appeared on the dark web or public spaces.

Using other options for your directory synchronization may be less resilient as Microsoft can still process sign-ins to 365 with Hash Sync even if a network connection to your on-premises environment is not available. This minimizes downtime and ensures business continuity.

Impact:

Compliance or regulatory restrictions may exist, depending on the organization's business sector, that preclude hashed versions of passwords from being securely transmitted to cloud data centers.

Audit:

To audit using the UI:

*Only Global Admin and Hybrid Identity Administrator roles have access to view the actual **Password Hash Sync** status message. Inadequate role access will result in a default message stating: "Unable to retrieve your tenant's password hash sync information."*

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Entra Connect`.
3. Select `Connect Sync`.
4. Under **Microsoft Entra Connect sync**, verify the `Password Hash Sync` status message indicates that synchronization is occurring and no errors are present, with one of the following messages:
    - Password hash synchronization is enabled
    - Password hash synchronization cloud configuration is enabled
    - Password hash synchronization heartbeat detected

To audit using the Microsoft Graph API:

Permission required: `OnPremDirectorySynchronization.Read.All`

1. Execute a `GET` request to the following relative URI:

```
v1.0/directory/onPremisesSynchronization
```

2. Verify that `features.passwordSyncEnabled` is `true`.

To audit for the on-prem tool:

1. Log in to the server that hosts the Microsoft Entra Connect tool.
2. Run `Azure AD Connect`, and then click `Configure` and `View or export current configuration`.
3. Verify that `PASSWORD HASH SYNCHRONIZATION` is enabled on your tenant.

To audit using PowerShell:

1. Open PowerShell on the on-premises server running Microsoft Entra Connect.
2. Run the following cmdlet:

```
Get-ADSyncAADCompanyFeature
```

3. Verify that `PasswordHashSync` is `True`.

Remediation:

To remediate using the on-prem Microsoft Entra Connect tool:

1. Log in to the on premises server that hosts the Microsoft Entra Connect tool
2. Double-click the `Azure AD Connect` icon that was created on the desktop
3. Click `Configure`.
4. On the `Additional tasks` page, select `Customize synchronization options` and click `Next`.
5. Enter the username and password for your global administrator.
6. On the `Connect your directories` screen, click `Next`.
7. On the `Domain and OU filtering` screen, click `Next`.
8. On the `Optional features` screen, check `Password hash synchronization` and click `Next`.
9. On the `Ready to configure` screen click `Configure`.
10. Once the configuration completes, click `Exit`.

Default Value:

- Microsoft Entra Connect sync `disabled` by default
- Password Hash Sync is Microsoft's recommended setting for new deployments

References:

1. https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/whatis-phs
2. https://www.microsoft.com/en-us/download/details.aspx?id=47594
3. https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/how-to-connect-sync-staging-server
4. https://learn.microsoft.com/en-us/entra/identity/hybrid/connect/how-to-connect-password-hash-synchronization
5. https://learn.microsoft.com/en-us/graph/api/resources/onpremisesdirectorysynchronizationfeature?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●
v7	16.4 Encrypt or Hash all Authentication Credentials Encrypt or hash with a salt all authentication credentials when stored.		●	●

5.2 ID Protection

5.2.1 Identity Protection

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

5.2.2 Conditional Access

This section includes the methods used to retrieve Conditional Access policies for automated audit procedures. Policies can be accessed through the Microsoft Graph API or the Microsoft Graph PowerShell SDK, each requiring the appropriate delegated permissions. The items below summarize the available retrieval options.

- Conditional Access policies retrieval is shown using the Microsoft Graph relative URI: `/identity/conditionalAccess/policies`
- The equivalent data can also be retrieved using the Microsoft Graph PowerShell cmdlet: `Get-MgIdentityConditionalAccessPolicy`
- The minimum delegated permission required to access these policies is: `Policy.Read.All`

5.2.2.1 Ensure multifactor authentication is enabled for all users in administrative roles (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Multifactor authentication is a process that requires an additional form of identification during the sign-in process, such as a code from a mobile device or a fingerprint scan, to enhance security.

Ensure users in administrator roles have MFA capabilities enabled.

Rationale:

Multifactor authentication requires an individual to present a minimum of two separate forms of authentication before access is granted. Multifactor authentication provides additional assurance that the individual attempting to gain access is who they claim to be. With multifactor authentication, an attacker would need to compromise at least two different authentication mechanisms, increasing the difficulty of compromise and thus reducing the risk.

Note: To ensure that accounts cannot be easily used to enumerate resources (reconnaissance) through Microsoft Admin Portals or through Microsoft Azure Service Management API, both MFA conditional access policies must target All

Resources:

- "Ensure multifactor authentication is enabled for all users" and
- "Ensure multifactor authentication is enabled for all users in administrative roles" (this recommendation)

Impact:

Implementation of multifactor authentication for all users in administrative roles will necessitate a change to user routine. All users in administrative roles will be required to enroll in multifactor authentication using phone, SMS, or an authentication application. After enrollment, use of multifactor authentication will be required for future access to the environment.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `Directory roles` specific to administrators are included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected with no exclusions.
    - Under `Grant` verify `Grant Access` is on and either `Require multifactor authentication` or `Require authentication strength` is checked.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeRoles` contains the directory roles specific to administrators*
    - `Conditions.Applications.IncludeApplications` is `All`
    - `GrantControls.BuiltInControls` contains `mfa` **OR** `GrantControls.AuthenticationStrength.id` is defined
    - `State` is `enabled`
3. Compliance is met when at least one policy is found to meet all the criteria listed above.
4. Verify that any exclusions are documented and reviewed annually.

Note: The Authentication Strength requirement is satisfied when any valid GUID is present in the `authenticationStrength` property of a matching policy. Because Authentication Strength configurations are inherently stronger than the built-in Require multifactor authentication control, the presence of a valid Authentication Strength also fulfills the MFA requirement for all users.

Note: A list of `Directory roles` can be found in the Remediation section.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Click `New policy`.
    - Under `Users or agents (Preview)` include `Select users and groups` and check `Directory roles`.
    - At a minimum, include the directory roles listed below in this section of the document.
    - Under `Target resources` include `All resources (formerly 'All cloud apps')` and do not create any exclusions.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Grant` select `Grant Access` and check either `Require multifactor authentication` or `Require authentication strength`.
    - Click `Select` at the bottom of the pane.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

At minimum these directory roles should be included for MFA:

- Application administrator
- Authentication administrator
- Billing administrator
- Cloud application administrator
- Conditional Access administrator
- Exchange administrator
- Global administrator
- Global reader
- Helpdesk administrator
- Password administrator
- Privileged authentication administrator
- Privileged role administrator
- Security administrator
- SharePoint administrator
- User administrator

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/howto-conditional-access-policy-admin-mfa
2. https://learn.microsoft.com/en-us/graph/api/conditionalaccessroot-list-policies?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.5 Require MFA for Administrative Access Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.	●	●	●
v7	16.3 Require Multi-factor Authentication Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.		●	●

5.2.2.2 Ensure multifactor authentication is enabled for all users (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Enable multifactor authentication for all users in the Microsoft 365 tenant. Users will be prompted to authenticate with a second factor upon logging in to Microsoft 365 services. The second factor is most commonly a text message to a registered mobile phone number where they type in an authorization code, or with a mobile application like Microsoft Authenticator.

Note: Since 2024, Microsoft has been rolling out mandatory multifactor authentication.

Rationale:

Multifactor authentication requires an individual to present a minimum of two separate forms of authentication before access is granted. Multifactor authentication provides additional assurance that the individual attempting to gain access is who they claim to be. With multifactor authentication, an attacker would need to compromise at least two different authentication mechanisms, increasing the difficulty of compromise and thus reducing the risk.

Note: To ensure that accounts cannot be easily used to enumerate resources (reconnaissance) through Microsoft Admin Portals or through Microsoft Azure Service Management API, both MFA conditional access policies must target All

Resources:

- "Ensure multifactor authentication is enabled for all users in administrative roles" and
- "Ensure multifactor authentication is enabled for all users" (this recommendation)

Impact:

Implementation of multifactor authentication for all users will necessitate a change to user routine. All users will be required to enroll in multifactor authentication using phone, SMS, or an authentication application. After enrollment, use of multifactor authentication will be required for future authentication to the environment.

External identities that attempt to access documents that utilize Purview Information Protection (Sensitivity Labels) will find their access disrupted. In order to mitigate this create an exclusion for `Microsoft Rights Management Services` ID: 00000012-0000-0000-c000-000000000000

Note: Organizations that struggle to enforce MFA globally due to budget constraints preventing the provision of company-owned mobile devices to every user, or due to regulations, unions, or policies that prevent forcing end users to use their personal devices, have another option. FIDO2 security keys can be used as an alternative. They are more secure, phishing-resistant, and affordable for organizations to issue to every end user.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected with no exclusions.
    - Under `Grant` verify `Grant Access` and either `Require multifactor authentication` or `Require authentication strength` is checked.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. For each policy returned, verify the following criteria:
   - `Conditions.Users.IncludeUsers` is `All`
   - `Conditions.Applications.IncludeApplications` is `All`
   - `GrantControls.BuiltInControls` contains `mfa` **OR** `GrantControls.AuthenticationStrength.id` is defined
   - `State` is `enabled`
3. Compliance is met when at least one policy is found to meet all the criteria listed above.
4. Verify that any exclusions are documented and reviewed annually.

Note: The Authentication Strength requirement is satisfied when any valid GUID is present in the `authenticationStrength` property of a matching policy. Because Authentication Strength configurations are inherently stronger than the built-in Require multifactor authentication control, the presence of a valid Authentication Strength also fulfills the MFA requirement for all users.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Click `New policy`.
   - Under `Users or agents (Preview)` include `All users`.
   - Under `Target resources` include `All resources (formerly 'All cloud apps')` and do not create any exclusions.
     - Under `Exclude` exclude any break-glass accounts.
   - Under `Grant` select `Grant Access` and check either `Require multifactor authentication` or `Require authentication strength`.
   - Click `Select` at the bottom of the pane.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default. It may be present as a Microsoft-managed policy or created from a Conditional Access template.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/howto-conditional-access-policy-all-users-mfa
2. https://learn.microsoft.com/en-us/graph/api/conditionalaccessroot-list-policies?view=graph-rest-1.0
3. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-mandatory-multifactor-authentication

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●
v7	16.3 Require Multi-factor Authentication Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.		●	●

5.2.2.3 Enable Conditional Access policies to block legacy authentication (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Entra ID supports the most widely used authentication and authorization protocols including legacy authentication. This authentication pattern includes basic authentication, a widely used industry-standard method for collecting username and password information.

The following messaging protocols support legacy authentication:

- Authenticated SMTP - Used to send authenticated email messages.
- Autodiscover - Used by Outlook and EAS clients to find and connect to mailboxes in Exchange Online.
- Exchange ActiveSync (EAS) - Used to connect to mailboxes in Exchange Online.
- Exchange Online PowerShell - Used to connect to Exchange Online with remote PowerShell. If you block Basic authentication for Exchange Online PowerShell, you need to use the Exchange Online PowerShell Module to connect. For instructions, see Connect to Exchange Online PowerShell using multifactor authentication.
- Exchange Web Services (EWS) - A programming interface that's used by Outlook, Outlook for Mac, and third-party apps.
- IMAP4 - Used by IMAP email clients.
- MAPI over HTTP (MAPI/HTTP) - Primary mailbox access protocol used by Outlook 2010 SP2 and later.
- Offline Address Book (OAB) - A copy of address list collections that are downloaded and used by Outlook.
- Outlook Anywhere (RPC over HTTP) - Legacy mailbox access protocol supported by all current Outlook versions.
- POP3 - Used by POP email clients.
- Reporting Web Services - Used to retrieve report data in Exchange Online.
- Universal Outlook - Used by the Mail and Calendar app for Windows 10.
- Other clients - Other protocols identified as utilizing legacy authentication.

Rationale:

Legacy authentication protocols do not support multi-factor authentication. These protocols are often used by attackers because of this deficiency. Blocking legacy authentication makes it harder for attackers to gain access.

Note: Basic authentication is now disabled in all tenants. Before December 31 2022, you could re-enable the affected protocols if users and apps in your tenant couldn't connect. Now no one (you or Microsoft support) can re-enable Basic authentication in your tenant.

Impact:

Enabling this setting will block legacy authentication, preventing access from older versions of Microsoft Office, Exchange ActiveSync, and protocols such as IMAP, POP, and SMTP. As a result, some users may need to upgrade to newer Office versions or use email clients that support modern authentication.

This change may also affect multifunction devices (MFPs), such as printers using legacy authentication for scan-to-email. Microsoft provides mail flow best practices (linked below) to configure MFPs without relying on legacy authentication.

https://learn.microsoft.com/en-us/exchange/mail-flow-best-practices/how-to-set-up-a-multifunction-device-or-application-to-send-email-using-microsoft-365-or-office-365

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected.
    - Verify that only documented resource exclusions exist and that they are reviewed annually.
    - Under `Conditions` select `Client apps` then verify `Exchange ActiveSync clients` and `Other clients` is checked.
    - Under `Grant` verify `Block access` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.ClientAppTypes` contains `exchangeActiveSync` **OR** `other`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `Conditions.ClientAppTypes` contains `exchangeActiveSync`
    - `Conditions.ClientAppTypes` contains `other`
    - `GrantControls.BuiltInControls` is `block`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` include `All resources (formerly 'All cloud apps')`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Conditions` select `Client apps` and check the boxes for `Exchange ActiveSync clients` and `Other clients`.
    - Under `Grant` select `Block Access`.
    - Click `Select`.
4. Set the policy `On` and click `Create`.

Default Value:

Basic authentication is disabled by default as of January 2023.

References:

1. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/disable-basic-authentication-in-exchange-online
2. https://learn.microsoft.com/en-us/exchange/mail-flow-best-practices/how-to-set-up-a-multifunction-device-or-application-to-send-email-using-microsoft-365-or-office-365
3. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/deprecation-of-basic-authentication-exchange-online

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	9.2 Ensure Only Approved Ports, Protocols and Services Are Running Ensure that only network ports, protocols, and services listening on a system with validated business needs, are running on each system.		●	●

5.2.2.4 Ensure Sign-in frequency is enabled and browser sessions are not persistent for Administrative users (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

In complex deployments, organizations might have a need to restrict authentication sessions. Conditional Access policies allow for the targeting of specific user accounts. Some scenarios might include:

- Resource access from an unmanaged or shared device
- Access to sensitive information from an external network
- High-privileged users
- Business-critical applications

Note: This CA policy can be added to the previous CA policy in this benchmark "Ensure multifactor authentication is enabled for all users in administrative roles"

Rationale:

Forcing a time out for MFA will help ensure that sessions are not kept alive for an indefinite period of time, ensuring that browser sessions are not persistent will help in prevention of drive-by attacks in web browsers, this also prevents creation and saving of session cookies leaving nothing for an attacker to take.

Impact:

Users with Administrative roles will be prompted at the frequency set for MFA.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `Directory roles` specific to administrators are included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected.
    - Verify that only documented resource exclusions exist and that they are reviewed annually.
    - Under `Session` verify `Sign-in frequency` is checked and set to `Periodic reauthentication`.
    - Verify the timeframe is set to the time determined by the organization.
    - Verify that `Periodic reauthentication` does not exceed `4 hours` (or less).
    - Verify that `Persistent browser session` is set to `Never persistent`.
4. Verify that `Enable policy` is set to `On`

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `SessionControls.PersistentBrowser.IsEnabled` is `true`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeRoles` contains the directory roles specific to administrators*
    - `Conditions.Applications.IncludeApplications` is `All`
    - `SessionControls.SignInFrequency.IsEnabled` is `true`
    - `SessionControls.SignInFrequency.FrequencyInterval` is `everyTime` **OR** is `timeBased` **AND** does not exceed `4 hours`.
    - `SessionControls.PersistentBrowser.IsEnabled` is `true`
    - `SessionControls.PersistentBrowser.Mode` is `never`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Note: A list of directory roles applying to Administrators can be found in the remediation section.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Click `New policy`.
    - Under `Users or agents (Preview)` include `Select users and groups` and check `Directory roles`.
    - At a minimum, include the directory roles listed below in this section of the document.
    - Under `Target resources` include `All resources (formerly 'All cloud apps')`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Grant` select `Grant Access` and check `Require multifactor authentication`.
    - Under `Session` select `Sign-in frequency` select `Periodic reauthentication` and set it to `4 hours` (or less).
    - Check `Persistent browser session` then select `Never persistent` in the drop-down menu.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

At minimum these directory roles should be included in the policy:

- Application administrator
- Authentication administrator
- Billing administrator
- Cloud application administrator
- Conditional Access administrator
- Exchange administrator
- Global administrator
- Global reader
- Helpdesk administrator
- Password administrator
- Privileged authentication administrator
- Privileged role administrator
- Security administrator
- SharePoint administrator
- User administrator

Default Value:

The default configuration for user sign-in frequency is a rolling window of 90 days.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/howto-conditional-access-session-lifetime

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●

5.2.2.5 Ensure 'Phishing-resistant MFA strength' is required for Administrators (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Authentication strength is a Conditional Access control that allows administrators to specify which combination of authentication methods can be used to access a resource. For example, they can make only phishing-resistant authentication methods available to access a sensitive resource. But to access a non-sensitive resource, they can allow less secure multifactor authentication (MFA) combinations, such as password + SMS.

Microsoft has 3 built-in authentication strengths. MFA strength, Passwordless MFA strength, and Phishing-resistant MFA strength. Ensure administrator roles are using a CA policy with `Phishing-resistant MFA strength`.

Administrators can then enroll using one of 3 methods:

- FIDO2 Security Key
- Windows Hello for Business
- Certificate-based authentication (Multi-Factor)

Note: Additional steps to configure methods such as FIDO2 keys are not covered here but can be found in related MS articles in the references section. The Conditional Access policy only ensures 1 of the 3 methods is used.

Warning: Administrators should be pre-registered for a strong authentication mechanism before this Conditional Access Policy is enforced. Additionally, as stated elsewhere in the CIS Benchmark a break-glass administrator account should be excluded from this policy to ensure unfettered access in the case of an emergency.

Rationale:

Sophisticated attacks targeting MFA are more prevalent as the use of it becomes more widespread. These 3 methods are considered phishing-resistant as they remove passwords from the login workflow. It also ensures that public/private key exchange can only happen between the devices and a registered provider which prevents login to fake or phishing websites.

Impact:

If administrators aren't pre-registered for a strong authentication method prior to a conditional access policy being created, then a condition could occur where a user can't register for strong authentication because they don't meet the conditional access policy requirements and therefore are prevented from signing in.

Additionally, Internet Explorer based credential prompts in PowerShell do not support prompting for a security key. Implementing phishing-resistant MFA with a security key may prevent admins from running their existing sets of PowerShell scripts. Device Authorization Grant Flow can be used as a workaround in some instances.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `Directory roles` specific to administrators are included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Directory Roles should include at minimum the roles listed in the remediation section.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected with no exclusions.
    - Under `Grant` verify `Grant Access` is selected and `Require authentication strength` is checked with `Phishing-resistant MFA` set as the value.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `GrantControls.AuthenticationStrength.Id` contains any valid id.
3. For each policy returned, verify the following criteria:
   - `Conditions.Users.IncludeRoles` contains the directory roles specific to administrators*
   - `Conditions.Applications.IncludeApplications` is `All`
   - `GrantControls.AuthenticationStrength.AllowedCombinations` *only* contains `windowsHelloForBusiness` **OR** `fido2` **OR** `x509CertificateMultiFactor`
   - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Click `New policy`.
   - Under `Users or agents (Preview)` include `Select users and groups` and check `Directory roles`.
   - At a minimum, include the directory roles listed below in this section of the document.
   - Under `Target resources` include `All resources (formerly 'All cloud apps')` and do not create any exclusions other than break-glass accounts.
   - Under `Grant` select `Grant Access` and check `Require authentication strength` and set `Phishing-resistant MFA` in the dropdown box.
   - Click `Select`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Warning: Ensure administrators are pre-registered with strong authentication before enforcing the policy. After which the policy must be set to `On`.

At minimum these directory roles should be included for the policy:

- Application administrator
- Authentication administrator
- Billing administrator
- Cloud application administrator
- Conditional Access administrator
- Exchange administrator
- Global administrator
- Global reader
- Helpdesk administrator
- Password administrator
- Privileged authentication administrator
- Privileged role administrator
- Security administrator
- SharePoint administrator
- User administrator

Default Value:

This policy does not exist by default. It can be created from a Conditional Access template.

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-passwordless#fido2-security-keys
2. https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-enable-passkey-fido2
3. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-strengths
4. https://learn.microsoft.com/en-us/entra/id-protection/howto-identity-protection-configure-mfa-policy

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.5 Require MFA for Administrative Access Require MFA for all administrative access accounts, where supported, on all enterprise assets, whether managed on-site or through a third-party provider.	●	●	●

5.2.2.6 Enable Identity Protection user risk policies (Automated)

Profile Applicability:

- E5 Level 1

Description:

Microsoft Entra ID Protection user risk policies detect the probability that a user account has been compromised.

Note: While Identity Protection also provides two risk policies with limited conditions, Microsoft highly recommends setting up risk-based policies in Conditional Access as opposed to the "legacy method" for the following benefits:

- Enhanced diagnostic data
- Report-only mode integration
- Graph API support
- Use more Conditional Access attributes like sign-in frequency in the policy

Rationale:

With the user risk policy turned on, Entra ID protection detects the probability that a user account has been compromised. Administrators can configure a user risk conditional access policy to automatically respond to a specific user risk level.

Impact:

Upon policy activation, account access will be either blocked or the user will be required to use multi-factor authentication (MFA) and change their password. Users without registered MFA will be denied access, necessitating an admin to recover the account. To avoid inconvenience, it is advised to configure the MFA registration policy for all users under the User Risk policy.

Additionally, users identified in the Risky Users section will be affected by this policy. To gain a better understanding of the impact on the organization's environment, the list of Risky Users should be reviewed before enforcing the policy.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected.
    - Under `Conditions` verify `User risk` is set to `High`.
    - Under `Grant` verify `Grant access` is selected and either `Require multifactor authentication` or `Require authentication strength` are checked. Then verify `Require password change` is checked.
    - Under `Session` ensure `Sign-in frequency` is set to `Every time`.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.UserRiskLevels` contains any string.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `Conditions.UserRiskLevels` contains `high`
    - `GrantControls.BuiltInControls` contains `passwordChange`
    - `GrantControls.BuiltInControls` contains `mfa` **OR** `GrantControls.AuthenticationStrength.id` is any id
    - `SessionControls.SignInFrequency.IsEnabled` is `true`
    - `SessionControls.SignInFrequency.FrequencyInterval` is `everyTime`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Note: If the `UserRiskLevels` array includes `medium` or `low`, this still qualifies as compliant, as these enforcement levels are considered more strict. However, it must always include `high`; omitting this level would exclude users who are classified as high risk.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` choose `All users`
    - Under `Target resources` choose `All resources (formerly 'All cloud apps')`
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Conditions` choose `User risk` then `Yes` and select the user risk level `High`.
    - Under `Grant` select `Grant access` then check `Require multifactor authentication` or `Require authentication strength`. Finally check `Require password change`.
    - Under `Session` set `Sign-in frequency` to `Every time`.
    - Click `Select`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default. It may be created from a Conditional Access template.

References:

1. https://learn.microsoft.com/en-us/entra/id-protection/howto-identity-protection-risk-feedback
2. https://learn.microsoft.com/en-us/entra/id-protection/concept-identity-protection-risks

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 Conduct Audit Log Reviews Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			●

5.2.2.7 Enable Identity Protection sign-in risk policies (Automated)

Profile Applicability:

- E5 Level 1

Description:

Microsoft Entra ID Protection sign-in risk detects risks in real-time and offline. A risky sign-in is an indicator for a sign-in attempt that might not have been performed by the legitimate owner of a user account.

Note: While Identity Protection also provides two risk policies with limited conditions, Microsoft highly recommends setting up risk-based policies in Conditional Access as opposed to the "legacy method" for the following benefits:

- Enhanced diagnostic data
- Report-only mode integration
- Graph API support
- Use more Conditional Access attributes like sign-in frequency in the policy

Rationale:

Turning on the sign-in risk policy ensures that suspicious sign-ins are challenged for multi-factor authentication.

Impact:

When the policy triggers, the user will need MFA to access the account. In the case of a user who hasn't registered MFA on their account, they would be blocked from accessing their account. It is therefore recommended that the MFA registration policy be configured for all users who are a part of the Sign-in Risk policy.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected.
    - Under `Conditions` verify `Sign-in risk` is set to `Yes` ensuring `High` and `Medium` are selected.
    - Under `Grant` verify grant `Grant access` is selected and `Require multifactor authentication` checked.
    - Under `Session` verify `Sign-in Frequency` is set to `Every time`.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.SignInRiskLevels` contains any string.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `Conditions.SignInRiskLevels` contains `high`
    - `Conditions.SignInRiskLevels` contains `medium`
    - `GrantControls.BuiltInControls` contains `mfa` **OR** `GrantControls.AuthenticationStrength.id` is any id
    - `SessionControls.SignInFrequency.IsEnabled` is `true`
    - `SessionControls.SignInFrequency.FrequencyInterval` is `everyTime`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Note: If the `SignInRiskLevels` array includes `low`, this still qualifies as compliant, as these enforcement levels are considered more strict. However, it must always include `high` and `medium`; omitting these levels would exclude users who are classified as such.

Note 2: If `GrantControls.BuiltInControls` is `block` then the *Grant* and *Session* controls are considered satisfied, as this is considered a more strict enforcement of sign-in risk control.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` choose `All users`.
    - Under `Target resources` choose `All resources (formerly 'All cloud apps')`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Conditions` choose `Sign-in risk` then `Yes` and check the risk level boxes `High` and `Medium`.
    - Under `Grant` click `Grant access` then select `Require multifactor authentication`.
    - Under `Session` select `Sign-in Frequency` and set to `Every time`.
    - Click `Select`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default. It may be created from a Conditional Access template.

References:

1. https://learn.microsoft.com/en-us/entra/id-protection/howto-identity-protection-risk-feedback
2. https://learn.microsoft.com/en-us/entra/id-protection/concept-identity-protection-risks

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●
v8	8.11 Conduct Audit Log Reviews Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●
v7	16.13 Alert on Account Login Behavior Deviation Alert when users deviate from normal login behavior, such as time-of-day, workstation location and duration.			●

5.2.2.8 Ensure 'sign-in risk' is blocked for medium and high risk (Automated)

Profile Applicability:

- E5 Level 2

Description:

Microsoft Entra ID Protection sign-in risk detects risks in real-time and offline. A risky sign-in is an indicator for a sign-in attempt that might not have been performed by the legitimate owner of a user account.

Note: While Identity Protection also provides two risk policies with limited conditions, Microsoft highly recommends setting up risk-based policies in Conditional Access as opposed to the "legacy method" for the following benefits:

- Enhanced diagnostic data
- Report-only mode integration
- Graph API support
- Use more Conditional Access attributes like sign-in frequency in the policy

Rationale:

Sign-in risk is determined at the time of sign-in and includes criteria across both real-time and offline detections for risk. Blocking sign-in to accounts that have risk can prevent undesired access from potentially compromised devices or unauthorized users.

Impact:

Sign-in risk is heavily dependent on detecting risk based on atypical behaviors. Due to this it is important to run this policy in a report-only mode to better understand how the organization's environment and user activity may influence sign-in risk before turning the policy on. Once it's understood what actions may trigger a medium or high sign-in risk event I.T. can then work to create an environment to reduce false positives. For example, employees might be required to notify security personnel when they intend to travel with intent to access work resources.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected with no exclusions.
    - Under `Conditions` verify `Sign-in risk` values of `High` and `Medium` are selected.
    - Under `Grant` verify `Block access` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.SignInRiskLevels` contains any string.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `Conditions.Applications.ExcludeApplications` is null or empty
    - `Conditions.SignInRiskLevels` contains `high`
    - `Conditions.SignInRiskLevels` contains `medium`
    - `GrantControls.BuiltInControls` is `block`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Note: If the `SignInRiskLevels` array includes `low`, this still qualifies as compliant, as these enforcement levels are considered more strict. However, it must always include `high` and `medium`; omitting these levels would exclude users who are classified as such.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` include `All resources (formerly 'All cloud apps')` and do not set any exclusions.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Conditions` choose `Sign-in risk` values of `High` and `Medium` and click `Done`.
    - Under `Grant` choose `Block access` and click `Select`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/id-protection/concept-identity-protection-risks#risk-detections-mapped-to-riskeventtype

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.11 Conduct Audit Log Reviews Conduct reviews of audit logs to detect anomalies or abnormal events that could indicate a potential threat. Conduct reviews on a weekly, or more frequent, basis.		●	●

5.2.2.9 Ensure a managed device is required for authentication (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Conditional Access (CA) can be configured to enforce access based on the device's compliance status or whether it is Entra hybrid joined. Collectively this allows CA to classify devices as managed or unmanaged, providing more granular control over authentication policies.

When using `Require device to be marked as compliant`, the device must pass checks configured in compliance policies defined within Microsoft Intune. Before these checks can be applied, the device must first be enrolled in Intune MDM.

By selecting `Require Microsoft Entra hybrid joined device` this means the device must first be synchronized from an on-premises Active Directory to qualify for authentication. When configured to the recommended state below only one condition needs to be met for the user to authenticate from the device. This functions as an "OR" operator.

The recommended state for authentication is:

- `Require device to be marked as compliant`
- `Require Microsoft Entra hybrid joined device` (optional for hybrid environments)
- `Require one of the selected controls`

Rationale:

"Managed" devices are considered more secure because they often have additional configuration hardening enforced through centralized management such as Intune or Group Policy. These devices are also typically equipped with MDR/EDR, managed patching and alerting systems. As a result, they provide a safer environment for users to authenticate and operate from.

This policy also ensures that attackers must first gain access to a compliant or trusted device before authentication is permitted, reducing the risk posed by compromised account credentials. When combined with other distinct Conditional Access (CA) policies, such as requiring multi-factor authentication, this adds one additional factor before authentication is permitted.

Note: Avoid combining these two settings with other `Grant` settings in the same policy. In a single policy you can only choose between `Require all the selected controls` or `Require one of the selected controls`, which limits the ability to integrate this recommendation with others in this benchmark. CA policies function as an "AND" operator across multiple policies. The goal here is to both (Require MFA for all users) **AND** (Require device to be marked as compliant **OR** Require Microsoft Entra hybrid joined device).

Impact:

Unmanaged devices will not be permitted as a valid authenticator. As a result this may require the organization to mature their device enrollment and management. The following devices can be considered managed:

- Entra hybrid joined from Active Directory
- Entra joined and enrolled in Intune, with compliance policies
- Entra registered and enrolled in Intune, with compliance policies

If `Guest or external users` are collaborating with the organization, they must either be excluded or onboarded with a compliant device to authenticate. Failure to adequately survey the environment and test the Conditional Access (CA) policy in the `Report-only` state could result in access disruptions for these guest users.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected.
    - Verify that only documented resource exclusions exist and that they are reviewed annually.
    - Under `Grant` verify that `Require device to be marked as compliant` is checked.
    - Under `Grant` verify that no other controls are checked except, optionally, `Require Microsoft Entra hybrid joined device`.
    - Verify `Require one of the selected controls` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `GrantControls.BuiltInControls` contains `compliantDevice` or `domainJoinedDevice`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `GrantControls.BuiltInControls` contains `compliantDevice`
    - `GrantControls.BuiltInControls` does not contain any values other than `compliantDevice` and `domainJoinedDevice`
    - `GrantControls.Operator` is `OR`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access and select Policies.
3. Create a new policy by selecting New policy.
    - Under Users or agents (Preview) include All users.
    - Under Target resources include All resources (formerly 'All cloud apps').
        - Under Exclude exclude any break-glass accounts.
    - Under Grant select Grant access.
    - Select the checkbox Require device to be marked as compliant.
    - Optionally, also select Require Microsoft Entra hybrid joined device if the organization uses hybrid joined devices.
    - Choose Require one of the selected controls.
    - Click Select at the bottom.
4. Under Enable policy set it to Report-only.
5. Click Create.
6. After allowing the policy to run in Report-only mode for at least one week, review the Sign-in logs for any unexpected impact, then return to the policy and set Enable policy to On.

Note: Guest user accounts, if collaborating with the organization, should be considered when testing this policy.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-grant#require-device-to-be-marked-as-compliant
2. https://learn.microsoft.com/en-us/entra/identity/devices/concept-hybrid-join
3. https://learn.microsoft.com/en-us/mem/intune/fundamentals/deployment-guide-enrollment

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.		●	●

5.2.2.10 Ensure a managed device is required to register security information (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Conditional Access (CA) can be configured to enforce access based on the device's compliance status or whether it is Entra hybrid joined. Collectively, this allows CA to classify devices as managed or unmanaged, providing more granular control over whether a user can register security information from a device.

When using `Require device to be marked as compliant`, the device must pass checks configured in compliance policies defined within Microsoft Intune. Before these checks can be applied, the device must first be enrolled in Intune MDM.

By selecting `Require Microsoft Entra hybrid joined device` this means the device must first be synchronized from an on-premises Active Directory to qualify. When configured to the recommended state below only one condition needs to be met for the user to authenticate from the device. This functions as an "OR" operator.

The recommended state for registering security information is:

- `Require device to be marked as compliant`
- `Require Microsoft Entra hybrid joined device` (optional for hybrid environments)
- `Require one of the selected controls`

Rationale:

Requiring registration on a managed device significantly reduces the risk of bad actors using stolen credentials to register security information. Accounts that are created but never registered with an MFA method are particularly vulnerable to this type of attack. Enforcing this requirement will both reduce the attack surface for fake registrations and ensure that legitimate users register using trusted devices which typically have additional security measures in place already.

Impact:

The organization will be required to have a mature device management process. New devices provided to users will need to be pre-enrolled in Intune, auto-enrolled, or be Entra hybrid joined. Otherwise, the user will be unable to complete registration, requiring additional resources from I.T. This could be more disruptive in remote worker environments where the MDM maturity is low.

Users who do not yet have access to a managed device, such as new hires, users with lost or replaced devices, or users registering MFA methods on personal mobile devices — will be unable to satisfy the device compliance grant control. To address this, organizations should configure a Temporary Access Pass (TAP) policy and issue a one-time TAP to these users. A one-time TAP satisfies multifactor authentication requirements and allows the user to register security information from any device or location.

B2B collaboration users (guest accounts) will also be blocked by this policy, as their devices are not managed in the resource tenant. Organizations should consider excluding `All guest and external users` from this policy. Alternatively, organizations that trust partner device compliance claims can configure this through cross-tenant access settings.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `User actions` is selected with `Register security information` checked.
    - Under `Grant` verify that `Require device to be marked as compliant` is checked.
    - Under `Grant` verify that no other controls are checked except, optionally, `Require Microsoft Entra hybrid joined device`.
    - Verify `Require one of the selected controls` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.Applications.IncludeUserActions` contains `urn:user:registersecurityinfo`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeUserActions` is `urn:user:registersecurityinfo`
    - `GrantControls.BuiltInControls` contains `compliantDevice`
    - `GrantControls.BuiltInControls` does not contain any values other than `compliantDevice` and `domainJoinedDevice`
    - `GrantControls.Operator` is `OR`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` select `User actions` and check `Register security information`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Grant` select `Grant access`.
    - Select the checkbox `Require device to be marked as compliant`.
    - Optionally, also select `Require Microsoft Entra hybrid joined device` if the organization uses hybrid joined devices.
    - Choose `Require one of the selected controls`.
    - Click `Select` at the bottom.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-grant#require-device-to-be-marked-as-compliant
2. https://learn.microsoft.com/en-us/entra/identity/devices/concept-hybrid-join
3. https://learn.microsoft.com/en-us/mem/intune/fundamentals/deployment-guide-enrollment
4. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-cloud-apps#user-actions
5. https://docs.azure.cn/en-us/entra/identity/authentication/concept-authentication-strength-how-it-works#how-multiple-authentication-strength-policies-are-evaluated-for-registering-security-info

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.		●	●

5.2.2.11 Ensure sign-in frequency for Intune Enrollment is set to 'Every time' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Sign-in frequency defines the time period before a user is asked to sign in again when attempting to access a resource. The Microsoft Entra ID default configuration for user sign-in frequency is a rolling window of 90 days.

The recommended state is a `Sign-in frequency` of `Every time` for `Microsoft Intune Enrollment`

Note: Microsoft accounts for a five-minute clock skew when 'every time' is selected in a conditional access policy, ensuring that users are not prompted more frequently than once every five minutes.

Rationale:

Intune Enrollment is considered a sensitive action and should be safeguarded. An attack path exists that allows for a bypass of device compliance Conditional Access rule. This could allow compromised credentials to be used through a newly registered device enrolled in Intune, enabling persistence and privilege escalation.

Setting sign-in frequency to every time limits the timespan an attacker could use fresh credentials to enroll a new device to Intune.

Impact:

New users enrolling into Intune through an automated process may need to sign-in again if the enrollment process goes on for too long.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `Resources (formerly cloud apps)` includes `Microsoft Intune Enrollment`.
    - Under `Grant` verify `Require multifactor authentication` or `Require authentication strength` is checked.
    - Under `Session` verify `Sign-in frequency` is set to `Every time`.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

Note: The Authentication Strength requirement is satisfied when any valid GUID is present in the `authenticationStrength` property of a matching policy. Because Authentication Strength configurations are inherently stronger than the built-in Require multifactor authentication control, the presence of a valid Authentication Strength also fulfills the MFA requirement for all users.

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.Applications.IncludeApplications` contains `d4ebce55-015a-49b5-a083-c84d1797ae8c`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` contains `d4ebce55-015a-49b5-a083-c84d1797ae8c`
    - `GrantControls.BuiltInControls` contains `mfa` **OR** `GrantControls.AuthenticationStrength.id` is defined
    - `SessionControls.SignInFrequency.IsEnabled` is `true`
    - `SessionControls.SignInFrequency.FrequencyInterval` is `everyTime`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

Note: If the Microsoft Intune Enrollment cloud app isn't available then it must be created. To add the app for new tenants, a Microsoft Entra administrator must create a service principal object, with app ID `d4ebce55-015a-49b5-a083-c84d1797ae8c`, in PowerShell or Microsoft Graph.

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` select `Resources (formerly cloud apps)`, choose `Select resources` and add `Microsoft Intune Enrollment` to the list.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Grant` select `Grant access`.
    - Check either `Require multifactor authentication` or `Require authentication strength`.
    - Under `Session` check `Sign-in frequency` and select `Every time`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default. Sign-in frequency defaults to 90 days.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-session-lifetime#require-reauthentication-every-time
2. https://www.blackhat.com/eu-24/briefings/schedule/#unveiling-the-power-of-intune-leveraging-intune-for-breaking-into-your-cloud-and-on-premise-42176
3. https://www.glueckkanja.com/blog/security/2025/01/compliant-device-bypass-en/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.2.12 Ensure the device code sign-in flow is blocked (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The Microsoft identity platform supports the device authorization grant, which allows users to sign in to input-constrained devices such as a smart TV, IoT device, or a printer. To enable this flow, the device has the user visit a webpage in a browser on another device to sign in. Once the user signs in, the device is able to get access tokens and refresh tokens as needed.

The recommended state is to `Block access` for `Device code flow` in Conditional Access.

Rationale:

Since August 2024, Microsoft has observed threat actors, such as Storm-2372, employing "device code phishing" attacks. These attacks deceive users into logging into productivity applications, capturing authentication tokens to gain further access to compromised accounts.

To mitigate this specific attack, block authentication code flows and permit only those from devices within trusted environments, identified by specific IP addresses.

Impact:

Some administrative overhead will be required for stricter management of these devices. Since exclusions do not violate compliance, this feature can still be utilized effectively within a controlled environment.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `Resources (formerly cloud apps)` includes `All resources (formerly 'All cloud apps')`
    - Under `Conditions` > `Authentication flows` verify `Configure` is set to `Yes` and `Device code flow` is checked.
    - Under `Grant` verify `Block access` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `Conditions.AuthenticationFlows.TransferMethods` contains `deviceCodeFlow`.
3. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `Conditions.AuthenticationFlows.TransferMethods` contains `deviceCodeFlow`
    - `GrantControls.BuiltInControls` is `block`
    - `State` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` > `Resources (formerly cloud apps)` include `All resources (formerly 'All cloud apps')`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Conditions` > `Authentication flows` set `Configure` to `Yes` and check `Device code flow`.
    - Click `Save`.
    - Under `Grant` select `Block access` and click `Select`.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On

Default Value:

This policy does not exist by default. It may be present as a Microsoft-managed policy.

References:

1. https://learn.microsoft.com/en-us/entra/identity-platform/v2-oauth2-device-code
2. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-flows
3. https://www.microsoft.com/en-us/security/blog/2025/02/13/storm-2372-conducts-device-code-phishing-campaign/
4. https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-block-authentication-flows#device-code-flow-policies

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

5.2.2.13 Ensure that periodic reauthentication is required for all users (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Sign-in frequency defines the time period before a user is asked to sign in again when attempting to access a resource. The Microsoft Entra ID default configuration for user sign-in frequency is a rolling window of 90 days.

The recommended state for all users is to enforce `periodic reauthentication` for `7 days` or less.

Rationale:

A 7-day interval balances security and user experience by reducing the maximum lifespan of compromised credentials or stolen tokens without introducing excessive reauthentication prompts that can increase phishing susceptibility and user fatigue.

Impact:

Most users will not find weekly reauthentication requirements disruptive. Organizations with legacy applications, custom authentication workflows, or users relying on long-running sessions (such as shared or kiosk devices) may need to evaluate compatibility and apply appropriate exclusions to prevent user disruption.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria and is set to `On`:
    - Under `Users or agents (Preview)` verify `All users` is included.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `Resources (formerly cloud apps)` includes `All resources (formerly 'All cloud apps')`
    - Under `Session` ensure `Sign-in frequency` is checked, and `Periodic reauthentication` is set to `7 days` or less.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `SessionControls.SignInFrequency.IsEnabled` is `true`
3. Filter out policies where `Conditions.signInRiskLevels` and `Conditions.userRiskLevels` have values defined, excluding these from the assessment.
4. For each policy returned, verify the following criteria:
    - `Conditions.Users.IncludeUsers` is `All`
    - `Conditions.Applications.IncludeApplications` is `All`
    - `SessionControls.SignInFrequency.frequencyInterval` is `timeBased`
    - `SessionControls.SignInFrequency.type` is `days`*
    - `SessionControls.SignInFrequency.value` is `7` (or less)*
    - `State` is `enabled`
5. Compliance is met when at least one policy is found to meet all the criteria listed above.
6. Verify that any exclusions are documented and reviewed annually.

Note: Any `SignInFrequency` type and value combination is considered compliant as long as the reauthentication interval is **less than or equal to 7 days**. For example, a policy applied to all users that requires reauthentication every 20 hours would still meet the requirement.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Create a new policy by selecting `New policy`.
    - Under `Users or agents (Preview)` include `All users`.
    - Under `Target resources` verify `Resources (formerly cloud apps)` include `All resources (formerly 'All cloud apps')`.
        - Under `Exclude` exclude any break-glass accounts.
    - Under `Session` select `Sign-in frequency` and set `Periodic reauthentication` to `7 days` or less.
4. Under `Enable policy` set it to `Report-only`.
5. Click `Create`.
6. After allowing the policy to run in `Report-only` mode for at least one week, review the `Sign-in logs` for any unexpected impact, then return to the policy and set `Enable policy` to `On`.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/howto-conditional-access-session-lifetime

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.3 Configure Automatic Session Locking on Enterprise Assets Configure automatic session locking on enterprise assets after a defined period of inactivity. For general purpose operating systems, the period must not exceed 15 minutes. For mobile end-user devices, the period must not exceed 2 minutes.	●	●	●

5.2.2.14 Ensure trusted 'named locations' are defined (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Microsoft Entra ID Conditional Access allows an organization to configure Named locations and configure whether those locations are trusted or untrusted. These settings provide organizations the means to specify Geographical locations for use in conditional access policies, or define actual IP addresses and IP ranges and whether or not those IP addresses and/or ranges are trusted by the organization.

The recommended state is to define at least one trusted, IP range `named location`.

Rationale:

Defining trusted source IP addresses or ranges enables organizations to better tailor and enforce Conditional Access policies based on whether authentication attempts originate from trusted or untrusted network locations. Users signing in from trusted IP ranges can be granted reduced access requirements or fewer authentication prompts, while users coming from untrusted or unknown locations may face stricter controls.

Additionally, marking named locations as trusted improves the accuracy of Microsoft Entra ID Protection's risk evaluations. When a user authenticates from a trusted location, their sign-in risk is appropriately lowered, helping reduce false positives and ensuring that risk-based policies trigger only when truly necessary.

Impact:

Configuring named locations by country cannot designate those locations as trusted, which means Conditional Access policies cannot use the "All trusted locations" option and must instead rely on explicitly selecting locations. This increases the administrative effort needed to configure and maintain these policies and requires more thorough testing to prevent unintended authentication blocks. Because Conditional Access policies can fully prevent users from signing in to Entra ID if misconfigured, organizations should maintain a dedicated break-glass Global Administrator account that is excluded from all Conditional Access policies and secured with a strong passphrase and hardware-based authentication. This account exists solely to recover access if all other administrators are locked out.

Audit:

To audit using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access and select Policies.
3. Under Manage, click Named locations.
4. For each named location with a **Location type** of IP ranges, verify there is one with the following criteria:
    - Trusted is set to Yes.
    - At least one IP Range is defined
5. Compliance is met when at least one named location is found to meet all the criteria listed above.

To audit using the Microsoft Graph API:

1. Execute a GET request to the following relative URI:

```
v1.0/identity/conditionalAccess/namedLocations?$filter=isof('microsoft.graph.
ipNamedLocation')
```

2. For each named location returned, verify the following criteria:
    - isTrusted is true
    - ipRanges contains at least one ipv4 or ipv6 range
3. Compliance is met when at least one named location is found to meet all the criteria listed above.

Remediation:

To remediate using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access and select Policies.
3. Under Manage, click Named locations.
4. Click on IP ranges location to add a new location.
5. Enter a name for this location setting in the Name field.
6. Click on the + icon.
7. Add only a **trusted** IP Address Range in CIDR notation inside the text box that appears.
8. Click on the Add button.
9. Repeat steps 6 through 8 for each additional IP range.
10. Select the Mark as trusted location checkbox.
11. Once finished, click on Create.

Note: There is no single prescribed method for applying a named location to a Conditional Access policy, as the correct configuration depends on the specific access control requirements. Implementers should have a clear understanding of how named locations function before applying them to production policies.

Default Value:

Named locations are not configured by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-assignment-network
2. https://learn.microsoft.com/en-us/entra/id-protection/concept-risk-detection-types#locations
3. https://learn.microsoft.com/en-us/graph/api/resources/conditionalaccesspolicy?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●
v8	12.2 Establish and Maintain a Secure Network Architecture Establish and maintain a secure network architecture. A secure network architecture must address segmentation, least privilege, and availability, at a minimum.		●	●
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.		●	●

5.2.2.15 Ensure exclusionary geographic access controls are utilized (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Conditional Access Policies can be used to block access from geographic locations that are deemed out-of-scope for your organization or application. The scope and variables for this policy should be carefully examined and defined.

The recommended state is to configure at least one policy to `block access` from untrusted locations.

Rationale:

Using Conditional Access as a deny list at the tenant or subscription level enables an organization to block inbound and outbound traffic from geographic locations that fall outside its operational scope (e.g., customers, suppliers) or legal jurisdiction. Restricting access to only required regions significantly reduces unnecessary exposure to international threat actors, including advanced persistent threats (APTs), and helps maintain a more controlled and defensible security posture.

Note: Because the selection of allowed or blocked locations is unique to each organization, this control does not prescribe specific countries or regions. Each organization should determine its geographic access requirements based on operational needs, regulatory obligations, and risk tolerance.

Impact:

Limiting access geographically will deny access to users that are traveling or working remotely in a different part of the world. A point-to-site or site to site tunnel such as a VPN is recommended to address exceptions to geographic access policies.

CAUTION: If these policies are created without first auditing and testing the result, misconfiguration can potentially lock out administrators or create undesired access issues.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria:
    - Under `Users or agents (Preview)` verify `All users` is included
    - Verify that only documented user exclusions exist and that they are reviewed annually
    - Under `Target resources` verify `All resources (formerly 'All cloud apps')` is selected
    - Under `Network` verify `Include`> `Selected networks and locations` contains at least one **untrusted** location
    - Under `Network` verify `Exclude` contains **trusted** locations through either `All trusted networks and locations` or `Selected networks and locations`
    - Under `Grant` verify `Block access` is selected
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. For each policy returned, verify the following criteria:
    - `conditions.users.includeUsers` is `All`
    - `conditions.applications.includeApplications` is `All`
    - `conditions.locations.includeLocations` contains at least one GUID of at least one **untrusted** location.
    - `conditions.locations.excludeLocations` is `AllTrusted` **OR** contains at least one GUID of at least one **trusted** location.
    - `grantControls.builtInControls` is `block`
    - `state` is `enabled`
3. Compliance is met when at least one policy is found to meet all the criteria listed above.
4. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access and select Policies.
3. Create a new policy by selecting New policy.
    - Under Users or agents (Preview) include All users
    - Under Target resources include All resources (formerly 'All cloud apps').
        - Under Exclude exclude any break-glass accounts.
    - Under Network set Configure to Yes:
        - Select Include, then add entries for untrusted locations that should be **blocked**
        - Select Exclude, then add entries for trusted locations that should be **allowed**
4. Under Access Controls, select Grant select Block Access.
5. Under Enable policy set it to Report-only.
6. Click Create.
7. After allowing the policy to run in Report-only mode for at least one week, review the Sign-in logs for any unexpected impact, then return to the policy and set Enable policy to On.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-block-by-location
2. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-conditional-access-report-only

Additional Information:

These policies should be tested by using the What If tool in the References. Setting these can and will create issues with logging in for users until they use an MFA device linked to their accounts. Further testing can also be done via the insights and reporting resource in References which monitors Azure sign ins.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●
v7	12.1 Maintain an Inventory of Network Boundaries Maintain an up-to-date inventory of all of the organization's network boundaries.	●	●	●

5.2.2.16 Ensure Token Protection is enforced for session tokens (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Token Protection is a Conditional Access session control that attempts to reduce token replay attacks by ensuring only device bound sign-in session tokens, like Primary Refresh Tokens (PRTs), are accepted by Microsoft Entra ID when applications request access to protected resources.

When a user registers a supported device with Microsoft Entra, a PRT is issued and cryptographically bound to that device. This binding ensures that even if a threat actor steals the token, it can't be used from another device. With Token Protection enforced, Microsoft Entra validates that only these bound sign-in session tokens are used by supported applications.

The recommended state is to enforce Token Protection for `Office 365 Exchange Online`, `Office 365 SharePoint Online` and `Microsoft Teams Services`.

Rationale:

When properly configured, Conditional Access can aid in preventing attacks involving token theft, via hijacking or replay, as part of the attack flow. Although currently considered a rare event, the impact from token impersonation can be severe.

Impact:

Token Protection currently supports native applications only. Browser-based applications are not supported. There are also many other known limitations documented in the link below:

https://learn.microsoft.com/en-us/entra/identity/conditional-access/deployment-guide-token-protection-windows#known-limitations

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access` and select `Policies`.
3. Verify that a policy exists with the following criteria:
    - Under `Users or agents (Preview)` verify that **None** is *not* selected.
    - Verify that only documented exclusions exist and that they are reviewed annually
    - Under `Target resources` select `Select resources` and verify at minimum the following are checked:
        - `Office 365 Exchange Online`
        - `Office 365 SharePoint Online`
        - `Microsoft Teams Services`
4. Under `Conditions` > `Device Platforms`: verify that `Configure` is set to `Yes` and `Include` indicates `Windows` platforms.
5. Under `Conditions` > `Client Apps`: verify that `Configure` is set to `Yes` and only `Mobile Apps and Desktop Clients` is selected.
6. Under `Access controls` > `Session`, verify that `Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS)` is selected.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `sessionControls.secureSignInSession.isEnabled` is `true`.
3. For each policy returned, verify the following criteria:
    - `conditions.users.includeUsers` is **not** `None`
    - `conditions.applications.includeApplications` contains at least the following GUIDs:
        - `00000002-0000-0ff1-ce00-000000000000` (Office 365 Exchange Online)
        - `00000003-0000-0ff1-ce00-000000000000` (Office 365 SharePoint Online)
        - `cc15fd57-2c6c-4117-a88c-83b1d56b4bbe` (Microsoft Teams Services)
    - `conditions.platforms.includePlatforms` contains `windows`
    - `conditions.clientAppTypes` is `mobileAppsAndDesktopClients`
    - `sessionControls.secureSignInSession.isEnabled` is `true`

    - State is enabled
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access and select Policies.
3. Select New policy.
4. Select Users or agents (Preview):
    1. Under Include, select the users or groups to apply this policy.
    2. Under Exclude exclude any break-glass accounts.
5. Select Target resources > Resources > Include > Select resources
    1. Under Select specific resources, select the following applications:
        1. Office 365 Exchange Online
        2. Office 365 SharePoint Online
        3. Microsoft Teams Services
    2. Choose Select
6. Select Conditions:
    1. Under Device platforms
        1. Set Configure to Yes.
        2. Include > Select device platforms > Windows.
        3. Select Done.
    2. Under Client apps:
        1. Set Configure to Yes
        2. Under Modern authentication clients, only select Mobile apps and desktop clients.
        3. Select Done
7. Under Access controls > Session, select Require token protection for sign-in sessions (Generally available for Windows. Preview for MacOS, iOS) and click Select.
8. Under Enable policy set it to Report-only.
9. Click Create.
10. After allowing the policy to run in Report-only mode for at least one week, review the Sign-in logs for any unexpected impact, then return to the policy and set Enable policy to On.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-token-protection
2. https://learn.microsoft.com/en-us/entra/identity/conditional-access/deployment-guide-token-protection-windows
3. https://learn.microsoft.com/en-us/entra/identity/devices/protecting-tokens-microsoft-entra-id

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.2.2.17 Ensure authentication transfer is blocked (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Authentication transfer is a flow that lets users seamlessly transfer authenticated state from one device to another. For example, users might see a QR code in the desktop version of Outlook that, when scanned on their mobile device, transfers their authenticated state to the mobile device.

The recommended state is to block `Authentication transfer`.

Rationale:

Blocking authentication transfer helps protect against token theft and replay attacks by preventing the use of device tokens to silently authenticate on other devices or browsers. When authentication transfer is enabled, a threat actor who gains access to one device can access resources to unapproved devices, bypassing standard authentication and device compliance checks. When administrators block this flow, organizations can ensure that each authentication request must originate from the original device, maintaining the integrity of the device compliance and user session context.

Impact:

Users will no longer be able to use authentication transfer to sign into mobile versions of Microsoft apps (e.g., scanning a QR code in Outlook desktop to sign into Outlook mobile). Each device will require independent, interactive sign-in subject to applicable Conditional Access policies.

Audit:

Note: Break-glass accounts should be excluded from all Conditional Access policies.

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Conditional Access`.
3. Verify that a policy exists with the following criteria:
    - Under `Users or agents (Preview)` verify `All users` is selected.
    - Verify that only documented user exclusions exist and that they are reviewed annually.
    - Under `Target resources` verify `Resources (formerly cloud apps)` includes `All resources (formerly 'All cloud apps')`
    - Under `Conditions` > `Authentication flows` verify `Configure` is set to `Yes` and `Authentication transfer` is checked.
    - Under `Grant` verify `Block access` is selected.
4. Verify that `Enable policy` is set to `On`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identity/conditionalAccess/policies
```

2. Filter to policies where `conditions.authenticationFlows.transferMethods` contains `authenticationTransfer`.
3. For each policy returned, verify the following criteria:
    - `conditions.users.includeUsers` is `All`
    - `conditions.applications.includeApplications` is `All`
    - `conditions.authenticationFlows.transferMethods` contains `authenticationTransfer`
    - `grantControls.builtInControls` is `block`
    - `state` is `enabled`
4. Compliance is met when at least one policy is found to meet all the criteria listed above.
5. Verify that any exclusions are documented and reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the Microsoft Entra admin center https://entra.microsoft.com.
2. Expand Entra ID > Conditional Access.
3. Create a new policy by selecting New policy.
    - Under Users or agents (Preview) include All users.
    - Under Target resources > Resources (formerly cloud apps) include All resources (formerly 'All cloud apps').
        - Under Exclude exclude any break-glass accounts.
    - Under Conditions > Authentication flows set Configure to Yes and check Authentication transfer.
        - Click Save.
    - Under Grant select Block access and click Select.
4. Under Enable policy set it to Report-only until the organization is ready to enable it.
5. Click Create.
6. After allowing the policy to run in Report-only mode for at least one week, review the Sign-in logs for any unexpected impact, then return to the policy and set Enable policy to On.

Default Value:

This policy does not exist by default.

References:

1. https://learn.microsoft.com/en-us/entra/identity/conditional-access/policy-block-authentication-flows#authentication-transfer-policies
2. https://learn.microsoft.com/en-us/entra/fundamentals/zero-trust-protect-identities#authentication-transfer-is-blocked
3. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-flows
4. https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-authentication-transfer

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v8	13.5 Manage Access Control for Remote Assets Manage access control for assets remotely connecting to enterprise resources. Determine amount of access to enterprise resources based on: up-to-date anti-malware software installed, configuration compliance with the enterprise's secure configuration process, and ensuring the operating system and applications are up-to-date.		●	●

5.2.3 Authentication Methods

5.2.3.1 Ensure Microsoft Authenticator is configured to protect against MFA fatigue (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft provides supporting settings to enhance the configuration of the Microsoft Authenticator application. These settings provide users with additional information and context when they receive MFA passwordless and push requests, including the geographic location of the request, the requesting application, and a requirement for number matching.

The recommended state is `Enabled` for the following:

- `Show application name in push and passwordless notifications`
- `Show geographic location in push and passwordless notifications`

Note: On February 27, 2023 Microsoft started enforcing number matching tenant-wide for all users using Microsoft Authenticator.

Rationale:

As the use of strong authentication has become more widespread, attackers have started to exploit the tendency of users to experience "MFA fatigue." This occurs when users are repeatedly asked to provide additional forms of identification, leading them to eventually approve requests without fully verifying the source. To counteract this, number matching can be employed to ensure the security of the authentication process. With this method, users are prompted to confirm a number displayed on their original device and enter it into the device being used for MFA. Additionally, other information such as geolocation and application details are displayed to enhance the end user's awareness. Among these 3 options, number matching provides the strongest net security gain.

Impact:

Additional interaction will be required by end users using number matching as opposed to simply pressing "Approve" for login attempts.

Audit:

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Authentication methods` and select `Policies`.
3. Under **Method** select `Microsoft Authenticator`.
4. Under `Enable and Target` verify the setting is set to `Enable`.
5. In the `Include` tab verify that `All users` is selected.
6. In the `Exclude` tab verify only valid groups are present (i.e. Break Glass accounts).
7. Select `Configure`
8. Verify the following Microsoft Authenticator settings:
    - `Show application name in push and passwordless notifications` Status is set to `Enabled`, Target `All users`
    - `Show geographic location in push and passwordless notifications` Status is set to `Enabled`, Target `All users`
9. In each setting select `Exclude` and verify only valid groups are present (i.e. Break Glass accounts).

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/policies/authenticationMethodsPolicy/authenticationMethodConfigurations/
microsoftAuthenticator
```

2. Verify that the `state` is `enabled`.
3. Verify that `includeTargets.id` is `all_users`.
4. Verify that the `excludeTargets` only includes valid groups (i.e. Break Glass accounts).
5. Under `featureSettings` verify the following settings:
    - `displayAppInformationRequiredState.state` is `enabled`
    - `displayAppInformationRequiredState.includeTarget.id` is `all_users`
    - `displayLocationInformationRequiredState.state` is `enabled`
    - `displayLocationInformationRequiredState.includeTarget.id` is `all_users`
6. In each setting `excludeTarget` only includes a valid group (i.e. Break Glass accounts) or a target `id` of `00000000-0000-0000-0000-000000000000`

Note: Compliance cannot be easily validated for exclusions so adding these to a report for human manual review is recommended. These should be reviewed annually.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Click to expand `Entra ID` > `Authentication methods` and select `Policies`.
3. Select `Microsoft Authenticator`
4. Under `Enable and Target` ensure the setting is set to `Enable`.
5. Select `Configure`
6. Set the following Microsoft Authenticator settings:
    - `Show application name in push and passwordless notifications` Status is set to `Enabled`, Target `All users`
    - `Show geographic location in push and passwordless notifications` Status is set to `Enabled`, Target `All users`

Note: Valid groups such as break glass accounts can be excluded per organization policy.

Default Value:

Microsoft-managed

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-default-enablement
2. https://techcommunity.microsoft.com/t5/microsoft-entra-blog/defend-your-users-from-mfa-fatigue-attacks/ba-p/2365677
3. https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-mfa-number-match
4. https://learn.microsoft.com/en-us/graph/api/authenticationmethodspolicy-get?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.3.2 Ensure custom banned passwords lists are used (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

With Entra Password Protection, default global banned password lists are automatically applied to all users in an Entra ID tenant. To support business and security needs, custom banned password lists can be defined. When users change or reset their passwords, these banned password lists are checked to enforce the use of strong passwords.

A custom banned password list should include some of the following examples:

- Brand names
- Product names
- Locations, such as company headquarters
- Company-specific internal terms
- Abbreviations that have specific company meaning

Rationale:

Creating a new password can be difficult regardless of one's technical background. It is common to look around one's environment for suggestions when building a password, however, this may include picking words specific to the organization as inspiration for a password. An adversary may employ what is called a 'mangler' to create permutations of these specific words in an attempt to crack passwords or hashes making it easier to reach their goal.

Impact:

If a custom banned password list includes too many common dictionary words, or short words that are part of compound words, then perfectly secure passwords may be blocked. The organization should consider a balance between security and usability when creating a list.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/
2. Expand Entra ID > Authentication methods and select Password protection.
3. Verify that Enforce custom list is set to Yes
4. Verify that Custom banned password list contains entries specific to the organization or matches a pre-determined list.

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Directory.Read.All"
2. Run the following commands:

```
$PwRuleSettings = '5cf42378-d67d-4f36-ba46-e8b86229381d'
Get-MgGroupSetting | Where-Object TemplateId -eq $PwRuleSettings |
    Select-Object -ExpandProperty Values
```

3. Verify that EnableBannedPasswordCheck is True and BannedPasswordList is populated.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/
2. Expand Entra ID > Authentication methods and select Password protection.
3. Set Enforce custom list to Yes
4. In Custom banned password list create a list using suggestions outlined in this document.
5. Click Save

Note: Below is a list of examples that can be used as a starting place. The references section contains more suggestions.

- Brand names
- Product names
- Locations, such as company headquarters
- Company-specific internal terms
- Abbreviations that have specific company meaning

Default Value:

By default the custom banned password list is not 'Enabled'.

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-password-ban-bad#custom-banned-password-list
2. https://learn.microsoft.com/en-us/entra/identity/authentication/tutorial-configure-custom-password-protection
3. https://www.microsoft.com/en-us/research/publication/password-guidance/
4. https://learn.microsoft.com/en-us/security/benchmark/azure/mcsb-identity-management#im-6-use-strong-authentication-controls

Additional Information:

Organization-specific terms can be added to the custom banned password list, such as the following examples:

- Brand names
- Product names
- Locations, such as company headquarters
- Company-specific terms
- Abbreviations that have specific company meaning
- Months and weekdays with your company's local languages

The default global banned password list is already applied to your resources which applies the following basic requirements:

Characters allowed:

- Uppercase characters (A - Z)
- Lowercase characters (a - z)
- Numbers (0 - 9)
- Symbols:
- @ # $ % ^ & * - _ ! + = [ ] { } | \ : ' , . ? / ` ~ " ( ) ; < >
- blank space

Characters not allowed:

- Unicode characters

Password length:

Passwords require:

- A minimum of eight characters
- A maximum of 256 characters

Password complexity:

Passwords require three out of four of the following categories:

- Uppercase characters
- Lowercase characters
- Numbers
- Symbols

Note: Password complexity check isn't required for Education tenants.

Password not recently used:

- When a user changes or resets their password, the new password can't be the same as the current or recently used passwords.
- Password isn't banned by Entra ID Password Protection.
- The password can't be on the global list of banned passwords for Azure AD Password Protection, or on the customizable list of banned passwords specific to your organization.

Evaluation

New passwords are evaluated for strength and complexity by validating against the combined list of terms from the global and custom banned password lists. Even if a user's password contains a banned password, the password may be accepted if the overall password is otherwise strong enough.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.2.3.3 Ensure password protection is enabled for on-prem Active Directory (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft Entra Password Protection provides a global and custom banned password list. A password change request fails if there's a match in these banned password list. To protect on-premises Active Directory Domain Services (AD DS) environment, install and configure Entra Password Protection.

Note: This recommendation applies to Hybrid deployments only and will have no impact unless working with on-premises Active Directory.

Rationale:

This feature protects an organization by prohibiting the use of weak or leaked passwords. In addition, organizations can create custom banned password lists to prevent their users from using easily guessed passwords that are specific to their industry. Deploying this feature to Active Directory will strengthen the passwords that are used in the environment.

Impact:

The potential impact associated with implementation of this setting is dependent upon the existing password policies in place in the environment. For environments that have strong password policies in place, the impact will be minimal. For organizations that do not have strong password policies in place, implementation of Microsoft Entra Password Protection may require users to change passwords and adhere to more stringent requirements than they have been accustomed to.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Authentication methods and select Password protection.
3. Verify that Enable password protection on Windows Server Active Directory is set to Yes and that Mode is set to Enforced.

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Directory.Read.All"
2. Run the following command:

```
(Get-MgGroupSetting | ? { $_.TemplateId -eq '5cf42378-d67d-4f36-ba46-e8b86229381d' }).Values
```

3. Verify that EnableBannedPasswordCheckOnPremises is set to True and BannedPasswordCheckOnPremisesMode is set to Enforce.

Remediation:

To remediate using the UI:

- Download and install the Azure AD Password Proxies and DC Agents from the following location: https://www.microsoft.com/download/details.aspx?id=57071 After installed follow the steps below.

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Authentication methods and select Password protection.
3. Set Enable password protection on Windows Server Active Directory to Yes and Mode to Enforced.

Default Value:

Enable - Yes

Mode - Audit

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-password-ban-bad-on-premises-operations

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.2 Use Unique Passwords Use unique passwords for all enterprise assets. Best practice implementation includes, at a minimum, an 8-character password for accounts using MFA and a 14-character password for accounts not using MFA.	●	●	●
v7	4.4 Use Unique Passwords Where multi-factor authentication is not supported (such as local administrator, root, or service accounts), accounts will use passwords that are unique to that system.		●	●

5.2.3.4 Ensure all member users are 'MFA capable' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft defines Multifactor authentication capable as being registered and enabled for a strong authentication method. The method must also be allowed by the authentication methods policy.

Ensure all member users are `MFA capable`.

Rationale:

Multifactor authentication requires an individual to present a minimum of two separate forms of authentication before access is granted.

Users who are not `MFA Capable` have never registered a strong authentication method for multifactor authentication that is within policy and may not be using MFA. This could be a result of having never signed in, exclusion from a Conditional Access (CA) policy requiring MFA, or a CA policy does not exist. Reviewing this list of users will help identify possible lapses in policy or procedure.

Impact:

When using the UI audit method guest users will appear in the report and unless the organization is applying MFA rules to guests then they will need to be manually filtered. Accounts that provide on-premises directory synchronization also appear in these reports.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `User registration details`.
3. Set the filter option `Multifactor authentication capable` to `Not Capable`.
4. Review the non-guest users in this list.
5. Excluding any exceptions users found in this report may require remediation.

To audit using PowerShell:

1. Connect to Graph using `Connect-MgGraph -Scopes "UserAuthenticationMethod.Read.All,AuditLog.Read.All"`
2. Run the following:

```
Get-MgReportAuthenticationMethodUserRegistrationDetail `
    -Filter "IsMfaCapable eq false and UserType eq 'Member'" |
        ft UserPrincipalName,IsMfaCapable,IsAdmin
```

3. Verify that `IsMfaCapable` is set to `True`.
4. Excluding any exceptions users found in this report may require remediation.

Note: The CA rule must be in place for a successful deployment of Multifactor Authentication. This policy is outlined in the conditional access section 5.2.2

Note 2: Possible exceptions include on-premises synchronization accounts.

Remediation:

Remediation steps will depend on the status of the personnel in question or configuration of Conditional Access policies and will not be covered in detail. Administrators should review each user identified on a case-by-case basis using the conditions below.

User has never signed on:

- Employment status should be reviewed, and appropriate action taken on the user account's roles, licensing and enablement.

Conditional Access policy applicability:

- Ensure a CA policy is in place requiring all users to use MFA.
- Ensure the user is not excluded from the CA MFA policy.
- Ensure the policy's state is set to `On`.
- Use `What if` to determine applicable CA policies. (Protection > Conditional Access > Policies)
- Review the user account in `Sign-in logs`. Under the `Activity Details` pane click the `Conditional Access` tab to view applied policies.

Note: Conditional Access is covered step by step in section 5.2.2

References:

1. https://learn.microsoft.com/en-us/powershell/module/microsoft.graph.reports/update-mgreportauthenticationmethoduserregistrationdetail?view=graph-powershell-1.0#-ismfacapable
2. https://learn.microsoft.com/en-us/entra/identity/monitoring-health/how-to-view-applied-conditional-access-policies
3. https://learn.microsoft.com/en-us/entra/identity/conditional-access/what-if-tool
4. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-authentication-methods-activity

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●
v7	16.3 Require Multi-factor Authentication Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.		●	●

5.2.3.5 Ensure weak authentication methods are disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Authentication methods support a wide variety of scenarios for signing in to Microsoft 365 resources. Some of these methods are inherently more secure than others but require more investment in time to get users enrolled and operational.

SMS and Voice Call rely on telephony carrier communication methods to deliver the authenticating factor.

The recommended state is to `Disable` these methods:

- SMS
- Voice Call

Rationale:

Traditional MFA methods such as SMS codes, email-based OTPs, and push notifications are becoming less effective against today's attackers. Sophisticated phishing campaigns have demonstrated that second factors can be intercepted or spoofed. Attackers now exploit social engineering, man-in-the-middle tactics, and user fatigue (e.g., MFA bombing) to bypass these mechanisms. These risks are amplified in distributed, cloud-first organizations with hybrid workforces and varied device ecosystems.

The SMS and Voice call methods are vulnerable to SIM swapping which could allow an attacker to gain access to your Microsoft 365 account.

Impact:

There may be increased administrative overhead in adopting more secure authentication methods depending on the maturity of the organization.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Authentication methods and select Policies.
3. Verify that the following methods in the Enabled column are set to No.
    - Method: SMS
    - Method: Voice call

To audit using Powershell:

1. Connect to Graph using Connect-MgGraph -Scopes "Policy.Read.All"
2. Run the following:

```
(Get-MgPolicyAuthenticationMethodPolicy).AuthenticationMethodConfigurations
```

3. Verify that Sms and Voice are disabled.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Policies`.
3. Inspect each method that is out of compliance and remediate:
    - Click on the method to open it.
    - Change the `Enable` toggle to the off position.
    - Click `Save`.

Note: If the save button remains greyed out after toggling a method off, then first turn it back on and then change the position of the `Target` selection (all users or select groups). Turn the method off again and save. This was observed to be a bug in the UI at the time this document was published.

To remediate using Powershell:

1. Connect to Graph using `Connect-MgGraph -Scopes "Policy.ReadWrite.AuthenticationMethod"`
2. Run the following to disable both authentication methods:

```
$params = @(
        @{ Id = "Sms"; State = "disabled" },
        @{ Id = "Voice"; State = "disabled" }
)

Update-MgPolicyAuthenticationMethodPolicy -AuthenticationMethodConfigurations
$params
```

Default Value:

- SMS : Disabled
- Voice Call : Disabled

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-methods-manage
2. https://learn.microsoft.com/en-us/security/zero-trust/sfi/phishing-resistant-mfa#context-and-problem
3. https://www.microsoft.com/en-us/microsoft-365-life-hacks/privacy-and-safety/what-is-sim-swapping

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.3.6 Ensure system-preferred multifactor authentication is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

System-preferred multifactor authentication (MFA) prompts users to sign in by using the most secure method they registered.

The user is prompted to sign-in with the most secure method according to the below order. The order of authentication methods is dynamic. It's updated by Microsoft as the security landscape changes, and as better authentication methods emerge.

1. Temporary Access Pass
2. Passkey (FIDO2)
3. Microsoft Authenticator notifications
4. External authentication methods
5. Time-based one-time password (TOTP)
6. Telephony
7. Certificate-based authentication

The recommended state is `Enabled`.

Rationale:

Regardless of the authentication method enabled by an administrator or set as preferred by the user, the system will dynamically select the most secure option available at the time of authentication. This approach acts as an additional safeguard to prevent the use of weaker methods, such as voice calls, SMS, and email OTPs, which may have been inadvertently left enabled due to misconfiguration or lack of configuration hardening.

Enforcing the default behavior also ensures the feature is not disabled.

Impact:

The Microsoft managed value of system-preferred MFA is Enabled and as such enforces the default behavior. No additional impact is expected.

Note: Due to known issues with certificate-based authentication (CBA) and system-preferred MFA, Microsoft moved CBA to the bottom of the list. It is still considered a strong authentication method.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Settings`.
3. Verify the **System-preferred multifactor authentication** `State` is set to `Enabled` and `All users` are included.
4. Verify that only documented exclusions exist and that they are reviewed annually

To audit using PowerShell:

1. Connect to Microsoft Graph using Connect-MgGraph -Scopes "Policy.Read.AuthenticationMethod"
2. Run the following commands:

```
$Uri =
'https://graph.microsoft.com/beta/policies/authenticationMethodsPolicy'
(Invoke-MgGraphRequest -Method GET -Uri $Uri).systemCredentialPreferences
```

3. Verify that `includeTargets` is set to `all_users` and `state` is set to `enabled`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Settings`.
3. Set the **System-preferred multifactor authentication** `State` to `Enabled` and include `All users`.
4. Any users exclusions should be documented and reviewed annually.

Default Value:

Microsoft Managed (Enabled)

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-system-preferred-multifactor-authentication
2. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-system-preferred-multifactor-authentication#how-does-system-preferred-mfa-determine-the-most-secure-method

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.3.7 Ensure the email OTP authentication method is disabled (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Authentication methods support a wide variety of scenarios for signing in to Microsoft 365 resources. Some of these methods are inherently more secure than others but require more investment in time to get users enrolled and operational.

The email one-time passcode feature is a way to authenticate B2B collaboration users when they can't be authenticated through other means, such as Microsoft Entra ID, Microsoft account (MSA), or social identity providers. When a B2B guest user tries to redeem your invitation or sign in to your shared resources, they can request a temporary passcode, which is sent to their email address. Then they enter this passcode to continue signing in.

The recommended state is to `Disable` email OTP.

Rationale:

Traditional MFA methods such as SMS codes, email-based OTPs, and push notifications are becoming less effective against today’s attackers. Sophisticated phishing campaigns have demonstrated that second factors can be intercepted or spoofed. Attackers now exploit social engineering, man-in-the-middle tactics, and user fatigue (e.g., MFA bombing) to bypass these mechanisms. These risks are amplified in distributed, cloud-first organizations with hybrid workforces and varied device ecosystems.

Impact:

Disabling Email OTP will prevent one-time pass codes from being sent to unverified guest users accessing Microsoft 365 resources on the tenant such as "@yahoo.com". They will be required to use a personal Microsoft account, a managed Microsoft Entra account, be part of a federation or be configured as a guest in the host tenant's Microsoft Entra ID.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Authentication methods and select Policies.
3. Verify that Email OTP is set to No in the Enabled column.

To audit using Powershell:

1. Connect to Graph using Connect-MgGraph -Scopes "Policy.Read.All"
2. Run the following:

```
(Get-MgPolicyAuthenticationMethodPolicy).AuthenticationMethodConfigurations
```

3. Verify the id type Email is set to disabled.

Remediation:

To remediate using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/.
2. Expand Entra ID > Authentication methods and select Policies.
3. Click on Email OTP.
4. Change the Enable toggle to the off position\
5. Click Save.

Note: If the save button remains greyed out after toggling a method off, then first turn it back on and then change the position of the Target selection (all users or select groups). Turn the method off again and save. This was observed to be a bug in the UI at the time this document was published.

To remediate using Powershell:

1. Connect to Graph using Connect-MgGraph -Scopes "Policy.ReadWrite.AuthenticationMethod"
2. Run the following:

```
$params = @(
        @{ Id = "Email"; State = "disabled" }
)

Update-MgPolicyAuthenticationMethodPolicy -AuthenticationMethodConfigurations
$params
```

Default Value:

- Email OTP : Enabled

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-methods-manage
2. https://learn.microsoft.com/en-us/entra/external-id/one-time-passcode
3. https://learn.microsoft.com/en-us/security/zero-trust/sfi/phishing-resistant-mfa#context-and-problem

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.3.8 Ensure that Account 'Lockout threshold' is '10' or less (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The account lockout threshold determines how many failed login attempts are permitted prior to placing the account in a locked-out state and initiating a variable lockout duration.

The recommended `Lockout threshold` is `10` or less.

Rationale:

Account lockout is a method of protecting against brute-force and password spray attacks. Once the lockout threshold has been exceeded, the account enters a locked-out state which prevents all login attempts for a variable duration. The lockout in combination with a reasonable duration reduces the total number of failed login attempts that a malicious actor can execute in a given period of time.

Impact:

If account lockout threshold is set too low (less than 3), users may experience frequent lockout events and the resulting security alerts may contribute to alert fatigue.

If account lockout threshold is set too high (more than 10), malicious actors can programmatically execute more password attempts in a given period of time.

In hybrid environments using pass-through authentication (PTA), the Microsoft Entra lockout threshold must be set lower than the AD DS account lockout threshold. If the AD DS threshold is equal to or lower than the Entra threshold, AD DS will lock the account before Entra smart lockout activates, bypassing the cloud-side protection and resulting in on-premises account lockouts that require manual administrator intervention to clear. Microsoft recommends configuring the AD DS lockout threshold to be at least two to three times greater than the Entra lockout threshold.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Password protection`.
3. Verify that `Lockout threshold` is set to `10` or less.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/groupSettings
```

2. Filter to **Password Rule settings**, where `templateId` is `5cf42378-d67d-4f36-ba46-e8b86229381d`
3. Verify that `LockoutThreshold` is `10` or less.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Password protection`.
3. Set `Lockout threshold` to `10` or less.

Note: In hybrid environments using pass-through authentication (PTA), Microsoft recommends to configure the AD DS account lockout threshold to be at least two to three times greater than the value set here to ensure Entra smart lockout activates before AD DS lockout.

Default Value:

By default, Lockout threshold is set to `10`.

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-password-smart-lockout#manage-microsoft-entra-smart-lockout-values
2. https://learn.microsoft.com/en-us/graph/api/group-list-settings?view=graph-rest-1.0

Additional Information:

NOTE: The variable number for failed login attempts allowed before lockout is prescribed by many security and compliance frameworks. The **appropriate** setting for this variable should be determined by the most restrictive security or compliance framework that your organization follows.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.2.3.9 Ensure that Account 'Lockout duration in seconds' is at least 60 seconds (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The account lockout duration value determines how long an account retains the status of lockout, and therefore how long before a user can continue to attempt to login after passing the lockout threshold.

The recommended state is `Lockout duration in seconds` is at least `60`.

Rationale:

Account lockout is a method of protecting against brute-force and password spray attacks. Once the lockout threshold has been exceeded, the account enters a locked-out state which prevents all login attempts for a variable duration. The lockout in combination with a reasonable duration reduces the total number of failed login attempts that a malicious actor can execute in a given period of time.

Impact:

If account lockout duration is set too low (less than 60 seconds), malicious actors can perform more password spray and brute-force attempts over a given period of time.

If the account lockout duration is set too high (more than 300 seconds) users may experience inconvenient delays during lockout.

In hybrid environments using pass-through authentication (PTA), the Microsoft Entra lockout duration must be set longer than the AD DS account lockout duration. Note that Entra lockout duration is configured in seconds while AD DS lockout duration is configured in minutes; verify the units when comparing the two values to ensure Entra smart lockout expires after AD DS lockout.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Password protection`.
3. Verify that `Lockout duration in seconds` is set to `60` or higher.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/groupSettings
```

2. Filter to **Password Rule settings**, where `templateId` is `5cf42378-d67d-4f36-ba46-e8b86229381d`
3. Verify that `LockoutDurationInSeconds` is greater than or equal to `60`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Authentication methods` and select `Password protection`.
3. Set the `Lockout duration in seconds` to `60` or higher.
4. Click `Save`.

Note: In hybrid environments using pass-through authentication (PTA), ensure the AD DS account lockout duration is shorter than the value set here. The Entra lockout duration is configured in seconds while AD DS lockout duration is configured in minutes; account for the unit difference when comparing the two values.

Default Value:

By default, Lockout duration in seconds is set to `60`.

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-password-smart-lockout#manage-microsoft-entra-smart-lockout-values
2. https://learn.microsoft.com/en-us/graph/api/group-list-settings?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.2.3.10 Ensure Microsoft Authenticator on companion applications is disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Microsoft Entra ID includes a feature called Authenticator Lite, which embeds a subset of Microsoft Authenticator functionality into companion applications such as Outlook mobile. When enabled, users can satisfy MFA requirements using push notifications or time-based one-time passcodes (TOTP) directly from the companion application without installing the standalone Microsoft Authenticator app.

The recommended state is `Microsoft Authenticator on companion applications` set to `Disabled`.

Rationale:

Authenticator Lite does not support application name or geographic location context in push notifications, regardless of tenant-wide Authenticator feature settings. These are key defenses against MFA fatigue attacks that are only available in the full Microsoft Authenticator app. Authenticator Lite also does not satisfy Conditional Access authentication strength requirements, does not support passwordless authentication, and does not support SSPR via push notifications. Disabling this feature ensures users authenticate through the full Microsoft Authenticator app where all available security protections are active.

Impact:

Users who have registered Authenticator Lite as their only MFA method will be unable to complete MFA until they install and register the standalone Microsoft Authenticator app. Administrators should communicate this change in advance and verify that affected users have registered an alternative MFA method before disabling this feature to avoid authentication lockouts.

Audit:

To audit using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Authentication methods` and select `Policies`.
3. Under **Method** select `Microsoft Authenticator`.
4. Select `Configure`.
5. Verify that `Microsoft Authenticator on companion applications`: `Status` is set to `Disabled`.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
beta/policies/authenticationMethodsPolicy/authenticationMethodConfigurations/
microsoftAuthenticator
```

2. Verify that `featureSettings.companionAppAllowedState.state` is `disabled`.

Remediation:

To remediate using the UI:

1. Navigate to the `Microsoft Entra admin center` https://entra.microsoft.com.
2. Expand `Entra ID` > `Authentication methods` and select `Policies`.
3. Under **Method** select `Microsoft Authenticator`.
4. Select `Configure`.
5. Set `Microsoft Authenticator on companion applications`: `Status` to `Disabled`.
6. Select `Save`.

Default Value:

Microsoft managed (enabled as of June 26, 2023)

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-mfa-authenticator-lite
2. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-default-enablement
3. https://learn.microsoft.com/en-us/entra/identity/authentication/how-to-mfa-additional-context

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●

5.2.4 Password reset

5.2.4.1 Ensure 'Self service password reset enabled' is set to 'All' (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Enabling self-service password reset allows users to reset their own passwords in Entra ID. When users sign in to Microsoft 365, they will be prompted to enter additional contact information that will help them reset their password in the future. If combined registration is enabled additional information, outside of multi-factor, will not be needed.

The recommended state is `All`.

Note: Effective Oct. 1st, 2022, Microsoft will begin to enable combined registration for all users in Entra ID tenants created before August 15th, 2020. Tenants created after this date are enabled with combined registration by default.

Rationale:

Enabling Self-Service Password Reset (SSPR) significantly reduces helpdesk interactions, streamlining support operations and improving user experience. Traditional methods involving temporary passwords pose notable security risks—they are often weak, predictable, and susceptible to interception. This creates a window of opportunity for threat actors to compromise accounts before users can update their credentials. SSPR minimizes credential exposure and strengthens overall identity protection.

Impact:

Users will be required to provide additional contact information in order to enroll in SSPR. Some light user education may be necessary, particularly for individuals who are accustomed to contacting the help desk for password reset assistance.

In hybrid environments, SSPR writeback must be enabled before users are able to reset their passwords through self-service.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Properties`.
3. Verify that `Self service password reset enabled` is set to `All`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Properties`.
3. Set `Self service password reset enabled` to `All`

References:

1. https://learn.microsoft.com/en-us/microsoft-365/admin/add-users/let-users-reset-passwords?view=o365-worldwide
2. https://learn.microsoft.com/en-us/entra/identity/authentication/tutorial-enable-sspr
3. https://learn.microsoft.com/en-us/entra/identity/authentication/howto-registration-mfa-sspr-combined
4. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-writeback

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.2.4.2 Ensure that 2 methods are required for password reset (Manual)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Ensures that two alternate forms of identification are provided before allowing a password reset.

The recommended state is `Number of methods required to reset` set to `2`.

Rationale:

Requiring Multi-factor Authentication (MFA) for Self-service Password Reset (SSPR) strengthens the password reset process by confirming the user's identity with two separate methods of authentication. With multiple methods required for password reset, an attacker would have to compromise multiple authentication methods before resetting a user's password.

Impact:

If multiple methods are required for password reset and a user has lost access to other authentication methods, the resetting user will need an administrator with permissions to remove the lost authentication method. Policy and training are recommended to teach administrators to verify the identity of the requesting user so that social engineering is not an effective vector of compromise.

If multifactor authentication is not currently enabled for all users, users with only one registered form of authentication will not be able to reset their passwords through SSPR until another form of authentication is registered.

If multifactor authentication is already enabled for all users, the impact of this recommendation should be minimal.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Authentication methods`.
3. Verify that `Number of methods required to reset` is set to `2`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Authentication methods`.
3. Set the `Number of methods required to reset` to `2`
4. Click `Save`

Default Value:

By default, the `Number of methods required to reset` is `1`.

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/tutorial-enable-sspr
2. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-registration-mfa-sspr-combined
3. https://support.microsoft.com/en-us/account-billing/reset-your-work-or-school-password-using-security-info-23dde81f-08bb-4776-ba72-e6b72b9dda9e
4. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-methods

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.3 Require MFA for Externally-Exposed Applications Require all externally-exposed enterprise or third-party applications to enforce MFA, where supported. Enforcing MFA through a directory service or SSO provider is a satisfactory implementation of this Safeguard.	●	●	●
v7	16.3 Require Multi-factor Authentication Require multi-factor authentication for all user accounts, on all systems, whether managed onsite or by a third-party provider.		●	●

5.2.4.3 Ensure SSPR registration and authentication re-confirmation are required (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The `Require users to register when signing in?` setting controls whether users are prompted to register their self-service password reset (SSPR) authentication methods at their next sign-in. When set to `Yes`, users who have not yet registered are prompted to do so upon signing in.

The `Number of days before users are asked to re-confirm their authentication information` setting designates the period of time before registered users are prompted to re-confirm their existing authentication information is still valid, up to a maximum of 730 days. If set to `0` days, registered users will never be prompted to re-confirm their authentication information.

Rationale:

Without requiring users to register, users may never establish SSPR authentication methods, rendering the re-confirmation setting ineffective regardless of the value it is set to. When users do register authentication methods for self-service password reset (SSPR), those methods may become stale over time as phone numbers, email addresses, or other contact information changes. If re-confirmation is disabled, outdated recovery information persists indefinitely. An attacker who gains access to a former phone number or email address associated with a user's account can exploit that stale recovery information to reset the user's password and take over the account. Requiring registration and periodic re-confirmation ensures that the authentication methods on record remain accurate and under the user's control.

Impact:

Because both settings default to the compliant state, organizations that have not altered them will experience no impact. Re-enabling registration prompts unregistered users to register at their next sign-in; re-enabling re-confirmation prompts registered users to verify their information on the configured interval. Organizations with large user populations and short re-confirmation intervals should expect increased SSPR support volume.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Registration`.
3. Verify that `Require users to register when signing in?` is set to `Yes`.
4. Verify that `Number of days before users are asked to re-confirm their authentication information` is not set to `0`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Registration`.
3. Set `Require users to register when signing in?` to `Yes`.
4. Set `Number of days before users are asked to re-confirm their authentication information` to any organization-approved value other than `0`.
5. Click `Save`.

Default Value:

- `Require users to register when signing in?`: `Yes`
- `Number of days before users are asked to re-confirm their authentication information`: `180`

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-howitworks#registration
2. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-authentication-methods

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	5.1 Establish and Maintain an Inventory of Accounts Establish and maintain an inventory of all accounts managed in the enterprise. The inventory must include both user and administrator accounts. The inventory, at a minimum, should contain the person's name, username, start/stop dates, and department. Validate that all active accounts are authorized, on a recurring schedule at a minimum quarterly, or more frequently.	●	●	●

5.2.4.4 Ensure that users are notified on password resets (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting determines whether or not users receive an email to their primary and alternate email addresses notifying them when their own password has been reset via the Self-Service Password Reset portal.

The recommended state is `Notify users on password resets?` is set to `Yes`.

Rationale:

User notification on password reset is a proactive way of confirming password reset activity. It helps the user to recognize unauthorized password reset activities.

Impact:

Users will receive emails alerting them to password changes to both their primary and alternate emails.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Notifications`.
3. Verify that `Notify users on password resets?` is set to `Yes`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Notifications`.
3. Set `Notify users on password resets?` to `Yes`
4. Click `Save`.

Default Value:

`Yes`

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/tutorial-enable-sspr#set-up-notifications-and-customizations
2. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-howitworks#notifications
3. https://support.microsoft.com/en-us/account-billing/reset-your-work-or-school-password-using-security-info-23dde81f-08bb-4776-ba72-e6b72b9dda9e

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.2.4.5 Ensure all admins are notified when other admins reset their password (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting determines whether or not all global administrators receive an email to their primary email address when other administrators reset their own passwords via the Self-Service Password Reset Portal.

The recommended state is `Notify all admins when other admins reset their password?` is set to `Yes`.

Rationale:

Administrator accounts are sensitive. Any password reset activity notification, when sent to all Administrators, ensures that all Global Administrators can passively confirm if such a reset is a common pattern within their group. For example, if all Administrators change their password every 30 days, any password reset activity before that may require administrator(s) to evaluate any unusual activity and confirm its origin.

Impact:

All Global Administrators will receive a notification from Azure every time a password is reset. This is useful for auditing procedures to confirm that there are no out of the ordinary password resets for Administrators. There is additional overhead, however, in the time required for Global Administrators to audit the notifications. This setting is only useful if all Global Administrators pay attention to the notifications and audit each one.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Notifications`.
3. Verify that `Notify all admins when other admins reset their password?` is set to `Yes`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Password reset` and select `Notifications`.
3. Set `Notify all admins when other admins reset their password?` to `Yes`
4. Click `Save`

Default Value:

`No`

References:

1. https://learn.microsoft.com/en-us/entra/identity/authentication/concept-sspr-howitworks#notifications
2. https://learn.microsoft.com/en-us/entra/identity/authentication/tutorial-enable-sspr#set-up-notifications-and-customizations

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

5.3 ID Governance

5.3.1 Ensure privileged role assignments are activated and not assigned (Automated)

Profile Applicability:

- E5 Level 2

Description:

Microsoft Entra Privileged Identity Management (PIM) provides just-in-time (JIT) activation workflows for privileged Entra ID and Microsoft 365 roles, enabling time-bound access with approval and justification requirements. Rather than holding permanent role assignments, users are made eligible for a role and must explicitly activate it when needed. PIM supports requiring multi-factor authentication at activation, mandatory justification, approval workflows, and configurable activation durations.

Rationale:

Permanent active role assignments expose privileged access continuously, regardless of whether a user is actively performing administrative tasks. If a permanently privileged account is compromised, an attacker immediately holds full role permissions with no time boundary. PIM eliminates standing privilege by requiring users to explicitly activate role assignments, scoping elevated access to a defined duration and requiring justification and, optionally, approval. This reduces the window of opportunity for both external attackers and insider threats to exploit privileged access.

Impact:

The implementation of Just in Time privileged access is likely to necessitate changes to administrator routine. Administrators will only be granted access to administrative roles when required. When administrators request role activation, they will need to document the reason for requiring role access, anticipated time required to have the access, and to reauthenticate to enable role access.

Note: If all global admins become eligible then there will be no global admin to receive notifications, by default. Alerts are sent to TenantAdmins, including Global Administrators, by default. To ensure proper receipt, configure alerts to be sent to security or operations staff with valid email addresses or a security operations center. Otherwise, after adoption of this recommendation, alerts sent to TenantAdmins may go unreceived due to the lack of a licensed permanently active Global Administrator.

Audit:

Note: There is no programmatic way to reliably determine whether a principal is a designated break-glass account. Global Administrator assignments require manual review and judgment to confirm that any permanent assignments belong exclusively to the organization's two approved break-glass accounts.

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Roles & admins` and select `All roles`.
3. Select `Add filters` and apply the `Privileged` filter to scope the review to built-in and custom privileged roles.
4. For each **PRIVILEGED** role that has **one or more** assignments, perform the following review of active assignments:
    1. Select the role to open it.
    2. Open the `Active assignments` tab.
    3. For each assignment where `Type` is `User` or `Group`, verify that `State` is `Activated`.
        - A `State` of `Assigned` is permitted only for approved break-glass accounts assigned to the Global Administrator role, and no more than 2 such accounts may hold this permanent assignment.
    4. For each assignment where `Type` is `Service principal`, verify that `State` is `Assigned` and an `End time` is designated.
5. Compliance is met when all privileged role assignments meet the verification requirements in step 4. Usage of PIM for management of other administrator roles is recommended but not required for compliance.

To audit using Microsoft Graph API:

1. Execute a `GET` request to the following relative URI to retrieve privileged roles (custom or built-in):

```
beta/roleManagement/directory/roleDefinitions?$filter=isPrivileged eq
true&$select=id,displayName,isPrivileged,isBuiltIn,isEnabled
```

2. Execute a `GET` request to the following relative URI to retrieve all instances of active role assignments:

```
v1.0/roleManagement/directory/roleAssignmentScheduleInstances?$expand=princip
al
```

3. Correlate by matching each assignment instance's `roleDefinitionId` to the privileged role list's `id` to produce a list of privileged role assignment instances.
4. For each privileged role assignment instance, verify the appropriate condition for the principal type:

- **For users and groups** (`principal@odata.type` is `#microsoft.graph.user` or `#microsoft.graph.group`), verify that `assignmentType` is `Activated`. An `assignmentType` of `Assigned` is permitted only for approved break-glass accounts assigned to the Global Administrator role, and no more than 2 such accounts may hold this permanent assignment.
- **For service principals** (`principal@odata.type` is `#microsoft.graph.servicePrincipal`), verify that `assignmentType` is `Assigned` and `endDateTime` is defined (time-bound assignment).

5. Compliance is met when all privileged role assignments meet the verification requirements in step 4. Usage of PIM for management of other administrator roles is recommended but not required for compliance.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `Entra ID` > `Roles & admins` and select `All roles`.
3. For each user or group role assignment that is out of compliance:
   - Click on the role to open it in PIM.
   - Select the `Active assignments` tab.
   - Under **action** click `Update` or `Remove`.
     - If `Update` is selected, set the `Assignment type` to `Eligible` and click `Save`.
     - If `Remove` is selected, the assignment will be removed and the principal will no longer hold the role.
4. For each privileged role with a non-compliant service principal active assignment:

1. Open the `Active assignments` tab.
2. Click `Update` to modify the service principal assignment.
3. Uncheck `Permanently assigned` and set an appropriate end time to create a time-bound assignment based on business needs.
4. Click `Save` to apply the changes.

5. Repeat for any other privileged role assignments that are out of compliance.

Note: CIS Safeguard 6.8, *Define and Maintain Role-Based Access Control*, recommends reviewing access on a recurring schedule, at least annually and more frequently as needed. This practice is strongly encouraged for service principals when defining time-bound assignments.

Default Value:

Without Privileged Identity Management configured, all privileged role assignments are permanent active assignments with no expiration or activation requirement.

References:

1. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-configure

Additional Information:

In addition to enforcing just-in-time activation for active privileged role assignments, organizations are encouraged to periodically review *eligible* PIM role assignments to confirm ongoing business justification and remove stale entries. Annual review at minimum is recommended. This is a governance process that requires manual judgment and is outside the scope of the automated compliance check for this recommendation.

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.3.2 Ensure 'Access reviews' for guest users are configured (Automated)

Profile Applicability:

- E5 Level 1

Description:

Access reviews enable administrators to establish an efficient automated process for reviewing group memberships, access to enterprise applications, and role assignments. These reviews can be scheduled to recur regularly, with flexible options for delegating the task of reviewing membership to different members of the organization. When configured for guest users, access reviews can automatically remove access if no reviewer responds within the review period, enforcing a fail-closed posture for external identities.

Rationale:

Access to groups and applications for guests can change over time. If a guest user's access to a particular resource goes unnoticed, they may unintentionally gain access to sensitive data if a member adds new files or data to the resource. Access reviews can help reduce the risks associated with outdated assignments by requiring a member of the organization to conduct the reviews. Furthermore, these reviews can enable a fail-closed mechanism to remove access to the subject if the reviewer does not respond to the review.

Impact:

Legitimate guest users may lose access to resources if designated reviewers fail to respond within the review window, requiring re-invitation and re-provisioning of access. Organizations with a large number of Microsoft 365 groups may face significant reviewer workload from monthly review cycles, which can lead to approval fatigue.

- Microsoft Entra ID Governance licensing (included in Microsoft 365 E5) is required to configure access reviews.
- As of January 15, 2026, a linked Azure subscription is required to use Entra ID Governance features for guest users.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/
2. Expand ID Governance and select Access reviews
3. Inspect the access reviews, and verify an access review is created with the following criteria:
    - Overview: Scope is set to Guest users only and Review status is Active
    - Reviewers: At least one reviewer is assigned, and the reviewer is not a guest user.
    - Settings > General:
        - Mail notifications is set to Enable
        - Reminders is set to Enable
    - Settings > Reviewers:
        - Require reason on approval is set to Enable
    - Settings > Scheduling:
        - Frequency is set to Monthly or more frequent
        - Duration (in days) does not exceed 14 days
        - End is set to Never
    - Settings > When completed:
        - Auto apply results to resource is set to Enable
        - If reviewers don't respond is set to Remove access
4. The control is compliant if there is at least one access review for guests that meets all criteria above.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identityGovernance/accessReviews/definitions
```

2. Apply the following filters to identify access reviews targeting guest users:
   - `scope.resourceScopes.query` matches the pattern `userType eq 'Guest'` **OR**
   - `scope.query` matches the pattern `userType eq 'Guest'`
3. For each review that passes the filters above, verify the following criteria:
   - **Recurrence is configured as monthly or more frequent:**
     - `recurrence.pattern.type` is `absoluteMonthly` **OR**
     - `recurrence.pattern.type` is `weekly`
   - `reviewers` is not empty
   - `settings.mailNotificationsEnabled` is `true`
   - `settings.instanceDurationInDays` is `14` days or less
   - `settings.reminderNotificationsEnabled` is `true`
   - `settings.justificationRequiredOnApproval` is `true`
   - `settings.autoApplyDecisionsEnabled` is `true`
   - `settings.defaultDecision` is `Deny`
   - `settings.recurrence.range.type` is `noEnd`
4. The control is compliant if there is at least one access review for guests that meets all criteria above.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `ID Governance` and select `Access reviews`
3. Click `New access review`.
4. In the `Resource review` box click `Select`.
5. In **Review Type** set the following:
    - `Select what to review` choose `Teams + Groups`.
    - `Review Scope` to `All Microsoft 365 groups with guest users`.
    - `Scope` to `Guest users only` then click `Next: Reviews`.
6. In **Reviews** set the following:
    - `Select reviewers` to `Group members` or `Selected users and groups`, ensuring that at least one reviewer is assigned and that the guest is not performing a self-review.
    - `Duration (in days)` to `14` days or less.
    - `Review recurrence` to `Monthly` or more frequent.
    - `Start date` for the review, ensuring the review becomes active before the next audit date.
    - `End` to `Never`, then click `Next: Settings`.
7. In **Settings** set the following:
    - `Auto apply results to resource` is checked.
    - `If reviewers don't respond` to `Remove access`
    - `Justification required` is checked.
    - `E-mail notifications` is checked.
    - `Reminders` is checked.
    - Click `Next: Review + Create`
8. Click `Create`.

To remediate using the Microsoft Graph API:

To create a new access review, execute a `POST` request to the following relative URI. To update an existing review, execute a `PATCH` request to the same URI appended with the review's `id`:

```
v1.0/identityGovernance/accessReviews/definitions
```

The request body must include properties that satisfy the audit criteria above. The Graph API documentation provides complete sample request bodies in multiple languages including HTTP, PowerShell, and Python. See Reference 3 for details.

Default Value:

By default access reviews are not configured.

References:

1. https://learn.microsoft.com/en-us/entra/id-governance/access-reviews-overview
2. https://learn.microsoft.com/en-us/entra/id-governance/create-access-review
3. https://learn.microsoft.com/en-us/graph/api/resources/accessreviewscheduledefinition?view=graph-rest-1.0

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.3.3 Ensure 'Access reviews' for privileged roles are configured (Automated)

Profile Applicability:

- E5 Level 1

Description:

Access reviews in Microsoft Entra Privileged Identity Management (PIM) enable administrators to periodically validate whether users still require their privileged role assignments. These reviews can be scheduled to recur on a regular cadence and can be delegated to reviewers other than the role holders themselves, such as security auditors.

Rationale:

Regular review of critical high privileged roles in Entra ID will help identify role drift, or potential malicious activity. This will enable the practice and application of "separation of duties" where even non-privileged users like security auditors can be assigned to review assigned roles in an organization.

These reviews can optionally be configured to automatically remove access if a reviewer does not respond within the review window, though this recommendation conservatively sets non-response to result in no change to avoid inadvertent removal of privileged accounts including break-glass accounts.

Impact:

In order to avoid disruption reviewers who have the authority to revoke roles should be trusted individuals who understand the significance of access reviews. Additionally, the principle of separation of duties should be applied to ensure that no administrator is responsible for reviewing their own access levels. This will cause additional administrative overhead.

If the reviews are configured to automatically revoke highly privileged roles like the Global Administrator role, then this could result in removing all Global Administrators from the organization. Care should be taken when configuring this setting especially in the case of break-glass accounts which would be included in the scope.

- Microsoft Entra ID Governance licensing (included in Microsoft 365 E5) is required to configure access reviews.

Audit:

To audit using the UI:

1. Navigate to Microsoft Entra admin center https://entra.microsoft.com/
2. Expand ID Governance > Privileged Identity Management.
3. Select Microsoft Entra Roles under Manage.
4. Select Access reviews
5. For each privileged role listed in the Additional Information section, verify an access review exists that meets the following criteria:
    - Overview:
        - Role assignment type is set to Eligible and Active
        - Scope is set to Everyone
        - Review status is Active
    - Reviewers: At least one reviewer is assigned, and the reviewer is not self-reviewing.
    - Settings > General:
        - Mail notifications is set to Enable
        - Reminders is set to Enable
    - Settings > Reviewers:
        - Require reason on approval is set to Enable
    - Settings > Scheduling:
        - Frequency is set to Monthly or more frequently
        - Duration (in days) does not exceed 14 days
        - End is set to Never
    - Settings > When completed:
        - Auto apply results to resource is set to Enable
        - If reviewers don't respond is set to No change

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI:

```
v1.0/identityGovernance/accessReviews/definitions
```

2. Apply the following filters to identify relevant access review definitions:
   - `scope.resourceScopes.query` matches the pattern `/directory/roleDefinitions/`
   - `scope.resourceScopes.query` matches the GUID of one of the 6 privileged directory roles outlined in the Additional Information section.
3. For each review that passes the filters above, verify the following criteria:
   - **Scoped to Eligible and Active role assignments:**
     - `scope.principalScopes.query` contains `/v1.0/users` **AND**
     - `scope.principalScopes.query` contains `/v1.0/groups`
   - **Recurrence is configured as monthly or more frequent:**
     - `recurrence.pattern.type` is `absoluteMonthly` **OR**
     - `recurrence.pattern.type` is `weekly`
     - `recurrence.range.startDate` is in the past relative to the audit date
   - `reviewers` is not empty
   - `settings.mailNotificationsEnabled` is `true`
   - `settings.reminderNotificationsEnabled` is `true`
   - `settings.justificationRequiredOnApproval` is `true`
   - `settings.instanceDurationInDays` is less than or equal to `14`
   - `settings.autoApplyDecisionsEnabled` is `true`
   - `settings.defaultDecision` is `None`
4. The control is compliant when all 6 privileged directory roles have an associated access review definition that meets all the criteria listed above.

Note: The 6 roles referenced and their associated GUIDs can be found in the **Additional Information** section.

Remediation:

Note: An access review is created for each role selected after completing the process.

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/
2. Expand `ID Governance` > `Privileged Identity Management`.
3. Select `Microsoft Entra Roles` under Manage.
4. Select `Access reviews` and click `New`.
    - Provide a name and description.
    - Set `Frequency` to `Monthly` or more frequently.
    - Set `Duration (in days)` to at most `14`.
    - Set `End` to `Never`.
    - Set `Users scope` to `All users and groups`.
    - In `Role` select the directory roles outlined in the Additional Information section.
    - Set `Assignment type` to `All active and eligible assignments`.
    - Set `Reviewers` to member(s) responsible for this type of review, other than self.
5. In **Upon completion settings** set the following:
    - `Auto apply results to resource` to `Enable`.
    - `If reviewers don't respond` to `No change`.
6. In **Advanced settings** set the following:
    - `Require reason on approval` to `Enable`
    - `Mail notifications` to `Enable`
    - `Reminders` to `Enable`
7. Click `Start` to save and begin the review series.

Warning: Care should be taken when configuring the `If reviewers don't respond` setting for Global Administrator reviews, if misconfigured break-glass accounts could automatically have roles revoked. Additionally, reviewers should be educated on the purpose of break-glass accounts to prevent accidental manual removal of roles.

To remediate using the Microsoft Graph API:

To create a new access review, execute a `POST` request to the following relative URI. To update an existing review, execute a `PATCH` request to the same URI appended with the review's `id`:

```
v1.0/identityGovernance/accessReviews/definitions
```

The request body must include properties that satisfy the audit criteria above. The Graph API documentation provides complete sample request bodies in multiple languages including HTTP, PowerShell, and Python. See Reference 3 for details

Default Value:

By default access reviews are not configured.

References:

1. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-create-roles-and-resource-roles-review
2. https://learn.microsoft.com/en-us/entra/id-governance/access-reviews-overview
3. https://learn.microsoft.com/en-us/graph/api/resources/accessreviewscheduledefinition?view=graph-rest-1.0

Additional Information:

The 6 privileged directory roles referenced in the audit and remediation procedures and their associated GUIDs are as follows:

Role Name	Role Definition GUID
Global Administrator	62e90394-69f5-4237-9190-012177145e10
Privileged Role Administrator	e8611ab8-c189-46e8-94e1-60213ab1f814
Exchange Administrator	29232cdf-9323-42fd-ade2-1d097af3e4de
SharePoint Administrator	f28a1f50-f6e7-4571-818b-6a12f2af6b6c
Teams Administrator	69091246-20e8-4a56-aa4d-066075b2a7a8
Security Administrator	194ae4cb-b126-40b2-bd5b-6091b380977d

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.2 Establish an Access Revoking Process Establish and follow a process, preferably automated, for revoking access to enterprise assets, through disabling accounts immediately upon termination, rights revocation, or role change of a user. Disabling accounts, instead of deleting accounts, may be necessary to preserve audit trails.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

5.3.4 Ensure approval is required for Global Administrator role activation (Automated)

Profile Applicability:

- E5 Level 1

Description:

Microsoft Entra Privileged Identity Management can be used to audit roles, allow just in time activation of roles and allow for periodic role attestation. Requiring approval before activation allows one of the selected approvers to first review and then approve the activation prior to PIM granted the role. The approver doesn't have to be a group member or owner.

The recommended state is `Require approval to activate` for the `Global Administrator` role.

Rationale:

Requiring approval for Global Administrator role activation enhances visibility and accountability every time this highly privileged role is used. This process reduces the risk of an attacker elevating a compromised account to the highest privilege level, as any activation must first be reviewed and approved by a trusted party.

Note: This only acts as protection for eligible users that are activating a role. Directly assigning a role does not require an approval workflow so therefore it is important to implement and use PIM correctly.

Impact:

Approvers do not need to be assigned the same role or be members of the same group. It's important to have at least two approvers and an emergency access (break-glass) account to prevent a scenario where no Global Administrators are available. For example, if the last active Global Administrator leaves the organization, and only eligible but inactive Global Administrators remain, a trusted approver without the Global Administrator role or an emergency access account would be essential to avoid delays in critical administrative tasks.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `ID Governance` > `Privileged Identity Management`.
3. Under **Manage** select `Microsoft Entra Roles`.
4. Under **Manage** select `Roles`.
5. Select `Global Administrator` in the list.
6. Select `Role settings`.
7. Verify that `Require approval to activate` is set to `Yes`.
8. Verify there is at least 1 `approvers` in the list.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI to retrieve the `policyID` for the Global Administrator-role:

```
v1.0/policies/roleManagementPolicyAssignments?$filter=scopeId eq '/' and
scopeType eq 'DirectoryRole' and roleDefinitionId eq '62e90394-69f5-4237-
9190-012177145e10'&$select=policyId
```

2. Execute a `GET` request to the following relative URI to retrieve the policy's Approval setting using the `policyId` from the previous call:

```
v1.0/policies/roleManagementPolicies/{policyID}/rules/Approval_EndUser_Assign
ment

# Example
https://graph.microsoft.com/v1.0/policies/roleManagementPolicies/DirectoryRol
e_9c4d49a8-1f7a-4256-b1a2-b7cb0e7180f4_86522f3f-cfd0-4634-95a0-
38083127ca00/rules/Approval_EndUser_Assignment
```

3. Verify that `isApprovalRequired` is `true`.
4. Verify that `approvalStages.primaryApprovers` contains one or more valid users.

Note: Approvers should be reviewed on a regular basis to ensure the members are active and valid.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `ID Governance` > `Privileged Identity Management`.
3. Under **Manage** select `Microsoft Entra Roles`.
4. Under **Manage** select `Roles`.
5. Select `Global Administrator` in the list.
6. Select `Role settings` and click `Edit`.
7. Check the `Require approval to activate` box.
8. Add at least one approver.
9. Click `Update`.

Default Value:

`Require approval to activate` : `No`.

References:

1. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-configure
2. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/groups-role-settings#require-approval-to-activate

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●

5.3.5 Ensure approval is required for Privileged Role Administrator activation (Automated)

Profile Applicability:

- E5 Level 1

Description:

Microsoft Entra Privileged Identity Management can be used to audit roles, allow just in time activation of roles and allow for periodic role attestation. Requiring approval before activation allows one of the selected approvers to first review and then approve the activation prior to PIM granted the role. The approver doesn't have to be a group member or owner.

The recommended state is `Require approval to activate` for the `Privileged Role Administrator` role.

Rationale:

This role grants the ability to manage assignments for all Microsoft Entra roles including the Global Administrator role. This role does not include any other privileged abilities in Microsoft Entra ID like creating or updating users. However, users assigned to this role can grant themselves or others additional privilege by assigning additional roles.

Requiring approval for activation enhances visibility and accountability every time this highly privileged role is used. This process reduces the risk of an attacker elevating a compromised account to the highest privilege level, as any activation must first be reviewed and approved by a trusted party.

Note: This only acts as protection for eligible users that are activating a role. Directly assigning a role does not require an approval workflow so therefore it is important to implement and use PIM correctly.

Impact:

Requiring approvers for automatic role assignment can slightly increase administrative overhead and add delays to tasks.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `ID Governance` > `Privileged Identity Management`.
3. Under **Manage** select `Microsoft Entra Roles`.
4. Under **Manage** select `Roles`.
5. Select `Privileged Role Administrator` in the list.
6. Select `Role settings`.
7. Verify `Require approval to activate` is set to `Yes`.
8. Verify there is at least one `approvers` in the list.

To audit using the Microsoft Graph API:

1. Execute a `GET` request to the following relative URI to retrieve the `policyID` for the Privileged Role Administrator-role:

```
v1.0/policies/roleManagementPolicyAssignments?$filter=scopeId eq '/' and
scopeType eq 'DirectoryRole' and roleDefinitionId eq 'e8611ab8-c189-46e8-
94e1-60213ab1f814'&$select=policyId
```

2. Execute a `GET` request to the following relative URI to retrieve the policy's Approval setting using the `policyId` from the previous call:

```
v1.0/policies/roleManagementPolicies/{policyID}/rules/Approval_EndUser_Assign
ment

# Example
https://graph.microsoft.com/v1.0/policies/roleManagementPolicies/DirectoryRol
e_d1fdbf46-5729-4c53-a951-7ab677be380f_3679e0d0-412a-444d-b517-
ab23973d6067/rules/Approval_EndUser_Assignment
```

3. Verify that `isApprovalRequired` is `true`.
4. Verify that `approvalStages.primaryApprovers` contains one or more valid users.

Note: Approvers should be reviewed on a regular basis to ensure the members are active and valid.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Entra admin center` https://entra.microsoft.com/.
2. Expand `ID Governance` > `Privileged Identity Management`.
3. Under **Manage** select `Microsoft Entra Roles`.
4. Under **Manage** select `Roles`.
5. Select `Privileged Role Administrator` in the list.
6. Select `Role settings` and click `Edit`.
7. Check the `Require approval to activate` box.
8. Add at least one approver.
9. Click `Update`.

Default Value:

`Require approval to activate` : `No`.

References:

1. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/pim-configure
2. https://learn.microsoft.com/en-us/entra/id-governance/privileged-identity-management/groups-role-settings#require-approval-to-activate

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.1 Establish an Access Granting Process Establish and follow a process, preferably automated, for granting access to enterprise assets upon new hire, rights grant, or role change of a user.	●	●	●

6 Exchange admin center

The Exchange admin center contains settings related to everything Exchange Online.

Direct link: https://admin.exchange.microsoft.com/

The PowerShell module most used in this section is `ExchangeOnlineManagement` and uses `Connect-ExchangeOnline` as the connection cmdlet.

The latest version of the module can be downloaded here:
https://www.powershellgallery.com/packages/ExchangeOnlineManagement/

6.1 Audit

6.1.1 Ensure 'AuditDisabled' organizationally is set to 'False' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The value False indicates that mailbox auditing on by default is turned on for the organization. Mailbox auditing on by default in the organization overrides the mailbox auditing settings on individual mailboxes. For example, if mailbox auditing is turned off for a mailbox (the AuditEnabled property on the mailbox is False), the default mailbox actions are still audited for the mailbox, because mailbox auditing on by default is turned on for the organization.

Turning off mailbox auditing on by default ($true) has the following results:

- Mailbox auditing is turned off for your organization.
- From the time you turn off mailbox auditing on by default, no mailbox actions are audited, even if mailbox auditing is enabled on a mailbox (the AuditEnabled property on the mailbox is True).
- Mailbox auditing isn't turned on for new mailboxes and setting the AuditEnabled property on a new or existing mailbox to True is ignored.
- Any mailbox audit bypass association settings (configured by using the Set-MailboxAuditBypassAssociation cmdlet) are ignored.
- Existing mailbox audit records are retained until the audit log age limit for the record expires.

The recommended state for this setting is `False` at the organization level. This will enable auditing and enforce the default.

Rationale:

Enforcing the default ensures auditing was not turned off intentionally or accidentally. Auditing mailbox actions will allow forensics and IR teams to trace various malicious activities that can generate TTPs caused by inbox access and tampering.

Impact:

None - this is the default behavior as of 2019.

Audit:

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-OrganizationConfig | Format-List AuditDisabled
```

3. Verify that `AuditDisabled` is set to `False`.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-OrganizationConfig -AuditDisabled $false
```

Default Value:

False

References:

1. https://learn.microsoft.com/en-us/purview/audit-mailboxes?view=o365-worldwide
2. https://learn.microsoft.com/en-us/powershell/module/exchange/set-organizationconfig?view=exchange-ps#-auditdisabled

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.1.2 Ensure mailbox audit actions are configured (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Mailbox audit logging is turned on by default in all organizations. This effort started in January 2019, and means that certain actions performed by mailbox owners, delegates, and admins are automatically logged. The corresponding mailbox audit records are available for admins to search in the mailbox audit log.

Mailboxes and shared mailboxes have actions assigned to them individually in order to audit the data the organization determines valuable at the mailbox level.

The recommended state per mailbox is `AuditEnabled` to `True` including all default audit actions with additional actions outlined below in the audit and remediation sections.

Note: Audit (Standard) licensing allows for up to 180 days log retention as of October 2023.

Rationale:

Whether it is for regulatory compliance or for tracking unauthorized configuration changes in Microsoft 365, enabling mailbox auditing and ensuring the proper mailbox actions are accounted for allows for Microsoft 365 teams to run security operations, forensics or general investigations on mailbox activities.

The following mailbox types ignore the organizational default and must have `AuditEnabled` set to `True` at the mailbox level in order to capture relevant audit data.

- Resource Mailboxes
- Public Folder Mailboxes
- DiscoverySearch Mailbox

Impact:

Adding additional audit action types and increasing the AuditLogAgeLimit from 90 to 180 days will have a limited impact on mailbox storage. Mailbox audit log records are stored in a subfolder (named Audits) in the Recoverable Items folder in each user's mailbox.

- Mailbox audit records count against the storage quota of the Recoverable Items folder.
- Mailbox audit records also count against the folder limit for the Recoverable Items folder. A maximum of 3 million items (audit records) can be stored in the Audits subfolder.

The following cmdlet in Exchange Online PowerShell can be run to display the size and number of items in the Audits subfolder in the Recoverable Items folder:

```
Get-MailboxFolderStatistics -Identity <MailboxIdentity> -FolderScope
RecoverableItems |
Where-Object {$_.Name -eq 'Audits'} | Format-List
FolderPath,FolderSize,ItemsInFolder
```

Note: It's unlikely that mailbox auditing on by default impacts the storage quota or the folder limit for the Recoverable Items folder.

Audit:

Inspect each `UserMailbox` and ensure `AuditEnabled` is `True` and the following audit actions are included *in addition* to default actions of each sign-in type.

- Admin actions: `Copy`, `FolderBind` and `Move`.
- Delegate actions: `FolderBind` and `Move`.
- Owner actions: `Create`, `MailboxLogin` and `Move`.

Note: The defaults can be found in the **Default Value** section and the combined total can be found in the scripts of the Audit/Remediation sections.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell script:

```
$AdminActions = @(
    "ApplyRecord", "Copy", "Create", "FolderBind", "HardDelete",
    "MailItemsAccessed", "Move", "MoveToDeletedItems", "SendAs",
    "SendOnBehalf", "Send", "SoftDelete", "Update",
    "UpdateCalendarDelegation", "UpdateFolderPermissions",
    "UpdateInboxRules"
)

$DelegateActions = @(
    "ApplyRecord", "Create", "FolderBind", "HardDelete", "Move",
    "MailItemsAccessed", "MoveToDeletedItems", "SendAs", "SendOnBehalf",
    "SoftDelete", "Update", "UpdateFolderPermissions", "UpdateInboxRules"
)

$OwnerActions = @(
    "ApplyRecord", "Create", "HardDelete", "MailboxLogin", "Move",
    "MailItemsAccessed", "MoveToDeletedItems", "Send", "SoftDelete",
    "Update", "UpdateCalendarDelegation", "UpdateFolderPermissions",
    "UpdateInboxRules"
)

function VerifyActions {
    param (
        [array]$ExpectedActions,
        [array]$ActualActions
    )

    $Missing = $ExpectedActions | Where-Object { $_ -notin $ActualActions }
    return $Missing
}

$MBX = Get-EXOMailbox -PropertySets Audit, Minimum -ResultSize Unlimited |
    Where-Object { $_.RecipientTypeDetails -eq "UserMailbox" }

$Results = foreach ($mailbox in $MBX) {
    $AdminMissing = VerifyActions -ExpectedActions $AdminActions `
        -ActualActions $mailbox.AuditAdmin
    $DelegateMissing = VerifyActions -ExpectedActions $DelegateActions `
        -ActualActions $mailbox.AuditDelegate
    $OwnerMissing = VerifyActions -ExpectedActions $OwnerActions `
        -ActualActions $mailbox.AuditOwner

    $IsCompliant = $AdminMissing.Count -eq 0 -and
                   $DelegateMissing.Count -eq 0 -and
                   $OwnerMissing.Count -eq 0 -and
                   $mailbox.AuditEnabled

    [PSCustomObject]@{
        Mailbox         = $mailbox.UserPrincipalName
        AuditEnabled    = $mailbox.AuditEnabled
        AdminMissing    = if ($AdminMissing.Count -gt 0) {
            $AdminMissing -join ", " } else { "None" }
        DelegateMissing = if ($DelegateMissing.Count -gt 0) {
            $DelegateMissing -join ", " } else { "None" }
        OwnerMissing    = if ($OwnerMissing.Count -gt 0) {
            $OwnerMissing -join ", " } else { "None" }
        ComplianceState = if ($IsCompliant) { "Compliant" } else {
```

```
            "Non-Compliant" }
    }
}

# Display results in table format
$Results | Format-Table -AutoSize
<# Optional: Export methods
$Results | Out-GridView -Title "Mailbox Audit Results"
$Results | Export-Csv -Path "6.1.2.csv" -NoTypeInformation
$Results | ConvertTo-Json | Out-File -FilePath "6.1.2.json"
#>
```

3. Inspect the results. Mailboxes will be labeled as either `Compliant` or `Non-compliant`, accompanied by supporting details that outline the missing actions for each type and the current state of AuditEnabled. Optional methods for exporting the data to CSV, JSON, or GridView are also shown at the end of the script.

Note: Mailboxes with Audit (Premium) licenses, which is included with E5, can retain audit logs beyond 180 days.

Remediation:

For each `UserMailbox` ensure `AuditEnabled` is `True` and the following audit actions are included *in addition* to default actions of each sign-in type.

- Admin actions: `Copy`, `FolderBind` and `Move`.
- Delegate actions: `FolderBind` and `Move`.
- Owner actions: `Create`, `MailboxLogin` and `Move`.

Note: The defaults can be found in the **Default Value** section and the combined total can be found in the scripts of the Audit/Remediation sections.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell script to remediate every 'UserMailbox' in the organization:

```
$AuditAdmin = @(
    "ApplyRecord", "Copy", "Create", "FolderBind", "HardDelete",
    "MailItemsAccessed", "Move", "MoveToDeletedItems", "SendAs",
    "SendOnBehalf", "Send", "SoftDelete", "Update",
    "UpdateCalendarDelegation", "UpdateFolderPermissions",
    "UpdateInboxRules"
)

$AuditDelegate = @(
    "ApplyRecord", "Create", "FolderBind", "HardDelete", "Move",
    "MailItemsAccessed", "MoveToDeletedItems", "SendAs", "SendOnBehalf",
    "SoftDelete", "Update", "UpdateFolderPermissions", "UpdateInboxRules"
)

$AuditOwner = @(
    "ApplyRecord", "Create", "HardDelete", "MailboxLogin", "Move",
    "MailItemsAccessed", "MoveToDeletedItems", "Send", "SoftDelete",
    "Update", "UpdateCalendarDelegation", "UpdateFolderPermissions",
    "UpdateInboxRules"
)


$MBX = Get-EXOMailbox -ResultSize Unlimited | Where-Object {
    $_.RecipientTypeDetails -eq "UserMailbox"
}
$MBX | Set-Mailbox -AuditEnabled $true `
-AuditLogAgeLimit 180 -AuditAdmin $AuditAdmin -AuditDelegate $AuditDelegate `
-AuditOwner $AuditOwner
```

3. The script will apply the prescribed Audit Actions for each sign-in type (Owner, Delegate, Admin) and the AuditLogAgeLimit to each UserMailbox in the organization.

Note: Mailboxes with Audit (Premium) licenses, which is included with E5, can retain audit logs beyond 180 days.

Default Value:

`AuditEnabled`: `True` for all mailboxes except below:

- Resource Mailboxes
- Public Folder Mailboxes
- DiscoverySearch Mailbox

AuditAdmin: ApplyRecord, Create, HardDelete, MailItemsAccessed, MoveToDeletedItems, Send, SendAs, SendOnBehalf, SoftDelete, Update, UpdateCalendarDelegation, UpdateFolderPermissions, UpdateInboxRules

AuditDelegate: ApplyRecord, Create, HardDelete, MailItemsAccessed, MoveToDeletedItems, SendAs, SendOnBehalf, SoftDelete, Update, UpdateFolderPermissions, UpdateInboxRules

AuditOwner: ApplyRecord, HardDelete, MailItemsAccessed, MoveToDeletedItems, Send, SoftDelete, Update, UpdateCalendarDelegation, UpdateFolderPermissions, UpdateInboxRules

References:

1. https://learn.microsoft.com/en-us/purview/audit-mailboxes?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●
v8	8.5 Collect Detailed Audit Logs Configure detailed audit logging for enterprise assets containing sensitive data. Include event source, date, username, timestamp, source addresses, destination addresses, and other useful elements that could assist in a forensic investigation.		●	●
v7	6.2 Activate audit logging Ensure that local logging has been enabled on all systems and networking devices.	●	●	●

6.1.3 Ensure 'AuditBypassEnabled' is not enabled on mailboxes (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

When configuring a user or computer account to bypass mailbox audit logging, the system will not record any access, or actions performed by the said user or computer account on any mailbox. Administratively this was introduced to reduce the volume of entries in the mailbox audit logs on trusted user or computer accounts.

Ensure `AuditBypassEnabled` is not enabled on accounts without a written exception.

Rationale:

If a mailbox audit bypass association is added for an account, the account can access any mailbox in the organization to which it has been assigned access permissions, without generating any mailbox audit logging entries for such access or recording any actions taken, such as message deletions.

Enabling this parameter, whether intentionally or unintentionally, could allow insiders or malicious actors to conceal their activity on specific mailboxes. Ensuring proper logging of user actions and mailbox operations in the audit log will enable comprehensive incident response and forensics.

Impact:

None - this is the default behavior.

Audit:

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
$MBXData = Get-MailboxAuditBypassAssociation -ResultSize unlimited
$Report = $MBXData | ? {$_.AuditBypassEnabled -eq $true} |
select Name,AuditBypassEnabled

$Report
<# Optional: Export methods
$Report | Out-GridView -Title "Mailbox Audit Bypass Association"
$Report | Export-Csv -Path "6.1.3.csv" -NoTypeInformation
#>
```

3. If nothing is returned, then there are no accounts with Audit Bypass enabled.

Note: The cmdlet `Get-MailboxAuditBypassAssociation` may display a WARNING on system objects that begin with "Asc-2X1", this is not part of the Audit procedure and can be ignored.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. The following example PowerShell script will disable AuditBypass for all mailboxes which currently have it enabled:

```
# Get mailboxes with AuditBypassEnabled set to $true
$MBXAudit = Get-MailboxAuditBypassAssociation -ResultSize unlimited | Where-
Object { $_.AuditBypassEnabled -eq $true }

foreach ($mailbox in $MBXAudit) {
    $mailboxName = $mailbox.Name
    Set-MailboxAuditBypassAssociation -Identity $mailboxName -
AuditBypassEnabled $false
    Write-Host "Audit Bypass disabled for mailbox Identity: $mailboxName" -
ForegroundColor Green
}
```

Default Value:

AuditBypassEnabled `False`

References:

1. https://learn.microsoft.com/en-us/powershell/module/exchange/get-mailboxauditbypassassociation?view=exchange-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	8.2 Collect Audit Logs Collect audit logs. Ensure that logging, per the enterprise's audit log management process, has been enabled across enterprise assets.	●	●	●

6.2 Mail flow

6.2.1 Ensure all forms of mail forwarding are blocked and/or disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Exchange Online offers several methods of managing the flow of email messages. These are Remote domain, Transport Rules, and Anti-spam outbound policies. These methods work together to provide comprehensive coverage for potential automatic forwarding channels:

- Outlook forwarding using inbox rules.
- Outlook forwarding configured using OOF rule.
- OWA forwarding setting (ForwardingSmtpAddress).
- Forwarding set by the admin using EAC (ForwardingAddress).
- Forwarding using Power Automate / Flow.

Ensure a `Transport rule` and `Anti-spam outbound policy` are used to block mail forwarding.

NOTE: Any exclusions should be implemented based on organizational policy.

Rationale:

Attackers often create these rules to exfiltrate data from your tenancy, this could be accomplished via access to an end-user account or otherwise. An insider could also use one of these methods as a secondary channel to exfiltrate sensitive data.

Impact:

Care should be taken before implementation to ensure there is no business need for case-by-case auto-forwarding. Disabling auto-forwarding to remote domains will affect all users in an organization. Any exclusions should be implemented based on organizational policy.

Audit:

Note: *Audit is a two step procedure as follows:*

STEP 1: Transport rules

To audit using the UI:

1. Select `Exchange` to open the Exchange admin center.
2. Select `Mail Flow` then `Rules`.
3. Review the rules and verify that none of them are forwards or redirects e-mail to external domains.

To audit using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command to review the Transport Rules that are redirecting email:

```
Get-TransportRule | Where-Object {$_.RedirectMessageTo -ne $null} | ft
Name,RedirectMessageTo
```

3. Verify that none of the addresses listed belong to external domains outside of the organization. If nothing returns then there are no transport rules set to redirect messages.

STEP 2: Anti-spam outbound policy

To audit using the UI:

1. Navigate to `Microsoft 365 Defender` https://security.microsoft.com/
2. Expand `E-mail & collaboration` then select `Policies & rules`.
3. Select `Threat policies` > `Anti-spam`.
4. Inspect `Anti-spam outbound policy (default)` and ensure `Automatic forwarding` is set to `Off - Forwarding is disabled`
5. Inspect any additional custom outbound policies and ensure `Automatic forwarding` is set to `Off - Forwarding is disabled`, in accordance with the organization's exclusion policies.

To audit using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. Run the following PowerShell cmdlet:

```
Get-HostedOutboundSpamFilterPolicy | ft Name, AutoForwardingMode
```

3. In each outbound policy verify `AutoForwardingMode` is `Off`.

Note: According to Microsoft if a recipient is defined in multiple policies of the same type (anti-spam, anti-phishing, etc.), only the policy with the highest priority is applied to the recipient. Any remaining policies of that type are not evaluated for the recipient (including the default policy). However, it is our recommendation to audit the default policy as well in the case a higher priority custom policy is removed. This will keep the organization's security posture strong.

Remediation:

Note: *Remediation is a two step procedure as follows:*

STEP 1: Transport rules

To remediate using the UI:

1. Select `Exchange` to open the Exchange admin center.
2. Select `Mail Flow` then `Rules`.
3. For each rule that redirects email to external domains, select the rule and click the 'Delete' icon.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Remove-TransportRule {RuleName}
```

STEP 2: Anti-spam outbound policy

To remediate using the UI:

1. Navigate to `Microsoft 365 Defender` https://security.microsoft.com/
2. Expand `E-mail & collaboration` then select `Policies & rules`.
3. Select `Threat policies` > `Anti-spam`.
4. Select `Anti-spam outbound policy (default)`
5. Click `Edit protection settings`
6. Set `Automatic forwarding rules` dropdown to `Off - Forwarding is disabled` and click `Save`
7. Repeat steps 4-6 for any additional higher priority, custom policies.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-HostedOutboundSpamFilterPolicy -Identity {policyName} -AutoForwardingMode
Off
```

3. To remove AutoForwarding from all outbound policies you can also run:

```
Get-HostedOutboundSpamFilterPolicy | Set-HostedOutboundSpamFilterPolicy -
AutoForwardingMode Off
```

References:

1. https://learn.microsoft.com/en-us/exchange/security-and-compliance/mail-flow-rules/mail-flow-rules
2. https://techcommunity.microsoft.com/t5/exchange-team-blog/all-you-need-to-know-about-automatic-email-forwarding-in/ba-p/2074888#:~:text=%20%20%20Automatic%20forwarding%20option%20%20,%
3. https://learn.microsoft.com/en-us/defender-office-365/outbound-spam-policies-external-email-forwarding?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.2.2 Ensure mail transport rules do not whitelist specific domains (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Mail flow rules (transport rules) in Exchange Online can be configured to set the spam confidence level (SCL) of a message to `-1`, which bypasses spam and phishing filtering. When a rule applies this action to messages based on the sender's domain, all mail from that domain is treated as trusted and skips anti-malware and anti-phishing evaluation regardless of message content.

Rationale:

Whitelisting domains in transport rules bypasses regular malware and phishing scanning, which can enable an attacker to launch attacks against your users from a safe haven domain.

Note: If an organization identifies a business need for an exception, the domain should only be whitelisted if inbound emails from that domain originate from a specific IP address. These exceptions should be documented and regularly reviewed.

Impact:

Removing SCL bypass rules will subject previously whitelisted domains to standard spam and phishing filtering. Mail from those domains that does not pass filtering may be quarantined or rejected, which could disrupt established business communications. Prior to removal, identify any rules in scope and coordinate with affected business owners. If a legitimate need exists, consider replacing domain-based whitelisting with approved sender lists at the connection level.

Audit:

To audit using the UI:

1. Navigate to `Exchange admin center` https://admin.exchange.microsoft.com
2. Click to expand `Mail Flow` and then select `Rules`.
3. Review each rule and ensure that a single rule does not contain both of these properties together:
    - Under **Apply this rule if:** `Sender's address domain portion belongs to any of these domains: '<domain>'`
    - Under **Do the following:** `Set the spam confidence level (SCL) to '-1'`

Note: Setting the spam confidence level to -1 indicates the message is from a trusted sender, so the message bypasses spam filtering. The recommendation fails if any external domain has a SCL of -1.

To audit using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-TransportRule | Where-Object { $_.setscl -eq -1 -and $_.SenderDomainIs -
ne $null }  | ft Name,SenderDomainIs,SetSCL
```

3. Transport rules that fail the audit will be shown. If no output is shown, the recommendation passes. To pass, all rules with `SetSCL` set to `-1` must not include any domains in the `SenderDomainIs` property.

Remediation:

To remediate using the UI:

1. Navigate to `Exchange admin center` https://admin.exchange.microsoft.com
2. Click to expand `Mail Flow` and then select `Rules`.
3. For each rule that sets the spam confidence level to -1 for a specific domain, select the rule and click `Delete`.

To remediate using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. To remove a specific non-compliant rule:

```
Remove-TransportRule -Identity "RuleName"
```

Note: If the rule serves a legitimate purpose beyond domain whitelisting, consider modifying it to remove the `SenderDomainIs` condition or the `SetSCL -1` action rather than deleting it entirely.

Default Value:

No mail flow rules that set the SCL to -1 based on sender domain exist by default.

References:

1. https://learn.microsoft.com/en-us/exchange/security-and-compliance/mail-flow-rules/configuration-best-practices
2. https://learn.microsoft.com/en-us/exchange/security-and-compliance/mail-flow-rules/mail-flow-rules

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.2.3 Ensure email from external senders is identified (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

External callouts provide a native experience to identify emails from senders outside the organization. This is achieved by presenting a new tag on emails called "External" (the string is localized based on the client language setting) and exposing related user interface at the top of the message reading view to see and verify the real sender's email address.

The recommended state is `ExternalInOutlook` set to `Enabled True`

Rationale:

Tagging emails from external senders helps to inform end users about the origin of the email. This can allow them to proceed with more caution and make informed decisions when it comes to identifying spam or phishing emails.

Mail flow rules are often used by Exchange administrators to accomplish the External email tagging by appending a tag to the front of a subject line. There are limitations to this outlined here. The preferred method in the CIS Benchmark is to use the native experience.

Note: Existing emails in a user's inbox from external senders are not tagged retroactively.

Impact:

Mail flow rules using external tagging must be disabled, along with third-party mail filtering tools that offer similar features, to avoid duplicate [External] tags.

External tags can consume additional screen space on systems with limited real estate, such as thin clients or mobile devices.

After enabling this feature via PowerShell, it may take 24-48 hours for users to see the External sender tag in emails from outside your organization. Rolling back the feature takes the same amount of time.

Note: Third-party tools that provide similar functionality will also meet compliance requirements, although Microsoft recommends using the native experience for better interoperability.

Audit:

To audit using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-ExternalInOutlook
```

3. For each identity verify `Enabled` is set to `True` and the `AllowList` only contains email addresses the organization has permitted to bypass external tagging.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-ExternalInOutlook -Enabled $true
```

Default Value:

Disabled (False)

References:

1. https://techcommunity.microsoft.com/t5/exchange-team-blog/native-external-sender-callouts-on-email-in-outlook/ba-p/2250098
2. https://learn.microsoft.com/en-us/powershell/module/exchange/set-externalinoutlook?view=exchange-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.3 Roles

6.3.1 Ensure users installing Outlook add-ins is not allowed (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Role assignment policies in Exchange Online control whether users can install and manage add-ins for Outlook. Three management roles govern this capability: `My Custom Apps` allows users to sideload custom add-ins, `My Marketplace Apps` allows users to install add-ins from the marketplace, and `My ReadWriteMailbox Apps` allows users to install add-ins that request read/write mailbox permissions. When these roles are assigned to a user's role assignment policy, users can self-install add-ins in both Outlook desktop and Outlook on the web, granting those add-ins access to mailbox data.

This recommendation applies to the default role assignment policy, which is automatically assigned to new mailboxes unless a custom policy is specified.

Rationale:

Attackers exploit vulnerable or malicious add-ins to read, exfiltrate, or modify mailbox content including email, calendar items, and contacts. Restricting user-installed add-ins reduces this attack surface and centralizes add-in approval with administrators.

Impact:

End users will be unable to self-install third-party Outlook add-ins. Administrators may receive requests to evaluate and deploy add-ins on behalf of users. Organizations that rely on user-deployed add-ins for business workflows should inventory those add-ins and deploy them centrally via Centralized Deployment before implementing this recommendation.

Audit:

To audit using the UI:

1. Navigate to `Exchange admin center` https://admin.exchange.microsoft.com.
2. Expand `Roles` and select `User roles`.
3. Select `Default Role Assignment Policy`.
4. In the properties pane on the right click on `Manage permissions`.
5. Under *Other roles* verify that `My Custom Apps`, `My Marketplace Apps`, and `My ReadWriteMailbox Apps` are not checked.

Note: As of this release of the Benchmark the manage permissions link no longer displays anything when a user assigned the Global Reader role clicks on it. As an alternative, users assigned the Global Reader directory role can inspect the Roles column or use the PowerShell method to perform the audit.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following script:

```
$RoleList = @(
    "My Custom Apps", "My Marketplace Apps", "My ReadWriteMailbox Apps"
)

$DefaultPolicy = Get-RoleAssignmentPolicy |
    Where-Object { $_.IsDefault -eq $true }

$NonCompliantRoles = $DefaultPolicy.AssignedRoles |
    Where-Object { $_ -in $RoleList }

Write-Host "Checking Default Role Assignment Policy: $($DefaultPolicy.Name)"

if ($NonCompliantRoles) {
    "Non-compliant - the following roles are assigned: " +
        ($NonCompliantRoles -join ", ")
} else {
    "Compliant - no add-in roles are assigned to the default policy."
}
```

3. Verify that the output indicates compliance. If `My Custom Apps`, `My Marketplace Apps`, or `My ReadWriteMailbox Apps` are listed, the default policy is non-compliant.

Remediation:

To remediate using the UI:

1. Navigate to Exchange admin center https://admin.exchange.microsoft.com.
2. Click to expand Roles and select User roles.
3. Select Default Role Assignment Policy.
4. In the properties pane on the right click on Manage permissions.
5. Under *Other roles* uncheck any non-compliant roles: My Custom Apps, My Marketplace Apps, and My ReadWriteMailbox Apps.
6. Click Save changes.

To remediate using PowerShell:

1. Connect to Exchange Online using Connect-ExchangeOnline.
2. Run the following script:

```
$TargetRoles = @(
    "My Custom Apps", "My Marketplace Apps", "My ReadWriteMailbox Apps"
)

$DefaultPolicy = Get-RoleAssignmentPolicy |
    Where-Object { $_.IsDefault -eq $true }

$Assignments = Get-ManagementRoleAssignment -RoleAssignee
$DefaultPolicy.Identity |
    Where-Object { $_.Role -in $TargetRoles }

foreach ($Assignment in $Assignments) {
    Remove-ManagementRoleAssignment -Identity $Assignment.Identity -
Confirm:$false
}
```

Default Value:

UI - My Custom Apps, My Marketplace Apps, and My ReadWriteMailbox Apps are checked.

PowerShell - My Custom Apps, My Marketplace Apps, and My ReadWriteMailbox Apps are assigned.

References:

1. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/add-ins-for-outlook/specify-who-can-install-and-manage-add-ins?source=recommendations
2. https://learn.microsoft.com/en-us/exchange/permissions-exo/role-assignment-policies

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	9.4 Restrict Unnecessary or Unauthorized Browser and Email Client Extensions Restrict, either through uninstalling or disabling, any unauthorized or unnecessary browser or email client plugins, extensions, and add-on applications.		●	●

6.3.2 Ensure the ability to add personal email accounts and calendars is disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Outlook on the web (OWA) mailbox policies include two settings that control personal account integration in Outlook. `PersonalAccountsEnabled` controls whether users can add personal email accounts (e.g., Outlook.com, Gmail, Yahoo) in the new Outlook for Windows. `PersonalAccountCalendarsEnabled` controls whether users can connect personal Outlook.com or Google calendars in Outlook on the web. Neither setting applies to classic Outlook for Windows, Outlook for Mac, or Outlook mobile apps.

The recommended state for the default OWA Mailbox Policy is:

- `PersonalAccountsEnabled` is set to `False`
- `PersonalAccountCalendarsEnabled` is set to `False`

Rationale:

Personal email accounts are not subject to corporate security controls such as anti-malware scanning, data loss prevention (DLP), Safe Links, or audit logging. Allowing personal accounts alongside the corporate mailbox enables side-channel data exfiltration (e.g., forwarding sensitive content to a personal inbox) and creates an ingress path for malware and phishing payloads that bypass tenant mail-flow protections.

Impact:

This control does not apply to classic Outlook for Windows, Outlook for Mac, or Outlook mobile apps. Organizations requiring broader coverage should evaluate additional controls like application management policies to restrict personal account usage on those clients. This also does not block users from accessing personal accounts via other email clients or web browsers.

Changes to OWA mailbox policies may take up to 60 minutes to take effect. If users previously added personal accounts before this policy was applied, those accounts will be disabled once the policy is detected, and affected users will see a message advising them to remove the personal account from Outlook, which may generate helpdesk inquiries.

The audit only applies to the default OWA mailbox policy. Users assigned to a non-default OWA mailbox policy are not covered; optionally, custom policies can be reviewed separately to ensure a level of enforcement beyond the compliance requirements of this control.

Audit:

Note: The default OWA Mailbox Policy is the only policy required for compliance with this control. Other mailbox policies are discretionary and left up to the organization to audit as needed.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following:

```
Get-OwaMailboxPolicy | Where-Object { $_.IsDefault } |
Format-List PersonalAccountsEnabled, PersonalAccountCalendarsEnabled
```

3. Verify the output matches the following:

```
PersonalAccountsEnabled          : False
PersonalAccountCalendarsEnabled  : False
```

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following:

```
$DefaultPolicy = Get-OwaMailboxPolicy | Where-Object { $_.IsDefault }
Set-OwaMailboxPolicy -Identity $DefaultPolicy.Identity -
PersonalAccountsEnabled $false -PersonalAccountCalendarsEnabled $false
```

Default Value:

- `PersonalAccountsEnabled` is `True`.
- `PersonalAccountCalendarsEnabled` is `True`.

References:

1. https://learn.microsoft.com/en-us/powershell/module/exchangepowershell/set-owamailboxpolicy?view=exchange-ps#-personalaccountsenabled
2. https://learn.microsoft.com/en-us/microsoft-365-apps/outlook/get-started/supported-account-types#prevent-adding-personal-accounts
3. https://learn.microsoft.com/en-us/microsoft-365-apps/outlook/manage/policy-management

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

6.4 Reports

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

6.5 Settings

6.5.1 Ensure modern authentication for Exchange Online is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Modern authentication in Microsoft 365 enables authentication features like multifactor authentication (MFA) using smart cards, certificate-based authentication (CBA), and third-party SAML identity providers. When you enable modern authentication in Exchange Online, Outlook 2016 and Outlook 2013 use modern authentication to log in to Microsoft 365 mailboxes. When you disable modern authentication in Exchange Online, Outlook 2016 and Outlook 2013 use basic authentication to log in to Microsoft 365 mailboxes.

When users initially configure certain email clients, like Outlook 2013 and Outlook 2016, they may be required to authenticate using enhanced authentication mechanisms, such as multifactor authentication. Other Outlook clients that are available in Microsoft 365 (for example, Outlook Mobile and Outlook for Mac 2016) always use modern authentication to log in to Microsoft 365 mailboxes.

Rationale:

Strong authentication controls, such as the use of multifactor authentication, may be circumvented if basic authentication is used by Exchange Online email clients such as Outlook 2016 and Outlook 2013. Enabling modern authentication for Exchange Online ensures strong authentication mechanisms are used when establishing sessions between email clients and Exchange Online.

Impact:

Users of older email clients, such as Outlook 2013 and Outlook 2016, will no longer be able to authenticate to Exchange using Basic Authentication, which will necessitate migration to modern authentication practices.

Audit:

To audit using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` and select `Org Settings`.
3. Select `Modern authentication`.
4. Verify that `Turn on modern authentication for Outlook 2013 for Windows and later (recommended)` is checked.

To audit using PowerShell:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect to Exchange Online using `Connect-ExchangeOnline`.
3. Run the following PowerShell command:

```
Get-OrganizationConfig | Format-Table -Auto Name, OAuth*
```

4. Verify that `OAuth2ClientProfileEnabled` is `True`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft 365 admin center` https://admin.microsoft.com.
2. Expand `Settings` and select `Org Settings`.
3. Select `Modern authentication`.
4. Check `Turn on modern authentication for Outlook 2013 for Windows and later (recommended)` to enable modern authentication.

To remediate using PowerShell:

1. Run the Microsoft Exchange Online PowerShell Module.
2. Connect to Exchange Online using `Connect-ExchangeOnline`.
3. Run the following PowerShell command:

```
Set-OrganizationConfig -OAuth2ClientProfileEnabled $True
```

Default Value:

True

References:

1. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/enable-or-disable-modern-authentication-in-exchange-online

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●
v7	16.5 Encrypt Transmittal of Username and Authentication Credentials Ensure that all account usernames and authentication credentials are transmitted across networks using encrypted channels.		●	●

6.5.2 Ensure MailTips are enabled for end users (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

MailTips are informative messages displayed to users while they're composing a message. While a new message is open and being composed, Exchange analyzes the message (including recipients). If a potential problem is detected, the user is notified with a MailTip prior to sending the message. Using the information in the MailTip, the user can adjust the message to avoid undesirable situations or non-delivery reports (also known as NDRs or bounce messages).

Rationale:

Setting up MailTips gives a visual aid to users when they send emails to large groups of recipients or send emails to recipients not within the tenant.

Impact:

Not applicable.

Audit:

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-OrganizationConfig | fl MailTips*
```

3. Verify the values for `MailTipsAllTipsEnabled`, `MailTipsExternalRecipientsTipsEnabled`, and `MailTipsGroupMetricsEnabled` are set to `True` and `MailTipsLargeAudienceThreshold` is set to an acceptable value; `25` is the default value.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
$TipsParams = @{
    MailTipsAllTipsEnabled                = $true
    MailTipsExternalRecipientsTipsEnabled  = $true
    MailTipsGroupMetricsEnabled            = $true
    MailTipsLargeAudienceThreshold         = '25'
}

Set-OrganizationConfig @TipsParams
```

Default Value:

MailTipsAllTipsEnabled: True MailTipsExternalRecipientsTipsEnabled: False MailTipsGroupMetricsEnabled: True MailTipsLargeAudienceThreshold: 25

References:

1. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/mailtips/mailtips
2. https://learn.microsoft.com/en-us/powershell/module/exchange/set-organizationconfig?view=exchange-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

6.5.3 Ensure additional storage providers are restricted in Outlook on the web (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting allows users to open certain external files while working in Outlook on the web. If allowed, keep in mind that Microsoft doesn't control the use terms or privacy policies of those third-party services.

Ensure `AdditionalStorageProvidersAvailable` is restricted on the default OWA policy.

Rationale:

By default, additional storage providers are allowed in Office on the Web (such as Box, Dropbox, Facebook, Google Drive, OneDrive Personal, etc.). This could lead to information leakage and additional risk of infection from organizational non-trusted storage providers. Restricting this will inherently reduce risk as it will narrow opportunities for infection and data leakage.

Impact:

The impact associated with this change is highly dependent upon current practices in the tenant. If users do not use other storage providers, then minimal impact is likely. However, if users do regularly utilize providers outside of the tenant this will affect their ability to continue to do so.

Audit:

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command to audit the default OWA policy:

```
Get-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default |
fl AdditionalStorageProvidersAvailable
```

3. Verify that `AdditionalStorageProvidersAvailable` is `False`.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-OwaMailboxPolicy -Identity OwaMailboxPolicy-Default -
AdditionalStorageProvidersAvailable $false
```

Default Value:

AdditionalStorageProvidersAvailable : True

References:

1. https://learn.microsoft.com/en-us/powershell/module/exchange/set-owamailboxpolicy?view=exchange-ps
2. https://support.microsoft.com/en-us/topic/3rd-party-cloud-storage-services-supported-by-office-apps-fce12782-eccc-4cf5-8f4b-d1ebec513f72

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v7	13.4 Only Allow Access to Authorized Cloud Storage or Email Providers Only allow access to authorized cloud storage or email providers.		●	●

6.5.4 Ensure SMTP AUTH is disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting enables or disables authenticated client SMTP submission (SMTP AUTH) at an organization level in Exchange Online.

The recommended state is `Turn off SMTP AUTH protocol for your organization` (checked).

Rationale:

SMTP AUTH is a legacy protocol. Disabling it at the organization level supports the principle of least functionality and serves to further back additional controls that block legacy protocols, such as in Conditional Access. Virtually all modern email clients that connect to Exchange Online mailboxes in Microsoft 365 can do so without using SMTP AUTH.

Impact:

This enforces the default behavior, so no impact is expected unless the organization is using it globally. A per-mailbox setting exists that overrides the tenant-wide setting, allowing an individual mailbox SMTP AUTH capability for special cases.

Audit:

To audit using the UI:

1. Navigate to `Exchange admin center` https://admin.exchange.microsoft.com.
2. Expand `Settings` and select `Mail flow`.
3. Ensure `Turn off SMTP AUTH protocol for your organization` is checked.

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-TransportConfig | Format-List SmtpClientAuthenticationDisabled
```

3. Verify that the value returned is `True`.

Remediation:

To remediate using the UI:

1. Navigate to `Exchange admin center` https://admin.exchange.microsoft.com.
2. Expand `Settings` and select `Mail flow`.
3. Check `Turn off SMTP AUTH protocol for your organization` to disable the protocol.

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-TransportConfig -SmtpClientAuthenticationDisabled $true
```

Default Value:

SmtpClientAuthenticationDisabled : True

References:

1. https://learn.microsoft.com/en-us/exchange/clients-and-mobile-in-exchange-online/authenticated-client-smtp-submission

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

6.5.5 Ensure Direct Send submissions are rejected (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Direct Send is a method used to send emails directly to an Exchange Online customer's hosted mailboxes from on-premises devices, applications, or third-party cloud services using the customer's own accepted domain. This method does not require any form of authentication because, by its nature, it mimics incoming anonymous emails from the internet, apart from the sender domain.

The recommended state is to configure `RejectDirectSend` to `True`.

Rationale:

Direct Send allows devices and applications to transmit unauthenticated email directly to Exchange Online. While this method may support legacy systems such as printers or scanners, it introduces significant security risks:

- Unauthenticated Email Delivery: Direct Send does not require authentication, making it an attractive vector for threat actors to deliver spoofed or malicious emails that appear to originate from trusted internal sources.
- Phishing and Spoofing Risks: Because these emails bypass standard authentication mechanisms, they can easily impersonate internal users or services, increasing the likelihood of successful phishing attacks.
- Lack of Visibility and Control: Emails sent via Direct Send may not be subject to the same security policies, logging, or filtering as authenticated traffic, reducing the organization's ability to monitor and respond to threats effectively.

Threat research from Varonis has shown that attackers are actively exploiting Direct Send to impersonate internal accounts and distribute malicious content without needing to compromise any credentials. These campaigns have successfully targeted organizations by leveraging predictable infrastructure and public user data to craft convincing phishing emails. Because these messages originate from outside the tenant but appear internal, they often evade detection and filtering mechanisms.

Impact:

Per Microsoft, there is a forwarding scenario that could be affected by this feature. It is possible that someone in your organization sends a message to a 3rd party and they in turn forward it to another mailbox in your organization. If the 3rd party's email provider does not support Sender Rewriting Scheme (SRS), the message will return with the original sender's address. Prior to this feature being enabled, those messages will already be punished by SPF failing but could still end up in inboxes. Enabling the Reject Direct Send feature without a partner mail flow connector being set up will lead to these messages being rejected outright.

Audit:

To audit using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Get-OrganizationConfig | fl RejectDirectSend
```

3. Verify that the value returned for `RejectDirectSend` is `True`.

Remediation:

To remediate using PowerShell:

1. Connect to Exchange Online using `Connect-ExchangeOnline`.
2. Run the following PowerShell command:

```
Set-OrganizationConfig -RejectDirectSend $true
```

Default Value:

RejectDirectSend : False

References:

1. https://techcommunity.microsoft.com/blog/exchange/introducing-more-control-over-direct-send-in-exchange-online/4408790?WT.mc_id=M365-MVP-9501
2. https://techcommunity.microsoft.com/blog/exchange/direct-send-vs-sending-directly-to-an-exchange-online-tenant/4439865
3. https://learn.microsoft.com/en-us/powershell/module/exchangepowershell/set-organizationconfig?view=exchange-ps
4. https://www.varonis.com/blog/direct-send-exploit
5. https://techcommunity.microsoft.com/discussions/microsoft-365/disable-direct-send-in-exchange-online-to-mitigate-ongoing-phishing-threats/4434649

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v8	12.6 Use of Secure Network Management and Communication Protocols Use secure network management and communication protocols (e.g., 802.1X, Wi-Fi Protected Access 2 (WPA2) Enterprise or greater).		●	●

7 SharePoint admin center

The SharePoint admin center contains settings related to SharePoint and OneDrive.

UI Direct link: https://admin.microsoft.com/sharepoint

The PowerShell module most used in this section is `Microsoft.Online.SharePoint.PowerShell` and uses `Connect-SPOService -Url https://contoso-admin.sharepoint.com` as the connection cmdlet (replacing tenant name with your value).

The latest version of the module can be downloaded here: https://www.powershellgallery.com/packages/Microsoft.Online.SharePoint.PowerShell/

7.1 Sites

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

7.2 Policies

7.2.1 Ensure modern authentication for SharePoint applications is required (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Modern authentication in Microsoft 365 enables authentication features like multifactor authentication (MFA) using smart cards, certificate-based authentication (CBA), and third-party SAML identity providers.

Rationale:

Strong authentication controls, such as the use of multifactor authentication, may be circumvented if basic authentication is used by SharePoint applications. Requiring modern authentication for SharePoint applications ensures strong authentication mechanisms are used when establishing sessions between these applications, SharePoint, and connecting users.

Impact:

Implementation of modern authentication for SharePoint will require users to authenticate to SharePoint using modern authentication. This may cause a minor impact to typical user behavior.

This may also prevent third-party apps from accessing SharePoint Online resources. Also, this will also block apps using the SharePointOnlineCredentials class to access SharePoint Online resources.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint.
2. Expand Policies and select Access control.
3. Select Apps that don't use modern authentication and ensure that it is set to Block access.

To audit using PowerShell:

1. Connect to SharePoint Online using Connect-SPOService -Url https://tenant-admin.sharepoint.com replacing tenant with your value.
2. Run the following SharePoint Online PowerShell command:

```
Get-SPOTenant | ft LegacyAuthProtocolsEnabled
```

3. Verify that the returned value is False.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint.
2. Expand Policies and select Access control.
3. Select Apps that don't use modern authentication.
4. Select the radio button for Block access.
5. Click Save.

To remediate using PowerShell:

1. Connect to SharePoint Online using Connect-SPOService -Url https://tenant-admin.sharepoint.com replacing tenant with your value.
2. Run the following SharePoint Online PowerShell command:

```
Set-SPOTenant -LegacyAuthProtocolsEnabled $false
```

Default Value:

True (Apps that don't use modern authentication are allowed)

References:

1. https://learn.microsoft.com/en-us/powershell/module/sharepoint-online/set-spotenant?view=sharepoint-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.7 Centralize Access Control Centralize access control for all enterprise assets through a directory service or SSO provider, where supported.		●	●

7.2.2 Ensure SharePoint and OneDrive integration with Azure AD B2B is enabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Entra ID B2B provides authentication and management of guests. Authentication happens via one-time passcode when they don't already have a work or school account or a Microsoft account. Integration with SharePoint and OneDrive allows for more granular control of how guest user accounts are managed in the organization's AAD, unifying a similar guest experience already deployed in other Microsoft 365 services such as Teams.

Note: Global Reader role currently can't access SharePoint using PowerShell.

Rationale:

External users assigned guest accounts will be subject to Entra ID access policies, such as multi-factor authentication. This provides a way to manage guest identities and control access to SharePoint and OneDrive resources. Without this integration, files can be shared without account registration, making it more challenging to audit and manage who has access to the organization's data.

Impact:

After enabling Microsoft Entra B2B integration, external users attempting to access previously shared links (One Time Passcode) will encounter access issues. They receive error 'This organization has updated its guest access settings'. To restore access, your users need to reshare files/folders/sites to external users.

Audit:

To audit using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService`
2. Run the following command:

```
Get-SPOTenant | ft EnableAzureADB2BIntegration
```

3. Verify that the returned value is `True`.

Remediation:

To remediate using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService`
2. Run the following command:

```
Set-SPOTenant -EnableAzureADB2BIntegration $true
```

Default Value:

False

References:

1. https://learn.microsoft.com/en-us/sharepoint/sharepoint-azureb2b-integration#enabling-the-integration
2. https://learn.microsoft.com/en-us/entra/external-id/what-is-b2b
3. https://learn.microsoft.com/en-us/powershell/module/sharepoint-online/set-spotenant?view=sharepoint-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.3 Ensure external content sharing is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

The external sharing settings govern sharing for the organization overall. Each site has its own sharing setting that can be set independently, though it must be at the same or more restrictive setting as the organization.

The new and existing guests option requires people who have received invitations to sign in with their work or school account (if their organization uses Microsoft 365) or a Microsoft account, or to provide a code to verify their identity. Users can share with guests already in your organization's directory, and they can send invitations to people who will be added to the directory if they sign in.

The recommended state is `New and existing guests` or less permissive.

Rationale:

Forcing guest authentication on the organization's tenant enables the implementation of controls and oversight over external file sharing. When a guest is registered with the organization, they now have an identity which can be accounted for. This identity can also have other restrictions applied to it through group membership and conditional access rules.

Impact:

When using B2B integration, Entra ID external collaboration settings, such as guest invite settings and collaboration restrictions apply.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Locate the External sharing section.
4. Under SharePoint, verify that the slider bar is set to New and existing guests or a less permissive level.

To audit using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Get-SPOTenant | fl SharingCapability
```

3. Verify that SharingCapability is set to one of the following values:
    - ExternalUserSharingOnly
    - ExistingExternalUserSharingOnly
    - Disabled

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Locate the External sharing section.
4. Under SharePoint, move the slider bar to New and existing guests or a less permissive level.
    - OneDrive will also be moved to the same level and can never be more permissive than SharePoint.

To remediate using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet to establish the minimum recommended state:

```
Set-SPOTenant -SharingCapability ExternalUserSharingOnly
```

Note: Other acceptable values for this parameter that are more restrictive include: Disabled and ExistingExternalUserSharingOnly.

Default Value:

Anyone (ExternalUserAndGuestSharing)

References:

1. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off
2. https://learn.microsoft.com/en-us/powershell/module/sharepoint-online/set-spotenant?view=sharepoint-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

7.2.4 Ensure OneDrive content sharing is restricted (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting governs the global permissiveness of OneDrive content sharing in the organization.

OneDrive content sharing can be restricted independent of SharePoint but can never be more permissive than the level established with SharePoint.

The recommended state is `Only people in your organization`.

Rationale:

OneDrive, designed for end-user cloud storage, inherently provides less oversight and control compared to SharePoint, which often involves additional content overseers or site administrators. This autonomy can lead to potential risks such as inadvertent sharing of privileged information by end users. Restricting external OneDrive sharing will require users to transfer content to SharePoint folders first which have those tighter controls.

Impact:

Users will be required to take additional steps to share OneDrive content or use other official channels.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Locate the External sharing section.
4. Under OneDrive, verify that the slider bar is set to Only people in your organization.

To audit using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Get-SPOTenant | fl OneDriveSharingCapability
```

3. Verify that the returned value is Disabled.

Alternative audit method using PowerShell:

1. Connect to SharePoint Online.
2. Use one of the following methods:

```
# Replace [tenant] with your tenant id
Get-SPOSite -Identity https://[tenant]-my.sharepoint.com/ | fl
Url,SharingCapability

# Or run this to filter to the specific site without supplying the tenant
name.
$OneDriveSite = Get-SPOSite -Filter { Url -like "*-my.sharepoint.com/" }
Get-SPOSite -Identity $OneDriveSite | fl Url,SharingCapability
```

2. Verify that the returned value for SharingCapability is Disabled

Note: As of March 2024, using Get-SPOSite with Where-Object or filtering against the entire site and then returning the SharingCapability parameter can result in a different value as opposed to running the cmdlet specifically against the OneDrive specific site using the -Identity switch as shown in the example.

Note 2: The parameter OneDriveSharingCapability may not be yet fully available in all tenants. It is demonstrated in official Microsoft documentation as linked in the references section but not in the Set-SPOTenant cmdlet itself. If the parameter is unavailable, then either use the UI method or alternative PowerShell audit method.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Locate the External sharing section.
4. Under OneDrive, set the slider bar to Only people in your organization.

To remediate using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Set-SPOTenant -OneDriveSharingCapability Disabled
```

Alternative remediation method using PowerShell:

1. Connect to SharePoint Online.
2. Run one of the following:

```
# Replace [tenant] with your tenant id
Set-SPOSite -Identity https://[tenant]-my.sharepoint.com/ -SharingCapability
Disabled

# Or run this to filter to the specific site without supplying the tenant
name.
$OneDriveSite = Get-SPOSite -Filter { Url -like "*-my.sharepoint.com/" }
Set-SPOSite -Identity $OneDriveSite -SharingCapability Disabled
```

Default Value:

Anyone (ExternalUserAndGuestSharing)

References:

1. https://learn.microsoft.com/en-us/powershell/module/sharepoint-online/set-spotenant?view=sharepoint-ps#-onedrivesharingcapability

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

7.2.5 Ensure that SharePoint guest users cannot share items they don't own (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

SharePoint gives users the ability to share files, folders, and site collections. Internal users can share with external collaborators, and with the right permissions could share to other external parties.

Rationale:

Sharing and collaboration are key; however, file, folder, or site collection owners should have the authority over what external users get shared with to prevent unauthorized disclosures of information.

Impact:

The impact associated with this change is highly dependent upon current practices. If users do not regularly share with external parties, then minimal impact is likely. However, if users do regularly share with guests/externally, minimum impacts could occur as those external users will be unable to 're-share' content.

Audit:

To audit using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Expand `More external sharing settings`, verify that `Allow guests to share items they don't own` is unchecked.

To audit using PowerShell:

1. Connect to SharePoint Online service using `Connect-SPOService`.
2. Run the following SharePoint Online PowerShell command:

```
Get-SPOTenant | ft PreventExternalUsersFromResharing
```

3. Verify that the returned value is `True`.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Expand More external sharing settings, uncheck Allow guests to share items they don't own.
4. Click Save.

To remediate using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following SharePoint Online PowerShell command:

```
Set-SPOTenant -PreventExternalUsersFromResharing $True
```

Default Value:

Checked (False)

References:

1. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off
2. https://learn.microsoft.com/en-us/sharepoint/external-sharing-overview

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.2.6 Ensure SharePoint external sharing is restricted (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

The external sharing features of SharePoint and OneDrive let users in the organization share content with people outside the organization (such as partners, vendors, clients, or customers). It can also be used to share between licensed users on multiple Microsoft 365 subscriptions if your organization has more than one subscription.

The recommended state is `Limit external sharing by domain` > `Allow only specific domains`

Rationale:

Attackers will often attempt to expose sensitive information to external entities through sharing, and restricting the domains that users can share documents with will reduce that surface area.

Impact:

Users will be unable to initiate new shares with parties whose domains are not on the approved allowlist, which may require administrative action before collaboration with new partners or vendors can begin. Administrators must keep the allowlist current to reflect active business relationships; an outdated list can block legitimate sharing and generate support requests. Note that existing shares to domains not on the allowlist are not revoked when this setting is configured.

Audit:

Note: If the SharePoint external sharing slider is set to `Only people in your organization`, this recommendation is compliant regardless of the configured value for `Limit external sharing by domain`.

To audit using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Locate the `External sharing` section.
4. If the SharePoint slider is set to `Only people in your organization`, this recommendation is compliant.
5. Otherwise, expand `More external sharing settings` and confirm that `Limit external sharing by domain` is checked.
6. Verify that `Allow only specific domains` is selected and that domains listed are approved by the organization.

To audit using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService`.
2. Run the following PowerShell command:

```
Get-SPOTenant | fl
SharingCapability,SharingDomainRestrictionMode,SharingAllowedDomainList
```

3. Verify that one of the following conditions is true:
    - `SharingCapability` is `Disabled`, OR
    - `SharingDomainRestrictionMode` is `AllowList` and `SharingAllowedDomainList` contains domains trusted by the organization for external sharing.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint.
2. Expand Policies > Sharing.
3. Expand More external sharing settings and check Limit external sharing by domain.
4. Select Add domains, choose Allow only specific domains, enter the list of approved domain names, and select Done.
5. Click Save at the bottom of the page.

To remediate using PowerShell:

1. Connect to SharePoint Online using Connect-SPOService.
2. Run the following PowerShell command:

```
Set-SPOTenant -SharingDomainRestrictionMode AllowList -
SharingAllowedDomainList "domain1.com domain2.com"
```

Default Value:

Limit external sharing by domain is unchecked

SharingDomainRestrictionMode: None

SharingAllowedDomainList: (empty)

References:

1. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off?WT.mc_id=365AdminCSH_spo#more-external-sharing-settings

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	13.4 Only Allow Access to Authorized Cloud Storage or Email Providers Only allow access to authorized cloud storage or email providers.		●	●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

7.2.7 Ensure link sharing is restricted in SharePoint and OneDrive (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting sets the default link type that a user will see when sharing content in OneDrive or SharePoint. It does not restrict or exclude any other options.

The recommended state is `Specific people (only the people the user specifies)` or `Only people in your organization`.

Rationale:

By defaulting to specific people, the user will first need to consider whether or not the content being shared should be accessible by the entire organization versus select individuals. This aids in reinforcing the concept of least privilege.

Impact:

Changing the default sharing link type influences the user experience when sharing files and folders in SharePoint and OneDrive. The configured default option will appear pre-selected in the sharing dialog, guiding users toward the organization's preferred sharing method.

Audit:

To audit using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Scroll to `File and folder links`.
4. Verify that the setting `Choose the type of link that's selected by default when users share files and folders in SharePoint and OneDrive` is set to `Specific people (only the people the user specifies)` or `Only people in your organization`.

To audit using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService`.
2. Run the following PowerShell command:

```
Get-SPOTenant | fl DefaultSharingLinkType
```

3. Verify that the returned value is `Direct` or `Internal`.

Remediation:

To remediate using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Scroll to `File and folder links`.
4. Set `Choose the type of link that's selected by default when users share files and folders in SharePoint and OneDrive` to `Specific people (only the people the user specifies)` or `Only people in your organization`.

To remediate using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService`.
2. Run one of the following PowerShell commands depending on the desired compliant state:

To set the default sharing link to specific people:

```
Set-SPOTenant -DefaultSharingLinkType Direct
```

To set the default sharing link to people in the organization:

```
Set-SPOTenant -DefaultSharingLinkType Internal
```

Default Value:

Only people in your organization (Internal)

References:

1. https://learn.microsoft.com/en-us/powershell/module/sharepoint-online/set-spotenant?view=sharepoint-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

7.2.8 Ensure external sharing is restricted by security group (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

External sharing of content can be restricted to specific security groups. This setting is global, applies to sharing in both SharePoint and OneDrive and cannot be set at the site level in SharePoint.

Rationale:

Without restricting external sharing to designated security groups, any user in the organization can share SharePoint or OneDrive content with external recipients. A compromised or insider-threat account can exfiltrate sensitive data by sharing files externally without additional authorization controls. Limiting external sharing to members of specific Entra ID security groups ensures that only reviewed and authorized users have this capability, reducing the attack surface for data exfiltration through sharing.

Impact:

Users who are not members of the designated security groups will lose the ability to create new external shares or invite new external guests. Existing sharing links they previously established will remain active for current recipients. Organizations should ensure the security groups are populated with appropriate members before enabling this setting to avoid inadvertently blocking all external sharing. Helpdesk volume may increase as users in non-designated groups encounter sharing restrictions.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Locate the External sharing section.
4. If the SharePoint slider is set to Only people in your organization, this recommendation is compliant.
5. Otherwise, scroll to and expand More external sharing settings.
6. Verify the following:
    - Allow only users in specific security groups to share externally is checked
    - Manage security groups contains at least one security group.

To audit using PowerShell:

1. Connect to SharePoint Online using Connect-SPOService.
2. Run the following PowerShell command:

```
Get-SPOTenant | fl SharingCapability, WhoCanShareAuthenticatedGuestAllowList
```

3. Verify the output using the following logic:
    - If SharingCapability is Disabled, the recommendation is compliant regardless of the value of WhoCanShareAuthenticatedGuestAllowList.
    - Otherwise, verify that WhoCanShareAuthenticatedGuestAllowList contains at least one security group GUID. If the value is empty or $null, the recommendation is not compliant.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Scroll to and expand More external sharing settings.
4. Set the following:
    - Check Allow only users in specific security groups to share externally
    - Click Manage security groups, then add at least one security group authorized for external sharing.

To remediate using PowerShell:

1. Connect to SharePoint Online using Connect-SPOService.
2. Run the following command, replacing <GroupObjectId> with the GUID of the security group to be authorized for external sharing:

```
Set-SPOTenant -WhoCanShareAuthenticatedGuestAllowList "<GroupObjectId>"
```

Note: To authorize multiple security groups, provide a comma-delimited list of Object IDs: "<GroupObjectId1>","<GroupObjectId2>".

Note: Users in the designated security groups must also be permitted to invite guests in Microsoft Entra. Verify this at Identity > External Identities > External collaboration settings.

Default Value:

By default, this restriction is not in place, allowing any user in the organization to share content externally, subject only to the top-level sharing slider.

References:

1. https://learn.microsoft.com/en-us/sharepoint/manage-security-groups
2. https://learn.microsoft.com/en-us/powershell/module/microsoft.online.sharepoint.powershell/set-spotenant?view=sharepoint-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

7.2.9 Ensure guest access to a site or OneDrive will expire automatically (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting configures the expiration time for each guest that is invited to the SharePoint site or with whom users share individual files and folders with.

Expiration can be a number 30 to 730.

The recommended state is `30`.

Rationale:

This setting ensures that guests who no longer need access to the site or link no longer have access after a set period of time. Allowing guest access for an indefinite amount of time could lead to loss of data confidentiality and oversight.

Note: Guest membership applies at the Microsoft 365 group level. Guests who have permission to view a SharePoint site or use a sharing link may also have access to a Microsoft Teams team or security group.

Impact:

Site collection administrators will have to renew access to guests who still need access after 30 days. They will receive an e-mail notification once per week about guest access that is about to expire.

Note: The guest expiration policy only applies to guests who use sharing links or guests who have direct permissions to a SharePoint site after the guest policy is enabled. The guest policy does not apply to guest users that have pre-existing permissions or access through a sharing link before the guest expiration policy is applied.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Scroll to and expand More external sharing settings.
4. Verify that Guest access to a site or OneDrive will expire automatically after this many days is checked and set to 30.

To audit using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Get-SPOTenant | fl ExternalUserExpirationRequired,ExternalUserExpireInDays
```

3. Verify the following values are returned:
    - ExternalUserExpirationRequired is True.
    - ExternalUserExpireInDays is 30.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Scroll to and expand More external sharing settings.
4. Set Guest access to a site or OneDrive will expire automatically after this many days to 30

To remediate using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Set-SPOTenant -ExternalUserExpireInDays 30 -ExternalUserExpirationRequired
$True
```

Default Value:

ExternalUserExpirationRequired `$false`

ExternalUserExpireInDays `60` days

References:

1. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off#change-the-organization-level-external-sharing-setting
2. https://learn.microsoft.com/en-us/microsoft-365/community/sharepoint-security-a-team-effort

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.10 Ensure reauthentication with verification code is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting configures if guests who use a verification code to access the site or links are required to reauthenticate after a set number of days.

The recommended state is `15` or less.

Rationale:

By increasing the frequency of times guests need to reauthenticate this ensures guest user access to data is not prolonged beyond an acceptable amount of time.

Impact:

Guests who use Microsoft 365 in their organization can sign in using their work or school account to access the site or document. After the one-time passcode for verification has been entered for the first time, guests will authenticate with their work or school account and have a guest account created in the host's organization.

Note: If OneDrive and SharePoint integration with Entra ID B2B is enabled as per the CIS Benchmark the one-time-passcode experience will be replaced. Please visit Secure external sharing in SharePoint - SharePoint in Microsoft 365 | Microsoft Learn for more information.

Audit:

To audit using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Scroll to and expand More external sharing settings.
4. Verify that People who use a verification code must reauthenticate after this many days is set to 15 or less.

To audit using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Get-SPOTenant | fl EmailAttestationRequired,EmailAttestationReAuthDays
```

3. Verify that the following values are returned:
    - EmailAttestationRequired True
    - EmailAttestationReAuthDays 15 or less days.

Remediation:

To remediate using the UI:

1. Navigate to SharePoint admin center https://admin.microsoft.com/sharepoint
2. Expand Policies > Sharing.
3. Scroll to and expand More external sharing settings.
4. Set People who use a verification code must reauthenticate after this many days to 15 or less.

To remediate using PowerShell:

1. Connect to SharePoint Online service using Connect-SPOService.
2. Run the following cmdlet:

```
Set-SPOTenant -EmailAttestationRequired $true -EmailAttestationReAuthDays 15
```

Default Value:

EmailAttestationRequired : `False`

EmailAttestationReAuthDays : `30`

References:

1. https://learn.microsoft.com/en-us/sharepoint/what-s-new-in-sharing-in-targeted-release
2. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off#change-the-organization-level-external-sharing-setting
3. https://learn.microsoft.com/en-us/entra/external-id/one-time-passcode

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

7.2.11 Ensure the SharePoint default sharing link permission is set (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting configures the permission that is selected by default for sharing link from a SharePoint site.

The recommended state is `View`.

Rationale:

Setting the view permission as the default ensures that users must deliberately select the edit permission when sharing a link. This approach reduces the risk of unintentionally granting edit privileges to a resource that only requires read access, supporting the principle of least privilege.

Impact:

Not applicable.

Audit:

To audit using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Scroll to **File and folder links**.
4. Verify that `Choose the permission that's selected by default for sharing links` is set to `View`.

To audit using PowerShell:

1. Connect to SharePoint Online service using `Connect-SPOService`.
2. Run the following cmdlet:

```
Get-SPOTenant | fl DefaultLinkPermission
```

3. Verify that the returned value is `View`.

Remediation:

To remediate using the UI:

1. Navigate to `SharePoint admin center` https://admin.microsoft.com/sharepoint
2. Expand `Policies` > `Sharing`.
3. Scroll to **File and folder links**.
4. Set `Choose the permission that's selected by default for sharing links` to `View`.

To remediate using PowerShell:

1. Connect to SharePoint Online service using `Connect-SPOService`.
2. Run the following cmdlet:

```
Set-SPOTenant -DefaultLinkPermission View
```

Default Value:

DefaultLinkPermission : Edit

References:

1. https://learn.microsoft.com/en-us/sharepoint/turn-external-sharing-on-or-off#file-and-folder-links

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

7.3 Settings

7.3.1 Ensure Office 365 SharePoint infected files are disallowed for download (Automated)

Profile Applicability:

- E5 Level 2

Description:

By default, SharePoint online allows files that Defender for Office 365 has detected as infected to be downloaded.

Rationale:

Defender for Office 365 for SharePoint, OneDrive, and Microsoft Teams protects your organization from inadvertently sharing malicious files. When an infected file is detected that file is blocked so that no one can open, copy, move, or share it until further actions are taken by the organization's security team.

Impact:

The only potential impact associated with implementation of this setting is potential inconvenience associated with the small percentage of false positive detections that may occur.

Audit:

To audit using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService -Url https://tenant-admin.sharepoint.com`, replacing "tenant" with the appropriate value.
2. Run the following PowerShell command:

```
Get-SPOTenant | Select-Object DisallowInfectedFileDownload
```

3. Ensure that the `DisallowInfectedFileDownload` is set to `True`.

Note: According to Microsoft, SharePoint cannot be accessed through PowerShell by users with the Global Reader role. For further information, please refer to the reference section.

Remediation:

To remediate using PowerShell:

1. Connect to SharePoint Online using `Connect-SPOService -Url https://tenant-admin.sharepoint.com`, replacing "tenant" with the appropriate value.
2. Run the following PowerShell command to set the recommended value:

```
Set-SPOTenant -DisallowInfectedFileDownload $true
```

Note: The Global Reader role cannot access SharePoint using PowerShell according to Microsoft. See the reference section for more information.

Default Value:

False

References:

1. https://learn.microsoft.com/en-us/defender-office-365/safe-attachments-for-spo-odfb-teams-configure?view=o365-worldwide
2. https://learn.microsoft.com/en-us/defender-office-365/anti-malware-protection-for-spo-odfb-teams-about?view=o365-worldwide
3. https://learn.microsoft.com/en-us/entra/identity/role-based-access-control/permissions-reference#global-reader

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	10.1 Deploy and Maintain Anti-Malware Software Deploy and maintain anti-malware software on all enterprise assets.	●	●	●
v7	7.10 Sandbox All Email Attachments Use sandboxing to analyze and block inbound email attachments with malicious behavior.			●
v7	8.1 Utilize Centrally Managed Anti-malware Software Utilize centrally managed anti-malware software to continuously monitor and defend each of the organization's workstations and servers.		●	●

8 Microsoft Teams admin center

The Microsoft Teams admin center contains settings related to Microsoft Teams.

UI Direct link: https://admin.teams.microsoft.com/

Following the October 2025 benchmark release, some subsections within this section assume your tenant has transitioned to the updated settings and policies experience. The guidance provided reflects the new blade design.

This experience is introduced with the message: “Save time and manage your organization’s settings and policies more efficiently with our simplified, all-in-one management center” and is accessible via the `Try the new experience button`. Using the new layout is not a prerequisite of applying the configuration hardening guidance but is recommended.

PowerShell specifics

- The PowerShell module most commonly used in this section is `MicrosoftTeams` and uses `Connect-MicrosoftTeams` as the connection cmdlet.
- The latest version of the module can be downloaded here: https://www.powershellgallery.com/packages/MicrosoftTeams/

In certain scenarios, the Microsoft Teams PowerShell module may throw unexpected errors during connection attempts. A reliable workaround is to launch PowerShell in single-threaded mode using the `-STA` (Single-Threaded Apartment) argument before executing any script blocks. This approach can help avoid issues related to multi-threading conflicts.

For PowerShell 5

```
powershell.exe -sta
```

For PowerShell 7.x

```
pwsh.exe -sta
```

8.1 Teams

8.1.1 Ensure external file sharing in Teams is enabled for only approved cloud storage services (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Microsoft Teams enables collaboration via file sharing. This file sharing is conducted within Teams, using SharePoint Online, by default; however, third-party cloud services are allowed as well.

Note: Skype for business is deprecated as of July 31, 2021 although these settings may still be valid for a period of time. See the link in the references section for more information.

Rationale:

Ensuring that only authorized cloud storage providers are accessible from Teams will help to dissuade the use of non-approved storage providers.

Impact:

The impact associated with this change is highly dependent upon current practices in the tenant. If users do not use other storage providers, then minimal impact is likely. However, if users do regularly utilize providers outside of the tenant this will affect their ability to continue to do so.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Select `Settings & policies` > `Global (Org-wide default) settings`.
3. Click `Teams` to open the **Teams settings** section.
4. Under **files** verify that only organizationally authorized cloud storage options are set to `On` and all others `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following to verify the recommended state:

```
$Params = @(
   'AllowDropbox'
   'AllowBox'
   'AllowGoogleDrive'
   'AllowShareFile'
   'AllowEgnyte'
)

Get-CsTeamsClientConfiguration -Identity Global | fl $Params
```

3. Verify that only authorized providers are set to `True` and all others `False.`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Select `Settings & policies` > `Global (Org-wide default) settings`.
3. Click `Teams` to open the **Teams settings** section.
4. Under **files** set storages providers to `Off` unless they have first been authorized by the organization.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following PowerShell command to disable external providers that are not authorized. (the example disables Citrix Files, DropBox, Box, Google Drive and Egnyte)

```
$Params = @{
    Identity = 'Global'
    AllowGoogleDrive = $false
    AllowShareFile = $false
    AllowBox = $false
    AllowDropBox = $false
    AllowEgnyte = $false
}

Set-CsTeamsClientConfiguration @Params
```

Default Value:

AllowDropBox : `True`

AllowBox : `True`

AllowGoogleDrive : `True`

AllowShareFile : `True`

AllowEgnyte : `True`

References:

1. https://learn.microsoft.com/en-us/microsoftteams/teams-powershell-managing-teams

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v7	14.7 Enforce Access Control to Data through Automated Tools Use an automated tool, such as host-based Data Loss Prevention, to enforce access controls to data even when data is copied off a system.			●

8.1.2 Ensure users can't send emails to a channel email address (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting controls whether Teams channels are allowed to receive emails sent to their unique email addresses. When enabled, emails sent to a channel's address will be delivered and appear in the channel's conversation thread; when disabled, the channel will reject incoming emails, preventing them from being posted.

The recommended state is `Off`.

Rationale:

Channel email addresses are not under the tenant’s domain and organizations do not have control over the security settings for this email address. An attacker could email channels directly if they discover the channel email address.

Impact:

Depending on the organization's adoption, disabling this may disrupt workflows that rely on email-to-channel communication, particularly in environments where email is used to bridge external systems or vendors into Teams. This could include reduced visibility of important updates or alerts that were previously routed into Teams channels via email.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Select `Settings & policies` > `Global (Org-wide default) settings`.
3. Click `Teams` to open the **Teams settings** section.
4. Under **email integration** verify that `Users can send emails to a channel email address` is `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsClientConfiguration -Identity Global | fl AllowEmailIntoChannel
```

3. Ensure the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Select `Settings & policies` > `Global (Org-wide default) settings`.
3. Click `Teams` to open the **Teams settings** section.
4. Under **email integration** set `Users can send emails to a channel email address` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsClientConfiguration -Identity Global -AllowEmailIntoChannel $false
```

Default Value:

On (True)

References:

1. https://learn.microsoft.com/en-us/microsoft-365/security/office-365-security/step-by-step-guides/reducing-attack-surface-in-microsoft-teams?view=o365-worldwide#restricting-channel-email-messages-to-approved-domains
2. https://learn.microsoft.com/en-us/microsoftteams/settings-policies-reference#email-integration
3. https://support.microsoft.com/en-us/office/send-an-email-to-a-channel-in-microsoft-teams-d91db004-d9d7-4a47-82e6-fb1b16dfd51e

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.2 Users

8.2.1 Ensure external domains are restricted in the Teams admin center (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This policy controls whether external domains are allowed, blocked or permitted based on an allowlist or denylist. When external domains are allowed, users in your organization can chat, add users to meetings, and use audio video conferencing with users in external organizations.

The recommended state is `Off` on the `Global (Org-wide default)` policy.

Rationale:

Unrestricted external federation allows any Teams user from any organization to initiate contact with your users, making them susceptible to social engineering, phishing, and malware delivery via Teams chat. Restricting external domains to an allowlist or blocking them entirely eliminates this unsolicited contact vector.

Real-world attacks and exploits delivered via Teams over external access channels include:

- DarkGate malware
- Social engineering / phishing attacks by "Midnight Blizzard"
- GIFShell
- Username enumeration

Impact:

Restricting external domains will limit users' ability to collaborate with individuals outside the organization unless their domain is explicitly allowlisted or they are invited as a guest in Microsoft Entra ID. Administrators choosing an allowlist approach will incur ongoing overhead to manage approved domains as external collaboration needs evolve.

Note: Organizations may create custom external access policies with federation enabled and assign them to specific users or groups requiring external access, while keeping the Global (Org-wide default) policy restrictive.

Audit:

Note: The focus of this control at a minimum is the `Global (Org-wide default)` policy. If the organization-wide setting is configured to `Allow only specific external domains` or `Block all external domains`, then this is also considered a passing state due to its increased restrictiveness.

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Verify that `Manage external domains for this policy` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Get-CsExternalAccessPolicy -Identity Global
```

3. Verify that `EnableFederationAccess` is `False`.

Organization settings: Optional passing state

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Organization settings` tab.
4. Verify that `Manage external domains for this organization` is set to one of the following:
    - `Off`
    - `On` with `Allow or block external domains` set to `Allow only specific external domains`
    - `On` with `Allow or block external domains` set to `Block all external domains`

To audit using PowerShell:

1. Run the following command:

```
Get-CsTenantFederationConfiguration | fl AllowFederatedUsers,AllowedDomains
```

2. Verify the output meets one of the following compliant conditions:
   - **Off:** `AllowFederatedUsers` is `False`
   - **Block all external domains:** `AllowFederatedUsers` is `True` and `AllowedDomains` is empty
   - **Allow only specific external domains:** `AllowFederatedUsers` is `True` and `AllowedDomains` contains only authorized domain names

Remediation:

Note: Configuring this setting at the organization level in `Organization settings` to either `Off`, `Block all external domains` or `Allow only specific external domains` is also a compliant remediation for this control.

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Set `Manage external domains for this policy` to `Off`.
6. Click `Save`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command to configure the `Global (Org-wide default)` policy.

```
Set-CsExternalAccessPolicy -Identity Global -EnableFederationAccess $false
```

Default Value:

EnableFederationAccess - $True

References:

1. https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat?tabs=organization-settings
2. https://www.microsoft.com/en-us/security/blog/2023/08/02/midnight-blizzard-conducts-targeted-social-engineering-over-microsoft-teams/
3. https://www.bitdefender.com/blog/hotforsecurity/gifshell-attack-lets-hackers-create-reverse-shell-through-microsoft-teams-gifs/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.2.2 Ensure communication with unmanaged Teams users is disabled (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting controls chats and meetings initiated through the external access channel with unmanaged Teams users (those not managed by an organization, such as Microsoft Teams (free)). This does not govern anonymous meeting join via shared link, which is controlled separately.

The recommended state is: `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts` set to `Off`.

Rationale:

Allowing users to communicate with unmanaged Teams users presents a potential security threat as little effort is required by threat actors to gain access to a trial or free Microsoft Teams account.

Real-world attacks and exploits delivered via Teams over external access channels include:

- DarkGate malware
- Social engineering / Phishing attacks by "Midnight Blizzard"
- GIFShell
- Username enumeration

Impact:

Users will be unable to communicate with Teams users who are not managed by an organization.

Organizations may choose to create additional policies for specific groups needing to communicate with unmanaged external users.

Note: The settings that govern chats and meetings with external unmanaged Teams users aren't available in GCC, GCC High, or DOD deployments, or in private cloud environments.

Audit:

Note: The focus of this control at a minimum is the `Global (Org-wide default)` policy. If the organization-wide setting is configured to `Off`, then this is also considered a passing state due to its increased restrictiveness.

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Verify that `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Get-CsExternalAccessPolicy -Identity Global
```

Verify that `EnableTeamsConsumerAccess` is set to `False`.

Organization settings: Optional passing state

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Organization settings` tab.
4. Verify that `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts` is set to `Off`.

To audit using PowerShell:

1. Run the following command:

```
Get-CsTenantFederationConfiguration | fl AllowTeamsConsumer
```

2. Verify that `AllowTeamsConsumer` is `False`.

Remediation:

Note: Configuring this setting at the organization level in `Organization settings` to `Off` is also a compliant remediation for this control.

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Set `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts` to `Off`.
6. Click `Save`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Set-CsExternalAccessPolicy -Identity Global -EnableTeamsConsumerAccess $false
```

Default Value:

- `EnableTeamsConsumerAccess` (Global policy): `True`
- `AllowTeamsConsumer` (Organization settings): `True`

References:

1. https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat?tabs=organization-settings
2. https://www.microsoft.com/en-us/security/blog/2023/08/02/midnight-blizzard-conducts-targeted-social-engineering-over-microsoft-teams/
3. https://www.bitdefender.com/blog/hotforsecurity/gifshell-attack-lets-hackers-create-reverse-shell-through-microsoft-teams-gifs/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.2.3 Ensure external Teams users cannot initiate conversations (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting prevents external users who are not managed by an organization from initiating contact with users in the protected organization.

The recommended state is to uncheck `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts`.

Note: Disabling this setting is used as an additional stop gap for the parent setting which disables communication with unmanaged Teams users entirely. If an organization chooses to have an exception to **Ensure communication with unmanaged Teams users is disabled** they can do so while also disabling the ability for the same group of users to initiate contact. Disabling communication entirely will also disable the ability for unmanaged users to initiate contact.

Rationale:

Allowing users to communicate with unmanaged Teams users presents a potential security threat as little effort is required by threat actors to gain access to a trial or free Microsoft Teams account.

Real-world attacks and exploits delivered via Teams over external access channels include:

- DarkGate malware
- Social engineering / Phishing attacks by "Midnight Blizzard"
- GIFShell
- Username enumeration

Impact:

Unmanaged Teams users (those using personal Microsoft accounts or free Teams) will be unable to initiate new chats or meeting invitations with members of the organization. Organization members may still be able to join externally-initiated meetings depending on the configuration of the parent setting.

Organizations that need to allow inbound contact from specific external users can assign a custom external access policy to those users that has `EnableTeamsConsumerInbound` enabled.

Note: Chats and meetings with external unmanaged Teams users isn't available in GCC, GCC High, or DOD deployments, or in private cloud environments.

Audit:

Note: The focus of this control at a minimum is the `Global (Org-wide default)` policy. If the equivalent organization-wide setting is disabled, then this is also considered a passing state due to its increased restrictiveness.

To audit using the UI:

Note: If the parent setting `People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts` is already set to `Off` then this setting will not be visible in the UI.

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Locate the parent setting **People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts**.
6. Verify that `People in my org can join external meetings and receive new chats from users who have unmanaged Microsoft accounts` is not checked.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Get-CsExternalAccessPolicy -Identity Global
```

Verify that `EnableTeamsConsumerInbound` is `False`

Organization settings: Optional passing state

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Select the `Organization settings` tab.
4. Locate the parent setting **People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts**.
5. Verify that `People in my org can join external meetings and receive new chats from users who have unmanaged Microsoft accounts` is not checked.

To audit using PowerShell:

1. Run the following command:

```
Get-CsTenantFederationConfiguration | fl AllowTeamsConsumerInbound
```

Verify that `AllowTeamsConsumerInbound` is `False`

Remediation:

Note: Configuring this setting at the organization level in `Organization settings` to `Off` is also a compliant remediation for this control.

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Open the `Policies` tab.
4. Click on the `Global (Org-wide default) settings` policy.
5. Locate the parent setting **People in my org can chat and have meetings with external users who have unmanaged Microsoft accounts**.
6. Uncheck `People in my org can join external meetings and receive new chats from users who have unmanaged Microsoft accounts`.
7. Click `Save`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Set-CsExternalAccessPolicy -Identity Global -EnableTeamsConsumerInbound
$false
```

Default Value:

- `EnableTeamsConsumerInbound` (Global policy) : `True`
- `AllowTeamsConsumerInbound` (Organization settings) : `True`

References:

1. https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat?tabs=organization-settings
2. https://www.microsoft.com/en-us/security/blog/2023/08/02/midnight-blizzard-conducts-targeted-social-engineering-over-microsoft-teams/
3. https://www.bitdefender.com/blog/hotforsecurity/gifshell-attack-lets-hackers-create-reverse-shell-through-microsoft-teams-gifs/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.2.4 Ensure the organization cannot communicate with accounts in trial Teams tenants (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting controls the organization's external access with Teams "trial-only" tenants. These are tenants that don't have any purchased seats.

When set to Blocked, users from these trial-only tenants aren't able to search and contact your users via chats, Teams calls, and meetings (using the users' authenticated identities) and your users aren't able to reach users in these trial-only tenants. Users from the trial-only tenant are also removed from existing chats.

The recommended state for `People in my organization can communicate with accounts in trial Teams tenant` is `Off`.

Rationale:

Microsoft introduced this setting as `Off` by default on July 29, 2024 in order to block attack vectors being exploited by threat actors who have abused trial tenants. Enforcing the default ensures the setting is not reenabled for any reason.

Allowing users to communicate with unmanaged Teams users presents a potential security threat as little effort is required by threat actors to gain access to a trial or free Microsoft Teams account.

Real-world attacks and exploits delivered via Teams over external access channels include:

- DarkGate malware
- Social engineering / Phishing attacks by "Midnight Blizzard"
- GIFShell
- Username enumeration

Impact:

Users currently in chat conversations with accounts from trial tenants will be removed from those existing chats when this setting is disabled. Organizations that have established communication with external contacts who are using trial tenants will need to use alternative channels (such as email) until those contacts migrate to a licensed tenant.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Select the `Organization settings` tab.
4. Verify that `People in my organization can communicate with accounts in trial Teams tenant` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Get-CsTenantFederationConfiguration
```

Verify that `ExternalAccessWithTrialTenants` is set to `Blocked`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com/.
2. Expand `External collaboration` and select `External access`.
3. Select the `Organization settings` tab.
4. Set `People in my organization can communicate with accounts in trial Teams tenant` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command:

```
Set-CsTenantFederationConfiguration -ExternalAccessWithTrialTenants "Blocked"
```

Default Value:

- `Off` (UI)
- `Blocked` (PowerShell)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat?tabs=organization-settings#block-federation-with-teams-trial-only-tenants
2. https://www.microsoft.com/en-us/security/blog/2023/08/02/midnight-blizzard-conducts-targeted-social-engineering-over-microsoft-teams/
3. https://www.bitdefender.com/en-us/blog/hotforsecurity/gifshell-attack-lets-hackers-create-reverse-shell-through-microsoft-teams-gifs

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.3 Teams devices

This section is intentionally blank and exists to ensure the structure of the benchmark is consistent.

8.4 Teams apps

8.4.1 Ensure app permission policies are configured (Manual)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting controls which class of apps are available for users to install.

Rationale:

Allowing users to install third-party or unverified apps poses a potential risk of introducing malicious software to the environment.

Impact:

Users will only be able to install approved classes of apps.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Expand `Teams apps` and select `Manage apps`.
3. In the upper right click `Actions` > `Org-wide app settings`.
4. For `Third-party apps` verify `Let users install and use available apps by default` is `Off`.
5. For `Custom apps` verify `Let users install and use available apps by default` is `Off`.
6. For `Custom apps` verify `Let users interact with custom apps in preview` is `Off`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Expand `Teams apps` and select `Manage apps`.
3. In the upper right click `Actions` > `Org-wide app settings`.
4. For `Third-party apps` set `Let users install and use available apps by default` to `Off`.
5. For `Custom apps` set `Let users install and use available apps by default` to `Off`.
6. For `Custom apps` set `Let users interact with custom apps in preview` to `Off`.

Default Value:

- Third-party apps: `On`
- Custom apps: `On`

References:

1. https://learn.microsoft.com/en-us/microsoftteams/app-centric-management
2. https://learn.microsoft.com/en-us/defender-office-365/step-by-step-guides/reducing-attack-surface-in-microsoft-teams?view=o365-worldwide#disabling-third-party--custom-apps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	2.5 Allowlist Authorized Software Use technical controls, such as application allowlisting, to ensure that only authorized software can execute or be accessed. Reassess bi-annually, or more frequently.		●	●
v7	2.7 Utilize Application Whitelisting Utilize application whitelisting technology on all assets to ensure that only authorized software executes and all unauthorized software is blocked from executing on assets.			●

8.5 Meetings

8.5.1 Ensure anonymous users can't join a meeting (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Anonymous users are users whose identity can't be verified. They may be logged in to an organization without a mutual trust relationship or they may not have an account (guest or user). Anonymous participants appear with "(Unverified)" appended to their name in meetings.

These users could include:

- Users who aren't logged in to Teams with a work or school account.
- Users from non-trusted organizations (as configured in external access) and from organizations that you trust but which don't trust your organization. When defining trusted organizations for external meetings and chat, ensure both organizations allow each other's domains. Meeting organizers and participants should have user policies that allow external access. These settings prevent attendees from being considered anonymous due to external access settings. For details, see IT Admins - Manage external meetings and chat with people and organizations using Microsoft identities

The recommended state is `Anonymous users can join a meeting unverified` set to `Off`.

Rationale:

For meetings that could contain sensitive information, it is best to allow the meeting organizer to vet anyone not directly sent an invite before admitting them to the meeting. This will also prevent the anonymous user from using the meeting link to have meetings at unscheduled times.

Note: Those companies that don't normally operate at a Level 2 environment, but do deal with sensitive information, may want to consider this policy setting.

Impact:

Individuals who were not sent or forwarded a meeting invite will not be able to join the meeting automatically.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** verify that `Anonymous users can join a meeting unverified` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl
AllowAnonymousUsersToJoinMeeting
```

3. Verify that the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** set `Anonymous users can join a meeting unverified` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -AllowAnonymousUsersToJoinMeeting
$false
```

Default Value:

On (True)

References:

1. https://learn.microsoft.com/en-us/defender-office-365/step-by-step-guides/reducing-attack-surface-in-microsoft-teams?view=o365-worldwide#configure-meeting-settings
2. https://learn.microsoft.com/en-us/microsoftteams/settings-policies-reference?WT.mc_id=TeamsAdminCenterCSH#meeting-join--lobby
3. https://learn.microsoft.com/en-us/MicrosoftTeams/configure-meetings-sensitive-protection
4. https://learn.microsoft.com/en-us/microsoftteams/anonymous-users-in-meetings
5. https://learn.microsoft.com/en-us/microsoftteams/plan-meetings-external-participants

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

8.5.2 Ensure anonymous users and dial-in callers can't start a meeting (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting controls if an anonymous participant can start a Microsoft Teams meeting without someone in attendance. Anonymous users and dial-in callers must wait in the lobby until the meeting is started by someone in the organization or an external user from a trusted organization.

Anonymous participants are classified as:

- Participants who are not logged in to Teams with a work or school account.
- Participants from non-trusted organizations (as configured in external access).
- Participants from organizations where there is not mutual trust.

Note: This setting only applies when `Who can bypass the lobby` is set to `Everyone`. If the `anonymous users can join a meeting` organization-level setting or meeting policy is `Off`, this setting only applies to dial-in callers.

Rationale:

Not allowing anonymous participants to automatically join a meeting reduces the risk of meeting spamming.

Impact:

Anonymous participants will not be able to start a Microsoft Teams meeting.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** verify that `Anonymous users and dial-in callers can start a meeting` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl
AllowAnonymousUsersToStartMeeting
```

3. Verify that the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** set `Anonymous users and dial-in callers can start a meeting` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -AllowAnonymousUsersToStartMeeting
$false
```

Default Value:

Off (False)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/anonymous-users-in-meetings
2. https://learn.microsoft.com/en-us/microsoftteams/who-can-bypass-meeting-lobby#overview-of-lobby-settings-and-policies

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

8.5.3 Ensure only people in my org can bypass the lobby (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting controls who can join a meeting directly and who must wait in the lobby until they're admitted by an organizer, co-organizer, or presenter of the meeting.

The recommended state is `People who were invited`, `People in my org` or `Only organizers and co-organizers`.

Rationale:

For meetings that could contain sensitive information, it is best to allow the meeting organizer to vet anyone not directly sent an invite before admitting them to the meeting. This will also prevent the anonymous user from using the meeting link to have meetings at unscheduled times.

Impact:

Individuals who are not part of the organization will have to wait in the lobby until they're admitted by an organizer, co-organizer, or presenter of the meeting.

Any individual who dials into the meeting regardless of status will also have to wait in the lobby. This includes internal users who are considered unauthenticated when dialing in.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** verify `Who can bypass the lobby` is set to one of the following:
    - `People who were invited`
    - `People in my org`
    - `Only organizers and co-organizers`

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl AutoAdmittedUsers
```

3. Verify that the returned value is one of the following strings:
    - `InvitedUsers`
    - `EveryoneInCompanyExcludingGuests`
    - `OrganizerOnly`

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under meeting join & lobby set `Who can bypass the lobby` to one of the following:
    - `People who were invited`
    - `People in my org`
    - `Only organizers and co-organizers`

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run one of the following PowerShell commands depending on the desired compliant state:

To set to `People who were invited`:

```
Set-CsTeamsMeetingPolicy -Identity Global -AutoAdmittedUsers "InvitedUsers"
```

To set to `People in my org`:

```
Set-CsTeamsMeetingPolicy -Identity Global -AutoAdmittedUsers
"EveryoneInCompanyExcludingGuests"
```

To set to `Only organizers and co-organizers`:

```
Set-CsTeamsMeetingPolicy -Identity Global -AutoAdmittedUsers "OrganizerOnly"
```

Default Value:

People in my org and guests (EveryoneInCompany)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/who-can-bypass-meeting-lobby#overview-of-lobby-settings-and-policies
2. https://learn.microsoft.com/en-us/powershell/module/skype/set-csteamsmeetingpolicy?view=skype-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

8.5.4 Ensure users dialing in can't bypass the lobby (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting controls if users who dial in by phone can join the meeting directly or must wait in the lobby. Admittance to the meeting from the lobby is authorized by the meeting organizer, co-organizer, or presenter of the meeting.

Rationale:

For meetings that could contain sensitive information, it is best to allow the meeting organizer to vet anyone not directly from the organization.

Impact:

Individuals who are dialing in to the meeting must wait in the lobby until a meeting organizer, co-organizer, or presenter admits them.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** verify that `People dialing in can bypass the lobby` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl AllowPSTNUsersToBypassLobby
```

3. Verify that the value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting join & lobby** set `People dialing in can bypass the lobby` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -AllowPSTNUsersToBypassLobby $false
```

Default Value:

Off (False)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/who-can-bypass-meeting-lobby#overview-of-lobby-settings-and-policies
2. https://learn.microsoft.com/en-us/powershell/module/skype/set-csteamsmeetingpolicy?view=skype-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

8.5.5 Ensure meeting chat does not allow anonymous users (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This policy setting controls who has access to read and write chat messages during a meeting.

Rationale:

Ensuring that only authorized individuals can read and write chat messages during a meeting reduces the risk that a malicious user can inadvertently show content that is not appropriate or view sensitive information.

Impact:

Only authorized individuals will be able to read and write chat messages during a meeting.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting engagement** verify that `Meeting chat` is set to `On for everyone but anonymous users` or a more restrictive value: `In-meeting only except anonymous` or `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl MeetingChatEnabledType
```

3. Verify that the returned value is `EnabledExceptAnonymous` or a more restrictive value `EnabledInMeetingOnlyForAllExceptAnonymous` or `Disabled`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting engagement** set `Meeting chat` to `On for everyone but anonymous users`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the minimum recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -MeetingChatEnabledType
"EnabledExceptAnonymous"
```

Note: The audit section outlines additional compliant states which are more restrictive than the recommended state.

Default Value:

On for everyone (Enabled)

References:

1. https://learn.microsoft.com/en-us/powershell/module/skype/set-csteamsmeetingpolicy?view=skype-ps#-meetingchatenabledtype

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

8.5.6 Ensure only organizers and co-organizers can present (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This policy setting controls who can present in a Teams meeting.

Note: Organizers and co-organizers can change this setting when the meeting is set up.

Rationale:

Ensuring that only authorized individuals are able to present reduces the risk that a malicious user can inadvertently show content that is not appropriate.

Impact:

Only organizers and co-organizers will be able to present without being granted permission.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **content sharing** verify `Who can present` is set to `Only organizers and co-organizers`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl DesignatedPresenterRoleMode
```

3. Verify that the returned value is `OrganizerOnlyUserOverride`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **content sharing** set `Who can present` to `Only organizers and co-organizers`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -DesignatedPresenterRoleMode
"OrganizerOnlyUserOverride"
```

Default Value:

Everyone (EveryoneUserOverride)

References:

1. https://learn.microsoft.com/en-US/microsoftteams/meeting-who-present-request-control
2. https://learn.microsoft.com/en-us/microsoftteams/meeting-who-present-request-control#manage-who-can-present
3. https://learn.microsoft.com/en-us/defender-office-365/step-by-step-guides/reducing-attack-surface-in-microsoft-teams?view=o365-worldwide#configure-meeting-settings-restrict-presenters
4. https://learn.microsoft.com/en-us/powershell/module/skype/set-csteamsmeetingpolicy?view=skype-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

8.5.7 Ensure external participants can't give or request control (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This policy setting allows control of who can present in meetings and who can request control of the presentation while a meeting is underway.

Rationale:

Ensuring that only authorized individuals and not external participants are able to present and request control reduces the risk that a malicious user can inadvertently show content that is not appropriate.

External participants are categorized as follows: external users, guests, and anonymous users.

Impact:

External participants will not be able to present or request control during the meeting.

Warning: This setting also affects webinars.

Note: At this time, to give and take control of shared content during a meeting, both parties must be using the Teams desktop client. Control isn't supported when either party is running Teams in a browser.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **content sharing** verify that `External participants can give or request control` is `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl
AllowExternalParticipantGiveRequestControl
```

3. Verify that the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **content sharing** set `External participants can give or request control` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -
AllowExternalParticipantGiveRequestControl $false
```

Default Value:

Off (False)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/meeting-who-present-request-control
2. https://learn.microsoft.com/en-us/powershell/module/skype/set-csteamsmeetingpolicy?view=skype-ps

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

8.5.8 Ensure external meeting chat is off (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This meeting policy setting controls whether users can read or write messages in external meeting chats with untrusted organizations. If an external organization is on the list of trusted organizations this setting will be ignored.

Rationale:

Restricting access to chat in meetings hosted by external organizations limits the opportunity for an exploit like GIFShell or DarkGate malware from being delivered to users.

Impact:

When joining external meetings users will be unable to read or write chat messages in Teams meetings with organizations that they don't have a trust relationship with. This will completely remove the chat functionality in meetings. From an I.T. perspective both the upkeep of adding new organizations to the trusted list and the decision-making process behind whether to trust or not trust an external partner will increase time expenditure.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting engagement** verify that `External meeting chat` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl
AllowExternalNonTrustedMeetingChat
```

3. Verify that the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab..
3. Select `Meetings` to open the **meeting settings** section.
4. Under **meeting engagement** set `External meeting chat` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -AllowExternalNonTrustedMeetingChat
$false
```

Default Value:

On(True)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/settings-policies-reference#meeting-engagement

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.5.9 Ensure meeting recording is off by default (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

This setting controls the ability for a user to initiate a recording of a meeting in progress.

The recommended state is `Off` for the `Global (Org-wide default)` meeting policy.

Rationale:

Disabling meeting recordings in the Global meeting policy ensures that only authorized users, such as organizers, co-organizers, and leads, can initiate a recording. This measure helps safeguard sensitive information by preventing unauthorized individuals from capturing and potentially sharing meeting content. Restricting recording capabilities to specific roles allows organizations to exercise greater control over what is recorded, aligning it with the meeting's confidentiality requirements.

Note: Creating a separate policy for users or groups who are allowed to record is expected and in compliance. This control is only for the default meeting policy.

Impact:

If there are no additional policies allowing anyone to record, then recording will effectively be disabled.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **Recording & transcription** verify that `Meeting recording` is set to `Off`.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to verify the recommended state:

```
Get-CsTeamsMeetingPolicy -Identity Global | fl AllowCloudRecording
```

3. Verify that the returned value is `False`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Meetings` to open the **meeting settings** section.
4. Under **Recording & transcription** set `Meeting recording` to `Off`.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following command to set the recommended state:

```
Set-CsTeamsMeetingPolicy -Identity Global -AllowCloudRecording $false
```

Default Value:

On (True)

References:

1. https://learn.microsoft.com/en-us/microsoftteams/settings-policies-reference#recording--transcription

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

8.6 Messaging

8.6.1 Ensure users can report security concerns in Teams (Automated)

Profile Applicability:

- E5 Level 1

Description:

User reporting settings allow a user to report a message as malicious for further analysis. This recommendation is composed of 3 different settings and all must be configured for compliance:

- **In the Teams admin center:** On by default and controls whether users are able to report messages from Teams. When this setting is turned off, users can't report messages within Teams, so the corresponding setting in the Microsoft 365 Defender portal is irrelevant.
- **In the Microsoft 365 Defender portal:** On by default for new tenants. Existing tenants need to enable it. If user reporting of messages is turned on in the Teams admin center, it also needs to be turned on the Defender portal for user reported messages to show up correctly on the User reported tab on the Submissions page.
- **Defender - Report message destinations:** This applies to more than just Microsoft Teams and allows for an organization to keep their reports contained. Due to how the parameters are configured on the backend it is included in this assessment as a requirement.

Rationale:

Users will be able to more quickly and systematically alert administrators of suspicious malicious messages within Teams. The content of these messages may be sensitive in nature and therefore should be kept within the organization and not shared with Microsoft without first consulting company policy.

Note:

- The reported message remains visible to the user in the Teams client.
- Users can report the same message multiple times.
- The message sender isn't notified that messages were reported.

Impact:

Enabling message reporting has an impact beyond just addressing security concerns. When users of the platform report a message, the content could include messages that are threatening or harassing in nature, possibly stemming from colleagues.

Due to this the security staff responsible for reviewing and acting on these reports should be equipped with the skills to discern and appropriately direct such messages to the relevant departments, such as Human Resources (HR).

Audit:

To audit using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Messaging` to open the **messaging settings** section.
4. Verify that `Report a security concern` is `On`.
5. Next, navigate to `Microsoft 365 Defender` https://security.microsoft.com/
6. Expand `System` > `Settings` and select `Email & collaboration`.
7. Click on `User reported settings`.
8. Under `Microsoft Teams` verify that `Monitor reported items in Microsoft Teams` is checked.
9. Verify that `Send reported messages to:` is set to `My reporting mailbox only` with report email addresses defined for authorized staff.

To audit using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Run the following cmdlet for to assess Teams:

```
Get-CsTeamsMessagingPolicy -Identity Global | fl
AllowSecurityEndUserReporting
```

3. Verify that the value returned is `True`.
4. Connect to Exchange Online PowerShell using `Connect-ExchangeOnline`.
5. Run this cmdlet to assess Defender:

```
Get-ReportSubmissionPolicy | fl Report*
```

6. Verify that the output matches the following values with organization specific email addresses:

```
ReportJunkToCustomizedAddress                : True
ReportNotJunkToCustomizedAddress             : True
ReportPhishToCustomizedAddress               : True
ReportJunkAddresses                          : {SOC@contoso.com}
ReportNotJunkAddresses                       : {SOC@contoso.com}
ReportPhishAddresses                         : {SOC@contoso.com}
ReportChatMessageEnabled                     : False
ReportChatMessageToCustomizedAddressEnabled : True
```

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Teams admin center` https://admin.teams.microsoft.com.
2. Click `Settings & policies` and select the `Global (Org-wide default) settings` tab.
3. Select `Messaging` to open the **messaging settings** section.
4. Set `Report a security concern` to `On`.
5. Next, navigate to `Microsoft 365 Defender` https://security.microsoft.com/
6. Expand `System` > `Settings` and select `Email & collaboration`.
7. Click on `User reported settings`.
8. Under `Microsoft Teams` check the box for `Monitor reported items in Microsoft Teams` and click `Save`.
9. Set `Send reported messages to:` to `My reporting mailbox only` with reports configured to be sent to authorized staff.

To remediate using PowerShell:

1. Connect to Teams PowerShell using `Connect-MicrosoftTeams`.
2. Connect to Exchange Online PowerShell using `Connect-ExchangeOnline`.
3. Run the following cmdlet:

```
Set-CsTeamsMessagingPolicy -Identity Global -AllowSecurityEndUserReporting
$true
```

4. To configure the Defender reporting policies, edit and run this script:

```
$usersub = "userreportedmessages@fabrikam.com" # Change this.

$params = @{
    Identity                          = "DefaultReportSubmissionPolicy"
    EnableReportToMicrosoft           = $false
    ReportChatMessageEnabled          = $false
    ReportChatMessageToCustomizedAddressEnabled = $true
    ReportJunkToCustomizedAddress     = $true
    ReportNotJunkToCustomizedAddress  = $true
    ReportPhishToCustomizedAddress    = $true
    ReportJunkAddresses               = $usersub
    ReportNotJunkAddresses            = $usersub
    ReportPhishAddresses              = $usersub
}

Set-ReportSubmissionPolicy @params

New-ReportSubmissionRule -Name DefaultReportSubmissionRule -
ReportSubmissionPolicy DefaultReportSubmissionPolicy -SentTo $usersub
```

Default Value:

On (`True`)

Report message destination: `Microsoft Only`

References:

1. https://learn.microsoft.com/en-us/defender-office-365/submissions-teams?view=o365-worldwide

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	0.0 Explicitly Not Mapped Explicitly Not Mapped			
v7	0.0 Explicitly Not Mapped Explicitly Not Mapped			

9 Microsoft Fabric

Microsoft Fabric is also known as Power BI and contains settings related to Power BI configuration.

Direct link: https://app.powerbi.com/admin-portal/

9.1 Tenant settings

To audit the Tenant settings section within the Microsoft Fabric admin center, users must have either the `Fabric Administrator` or `Global Administrator` role. The Global Reader role does not currently provide sufficient permissions to access or audit these settings.

Auditing with PowerShell

This section provides a PowerShell function designed to leverage the Microsoft Fabric REST API for collecting configuration details relevant to this Benchmark. The function can be executed once, and the results exported for manual review or programmatic auditing.

Requirements

- PowerShell 7.5
- `Az.Accounts` PowerShell module

The function supports authentication either interactively or via a service principal. Each has its own requirements, with the service principal method requiring the least permissions but with more upfront configuration.

Interactive login

The user must have the `Fabric Administrator` role assigned in order to authenticate.

Non-interactive login

- The fabric tenant setting `Service principals can call Fabric public APIs` must be enabled for a group that the service principal is a member of.
- The fabric tenant setting `Service principals can access read-only admin APIs` must be enabled for a group that the service principal is a member of.
- NO Power BI application permissions on app registration, these cause errors see *below.

Per Microsoft: A Microsoft Entra application doesn't require you to configure any delegated permissions or application permissions in the Azure portal when it has been created for a service principal. When you create a Microsoft Entra application for a service principal to access the Power BI REST API, we recommend that you avoid adding permissions. They're never used and can cause errors that are hard to troubleshoot.

Ref: https://learn.microsoft.com/en-us/power-bi/developer/embedded/embed-service-principal#method

Examples

Option: Run interactively, an authentication window will pop-up requiring a `Fabric Administrator` or higher to authenticate using the Az.Accounts module.

```
$FTS = Get-CISFabricTenantSettings -Interactive
```

Option: Run non-interactively, using a Service Principal. Requires passing in a hashtable with tenant information

```
# Example data below
$Params = @{
    CertificateThumbprint = 'XXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXXX'
    ApplicationId         = '00000000-0000-0000-0000-000000000000'
    TenantId              = 'YYYYYYYY-YYYY-YYYY-YYYY-YYYYYYYYYYYY'
}

$FTS = Get-CISFabricTenantSettings -TenantParams $Params
```

Note: Creating and configuring a service principal is not covered in this guide.

Output to a file for analysis

```
$FTS | ConvertTo-Json -Depth 4 | Out-File FabricSettings.json
```

The function

1. Save the script block to a PSM1 file i.e., `Get-CISFabricTenantSettings.psm1`
2. Import the function using `Import-Module Get-CISFabricTenantSettings.psm1`

```
function Get-CISFabricTenantSettings {
    <#
    .DESCRIPTION
    Collects Microsoft Fabric tenant settings via Fabric REST API.

    .PARAMETER TenantParams
    Hashtable containing service principal authentication parameters
    (ApplicationId, TenantId, CertificateThumbprint)

    .PARAMETER Interactive
    Switch to use interactive user authentication
    #>
    [CmdletBinding(DefaultParameterSetName = 'ServicePrincipal')]
    param(
        [Parameter(Mandatory = $true, ParameterSetName = 'ServicePrincipal')]
        [hashtable]$TenantParams,

        [Parameter(Mandatory = $true, ParameterSetName = 'Interactive')]
        [switch]$Interactive
    )

    try {
        if ($Interactive) {
            # Interactive user authentication
            $null = Connect-AzAccount -ErrorAction Stop
        }
        else {
            # Service principal authentication
            $null = Connect-AzAccount `
                -CertificateThumbprint $TenantParams.CertificateThumbprint `
                -ApplicationId $TenantParams.ApplicationId `
                -TenantId $TenantParams.TenantId `
                -ServicePrincipal `
                -ErrorAction Stop
        }

        # Get access token
        $ResourceURL = 'https://api.fabric.microsoft.com'
        $AccessToken = Get-AzAccessToken `
                -ResourceUrl $ResourceURL `
                -AsSecureString
    }
    catch {
        Write-Error "Failed to connect or retrieve access token: $_"
        return $null
    }
    finally {
        [void](Disconnect-AzAccount -ErrorAction SilentlyContinue)
    }

    # Collect Fabric tenant settings
    if ($AccessToken) {
        $SettingsFilter = @(
            'AllowGuestUserToAccessSharedContent'
            'ExternalSharingV2'
            'ElevatedGuestsTenant'
            'PublishToWeb'
```

```
            'RScriptVisual'
            'EimInformationProtectionEdit'
            'ShareLinkToEntireOrg'
            'EnableDatasetInPlaceSharing'
            'BlockResourceKeyAuthentication'
            'ServicePrincipalAccessPermissionAPIs'
            'AllowServicePrincipalsCreateAndUseProfiles'
            'ServicePrincipalAccessGlobalAPIs'
        )

        try {
            $Uri = 'https://api.fabric.microsoft.com/v1/admin/tenantsettings'
            $params = @{
                Uri            = $Uri
                Method         = 'Get'
                Authentication = 'Bearer'
                Token          = $AccessToken.Token
            }

            $TenantSettings = (Invoke-RestMethod @params).tenantsettings |
            Where-Object { $_.settingName -in $SettingsFilter }

            return $TenantSettings
        }
        catch {
            Write-Error "Failed to retrieve Fabric tenant settings: $_"
            return $null
        }
        finally {
            # Clean up
            Clear-Variable -Name AccessToken, params `
                -ErrorAction SilentlyContinue
        }
    }
}
```

9.1.1 Ensure guest user access is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting allows business-to-business (B2B) guests access to Microsoft Fabric, and contents that they have permissions to. With the setting turned off, B2B guest users receive an error when trying to access Power BI.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Establishing and enforcing a dedicated security group prevents unauthorized access to Microsoft Fabric for guests collaborating in Azure that are new or assigned guest status from other applications. This upholds the principle of least privilege and uses role-based access control (RBAC). These security groups can also be used for tasks like conditional access, enhancing risk management and user accountability across the organization.

Impact:

Security groups will need to be more closely tended to and monitored.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Guest users can access Microsoft Fabric` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `AllowGuestUserToAccessSharedContent` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is `false`.
    - `enabled` is `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Guest users can access Microsoft Fabric` to one of these states:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.2 Ensure external user invitations are restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting helps organizations choose whether new external users can be invited to the organization through Power BI sharing, permissions, and subscription experiences. This setting only controls the ability to invite through Power BI.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Note: To invite external users to the organization, the user must also have the Microsoft Entra Guest Inviter role.

Rationale:

Establishing and enforcing a dedicated security group prevents unauthorized access to Microsoft Fabric for guests collaborating in Azure that are new or assigned guest status from other applications. This upholds the principle of least privilege and uses role-based access control (RBAC). These security groups can also be used for tasks like conditional access, enhancing risk management and user accountability across the organization.

Impact:

Guest user invitations will be limited to only specific employees.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Users can invite guest users to collaborate through item sharing and permissions` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `ExternalSharingV2` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is `false`.
    - `enabled` is `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Users can invite guest users to collaborate through item sharing and permissions` to one of these states:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing
2. https://learn.microsoft.com/en-us/power-bi/enterprise/service-admin-azure-ad-b2b#invite-guest-users

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.3 Ensure guest access to content is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting allows Microsoft Entra B2B guest users to have full access to the browsing experience using the left-hand navigation pane in the organization. Guest users who have been assigned workspace roles or specific item permissions will continue to have those roles and/or permissions, even if this setting is disabled.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Establishing and enforcing a dedicated security group prevents unauthorized access to Microsoft Fabric for guests collaborating in Entra that are new or assigned guest status from other applications. This upholds the principle of least privilege and uses role-based access control (RBAC). These security groups can also be used for tasks like conditional access, enhancing risk management and user accountability across the organization.

Impact:

Security groups will need to be more closely tended to and monitored.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Guest users can browse and access Fabric content` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `ElevatedGuestsTenant` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is `false`.
    - `enabled` is `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Guest users can browse and access Fabric content` to one of these states:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Disabled

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●
v7	14.6 Protect Information through Access Control Lists Protect all information stored on systems with file system, network share, claims, application, or database specific access control lists. These controls will enforce the principle that only authorized individuals should have access to the information based on their need to access the information as a part of their responsibilities.	●	●	●

9.1.4 Ensure 'Publish to web' is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Power BI enables users to share reports and materials directly on the internet from both the application's desktop version and its web user interface. This functionality generates a publicly reachable web link that doesn't necessitate authentication or the need to be an Entra ID user in order to access and view it.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

When using Publish to Web anyone on the Internet can view a published report or visual. Viewing requires no authentication. It includes viewing detail-level data that your reports aggregate. By disabling the feature, restricting access to certain users and allowing existing embed codes organizations can mitigate the exposure of confidential or proprietary information.

Impact:

Depending on the organization's utilization administrators may experience more overhead managing embed codes, and requests.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Publish to web` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Choose how embed codes work` set to `Only allow existing codes` **AND** `Specific security groups` selected and defined

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `PublishToWeb` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is `false`.
    - `enabled` is `true` **AND** `createP2w` is `false` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: The `createP2w` property can be found nested under `properties`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Publish to web` to one of these states:
    - `Disabled`
    - `Enabled` with `Choose how embed codes work` set to `Only allow existing codes` **AND** `Specific security groups` selected and defined

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

Only allow existing codes

References:

1. https://learn.microsoft.com/en-us/power-bi/collaborate-share/service-publish-to-web
2. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing#publish-to-web

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.5 Ensure 'Interact with and share R and Python' visuals is 'Disabled' (Automated)

Profile Applicability:

- E3 Level 2
- E5 Level 2

Description:

Power BI allows the integration of R and Python scripts directly into visuals. This feature allows data visualizations by incorporating custom calculations, statistical analyses, machine learning models, and more using R or Python scripts. Custom visuals can be created by embedding them directly into Power BI reports. Users can then interact with these visuals and see the results of the custom code within the Power BI interface.

Rationale:

Disabling this feature can reduce the attack surface by preventing potential malicious code execution leading to data breaches, or unauthorized access. The potential for sensitive or confidential data being leaked to unintended users is also increased with the use of scripts.

Impact:

Use of R and Python scripting will require exceptions for developers, along with more stringent code review.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `R and Python visuals settings`.
4. Verify that `Interact with and share R and Python visuals` is set to `Disabled`

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `RScriptVisual` in the output.
3. Verify that `enabled` is `false`.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `R and Python visuals settings`.
4. Set `Interact with and share R and Python visuals` to `Disabled`

Default Value:

Enabled

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-r-python-visuals
2. https://learn.microsoft.com/en-us/power-bi/visuals/service-r-visuals
3. https://www.r-project.org/

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

9.1.6 Ensure 'Allow users to apply sensitivity labels for content' is 'Enabled' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Information protection tenant settings help to protect sensitive information in the Power BI tenant. Allowing and applying sensitivity labels to content ensures that information is only seen and accessed by the appropriate users.

The recommended state is `Enabled` or `Enabled for a subset of the organization`.

Note: Sensitivity labels and protection are only applied to files exported to Excel, PowerPoint, or PDF files, that are controlled by "Export to Excel" and "Export reports as PowerPoint presentation or PDF documents" settings. All other export and sharing options do not support the application of sensitivity labels and protection.

Note 2: There are some prerequisite steps that need to be completed in order to fully utilize labeling. See here.

Rationale:

Establishing data classifications and affixing labels to data at creation enables organizations to discern the data's criticality, sensitivity, and value. This initial identification enables the implementation of appropriate protective measures, utilizing technologies like Data Loss Prevention (DLP) to avert inadvertent exposure and enforcing access controls to safeguard against unauthorized access.

This practice can also promote user awareness and responsibility in regard to the nature of the data they interact with. Which in turn can foster awareness in other areas of data management across the organization.

Impact:

Additional license requirements like Power BI Pro are required, as outlined in the Licensed and requirements page linked in the description and references sections.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Information protection`.
4. Verify that `Allow users to apply sensitivity labels for content` is set to one of the following:
    - `Enabled`
    - `Enabled` with `Specific security groups` selected and defined.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `EimInformationProtectionEdit` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is `true`.
    - `enabled` is `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Information protection`.
4. Set `Allow users to apply sensitivity labels for content` to one of these states:
    - `Enabled`
    - `Enabled` with `Specific security groups` selected and defined.

Default Value:

Disabled

References:

1. https://learn.microsoft.com/en-us/power-bi/enterprise/service-security-enable-data-sensitivity-labels
2. https://learn.microsoft.com/en-us/fabric/governance/data-loss-prevention-overview
3. https://learn.microsoft.com/en-us/power-bi/enterprise/service-security-enable-data-sensitivity-labels#licensing-and-requirements

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.7 Establish and Maintain a Data Classification Scheme Establish and maintain an overall data classification scheme for the enterprise. Enterprises may use labels, such as “Sensitive,” “Confidential,” and “Public,” and classify their data according to those labels. Review and update the classification scheme annually, or when significant enterprise changes occur that could impact this Safeguard.		●	●

9.1.7 Ensure shareable links are restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Creating a shareable link allows a user to create a link to a report or dashboard, then add that link to an email or another messaging application.

There are 3 options that can be selected when creating a shareable link:

- People in your organization
- People with existing access
- Specific people

This setting solely deals with restrictions to `People in the organization`. External users by default are not included in any of these categories, and therefore cannot use any of these links regardless of the state of this setting.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

While external users are unable to utilize shareable links, disabling or restricting this feature ensures that a user cannot generate a link accessible by individuals within the same organization who lack the necessary clearance to the shared data. For example, a member of Human Resources intends to share sensitive information with a particular employee or another colleague within their department. The owner would be prompted to specify either `People with existing access` or `Specific people` when generating the link requiring the person clicking the link to pass a first layer access control list. This measure along with proper file and folder permissions can help prevent unintended access and potential information leakage.

Impact:

If the setting is `Enabled` then only specific people in the organization would be allowed to create general links viewable by the entire organization.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Allow shareable links to grant access to everyone in your organization` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `ShareLinkToEntireOrg` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is set to `false`.
    - `enabled` is set to `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Allow shareable links to grant access to everyone in your organization` to one of these states:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/power-bi/collaborate-share/service-share-dashboards?wt.mc_id=powerbi_inproduct_sharedialog#link-settings
2. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●

9.1.8 Ensure enabling of external data sharing is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Power BI admins can specify which users or user groups can share datasets externally with guests from a different tenant through the in-place mechanism. Disabling this setting prevents any user from sharing datasets externally by restricting the ability of users to turn on external sharing for datasets they own or manage.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Establishing and enforcing a dedicated security group prevents unauthorized access to Microsoft Fabric for guests collaborating in Azure that are new or from other applications. This upholds the principle of least privilege and uses role-based access control (RBAC). These security groups can also be used for tasks like conditional access, enhancing risk management and user accountability across the organization.

Impact:

Security groups will need to be more closely tended to and monitored.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Verify that `Allow specific users to turn on external data sharing` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `EnableDatasetInPlaceSharing` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is set to `false`.
    - `enabled` is set to `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Export and Sharing settings`.
4. Set `Allow specific users to turn on external data sharing` to one of these states:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-export-sharing

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	3.3 Configure Data Access Control Lists Configure data access control lists based on a user's need to know. Apply data access control lists, also known as access permissions, to local and remote file systems, databases, and applications.	●	●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.9 Ensure 'Block ResourceKey Authentication' is 'Enabled' (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

This setting blocks the use of resource key based authentication. The Block ResourceKey Authentication setting applies to streaming and PUSH datasets. If blocked users will not be allowed to send data to streaming and PUSH datasets using the API with a resource key.

The recommended state is `Enabled`.

Rationale:

Resource keys are a form of authentication that allows users to access Power BI resources (such as reports, dashboards, and datasets) without requiring individual user accounts. While convenient, this method bypasses the organization's centralized identity and access management controls. Enabling ensures that access to Power BI resources is tied to the organization's authentication mechanisms, providing a more secure and controlled environment.

Impact:

Developers will need to request a special exception in order to use this feature.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Verify that `Block ResourceKey Authentication` is set to `Enabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `BlockResourceKeyAuthentication` in the output.
3. Verify that `enabled` is set to `true`.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Set `Block ResourceKey Authentication` to `Enabled`

Default Value:

Disabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-developer
2. https://learn.microsoft.com/en-us/power-bi/connect-data/service-real-time-streaming

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●

9.1.10 Ensure access to APIs by service principals is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Use a service principal to access Fabric public APIs that include create, read, update, and delete (CRUD) operations, and are protected by a Fabric permission model.

To allow an app to use service principal authentication, its service principal must be included in an allowed security group. You can control who can access service principals by creating dedicated security groups and using these groups in other tenant settings.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Leaving API access unrestricted increases the attack surface in the event an adversary gains access to a Service Principal. APIs are a feature-rich method for programmatic access to many areas of Power Bi and should be guarded closely.

Impact:

Service principals will need to be members of specific security groups in order to perform public API calls.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Verify that `Service principals can call Fabric public APIs` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `ServicePrincipalAccessPermissionAPIs` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is set to `false`.
    - `enabled` is set to `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Set `Service principals can call Fabric public APIs` to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Enabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-developer

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.11 Ensure service principals cannot create and use profiles (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Service principal profiles provide a flexible solution for apps used in a multitenancy deployment. The profiles enable customer data isolation and tighter security boundaries between customers that are utilizing the app.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Service Principals should be restricted to a security group to limit which Service Principals can interact with profiles. This supports the principle of least privilege.

Impact:

Disabled is the default behavior.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Verify that `Allow service principals to create and use profiles` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `AllowServicePrincipalsCreateAndUseProfiles` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is set to `false`.
    - `enabled` is set to `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Set `Allow service principals to create and use profiles` to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Disabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-developer
2. https://learn.microsoft.com/en-us/power-bi/developer/embedded/embed-multi-tenancy

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

9.1.12 Ensure service principals ability to create workspaces, connections and deployment pipelines is restricted (Automated)

Profile Applicability:

- E3 Level 1
- E5 Level 1

Description:

Use a service principal to access these Fabric APIs that aren't protected by a Fabric permission model.

- Create Workspace
- Create Connection
- Create Deployment Pipeline

To allow an app to use service principal authentication, its service principal must be included in an allowed security group. You can control who can access service principals by creating dedicated security groups and using these groups in other tenant settings.

The recommended state is `Enabled for a subset of the organization` or `Disabled`.

Rationale:

Leaving API access unrestricted increases the attack surface in the event an adversary gains access to a Service Principal. APIs are a feature-rich method for programmatic access to many areas of Power Bi and should be guarded closely.

Impact:

Service principals will need to be members of specific security groups in order to perform public API calls.

Audit:

To audit using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Verify that `Service principals can create workspaces, connections, and deployment pipelines` is set to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

To audit using PowerShell:

1. Inspect the results of the `Get-CISFabricTenantSettings` function from the section overview.
2. Locate the **settingName** `ServicePrincipalAccessGlobalAPIs` in the output.
3. Verify that the properties adhere to **one** of the following compliant configurations:
    - `enabled` is set to `false`.
    - `enabled` is set to `true` **AND** `enabledSecurityGroups` contains at least one security group.
4. If neither condition is met, the setting is non-compliant.

Note: If the `Specific security groups` setting is not enabled then the `enabledSecurityGroups` property does not appear in the output.

Remediation:

To remediate using the UI:

1. Navigate to `Microsoft Fabric` https://app.powerbi.com/admin-portal
2. Select `Tenant settings`.
3. Scroll to `Developer settings`.
4. Set `Service principals can create workspaces, connections, and deployment pipelines` to one of the following:
    - `Disabled`
    - `Enabled` with `Specific security groups` selected and defined.

Important: If the organization doesn't actively use this feature it is recommended to keep it `Disabled`.

Default Value:

Disabled for the entire organization

References:

1. https://learn.microsoft.com/en-us/fabric/admin/service-admin-portal-developer

CIS Controls:

Controls Version	Control	IG 1	IG 2	IG 3
v8	4.8 Uninstall or Disable Unnecessary Services on Enterprise Assets and Software Uninstall or disable unnecessary services on enterprise assets and software, such as an unused file sharing service, web application module, or service function.		●	●
v8	6.8 Define and Maintain Role-Based Access Control Define and maintain role-based access control, through determining and documenting the access rights necessary for each role within the enterprise to successfully carry out its assigned duties. Perform access control reviews of enterprise assets to validate that all privileges are authorized, on a recurring schedule at a minimum annually, or more frequently.			●

Appendix: Summary Table

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1	**Microsoft 365 admin center**		
1.1	**Users**		
1.1.1	Ensure Administrative accounts are cloud-only (Automated)	☐	☐
1.1.2	Ensure two emergency access accounts have been defined (Manual)	☐	☐
1.1.3	Ensure that between two and four global admins are designated (Automated)	☐	☐
1.1.4	Ensure administrative accounts use licenses with a reduced application footprint (Automated)	☐	☐
1.2	**Teams & groups**		
1.2.1	Ensure that only organizationally managed/approved public groups exist (Automated)	☐	☐
1.2.2	Ensure sign-in to shared mailboxes is blocked (Automated)	☐	☐
1.3	**Settings**		
1.3.1	Ensure the 'Password expiration policy' is set to 'Set passwords to never expire (recommended)' (Automated)	☐	☐
1.3.2	Ensure 'Idle session timeout' is set to '3 hours (or less)' for unmanaged devices (Automated)	☐	☐
1.3.3	Ensure 'External sharing' of calendars is not available (Automated)	☐	☐
1.3.4	Ensure 'User owned apps and services' is restricted (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
1.3.5	Ensure internal phishing protection for Forms is enabled (Automated)	☐	☐
1.3.6	Ensure the customer lockbox feature is enabled (Automated)	☐	☐
1.3.7	Ensure 'third-party storage services' are restricted in 'Microsoft 365 on the web' (Automated)	☐	☐
1.3.8	Ensure that Sways cannot be shared with people outside of your organization (Manual)	☐	☐
1.3.9	Ensure shared bookings pages are restricted to select users (Automated)	☐	☐
2	**Microsoft Defender**		
2.1	**Email & collaboration**		
2.1.1	Ensure Safe Links for Office Applications is Enabled (Automated)	☐	☐
2.1.2	Ensure the Common Attachment Types Filter is enabled (Automated)	☐	☐
2.1.3	Ensure notifications for internal users sending malware is Enabled (Automated)	☐	☐
2.1.4	Ensure Safe Attachments policy is enabled (Automated)	☐	☐
2.1.5	Ensure Safe Attachments for SharePoint, OneDrive, and Microsoft Teams is Enabled (Automated)	☐	☐
2.1.6	Ensure Exchange Online Spam Policies are set to notify administrators (Automated)	☐	☐
2.1.7	Ensure that an anti-phishing policy has been created (Automated)	☐	☐
2.1.8	Ensure that SPF records are published for all Exchange Domains (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
2.1.9	Ensure that DKIM is enabled for all Exchange Online Domains (Automated)	☐	☐
2.1.10	Ensure DMARC records for all Exchange Online domains are published (Automated)	☐	☐
2.1.11	Ensure comprehensive attachment filtering is applied (Automated)	☐	☐
2.1.12	Ensure the connection filter IP allow list is not used (Automated)	☐	☐
2.1.13	Ensure the connection filter safe list is off (Automated)	☐	☐
2.1.14	Ensure inbound anti-spam policies do not contain allowed domains (Automated)	☐	☐
2.1.15	Ensure outbound anti-spam message limits are in place (Automated)	☐	☐
2.2	**Cloud apps**		
2.2.1	Ensure emergency access account activity is monitored (Manual)	☐	☐
2.3	**Audit**		
2.4	**System**		
2.4.1	Ensure Priority account protection is enabled and configured (Automated)	☐	☐
2.4.2	Ensure Priority accounts have 'Strict protection' presets applied (Automated)	☐	☐
2.4.3	Ensure Microsoft Defender for Cloud Apps is enabled and configured (Manual)	☐	☐
2.4.4	Ensure Zero-hour auto purge for Microsoft Teams is on (Automated)	☐	☐
2.4.5	Ensure 'AIR' remediation is enabled (Manual)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
3	**Microsoft Purview**		
3.1	**Audit**		
3.1.1	Ensure Microsoft 365 audit log search is Enabled (Automated)	☐	☐
3.2	**Data Loss Protection**		
3.2.1	Ensure DLP policies are enabled (Automated)	☐	☐
3.2.2	Ensure DLP policies are enabled for Microsoft Teams (Automated)	☐	☐
3.2.3	Ensure DLP policies are published for Copilot users (Automated)	☐	☐
3.3	**Information Protection**		
3.3.1	Ensure Information Protection sensitivity label policies are published (Automated)	☐	☐
3.4	**Insider Risk Management**		
3.5	**Communication Compliance**		
4	**Microsoft Intune admin center**		
4.1	Ensure devices without a compliance policy are marked 'not compliant' (Automated)	☐	☐
4.2	Ensure device enrollment for personally owned devices is blocked by default (Automated)	☐	☐
5	**Microsoft Entra admin center**		
5.1	**Entra ID**		
5.1.1	**Overview**		
5.1.2	**Users**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.1.2.1	Ensure 'Per-user MFA' is disabled (Manual)	☐	☐
5.1.2.2	Ensure users cannot register applications (Automated)	☐	☐
5.1.2.3	Ensure 'Restrict non-admin users from creating tenants' is set to 'Yes' (Automated)	☐	☐
5.1.2.4	Ensure access to the Entra admin center is restricted (Manual)	☐	☐
5.1.2.5	Ensure the option to remain signed in is hidden (Manual)	☐	☐
5.1.2.6	Ensure 'LinkedIn account connections' is disabled (Manual)	☐	☐
5.1.3	**Groups**		
5.1.3.1	Ensure users cannot create security groups (Automated)	☐	☐
5.1.3.2	Ensure that 'Restrict user ability to access groups features in My Groups' is set to 'Yes' (Manual)	☐	☐
5.1.3.3	Ensure that 'Owners can manage group membership requests in My Groups' is set to 'No' (Manual)	☐	☐
5.1.3.4	Ensure that 'Users can create Microsoft 365 groups in Azure portals, API or PowerShell' is set to 'No' (Automated)	☐	☐
5.1.4	**Devices**		
5.1.4.1	Ensure the ability to join devices to Entra is restricted (Automated)	☐	☐
5.1.4.2	Ensure the maximum number of devices per user is limited (Automated)	☐	☐
5.1.4.3	Ensure the GA role is not added as a local administrator during Entra join (Automated)	☐	☐
5.1.4.4	Ensure local administrator assignment is limited during Entra join (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.1.4.5	Ensure Local Administrator Password Solution is enabled (Automated)	☐	☐
5.1.4.6	Ensure users are restricted from recovering BitLocker keys (Automated)	☐	☐
5.1.5	**Enterprise apps**		
5.1.5.1	Ensure user consent to apps accessing company data on their behalf is not allowed (Automated)	☐	☐
5.1.5.2	Ensure the admin consent workflow is enabled (Automated)	☐	☐
5.1.5.3	Ensure password addition is blocked for applications (Automated)	☐	☐
5.1.5.4	Ensure password lifetime for applications does not exceed 180 days (Automated)	☐	☐
5.1.5.5	Ensure new application passwords are system-generated (Automated)	☐	☐
5.1.5.6	Ensure maximum certificate lifetime for applications does not exceed 180 days (Automated)	☐	☐
5.1.6	**External Identities**		
5.1.6.1	Ensure that collaboration invitations are sent to allowed domains only (Automated)	☐	☐
5.1.6.2	Ensure that guest user access is restricted (Automated)	☐	☐
5.1.6.3	Ensure guest user invitations are limited (Automated)	☐	☐
5.1.7	**User experiences**		
5.1.8	**Hybrid management**		
5.1.8.1	Ensure that password hash sync is enabled for hybrid deployments (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.2	**ID Protection**		
5.2.1	**Identity Protection**		
5.2.2	**Conditional Access**		
5.2.2.1	Ensure multifactor authentication is enabled for all users in administrative roles (Automated)	☐	☐
5.2.2.2	Ensure multifactor authentication is enabled for all users (Automated)	☐	☐
5.2.2.3	Enable Conditional Access policies to block legacy authentication (Automated)	☐	☐
5.2.2.4	Ensure Sign-in frequency is enabled and browser sessions are not persistent for Administrative users (Automated)	☐	☐
5.2.2.5	Ensure 'Phishing-resistant MFA strength' is required for Administrators (Automated)	☐	☐
5.2.2.6	Enable Identity Protection user risk policies (Automated)	☐	☐
5.2.2.7	Enable Identity Protection sign-in risk policies (Automated)	☐	☐
5.2.2.8	Ensure 'sign-in risk' is blocked for medium and high risk (Automated)	☐	☐
5.2.2.9	Ensure a managed device is required for authentication (Automated)	☐	☐
5.2.2.10	Ensure a managed device is required to register security information (Automated)	☐	☐
5.2.2.11	Ensure sign-in frequency for Intune Enrollment is set to 'Every time' (Automated)	☐	☐
5.2.2.12	Ensure the device code sign-in flow is blocked (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.2.2.13	Ensure that periodic reauthentication is required for all users (Automated)	☐	☐
5.2.2.14	Ensure trusted 'named locations' are defined (Automated)	☐	☐
5.2.2.15	Ensure exclusionary geographic access controls are utilized (Automated)	☐	☐
5.2.2.16	Ensure Token Protection is enforced for session tokens (Automated)	☐	☐
5.2.2.17	Ensure authentication transfer is blocked (Automated)	☐	☐
5.2.3	**Authentication Methods**		
5.2.3.1	Ensure Microsoft Authenticator is configured to protect against MFA fatigue (Automated)	☐	☐
5.2.3.2	Ensure custom banned passwords lists are used (Automated)	☐	☐
5.2.3.3	Ensure password protection is enabled for on-prem Active Directory (Automated)	☐	☐
5.2.3.4	Ensure all member users are 'MFA capable' (Automated)	☐	☐
5.2.3.5	Ensure weak authentication methods are disabled (Automated)	☐	☐
5.2.3.6	Ensure system-preferred multifactor authentication is enabled (Automated)	☐	☐
5.2.3.7	Ensure the email OTP authentication method is disabled (Automated)	☐	☐
5.2.3.8	Ensure that Account 'Lockout threshold' is '10' or less (Automated)	☐	☐
5.2.3.9	Ensure that Account 'Lockout duration in seconds' is at least 60 seconds (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
5.2.3.10	Ensure Microsoft Authenticator on companion applications is disabled (Automated)	☐	☐
5.2.4	**Password reset**		
5.2.4.1	Ensure 'Self service password reset enabled' is set to 'All' (Manual)	☐	☐
5.2.4.2	Ensure that 2 methods are required for password reset (Manual)	☐	☐
5.2.4.3	Ensure SSPR registration and authentication re-confirmation are required (Manual)	☐	☐
5.2.4.4	Ensure that users are notified on password resets (Manual)	☐	☐
5.2.4.5	Ensure all admins are notified when other admins reset their password (Manual)	☐	☐
5.3	**ID Governance**		
5.3.1	Ensure privileged role assignments are activated and not assigned (Automated)	☐	☐
5.3.2	Ensure 'Access reviews' for guest users are configured (Automated)	☐	☐
5.3.3	Ensure 'Access reviews' for privileged roles are configured (Automated)	☐	☐
5.3.4	Ensure approval is required for Global Administrator role activation (Automated)	☐	☐
5.3.5	Ensure approval is required for Privileged Role Administrator activation (Automated)	☐	☐
6	**Exchange admin center**		
6.1	**Audit**		

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.1.1	Ensure 'AuditDisabled' organizationally is set to 'False' (Automated)	☐	☐
6.1.2	Ensure mailbox audit actions are configured (Automated)	☐	☐
6.1.3	Ensure 'AuditBypassEnabled' is not enabled on mailboxes (Automated)	☐	☐
6.2	**Mail flow**		
6.2.1	Ensure all forms of mail forwarding are blocked and/or disabled (Automated)	☐	☐
6.2.2	Ensure mail transport rules do not whitelist specific domains (Automated)	☐	☐
6.2.3	Ensure email from external senders is identified (Automated)	☐	☐
6.3	**Roles**		
6.3.1	Ensure users installing Outlook add-ins is not allowed (Automated)	☐	☐
6.3.2	Ensure the ability to add personal email accounts and calendars is disabled (Automated)	☐	☐
6.4	**Reports**		
6.5	**Settings**		
6.5.1	Ensure modern authentication for Exchange Online is enabled (Automated)	☐	☐
6.5.2	Ensure MailTips are enabled for end users (Automated)	☐	☐
6.5.3	Ensure additional storage providers are restricted in Outlook on the web (Automated)	☐	☐
6.5.4	Ensure SMTP AUTH is disabled (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
6.5.5	Ensure Direct Send submissions are rejected (Automated)	☐	☐
7	**SharePoint admin center**		
7.1	**Sites**		
7.2	**Policies**		
7.2.1	Ensure modern authentication for SharePoint applications is required (Automated)	☐	☐
7.2.2	Ensure SharePoint and OneDrive integration with Azure AD B2B is enabled (Automated)	☐	☐
7.2.3	Ensure external content sharing is restricted (Automated)	☐	☐
7.2.4	Ensure OneDrive content sharing is restricted (Automated)	☐	☐
7.2.5	Ensure that SharePoint guest users cannot share items they don't own (Automated)	☐	☐
7.2.6	Ensure SharePoint external sharing is restricted (Automated)	☐	☐
7.2.7	Ensure link sharing is restricted in SharePoint and OneDrive (Automated)	☐	☐
7.2.8	Ensure external sharing is restricted by security group (Automated)	☐	☐
7.2.9	Ensure guest access to a site or OneDrive will expire automatically (Automated)	☐	☐
7.2.10	Ensure reauthentication with verification code is restricted (Automated)	☐	☐
7.2.11	Ensure the SharePoint default sharing link permission is set (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
7.3	**Settings**		
7.3.1	Ensure Office 365 SharePoint infected files are disallowed for download (Automated)	☐	☐
8	**Microsoft Teams admin center**		
8.1	**Teams**		
8.1.1	Ensure external file sharing in Teams is enabled for only approved cloud storage services (Automated)	☐	☐
8.1.2	Ensure users can't send emails to a channel email address (Automated)	☐	☐
8.2	**Users**		
8.2.1	Ensure external domains are restricted in the Teams admin center (Automated)	☐	☐
8.2.2	Ensure communication with unmanaged Teams users is disabled (Automated)	☐	☐
8.2.3	Ensure external Teams users cannot initiate conversations (Automated)	☐	☐
8.2.4	Ensure the organization cannot communicate with accounts in trial Teams tenants (Automated)	☐	☐
8.3	**Teams devices**		
8.4	**Teams apps**		
8.4.1	Ensure app permission policies are configured (Manual)	☐	☐
8.5	**Meetings**		
8.5.1	Ensure anonymous users can't join a meeting (Automated)	☐	☐
8.5.2	Ensure anonymous users and dial-in callers can't start a meeting (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
8.5.3	Ensure only people in my org can bypass the lobby (Automated)	☐	☐
8.5.4	Ensure users dialing in can't bypass the lobby (Automated)	☐	☐
8.5.5	Ensure meeting chat does not allow anonymous users (Automated)	☐	☐
8.5.6	Ensure only organizers and co-organizers can present (Automated)	☐	☐
8.5.7	Ensure external participants can't give or request control (Automated)	☐	☐
8.5.8	Ensure external meeting chat is off (Automated)	☐	☐
8.5.9	Ensure meeting recording is off by default (Automated)	☐	☐
8.6	**Messaging**		
8.6.1	Ensure users can report security concerns in Teams (Automated)	☐	☐
9	**Microsoft Fabric**		
9.1	**Tenant settings**		
9.1.1	Ensure guest user access is restricted (Automated)	☐	☐
9.1.2	Ensure external user invitations are restricted (Automated)	☐	☐
9.1.3	Ensure guest access to content is restricted (Automated)	☐	☐
9.1.4	Ensure 'Publish to web' is restricted (Automated)	☐	☐
9.1.5	Ensure 'Interact with and share R and Python' visuals is 'Disabled' (Automated)	☐	☐
9.1.6	Ensure 'Allow users to apply sensitivity labels for content' is 'Enabled' (Automated)	☐	☐

CIS Benchmark Recommendation		Set Correctly	
		Yes	No
9.1.7	Ensure shareable links are restricted (Automated)	☐	☐
9.1.8	Ensure enabling of external data sharing is restricted (Automated)	☐	☐
9.1.9	Ensure 'Block ResourceKey Authentication' is 'Enabled' (Automated)	☐	☐
9.1.10	Ensure access to APIs by service principals is restricted (Automated)	☐	☐
9.1.11	Ensure service principals cannot create and use profiles (Automated)	☐	☐
9.1.12	Ensure service principals ability to create workspaces, connections and deployment pipelines is restricted (Automated)	☐	☐

Appendix: Change History

Date: 5/19/26 Version: 7.0.0
ADD – The CIS Microsoft 365 Foundations Benchmark v7.0.0 now includes 12 new recommendations that have been relocated from the CIS Microsoft Azure Foundations Benchmark. Details are in the changelog below.
ADD - 2.4.5 Ensure 'AIR' remediation is enabled Ticket #27237
ADD - 3.2.3 Ensure DLP policies are published for Copilot users Ticket #27316
ADD - 5.1.3.2 Ensure that 'Restrict user ability to access groups features in My Groups' is set to 'Yes' Ticket #27250
ADD - 5.1.3.3 Ensure that 'Owners can manage group membership requests in My Groups' is set to 'No' Ticket #27251
ADD - 5.1.3.4 Ensure that 'Users can create Microsoft 365 groups in Azure portals, API or PowerShell' is set to 'No' Ticket #27252
ADD - 5.1.5.3 Ensure password addition is blocked for applications Ticket #27546
ADD - 5.1.5.4 Ensure password lifetime for applications does not exceed 180 days Ticket #27547
ADD - 5.1.5.5 Ensure new application passwords are system-generated Ticket #27548
ADD - 5.1.5.6 Ensure maximum certificate lifetime for applications does not exceed 180 days Ticket #27549

ADD - 5.2.2.13 Ensure that periodic reauthentication is required for all users Ticket #27114
ADD - 5.2.2.14 Ensure 'named locations' are defined and applied Ticket #27253
ADD - 5.2.2.15 Ensure exclusionary geographic access controls are utilized Ticket #27255
ADD - 5.2.2.16 Ensure Token Protection is enforced for session tokens Ticket #27254
ADD - 5.2.2.17 Ensure authentication transfer is blocked Ticket #21119
ADD - 5.2.3.10 Ensure Microsoft Authenticator on companion applications is disabled Ticket #27540
ADD - 5.2.3.8 Ensure that Account 'Lockout threshold' is '10' or less Ticket #27246
ADD - 5.2.3.9 Ensure that Account 'Lockout duration in seconds' is at least 60 seconds Ticket #27247
ADD - 5.2.4.2 Ensure that 2 methods are required for password reset Ticket #27243
ADD - 5.2.4.3 Ensure SSPR registration and authentication re-confirmation are required Ticket #27248
ADD - 5.2.4.4 Ensure that users are notified on password resets Ticket #27244
ADD - 5.2.4.5 Ensure all admins are notified when other admins reset their password Ticket #27245
ADD - 6.3.2 Ensure the ability to add personal email accounts and calendars is disabled Ticket #27118

ADD - GRIDs (Global Recommendation Ids) to recommendations, establishing unique identifiers Ticket #27736
REMOVE - (L1) and (L2) prefix tags from titles Ticket #27115
REMOVE - 5.1.3.1 Ensure a dynamic group for guest users is created Ticket #26814
REMOVE - 7.3.2 Ensure OneDrive sync is restricted for unmanaged devices Ticket #26841
UPDATE - 5.1.4.2 Ensure the maximum number of devices per user is limited - Change value from 20 to 10 devices Ticket #27010
UPDATE - 1.1.2 Ensure two emergency access accounts have been defined - Audit now checks for disabled accounts Ticket #26680
UPDATE - 1.1.3 Ensure that between two and four global admins are designated - Rationale, remediation and controls Ticket #27604
UPDATE - 1.2.1 Ensure that only organizationally managed/approved public groups exist - PSH procedure now filters to unified groups Ticket #27337
UPDATE - 1.3.1 Ensure the 'Password expiration policy' is set to 'Set passwords to never expire (recommended)' - Improve rationale Ticket #26855
UPDATE - 2.1.10 Ensure DMARC Records for all Exchange Online domains are published - Filter to specific domains, update audit and remediation procedure Ticket #26615
UPDATE - 2.1.11 Ensure comprehensive attachment filtering is applied - Comprehensive list of attachments is missing two default extensions Ticket #26915

UPDATE - 2.1.15 Ensure outbound anti-spam message limits are in place - Audit procedure now states `0` message limit is non-compliant Ticket #27144
UPDATE - 2.1.2 Ensure the Common Attachment Types Filter is enabled - Audit procedure to include default extensions Ticket #27229
UPDATE - 2.1.8 Ensure that SPF records are published for all Exchange Domains - Redefine audit criteria clearly, allow soft fail Ticket #26614
UPDATE - 2.1.9 Ensure that DKIM is enabled for all Exchange Online Domains - Exclude Initial and Coexistence domains from audit procedure Ticket #26569
UPDATE - 2.1.9 Ensure that DKIM is enabled for all Exchange Online Domains - Fix PSH Audit Procedure Ticket #26685
UPDATE - 2.1.9 Ensure that DKIM is enabled for all Exchange Online Domains - Simplify remediation procedure Ticket #26688
UPDATE - 2.4.1 Ensure Priority account protection is enabled and configured - Add automated audit procedure Ticket #27369
UPDATE - 2.4.2 Ensure Priority accounts have 'Strict protection' presets applied - Add automated audit procedure Ticket #27372
UPDATE - 3.2.1 Ensure DLP policies are enabled - Add automation and update both audit procedures Ticket #27374
UPDATE - 4.1 Ensure devices without a compliance policy are marked 'not compliant' - Changed from Level 2 to Level 1 Ticket #27201

UPDATE - 4.2 Ensure device enrollment for personally owned devices is blocked by default - Changed from Level 2 to Level 1 Ticket #27202
UPDATE - 5 Microsoft Entra admin center - Overview of Graph API usage in audit procedures Ticket #27205
UPDATE - 5.1.2.1 Ensure 'Per-user MFA' is disabled - Change from Automated to Manual Ticket #27119
UPDATE - 5.1.2.2 Ensure users cannot register applications - Moved to L1: Title, description, rationale, impact and remediation Ticket #27602
UPDATE - 5.1.2.4 Ensure access to the Entra admin center is restricted - Description and impact updated Ticket #27303
UPDATE - 5.1.3.2 Ensure users cannot create security groups - Renumbered to 5.1.3.1 Ticket #27445
UPDATE - 5.1.6.3 Ensure guest user invitations are limited - Title, clean Audit/Remediation Ticket #27603
UPDATE - 5.1.8.1 Ensure that password hash sync is enabled for hybrid deployments - Add Graph automation procedure Ticket #27737
UPDATE - 5.2.2 Conditional Access - Change guidance to use the general Conditional Access blade Ticket #27564
UPDATE - 5.2.2.1 Ensure multifactor authentication is enabled for all users in administrative roles - Add automated audit procedure Ticket #27207

UPDATE - 5.2.2.10 Ensure a managed device is required to register security information - Add automated audit procedure Ticket #27349
UPDATE - 5.2.2.11 Ensure sign-in frequency for Intune Enrollment is set to 'Every time' - Add automated audit procedure Ticket #27351
UPDATE - 5.2.2.12 Ensure the device code sign-in flow is blocked - Add automated audit procedure Ticket #27352
UPDATE - 5.2.2.2 Ensure multifactor authentication is enabled for all users - Add automated audit procedure Ticket #27206
UPDATE - 5.2.2.3 Enable Conditional Access policies to block legacy authentication - Add automated audit procedure Ticket #27208
UPDATE - 5.2.2.4 Ensure Sign-in frequency is enabled and browser sessions are not persistent for Administrative users - Add automated audit procedure Ticket #27209
UPDATE - 5.2.2.5 Ensure 'Phishing-resistant MFA strength' is required for Administrators - Add automated audit procedure Ticket #27216
UPDATE - 5.2.2.6 Enable Identity Protection user risk policies - Add automated audit procedure Ticket #27217
UPDATE - 5.2.2.7 Enable Identity Protection sign-in risk policies - Add automated audit procedure Ticket #27218
UPDATE - 5.2.2.8 Ensure 'sign-in risk' is blocked for medium and high risk - Add automated audit procedure Ticket #27219

UPDATE - 5.2.2.9 Ensure a managed device is required for authentication - Add automated audit procedure Ticket #27348
UPDATE - 5.2.2.9 Ensure a managed device is required for authentication - Hybrid requirement is now optional Ticket #27335
UPDATE - 5.2.3.1 Ensure Microsoft Authenticator is configured to protect against MFA fatigue - Add automated audit procedure Ticket #27284
UPDATE - 5.2.3.1 Ensure Microsoft Authenticator is configured to protect against MFA fatigue - Remove number matching Ticket #27225
UPDATE - 5.2.3.2 Ensure custom banned passwords lists are used - Add 'additional information' from Azure Foundations Ticket #27354
UPDATE - 5.2.4.1 Ensure 'Self service password reset enabled' is set to 'All' - Impact statement correction Ticket #27378
UPDATE - 5.3.1 Ensure privileged role assignments are activated and not assigned - New title, overhaul audit/remediation Ticket #27365
UPDATE - 5.3.2 Ensure 'Access reviews' for Guest Users are configured - Update description, rationale, impact, audit and remediation Ticket #27043
UPDATE - 5.3.2 Ensure 'Access reviews' for guest users are configure - Fix parity issues between audit/remediation Ticket #27616
UPDATE - 5.3.2 Ensure 'Access reviews' for Guest Users are configured - Replace automated procedure with Graph Ticket #27368

UPDATE - 5.3.3 Ensure 'Access reviews' for privileged roles are configured - Updated all fields, address parity issues and add automation Ticket #26630
UPDATE - 5.3.4 Ensure approval is required for Global Administrator role activation - Add automated audit procedure Ticket #27285
UPDATE - 5.3.4 Ensure approval is required for Global Administrator role activation - Approvers count changed from 2 to 1 Ticket #27696
UPDATE - 5.3.5 Ensure approval is required for Privileged Role Administrator activation - Add automated audit procedure Ticket #27286
UPDATE - 5.3.5 Ensure approval is required for Privileged Role Administrator activation - Approvers count changed from 2 to 1 Ticket #27697
UPDATE - 6.1.2 Ensure mailbox audit actions are configured - Audit/Remediation scripts to fit within character limit of PDF Ticket #27539
UPDATE - 6.2.2 Ensure mail transport rules do not whitelist specific domains - Update remediation to include note about safe rule removal Ticket #27650
UPDATE - 6.3.1 Ensure users installing Outlook add-ins is not allowed - Scope to the default policy only, all sections updated Ticket #27401
UPDATE - 6.5.5 Ensure Direct Send submissions are rejected - Remove item from impact as MS resolved issue Ticket #27409
UPDATE - 7.2.2 Ensure SharePoint and OneDrive integration with Azure AD B2B is enabled - Added impact Ticket #26912

UPDATE - 7.2.6 Ensure SharePoint external sharing is restricted - Also complaint if sharing is disabled Ticket #26956
UPDATE - 7.2.7 Ensure link sharing is restricted in SharePoint and OneDrive - Add impact statement Ticket #26946
UPDATE - 7.2.8 Ensure external sharing is restricted by security group - Add automation Ticket #27738
UPDATE - 7.2.8 Ensure external sharing is restricted by security group - Also complaint if sharing is disabled Ticket #26957
UPDATE - 7.2.9 Ensure guest access to a site or OneDrive will expire automatically - Value cannot be set below 30, removed the "or less" from control Ticket #26629
UPDATE - 8.2.1 Ensure external domains are restricted in the Teams admin center - To accommodate new UI layout Ticket #27664
UPDATE - 8.2.2 Ensure communication with unmanaged Teams users is disabled - Accommodate new UI layout Ticket #27670
UPDATE - 8.4.1 Ensure app permission policies are configured - Remove step 4, Microsoft Apps Ticket #27689
UPDATE - 8.5.3 Ensure only people in my org can bypass the lobby - Clarify compliant values in audit/remediation Ticket #26544
UPDATE - 8.6.1 Ensure users can report security concerns in Teams - Changed to E5 profile Ticket #26830

UPDATE - 9.1.4 Ensure 'Publish to web' is restricted - Fix property name in audit procedure (PublishToWeb) Ticket #27526
UPDATE - Revise CIS control mappings across benchmark, update to v8.1 standard Ticket #27735
UPDATE - Section 8.2: Navigation reflects new blade layout Ticket #27688
Date: 2/26/26 Version: 6.0.1
ADD – New Automated Assessment Content for CIS-CAT Pro Assessor
ADD – Automation script for section 9.1, Microsoft Fabric
UPDATE – Section 9.1, All Fabric settings now have audit procedures for PowerShell
UPDATE - 5.3.2 (L1) Ensure 'Access reviews' for Guest Users are configured - Audit Procedure is now backwards compatible with PowerShell 5 Ticket #26631
UPDATE - 1.3.9 (L1) Ensure shared bookings pages are restricted to select users - Fix typo in title (paged > pages) Ticket #26606
Minor spelling and grammar fixes
Date: 10/31/2025 Version: 6.0.0
ADD - 1.3.9 (L1) Ensure shared bookings paged are restricted to select users Ticket #25964
ADD - 2.1.15 (L1) Ensure outbound anti-spam message limits are in place Ticket #25610
ADD - 5.1.3.2 (L1) Ensure users cannot create security groups Ticket #26252
ADD - 5.1.4.1 (L2) Ensure the ability to join devices to Entra is restricted Ticket #26280

ADD - 5.1.4.2 (L2) Ensure the maximum number of devices per user is limited Ticket #26281
ADD - 5.1.4.3 (L1) Ensure the GA role is not added as a local administrator during Entra join Ticket #26282
ADD - 5.1.4.4 (L1) Ensure local administrator assignment is limited during Entra join Ticket #26284
ADD - 5.1.4.5 (L1) Ensure Local Administrator Password Solution is enabled Ticket #26285
ADD - 5.1.4.6 (L2) Ensure users are restricted from recovering BitLocker keys Ticket #26300
ADD - 5.2.3.7 (L2) Ensure the email OTP authentication method is disabled Ticket #26307
ADD - 6.5.5 (L2) Ensure Direct Send submissions are rejected Ticket #25791
ADD - 8.2.X (L1) Ensure the organization cannot communicate with accounts in trial Teams tenants Ticket #25902
ADD - 9.1.12 (L1) Ensure service principals ability to create workspaces, connections and deployment pipelines is restricted Ticket #26315
REMOVE - 7.3.3 (L1) Ensure custom script execution is restricted on personal sites - Setting now unavailable in SharePoint Ticket #25452
REMOVE - 7.3.4 (L1) Ensure custom script execution is restricted on site collections - Property is automatically disabled by MS after 24 hours Ticket #25741
REMOVE - 8.2.4 (L1) Ensure communication with Skype users is disabled Ticket #24834

UPDATE - 5.1.8.1 (L1) Ensure that password hash sync is enabled for hybrid deployments - Clarify audit procedure and required roles Ticket #26319
UPDATE - 1.2.1 (L2) Ensure that only organizationally managed/approved public groups exist - Minor updates to description and rationale Ticket #26047
UPDATE - 1.3.2 (L2) Ensure 'Idle session timeout' is set to '3 hours (or less)' for unmanaged devices - Corrected audit procedure script results in CA step Ticket #25255
UPDATE - 1.3.6 (L2) Ensure the customer lockbox feature is enabled - Added the correct reference Ticket #24733
UPDATE - 2.1.1 (L2) Ensure Safe Links for Office Applications is Enabled - Improved powershell audit method Ticket #26316
UPDATE - 2.1.11 (L2) Ensure comprehensive attachment filtering is applied - Simplify audit script, provide new output methods, clarify audit steps Ticket #25623
UPDATE - 2.1.3 (L1) Ensure notifications for internal users sending malware is Enabled - Include values in PSH audit procedure Ticket #25622
UPDATE - 3.1.1(L1) Ensure Microsoft 365 audit log search is Enabled Draft - Add note about PowerShell module issue Ticket #25569
UPDATE - 3.3.1 (L1) Ensure Information Protection sensitivity label policies are published - Add method to audit with PowerShell Ticket #23463
UPDATE - 4.2 (L2) Ensure device enrollment for personally owned devices is blocked by default - Modify audit script Ticket #26320

UPDATE - 5 Microsoft Entra admin center - Minor navigation changes to Entra blades through section 5 Ticket #25426
UPDATE - 5.1.3.1(L1) Ensure a dynamic group for guest users is created - Add '-All' switch to Get-MgGroup cmdlet Ticket #25575
UPDATE - 5.1.6.1 (L2) Ensure that collaboration invitations are sent to allowed domains only - Add PowerShell audit procedure Ticket #23464
UPDATE - 5.2.3.3 (L1) Ensure password protection is enabled for on-prem Active Directory - Add PowerShell audit method Ticket #25298
UPDATE - 5.2.3.5 (L1) Ensure weak authentication methods are disabled - Move email OTP to its own L2 control Ticket #24211
UPDATE - 5.2.3.6 (L1) Ensure system-preferred multifactor authentication is enabled - Add PowerShell audit method Ticket #24839
UPDATE - 5.2.4.1 (L1) Ensure 'Self service password reset enabled' is set to 'All' - Now has a more relevant security rationale Ticket #26251
UPDATE - 5.3.1 (L2) Ensure 'Privileged Identity Management' is used to manage roles - Add impact note about alert configuration Ticket #25577
UPDATE - 5.3.2 (L1) Ensure 'Access reviews' for Guest Users are configured - Changed audit script, tests for compliance now Ticket #26270
UPDATE - 5.3.3 (L1) Ensure 'Access reviews' for privileged roles are configured - Change maximum review duration to 14 days Ticket #25253

UPDATE - 6.1.2 (L1) Ensure mailbox audit actions are configured - Updated audit script to output to preferred formats Ticket #25264
UPDATE - 6.1.3 (L1) Ensure 'AuditBypassEnabled' is not enabled on mailboxes - Added output options in powershell audit procedure Ticket #25624
UPDATE - 6.2.2 (L1) Ensure mail transport rules do not whitelist specific domains - Define what the passing values are in the powershell audit procedure Ticket #25621
UPDATE - 6.5.4 (L1) Ensure SMTP AUTH is disabled - Remediation step 3 now correctly states to 'Check' instead of 'Uncheck' the setting, matching the Audit Ticket #25296
UPDATE - 7.2.6 (L2) Ensure SharePoint external sharing is restricted - New title, clarify title, description and audit procedure Ticket #23794
UPDATE - 8 Microsoft Teams admin center - Added information about PowerShell and Single Threaded Apartment. Ticket #25304
UPDATE - 8.1.1 (L2) Ensure external file sharing in Teams is enabled for only approved cloud storage services - Now uses new settings blade Ticket #26216
UPDATE - 8.1.1 (L2) Ensure external file sharing in Teams is enabled for only approved cloud storage services - Remediation now correctly targets the Global policy Ticket #26448
UPDATE - 8.1.2 (L1) Ensure users can't send emails to a channel email address - Clarify Description and Impact Ticket #26298
UPDATE - 8.1.2 (L1) Ensure users can't send emails to a channel email address - Now uses new settings blade Ticket #26217

UPDATE - 8.4.1(L1) Ensure app permission policies are configured - Removed note about Teams Administrator role requirement Ticket #25718
UPDATE - 8.5 Meetings - Updated section to use new settings & policies blade Ticket #26218
UPDATE - 8.5.5 (L2) Ensure meeting chat does not allow anonymous users - Add more restrictive values for compliance Ticket #24833
UPDATE - 8.6 Messaging - Updated section to use new settings & policies blade Ticket #26219
UPDATE - 9.1.10 (L1) Ensure access to APIs by Service Principals is restricted - Updated to reflect new setting name Ticket #25242
UPDATE - 6.5.3 (L2) Ensure additional storage providers are restricted in Outlook on the web - Audit procedure now targets default policy Ticket #26441